



File No.: EXP202204846

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following Background, Proven Facts, and Legal Grounds, the Director of the Spanish Agency for Data Protection resolves to adopt this resolution of the sanctioning procedure.

TABLE OF CONTENTS

BACKGROUND.....	4
PROVEN FACTS.....	32
LEGAL GROUNDS.....	68
Competence.....	68
Preliminary Issues.....	69
Claims Made.....	69
Claims Regarding the Initiation Agreement of the Sanctioning Procedure.....	70
Preliminary.- Specification of Certain Essential Factual Points for the Legal Analysis of the File.....	70
(a) Evidentiary Value of the Evaluation and Security Breach Management Report Prepared by ***COMPANY.1 ("***COMPANY.1").....	70
(b) Interactions with Facebook to Request the Removal of Ads through which the Sale/Rental of Access Credentials to Endesa's Systems was Offered.....	71
First.- On the Inappropriateness of the Sanction Imposed for Alleged Violation of Articles 5.1. f) and 32 of the GDPR.....	79
1. On the Implementation of Security Measures Appropriate to the Risk.....	79
(a) The AEPD understands that Endesa should have had implemented, from the beginning, the security measures that it began to apply once it became aware of the incident.....	79
(b) The AEPD understands that several months passed from the time Endesa identified the possible improvements it could implement regarding the security measures of the tools ***TOOL.1 and ***TOOL.2 until it implemented them.....	81
(c) The AEPD, taking (in its opinion) as a basis the report prepared by ***COMPANY.1, understands that Endesa could have implemented additional security measures on the tools ***TOOL.1 and ***TOOL.2.....	82
C/ Jorge Juan, 6	
www.aepd.es	
28001 – Madrid	
sedeagpd.gob.es	
2/214	
(d) The AEPD understands that Endesa was not diligent in contacting Facebook for the removal of the advertisements since, after receiving the response indicating that Facebook Spain was not the competent entity, it did not send any request to Facebook Ireland Limited in this regard and, therefore, did not implement the proposed security measures.....	83
(e) The AEPD understands that Endesa took several months to delete the accounts of the compromised users from the Company's systems.....	83
2. Regarding the concurrence of violations.....	84
3. Violation of the principle of legality.....	90
Second.- On the impropriety of the sanction imposed for the alleged violation of Article 33 of the GDPR.....	91

Third.- On the impropriety of the sanction imposed for the alleged violation of Article 34 of the GDPR.....	104
Fourth.- On the impropriety of the sanction imposed for the alleged violation of Article 44 of the GDPR.....	109
Fifth.- On the assessment of the sanction imposed on Endesa and the lack of relative proportionality of the Initiation Agreement of the sanctioning procedure.....	115
Allegations to the proposed resolution of the sanctioning procedure.....	124
Preliminary.- Specification of certain essential factual points for the legal analysis of the file.....	125
(a) On the importance that both the incident and the protection of personal data had and have for Endesa.....	125
(b) On the express challenge, once again, of the entirety of the evaluation and management report of the security breach prepared by ***EMPRESA.1 (“***EMPRESA.1”).....	126
(c) Interactions with Facebook to request the removal of the advertisements through which the sale/rental of access credentials to Endesa's systems was offered.....	128
First.- On the impropriety of the sanction imposed for the alleged violation of Articles 5.1.f) and 32 of the GDPR.....	130
1. On the implementation of security measures appropriate to the risk.....	130
2. The eventual imposition of two sanctions for the alleged violation of Articles 5.1.f) and 32 of the GDPR would be contrary to law due to the violation of the principle of non bis in idem or, where applicable, of the rules applicable in cases of conflicts of punitive norms.....	137
C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es 3/214	
2.1.- Approach.....	137
2.2.- The reasons put forward in the Proposal for Resolution cannot lead to the non-application of the principle of non bis in idem or, failing that, of the rules regarding the concurrence of punitive norms.....	140
2.3.- Conclusion: inadmissibility of separately sanctioning the alleged violations of articles 5.1.f) and 32 of the GDPR.....	149
3. Violation of the principle of legality.....	149
Second.- On the inadmissibility of the sanction imposed for the alleged infringement of article 33 of the GDPR.....	153
Third.- On the inadmissibility of the sanction imposed for the alleged infringement of article 34 of the GDPR.....	160
Fourth.- On the inadmissibility of the sanction imposed for the alleged infringement of article 44 of the GDPR.....	165
4.1 ENDESA indicates that, in procedural terms, the Agency has begun with a direct accusation in the Agreement to Initiate the present procedure, without any basis and without factual support of any kind.....	165
4.2. In addition to all of the above, and already in substantive terms, ENDESA categorically denies having failed to comply with the obligations established by the GDPR in relation to international transfers.....	171
Fifth.- On the assessment of the sanction imposed on Endesa and the lack of relative proportionality of	

the Proposal for Resolution.....	174
Integrity and confidentiality.....	182
Classification and qualification of the infringement of article 5.1.f) of the GDPR.....	186
Sanction for the infringement of article 5.1.f) of the GDPR.....	187
Security of processing.....	188
Classification and qualification of the infringement of article 32 of the GDPR.....	196
Sanction for the infringement of article 32 of the GDPR.....	196
Notification to the supervisory authority.....	199
Classification and qualification of the infringement of article 33 of the GDPR.....	200
Sanction for the infringement of article 33 of the GDPR.....	201
Communication to the data subject.....	202
Classification and qualification of the infringement of article 34 of the GDPR.....	204
Sanction for the infringement of article 34 of the GDPR.....	205
Transfers of data to third countries or international organizations.....	206
Classification and qualification of the infringement of article 44 of the GDPR.....	215
Sanction for the infringement of article 44 of the GDPR.....	215

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/214

Adoption of measures.....217

the Director of the Spanish Agency for Data Protection RESOLVES:.....217

BACKGROUND

FIRST: On February 10, 2022, a personal data security breach was reported to the Spanish Agency for Data Protection (AEPD), submitted by ENDESA ENERGÍA, S.A.U. with NIF A81948077 (hereinafter, ENDESA), consisting of a possible unauthorized access to certain commercial systems of Endesa Energía that could have affected about one thousand customers.

In this notification, the AEPD was informed of the following:

In August 2021, certain Facebook ads were detected advertising the sale of credentials to access the ***PLATFORM.1 of ENDESA (which contains basic data and data related to the supply point). This incident was assessed, and the relevant measures were adopted. On 01/17/2022, a Facebook ad with similar characteristics to the previous ones was detected, informing about the sale of customer databases for energy and gas. The ad was assessed, and no matches were found with ENDESA customer data included in the CRM system. On 02/08/2022, data from, among others, some ENDESA customers included in the CRM system were detected.

Approximate number of individuals whose personal data is collected, stored, or processed in any other way; referring exclusively to the processing in which the personal data breach occurred: 6,500,000.

The incident has been: Intentional, to harm the responsible party / processor or the affected individuals.

The origin of the incident has been: External: Others, unrelated to the responsible party and processor of the data.

What may have occurred?: Abuse of access privileges by an employee to extract, forward, or copy personal data.

As a consequence of the incident, the following has been affected: Confidentiality

Specifically referring to the data affected by the confidentiality breach.

Are the data securely encrypted, anonymized, or protected in such a way that they are unintelligible to anyone who may have accessed them or that individuals cannot be identified?: No

What may have occurred?: Identity theft, Loss of control over their personal data.

To what extent could the identified consequences affect individuals?:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es
5/214

Individuals will not be affected or may encounter very limited and reversible inconveniences that they will overcome without any problem (time to re-enter information, discomfort, irritations, etc.)

As of the date of this notification, are you aware that any of the identified damages have materialized, to the degree indicated in the previous question?: Yes

Types of affected data: Basic data (e.g., name, surname, date of birth), ID number, foreign ID number, passport and/or any other identifying document, Payment method data (Bank card, etc.), Contact data
In total, how many individuals have had their data affected by the personal data breach?: 1000

Indicate the date of detection of the breach: 08/02/2022

Do you know the date on which the breach began? Approximately 24/08/2021

Indicate the date on which the breach was resolved: 10/02/2022

Has the breach been communicated to the affected individuals under the previously described conditions?: They will not be informed

The affected individuals will not be informed because: There is no high risk to their rights and freedoms
Along with the notification, Annex I includes the measures taken to resolve the breach and minimize the impact:

“Following the initial detection in August 2021 of unauthorized sale of access credentials to the platform ***PLATAFORMA.1, the following measures were adopted to mitigate possible negative effects:

- Resetting the passwords of the affected users to access the platform ***PLATAFORMA.1. This measure is carried out continuously.
- Monitoring new postings on Facebook. This measure is carried out continuously.
- Disabling simultaneous sessions on ***PLATAFORMA.1, so that two or more people cannot access at the same time with a single user. This measure was implemented in November 2021.
- Expanding the traceability (logs) of accesses to ***PLATAFORMA.1 to obtain detailed information on the usage by users. This measure was implemented at the end of December 2021.
- Requesting the removal of Facebook ads where the sale of such users was offered. This measure is carried out continuously.

Subsequently, due to new detected events (sale on Facebook of certain databases that contain, among others, customer data from Endesa Energía included in the CRM system that houses basic data, contact data, CUPS, data related to the electricity or gas contract, and account number), the following additional measures will be implemented, among others:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/214

(...)

SECOND: With the outgoing record ***REGISTRO.1, the AEPD notifies ENDESA on March 8, 2022, an order to communicate the incident in question to the affected individuals within a maximum period of 30 days in accordance with Article 34 of the GDPR. This order informs that the communication to the interested parties will be made following the provisions of Article 34 of the GDPR, particularly in its second paragraph, requiring a clear and simple description of the nature of the personal data security breach and the possible measures that could be taken by the interested parties based on the risks that, in each case, could be identified by the affected individuals.

THIRD: On April 6, 2022, this Agency received a document from ENDESA with entry number ***REGISTRO.2, in which it informs that it has proceeded, on April 1, 2022, to send a communication by postal mail to the potentially affected individuals informing them about the events that occurred.

Along with the document, the following is provided:

- As Document number 2: the model of the letter sent, in Spanish and Catalan.

The content of this model in Spanish is as follows:

"March 31, 2022

Dear customer,

We are contacting you to inform you that we have detected a possible unauthorized access to certain commercial systems of Endesa Energía and that from the moment we became aware of this fact, we have adopted the appropriate security measures, both technical and organizational, to prevent a high-risk impact on the rights and freedoms of our customers, ensuring that the confidentiality and integrity of your personal data has not been compromised.

You can consult our privacy policy at www.endesa.com/es/protec-cion-datos-endesa, where you will find information regarding the processing of your personal data. If you prefer, you can directly contact our Data Protection Officer by sending a communication to ***EMAIL.1 to learn about the details of the measures taken or obtain more information.

We take this opportunity to thank you for the trust placed in Endesa.

Best regards,

Endesa Energía."

- As Document number 3: the responsible declaration of the provider ***EMPRESA.2 in which it acknowledges that it printed and made available to the company responsible for postal service 760 shipments on April 1, 2022, and the corresponding delivery receipt to Correos, from the same day.

FOURTH: On April 20, 2022, the General Subdirectorate of Data Inspection (SGID) received for evaluation the aforementioned notification of the data breach.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/214

the security of personal data submitted by ENDESA, received by this Agency on February 10, 2022, and the General Subdirectorate for Data Inspection (SGID) is ordered to carry out the appropriate preliminary investigations in order to determine a possible violation of data protection regulations.

FIFTH: The SGID proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), being aware of the following points:

In order to investigate the occurrence of the described facts, on June 27, 2022, via outgoing register ***REGISTRO.3, information was requested from ENDESA and, on September 16, 2022, and November 3, 2022, through outgoing registers ***REGISTRO.4 and ***REGISTRO.5, respectively, further documentation was requested. The responses to these requests were received at the electronic headquarters of the Spanish Agency for Data Protection on July 26, 2022, October 7, 2022, and November 11, 2022, with registration numbers ***REGISTRO.6, ***REGISTRO.7, and ***REGISTRO.8, respectively.

On September 27, 2022, via outgoing register ***REGISTRO.9, information was requested from the Data Protection Officer of ENDESA (A.A.A.), and on October 19, 2022, with registration number ***REGISTRO.10, his response was received by this Agency.

Additionally, on October 20, 2022, via outgoing register ***REGISTRO.11, information was requested from ***EMPRESA.1, an external provider of ENDESA, and on November 25, 2022, with registration number ***REGISTRO.12, their response was received at the electronic headquarters of the AEPD.

In its response to the request, received by this Agency on July 26, 2022, ENDESA stated that:

1. ***HERRAMIENTA.1 is a tool specifically designed to facilitate advice, attention, and sales in the different commercial channels of Endesa Energía. This tool incorporates the commercial information of the products and services offered by ENDESA at any given time (such as prices, supplements, validity, offers, or conditions), contains technical information of all supply points, as well as certain basic identifying data.

2. Users of ***HERRAMIENTA.1 can be of two types: (i) "internal" user, enabled for ENDESA employees, and (ii) "external" user, enabled for external providers. There are no other external users, such as customers.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/214

Both internal users and external users have access to all the main functionalities of the tool. In turn, from a functional perspective, the platform has the role of "basic" user and the role with "administrator profile." That is, a user with an "administrator profile" can also be either "internal" or "external." Only users who have the "administrator profile" can access the administration menu and upload information into the system (such as new offers, rates, or argumentation). They can also edit certain fields of the tool and obtain extractions and reports.

3. The registration of external and internal users is carried out by the responsible parties of each Cs or by the support tool's technical assistance, which can be accessed through the Intranet enabled for all internal employees of the Endesa Group. Access requests are made from the Intranet. An explanatory process is attached as Document number 2.

External and internal users access the platform by entering the username and the associated password.

4. The platform allows the option to enter the so-called Universal Supply Point Code (hereinafter, "CUPS") or the address of the supply point, to display the associated technical information (described in Document number 4). If the customer already has a valid contract with ENDESA, it also shows the following information: name and surname of the holder of the supply point, their National Identity Document number, contract number, CUPS, annual billing amount, technical data regarding the supply point, consumption data, and usage graph. Within the file related to the supply point, there are several sections that allow recommending other rates to the customer.

5. The breach was detected on February 8, 2022, when it was confirmed that personal data had been affected in the incident. On February 9, 2022, an assessment of the scope of the breach was made, in which the existence of a risk to the rights and freedoms of the affected individuals was considered, and the need to notify the AEPD was established. The assessment carried out is provided as Document number 5, digitally signed.

However, the date on which certain possible anomalies were noticed is August 24, 2021, when the person responsible for ***DEPARTMENT.1 of ENDESA sent an email to the Information Security officer of the Endesa Group, informing about a suspicious announcement on Facebook. This notice activated the analysis and investigation process, the first step of which is to confirm the veracity of the announcement. The mentioned email is provided as Document number 6.

Despite the monitoring of that situation, between both dates, ENDESA did not notice any anomalous situations from which the existence of a security breach could be concluded. Therefore, it was only on February 8, 2022, after the appropriate investigations, that knowledge of the existence of...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/214

certain coincidences between the customer database of ENDESA and the databases for sale on Facebook, and therefore a new assessment was carried out which resulted in the need to notify the Spanish Agency for Data Protection, an event that occurred on February 10, 2022.

These investigations were conducted as part of the continuous and systematic monitoring process of "critical events" and, specifically, through the implementation of early detection activities for any risk event carried out within the company. These tasks are performed by ***DEPARTMENT.2, in accordance with the provisions established in ***DOCUMENT.1, which is provided as Document number 7.

6. Only in the advertisements published on January 17, 2022, by the user B.B.B., was there detected an impact on energy customer databases. Screenshots of the published advertisements are provided as Document number 8.

7. To determine the number of potentially affected individuals by the incident, the following analysis was conducted:

(i) The alleged irregular practice carried out by a subcontractor of one of ENDESA's telephone sales service providers was verified, and it was confirmed that it had not extended to other providers.

(ii) The analysis perimeter was limited to all contracts made between July 1, 2021, when ENDESA's sales volume experienced an unusual and unjustified increase (+500%), and October 15, 2021, when the contract with the provider was terminated, and thus, they ceased to provide their services.

(iii) Subsequently, a quality control and audit of the contracts subject to assessment was carried out, and those cases in which the customers had already contacted ENDESA to carry out actions related to their contracts (for example, commercial inquiries) were excluded.

The number of potential individuals affected by the resulting incident was: 760 customers. In any case, once ENDESA communicated the breach to the affected parties, only one email was received from one of the recipients of that communication on April 6, 2022. Documentation verifying their identity was requested, and there has been no response from them. This fact is evidenced by Document number 9.

8. Although it is not possible to determine the possible objective sought by the individuals facilitating the sale of credentials for access to the platform ***TOOL.1, as well as, if applicable, the sale of ENDESA's customer databases, it is considered that the consequences of the breach are limited to the affected individuals potentially encountering certain inconveniences, very limited and, in any case, reversible.

Due to the apparently fraudulent objective of data theft, the consequences for the affected customers would fundamentally involve the sale of their data for the purpose of making commercial calls, as well as for sending emails and SMS, offering the possibility of changing energy marketing companies, which, in the worst-case scenarios and if materialized, could result in the change of marketing company without their consent.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/214

9. During the analysis of the incident, three assessments were conducted as information about it was gradually obtained, within the process of constant monitoring that had been carried out since the possible anomalies were detected. The evaluations conducted were as follows:

On September 13, 2021, the first assessment was made, which included the information obtained up to that moment. Based on this information, it was considered that the derived risk was low, mainly because there was no evidence that fraudulent access to the ***TOOL.1 platform had materialized.

The assessment conducted on September 13, 2021, digitally signed, is provided as Document number 10.

On September 28, 2021, a second assessment was made, which completed the information from the first and concluded that the derived risk continued to be low. The assessment conducted on September 28, 2021, digitally signed, is provided as Document number 11.

On February 9, 2022, the final assessment was made. It reflected the detection of certain advertisements on Facebook with characteristics similar to the previous ones, in which databases of ENDESA customers appeared. After several analyses of the published databases, matches were detected between the data appearing in those databases and the data that may be included in the commercial system of ENDESA (***TOOL.2). For this reason, it was deemed appropriate to report the incident to the Spanish Data Protection Agency. Reference is made to the assessment conducted on February 9, 2022, digitally signed, previously provided as Document number 5.

Consequently, and as previously stated, following the new facts detected on February 8, 2022, an assessment of the incident was carried out, taking into account the variation with respect to the previous situation and, proactively, the incident was reported to the Spanish Data Protection Agency

on February 10, 2022.

10. The breach was caused by the apparent fraudulent sale of credentials for the ***TOOL.1 platform. These credentials were assigned to suppliers of Endesa Energía, as external users of the platform, to facilitate tasks related to customer acquisition, advice, and service.

In this regard, reference is made to Document number 8, previously provided, which includes images of the advertisements for the sale of credentials.

11. ENDESA became aware of the possible illicit use of the credentials through an email from one of the suppliers indicating irregularities by several of its employees; in that same email, five users were indicated who had been employed in an apparently irregular manner.

On the other hand, four other users were identified who might be compromised, detected in the demonstration videos and in the screenshots of the published advertisements. The following are the details of all the compromised users:

- ***USER.1

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/214

- ***USER.2

- ***USER.3

- ***USER.4

- ***USER.5

- ***USER.6

- ***USER.7

- ***USER.8

- ***USER.9

12. As previously stated, ENDESA has not received any claims from potentially affected customers regarding this incident.

13. The risk analysis conducted on the access and use of ***TOOL.1 is provided as Document number 12, and the risk analysis of the access and use of ***TOOL.2 is provided as Document number 13.

14. ENDESA, as part of the Endesa Group, has a series of security rules and standards to ensure the protection of personal data, based mainly on the following elements: (i) a cybersecurity framework, (ii) internal regulations on cybersecurity.

[...]

- Specifically, the measures implemented in the applications subject to this security breach consist of (...).

15. Among the various activities and security measures that existed in ***TOOL.2 before the incident, the following stand out:

(...).

The accreditation that the application ***TOOL.2 was integrated (...) at the time of the incident is provided as Document number 17.

16. Among the various activities and security measures that were implemented in the ***TOOL.1 platform before the incident, the following stand out:

(...)

17. In order to reduce the impact of the detected incident and prevent new breaches of this type, additional measures have been adopted, which are detailed below.

As the incident developed and its possible effects were noticed, it was...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/214

The following measures have been implemented to reinforce the security of the applications

***HERRAMIENTA.1 and ***HERRAMIENTA.2:

(i) In the case of ***HERRAMIENTA.2, the multi-factor authentication has been activated in the application, so each user, in addition to entering their credentials in the application access area, must provide a security code received via a previously registered mobile phone. Document number 24 is attached.

Additionally, the multi-session option has also been disabled. Therefore, each user may only have one active session (Document number 25 is attached).

(ii) In the case of ***HERRAMIENTA.1, following the incident, the following security measures have been adopted:

- The multi-factor authentication has been activated in the application (Document number 26 is attached).

- The multi-session option has been disabled. Therefore, each user may only have one active session (Document number 27 is attached).

- Additionally, the logs (traceability) collected by the application in the production environment have been improved. This allows for greater evidence of user operations for future analysis and diagnosis. Document number 28 is attached.

Finally, the last identified announcement related to the illicit use of credentials for the

***HERRAMIENTA.1 platform was on December 13, 2021, and the last identified publication regarding the sale of electricity and gas customer databases occurred in January 2022 (Document number 29 is attached). Consequently, no new publications related to this incident have been detected after the notification made on February 10, 2022.

18. Document number 30 is provided, which is a copy of the incident log where the assessments made during the years 2021 and 2022 related to this case appear.

19. On September 15, 2022, the SGID verified that advertisements identified by ENDESA offering the sale of access credentials to ***HERRAMIENTA.1 and databases were still published on Facebook (see the diligence document dated December 16, 2022, in the file).

In its response to the request, received by this Agency on October 7, 2022, ENDESA stated that:

20. ENDESA identified in the advertisements and demonstration videos published on the social network Facebook four users of the tool ***HERRAMIENTA.1 (hereinafter “***HERRAMIENTA.1”) who were therefore compromised.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/214

Document number 2 is provided, containing screenshots of the advertisements published on Facebook, where the identification of the users used to access ***HERRAMIENTA.1 can be seen in the upper right margin.

Additionally, the other five compromised users of ***HERRAMIENTA.1 were identified by the subcontractor company of an ENDESA provider, which alerted about the irregular use that some of its advisors had made with certain access credentials to ***HERRAMIENTA.1 that they had acquired illegally (Document number 3 is attached).

21. On the other hand, the identified compromised users had been assigned to one of the following supplier companies of Endesa Energía:

- ***EMPRESA.3
- ***EMPRESA.4
- ***EMPRESA.5
- ***EMPRESA.6
- ***EMPRESA.7
- ***EMPRESA.8

22. The ENDESA supplier that provided telephone sales services, whose subcontractor carried out the

alleged irregular practice, was ***EMPRESA.1, and the subcontractor company to which it entrusted part of the commissioned services was ***EMPRESA.9.

Document number 4 is provided, which is a copy of the contract signed between ENDESA and ***EMPRESA.1.

Regarding the subcontracting of ***EMPRESA.9, Document number 5 is provided, which is an excerpt of the general contracting conditions applicable to the contract signed between ENDESA and ***EMPRESA.1 concerning the subcontracting regime, and Document number 6 is provided, which is the authorization issued by ENDESA to carry out the aforementioned subcontracting of ***EMPRESA.9.

23. Since the detection of the advertisements for the illegal sale of access credentials to the tool ***HERRAMIENTA.1 on the social network Facebook, as a first measure, the removal of the advertisements was repeatedly requested through the standard form enabled for this purpose by Facebook (as evidenced by Document number 7 as an example). As a result, Facebook disabled access or removed the content of the advertisements, but not all of them. Document number 8 is provided, which includes some of the responses provided by Facebook in this regard.

Secondly, in order to expedite the removal of all detected advertisements, on February 4, 2022, a written communication was sent via burofax to FACEBOOK SPAIN S.L. (hereinafter "FB SPAIN"), which is provided as Document number 9, informing them of the publication by users of the platform of certain information that could constitute a crime and requesting their collaboration for its removal. On February 8, 2022, this communication was responded to via email, indicating that FB SPAIN was not the competent entity to resolve the matter.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/214

issue, but rather FACEBOOK IRELAND LIMITED, and requesting that the communication be directed to said entity (Document number 10 is provided). Finally, on February 28, 2022, ENDESA sent a new communication (Document number 11 is provided), reiterating its initial letter to FB SPAIN.

24. In the analysis carried out for the correct identification of the clients whose data had apparently been unlawfully accessed from the ***HERRAMIENTA.3 tool and, therefore, could potentially have been processed without their consent, the following actions were taken:

i. First, once the provider ***EMPRESA.1 informed ENDESA of the irregular practice committed by personnel from ***EMPRESA.9 and the appropriate verifications were conducted, it was confirmed that this practice did not extend to other providers.

ii. Second, once the possible origin of the allegedly irregular contracts was identified, the temporal scope of their actions was limited, verifying that from July 1, 2021, the sales volume of ENDESA experienced an unusual and unjustified increase (specifically, sales increased by more than 500%), which could be representative of the irregular actions of the personnel hired by ***EMPRESA.9. As of October 15, 2021, the activity of this subcontractor was ceased – as a result of the termination of the contract with ***EMPRESA.9 – thus limiting the temporal analysis of the contracts to the period between July 1 and October 15, 2021.

iii. Finally, a quality control and audit of the contracts carried out by ***EMPRESA.9 within the established temporal scope was conducted. In this analysis, cases were excluded where the clients on whose behalf a contract was made involving ***EMPRESA.9 – within the defined time period – had contacted ENDESA to carry out actions related to their contracts (for example, commercial inquiries), which indicated that the clients themselves were aware of their contracts and did not express any objections.

25. Although it was on February 8, 2022, when, after the appropriate investigations, the extent of the security breach was understood upon confirming the existence of matches between ENDESA's customer database and the databases for sale on Facebook, ENDESA, on January 31, 2022, due to the breach of established procedures, decided to terminate the contract with ***EMPRESA.1 for violating the commitments made to Endesa Energía by said contractor.

Furthermore, the employees of ***EMPRESA.9 who allegedly made irregular use of access credentials to ***HERRAMIENTA.1 were dismissed as communicated by the company itself in the email dated October 20, 2021, and reported to local authorities (Document number 12 is provided).

In its response to the request, received by this Agency on October 19, 2022, the DPD of ENDESA stated that:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/214

26. The role of the Data Protection Officer is regulated in accordance with the provisions established in ***DOCUMENTO.2 (currently undergoing its fourth review). According to this internal regulation and other Group regulations, it is the responsibility of the Data Protection Officer to provide advice on Personal Data Protection, cooperating with other areas of the organization on matters that may relate -among others- to security incidents. This is a task carried out continuously, as coordination with the affected areas of the organization is permanent and operates through various mechanisms such as periodic meetings, issuance of reports, or participation in committees.

27. As part of this ongoing advice, as stated in the information included in the reports corresponding to the incident assessments conducted on September 13 and 28, 2021, and February 9, 2022, in his capacity as Data Protection Officer and together with the Security area, the Systems area, the ENDESA Sales team, and ***DEPARTAMENTO.3 participated in the various evaluations carried out in relation to the Breach. It should be noted that in the reports corresponding to the assessments conducted on September 13 and 28, 2021, it was highlighted that "...from ***DEPARTAMENTO.4, the need to continue the investigation is indicated in order to carry out a new assessment of the incident, as it is considered that the information provided is not complete and the present analysis is preliminary." Finally, in the report corresponding to the assessment on February 9, 2022, it was stated that "...after conducting an assessment, in a timely manner, of the scope of the security incident and the possible repercussions for the rights and freedoms of the affected data subjects, the preliminary decision is made to communicate the security incident to the supervisory authority." Therefore, as a consequence of the advice provided by the Data Protection Officer, the Breach was communicated to the Spanish Data Protection Agency on February 10, 2022.

28. The Data Protection Officer sent an email on February 9, 2022, in which he insisted on the need to carry out the notification of the Breach (attached as Document number 1). As a result of this request, the communication was made the following day after fully gathering the information requested in the notification form of the Spanish Data Protection Agency.

29. As part of the ongoing advice, as Data Protection Officer, personally and through the team of the Data Protection Office that he directs, constant monitoring of the Breach was carried out, particularly to determine the appropriateness or not of communication in light of any developments that may arise or the criteria that may emanate from that Agency.

30. As Data Protection Officer, along with other individuals, he participated in the meetings held regarding the notification sent to ENDESA by the Agency.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/214

Spanish Agency for Data Protection on March 8, 2022 (Document number 2 is provided), in which it ordered the data controller to carry out the communication of the security breach to the affected parties within a maximum period of 30 days. Specifically, on March 9, 2022, a first meeting was held to address this matter, and on March 28, 2022, a second meeting took place in which it was agreed how to send the communication.

31. During the period granted to carry out the communication, the team of the Data Protection Officer under their responsibility provided advice on how the communication should be carried out. As an

example, Document number 3 is provided, which is an email dated March 16, 2022, sent by one of the members of the Data Protection Officer's team under their responsibility, in which the need to include certain aspects in the communication sent to the affected parties on April 1, 2022, was highlighted. Likewise, Document number 4 is provided, which is an email sent in their capacity as Data Protection Officer, in which they insisted on the need to prioritize the sending of the communication to the affected parties regarding the Breach over other communications that were planned to be carried out that same month (the latter concerning issues not related to the Breach).

In its response to the request, received by this Agency on November 11, 2022, ENDESA stated that: 32. During the investigation initiated at the end of August 2021, a total of 440 advertisements were identified on the social network Facebook offering the rental and/or sale of access credentials to the ENDESA ***TOOL.1.

The two users identified from whose Facebook profiles these advertisements were published were those corresponding to "B.B.B." (who presumably also made posts under the profile of "C.C.C.") and "D.D.D.". During the course of the investigation, the Information Security area of ENDESA made contact with user B.B.B., who offered the sale of credentials to access ***TOOL.1 in exchange for a monthly payment. They also indicated that they had different users available for sale.

Thanks to the continuous and systematic process of monitoring "critical events" at ENDESA, new advertisements published by user B.B.B. were identified during January 2022, where the sale of customer databases from various energy supply companies was offered. After the appropriate investigations, in February 2022, certain matches between that database and the customer database of ENDESA housed in application ***TOOL.2 were verified – which led to an assessment that resulted in the need to notify the Spanish Agency for Data Protection, an event that occurred on February 10, 2022.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/214

Document number 2 includes screenshots of various Facebook ads in which B.B.B. or D.D.D. offered the rental or sale of credentials to access the platform ***HERRAMIENTA.1.

As a result of conversations held between the managers of ENDESA and their suppliers, and subsequently between these and their subcontractors, it has come to our attention that behind the user "B.B.B." / "C.C.C." is C.C.C., who, as has been communicated to this Office, was employed until the year 2016 by ***EMPRESA.10. This branch has never provided services for ENDESA, and consequently, C.C.C. never had an access user assigned to his name for ENDESA applications (Document number 3 is provided).

On the other hand, the user "D.D.D." corresponds to the employee of ***EMPRESA.11, a subcontracting company in ***PAÍS.1 of the supplier ***EMPRESA.12, who provides services for ENDESA, D.D.D., who, however, resigned at the beginning of the year 2020 (Document number 4 is provided).

According to the information that has been communicated to this Office by ENDESA, there is no record in the company's internal systems of a user registration in the name of D.D.D. (Document number 5 is provided).

Consequently, the two advertisers selling ENDESA user credentials on Facebook were not former employees of suppliers (or subcontractors of these) of ENDESA at the time of the ad publication (one was never an employee, and the other stopped working for a subcontractor of an ENDESA supplier long before the publication of the ads that led to the Breach).

33. Below are the compromised users put up for sale along with the supplier to which they were assigned:

***USUARIO.1

***EMPRESA.13 (hereinafter, ***EMPRESA.13)

***USUARIO.9

***EMPRESA.14 (hereinafter, ***EMPRESA.14)

***USUARIO.2

***EMPRESA.8 (hereinafter, ***EMPRESA.8)

***USUARIO.10

***EMPRESA.15

In relation to the suppliers ***EMPRESA.13, ***EMPRESA.14, and ***EMPRESA.8, all three provided sales services to ENDESA via telephone through outgoing calls from the company. As evidenced by the statements made by each of the territorial managers of ENDESA who managed the relationship with these suppliers, which are provided as Document number 6, the communication regarding the Breach and the misuse of the access users assigned to them was carried out through conversations and telephone meetings.

Regarding the supplier ***EMPRESA.15, it provided customer service and telephone sales to ENDESA, handling calls made by interested parties without prior commercial intervention from ENDESA. As evidenced by Document number 7, the operations manager, immediately after learning of the events, contacted the supplier to request explanations about what occurred and the immediate implementation of measures with the involved user.

34. Below are the details for each of the users regarding their registration and deregistration in the tool ***HERRAMIENTA.1, as well as the role assigned to each user and the functions and access permissions granted.

User Supplier Assigned		Date of Registration Request		Date of Reset or Deactivation		Date of Withdrawal and Deletion in Systems		Role Functions and Permissions Granted	
----- -----		----- -----		----- -----		----- -----		----- -----	
----- -----		----- -----		----- -----		----- -----		----- -----	
***USUARIO.1	***EMPRESA.13	11/03/2021	15/02/2022	24/08/2022	User	Query			
***USUARIO.9	***EMPRESA.14	09/12/2021	15/02/2022	24/08/2022	User	Query			
***USUARIO.2	***EMPRESA.8	26/11/2019	19/11/2021	19/11/2021	User	Query			
***USUARIO.10	***EMPRESA.15	21/12/2020	10/09/2021	24/08/2022	User	Query			
***USUARIO.1	***EMPRESA.16	20/10/2020	03/09/2021	24/08/2022	User	Query			
***USUARIO.1	***EMPRESA.15	15/08/2021	29/11/2021	04/03/2022	User	Query			
***USUARIO.1	***EMPRESA.16	20/10/2020	21/09/2021	24/08/2022	User	Query			
***USUARIO.1	***EMPRESA.17	28/10/2020	24/08/2022	24/08/2022	User	Query			

Document number 8 includes screenshots from the systems evidencing the registration dates, as well as the withdrawal and deletion in systems. Additionally, Document number 9 includes various communications that evidence the date on which the individuals responsible for assigning these users requested or informed about the deactivation or reset of the compromised credentials.

35. Regarding the tool ***HERRAMIENTA.2, below are the compromised users who had access permissions to said tool, along with the data related to their registration and deregistration, as well as the role assigned to each user and the functions and access permissions granted.

19/214

User

Provider

to

which the user was assigned

Date of

registration request

Date of

last access

Date of

deletion in systems

Role

Functions and

permissions granted

***USER.10
***COMPANY.15
12/04/2021
09/09/2021
10/09/2021
***ROLE.1
Consultation,
creation, and
modification
of data
(within
their
business scope).
***USER.10
***COMPANY.16
19/02/2020
26/11/2021
12/01/2022
***ROLE.3
Consultation,
creation, and
modification
of data
(within
their
business scope).
***USER.10
***COMPANY.15
06/03/2018
18/02/2022
16/03/2022
***ROLE.1
Consultation,
creation, and
modification
of data
(within
their
business scope).
***USER.10
***COMPANY.16
23/10/2020
25/11/2021
12/01/2022
***ROLE.3
Consultation,
creation, and
modification
of data
(within
their
business scope).
***USER.10

***COMPANY.17

20/07/2020

03/12/2021

17/02/2022

***ROLE.2

Consultation,
creation, and
modification
of data
(within
their
business scope).

Document number 10 is provided, including screenshots from the systems, as well as communications evidencing the dates of registration or registration requests, as well as the last access and the deletion of users in the tool ***TOOL.2.

36. The identified users had a role of "user" in the tool ***TOOL.1, with assigned permission for consultation, which allowed them to only view (i) in relation to all consumers, customers or not of ENDESA, technical data – such as power, voltage, estimated consumption – associated with the supply point by entering the address or the so-called Universal Supply Point Code (hereinafter "CUPS"); and (ii) in the case of ENDESA customers with a valid contract, they could access the following information: name and surname of the holder of the supply point, National Identity Document number, contract number, CUPS, annual billing amount, debt indicator, pricing information, technical data regarding the supply point, consumption data, and usage graph.

The approximate volume of supply points that can potentially be consulted – one by one, individually – from the tool ***TOOL.1, provided that a CUPS or an address is entered beforehand, is 30.6 million electricity supply points and 8.6 million gas supply points. In the case of customers with a valid contract, the approximate volume that a user can consult, under the same premises indicated above, is 4.8 million electricity customers and 1.2 million gas customers.

Regarding the tool ***TOOL.2, the identified committed users could access data related to customers with a valid contract with ENDESA, with the approximate volume during the period from July 1, 2021, to October 15, 2021, being 4.8 million electricity customers and 1.2 million gas customers. As for the type of data that could be viewed, they mainly include: name and surname of the holder of the supply point, postal address, National Identity Document number, CUPS, phone number, email, contracted products, invoices, bank account number, credit quality, debts with the company.

Finally, as has been communicated to this Office, regarding the committed users and the period in which the Breach occurred, there is no record (logs) of the use of the tools ***TOOL.1 or ***TOOL.2. It is necessary to indicate that, due to the Breach, a series of measures were adopted, including the expansion of traceability (logs) of access to ***TOOL.1 to obtain detailed information on the actual use made by users – a measure that was implemented at the end of December 2021.

37. Document number 11 is provided, a copy of the burofax sent to ***COMPANY.1 notifying the termination of the contract, which has been communicated to this Office by the corresponding unit responsible for the actions taken in this regard.

In its response to the request, received by this Agency on November 25, 2022, ***COMPANY.1 has stated that:

38. Regarding the irregular practice carried out by personnel from the subcontracted company ***COMPANY.9 (***COMPANY.9), a detailed and chronological description of the events:

- 19/10/2021. ***COMPANY.1 detects that a user from the agent ***COMPANY.9 has attempted to carry out a fraudulent registration since, among other issues, it can be seen that the phone number used to send the customer the SMS confirmation of sale (the customer must respond to this SMS to confirm the sale) is the same as another phone number used for the same purpose for another customer.

C/ Jorge Juan, 6
www.aepd.es

This means that it is possible that the client did not accept the contract, having accepted it through SMS confirmation by a person other than the account holder.

- 19/10/2021. Upon suspicion that this may have been carried out by other agents of ***EMPRESA.9, ***EMPRESA.1 initiates an internal audit and communicates to the person responsible for their account at ENDESA what happened via telephone, also sending an email (the email is attached as image 1 in Document 2) with the initial inquiries made and the first measures taken in this regard. On the same day, a total closure of all users of ***EMPRESA.9 and access to any tool of the ENDESA campaign is carried out, and an internal audit is initiated to assess the volume of clients affected by fraudulent contracts.

- 19/10/2021. ***EMPRESA.1 sends a communication to all its Subagents (***EMPRESA.9 and other collaborators) participating in the ENDESA campaign informing them of what happened, the internal audit opened, and the consequences of engaging in such criminal practices (the email is attached as image 2 in Document 2).

- 20/10/2021. ***EMPRESA.1, after the audit conducted, sends a communication to ENDESA indicating the operations affected by the fraudulent practice of ***EMPRESA.9, identifying 137 contracts made and another 7 operations pending validation by ENDESA that have not been registered. Additionally, 172 orders pending validation by the back office of ***EMPRESA.9 are identified and blocked to prevent their processing. Furthermore, this communication outlines the measures intended to be implemented in the coming days to detect any other additional irregularities. Among these measures, it is proposed to ENDESA to make calls to clients who may have been affected to confirm both the legality of the contract and the verification of the account number provided. However, ENDESA prohibits ***EMPRESA.1 from making these commercial calls indicating that they will proceed themselves to verify the contracts (the communication sent to Endesa is attached as image 3 in Document 2).

On the other hand, in this communication made to ENDESA, an email from the manager of ***EMPRESA.9 is attached, informing ***EMPRESA.1 of the complaints filed with the Police of ***PAÍS.1 against its agents involved in this fraudulent practice, as well as the phone numbers used fraudulently for the confirmation of sales via SMS.

- 25/10/2021. To prevent workers from ***EMPRESA.9 from seeking refuge in other subcontractors, on October 25, ***EMPRESA.1 proceeded to close the systems and to officially communicate to the rest of the agents in the area the closure of the campaign.

- 27/10/2021. ***EMPRESA.1 receives an email from the manager of ***EMPRESA.9 detailing the inquiries made regarding the fraudulent practice carried out by some of its agents and their modus operandi, as some of the salespeople have decided to cooperate after seeing the complaint filed against them with the Police. This email details the three ways of operating, according to the management of ***EMPRESA.9, of the salespeople.

The operating methods detailed in the email are as follows:

1. They contacted the client and explained the product; if the client agreed and was aware of the contract, they proceeded with the closing. However, the client raised an objection indicating that they could not respond to the SMS for various reasons (blocked for SMS, did not have a mobile phone, no battery, about to travel, etc.). What the salesperson did was obtain a number from another client who was with Endesa and asked this latter to respond to the SMS.
2. Through the internet, the salespeople contracted the ***PLATAFORMA.1 program from ENDESA. As can be seen in images 4.1, 4.2, 4.3, and 4.4 attached in Document 2, different people "marketed" access to the ***PLATAFORMA.1 program from ENDESA. What the salespeople did was use this tool to extract data from ENDESA clients, so the recordings were made with other people.
3. Another case involved clients who, at some point, did not want to pass texts because they were too long and got tired of receiving several calls. In this case, they simulated sales with other people, and the message was also responded to by others (the email sent by ***EMPRESA.9 and received by ***EMPRESA.1 is attached as image 4 in Document 2).

39. The evaluation report of the breach presented at the internal risk committee is attached as Document 1. It should be noted that the breach is managed in the capacity of Data Processor, having collaborated with the responsible party to the extent that they requested and allowed such collaboration.

40. A copy of the Record of the activities of processing personal data of ENDESA clients carried out by ***EMPRESA.1 in the capacity of data processor, regarding treatments related to telephone sales, is attached as Document 3.

41. List of users involved in the irregular practice:

- Users of ***EMPRESA.1 with access to: ***EMPRESA.1 had a single access user (***USUARIO.11) to the tool of ***HERRAMIENTA.4.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/214

- Users of ***COMPANY.1 for performing bulk uploads of requests through the tool ***TOOL.4: ***COMPANY.1 had a single access user (***USER.12).

- Users of ***COMPANY.9 authorized to upload sales requests in the CRM of ***COMPANY.1. A list of all 46 related users through whom fraudulent sales have been uploaded is provided.

42. In order to understand the relationship between the parties involved in the contracting of products and services from ENDESA, it is important to clarify that:

- Each user of ***COMPANY.9 had an independent user in the CRM of ***COMPANY.1 to perform the upload of the requests for contracts that they had formalized through the commercial solicitation calls made. Through their user, each agent uploaded the following information into the CRM of ***COMPANY.1:

- The necessary data for the client to carry out the contracting.

- The recording of the call from start to finish, including the commercial offer + legal texts + client consent to the commercial offer and contracting of the Offered Products and Services, and the necessary files for the complete call submission.

Once this information was uploaded by each agent, an Excel file was generated in the systems of ***COMPANY.1 with the necessary data for the Back Office of ENDESA to manage the data in the commercial systems of ENDESA. The data used to generate the Excel was obtained from the upload that the agent had previously made in the CRM of ***COMPANY.1.

Additionally, a certificate was generated by a trusted third party with the SMS sent for the confirmation of the sale, which also certified the YES or NO from the client regarding the Commercial Offer.

- Once the above procedure was completed, ***COMPANY.1 proceeded, daily, to perform a bulk upload via FTP in the tool ***TOOL.4, owned by ENDESA, of all the information described above, that is, the recording of the call, the certificate from a trusted third party of the acceptance SMS from the client, and the Excel with the client information for management by the Back Office of ENDESA. For this bulk upload, ***COMPANY.1 only had access to the user of ***TOOL.4 and FTP access.

In relation to the aforementioned, it is important to highlight that the sub-agents (users of ***COMPANY.9) could only access the CRM of ***COMPANY.1, without having any direct access to the CRM of Endesa.

43. Regarding the users of ***COMPANY.9 with access to the CRM of ***COMPANY.1, it is noteworthy that there are different user profiles in the CRM of ***COMPANY.1 (Doc. 4, image 1 is attached to certify the relationship of user profiles), with ***COMPANY.1 being responsible for the application in any case.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/214

44. For its part, ***EMPRESA.1 only had one user with access to the following ENDESA tools:

- ***HERRAMIENTA.4 and the FTP access authorized by ENDESA to perform the bulk upload of contracting requests. (Doc. 4, images 4 and 5 are attached to substantiate the registration process in the application). With the user profile authorized by ENDESA, it was only possible to upload sales from the CRM of ***EMPRESA.1 to ***HERRAMIENTA.4 and view ENDESA's feedback on the status of the uploaded sales. (...)

- ***PLATAFORMA.1: This is the platform for downloading ENDESA's "do not disturb" files.

***EMPRESA.1, through this platform, downloaded the files that ENDESA made available to it weekly, which contained the phone numbers of customers who had exercised their right to object to receiving commercial calls from ENDESA. Once this file was obtained, it was cross-referenced with the databases used for making commercial calls. There was only one user with access to this application, and access was through the web. ***EMPRESA.1 only had permissions in this application to download the file. There is no other application that ***EMPRESA.1 and/or its collaborators had access to within the framework of the contractual relationship with ENDESA for the telephone recruitment of customers.

45. Each user of ***EMPRESA.9 could upload to the CRM of ***EMPRESA.1 exclusively the operations that they themselves had carried out, being able to view only the statuses of those operations until the complete closure of the sale by ENDESA. They only had access to the personal data that they themselves entered into the CRM of ***EMPRESA.1, which were, in any case, identifying and contact data (name, surname, ID number, phone number, email, supply point address, voice, CUPS number, billing address), economic data (bank account number), and personal characteristics (date of birth). A table is provided differentiating between customers with whom the complete contracting process was finalized and customers with whom, for various reasons, the contracting was not formalized. In any case, not all customers to whom these users had access were affected by the fraudulent practice of ***EMPRESA.9, as only 137 operations were affected whose fraudulent contracting was completed. For its part, ***EMPRESA.1 could access ***HERRAMIENTA.4 with its user to view the status of any contracting by any of its Subagents, being able to access the same type of personal data as described in the previous point.

46. In the CRM of ***EMPRESA.1, the following were recorded:

- the access logs of users to the CRM of ***EMPRESA.1 (date, time, IP address, and result)
- the logs of access registrations to the server URLs (date, time, IP address, and result)
- Traceability in the database (date, time, and user) of the creation of an operation by a user and of a modification of the status of the operation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/214

operation (for example, if there is any incident in the contracting, lack of documentation, or the contracting has been denied by ENDESA).

Additionally, it was allowed to impose an access limitation to the CRM by IP so that users could only access from an IP known to a higher user profile. It is noteworthy that the fraudulent practices carried out by the users of ***EMPRESA.9 were due to intentional actions performed by the users themselves, that is, the contracts were not executed due to unauthorized access by third parties to the CRM of ***EMPRESA.1, but rather through premeditated actions by the authorized users. For this reason, in the log analysis conducted, a "normal" operation of user activity is observed, without any irregularities in the use of the users being noticeable.

47. After the internal audit conducted by ***EMPRESA.1 upon becoming aware of the fraudulent practice carried out by ***EMPRESA.9, it was determined that there were a total of 137 contracts that were possibly affected. This was deduced because, in these operations, the phone number used for sending the SMS requesting customer consent to close the sale matched that of at least one other operation.

48. Attached as Document 5 is a copy of the contract signed with ***EMPRESA.9 that was in force during the period when the security breach occurred, as well as its termination effective October 19, 2021, the day on which the fraudulent practice carried out by ***EMPRESA.9 was discovered. In the

contract termination document, a typographical error can be seen in the date of the contract subject to termination, as it refers to the date on which the first contract with ***EMPRESA.9 for the distribution of ENDESA services was formalized, which was no longer in force on the date of the security breach. In any case, since it was the only commercial campaign that ***EMPRESA.9 managed on behalf of ***EMPRESA.1 in favor of ENDESA, with the aforementioned termination communication, the commercial relationship between the parties was understood to be resolved, and among other things, access for their users to load sales in the CRM of ***EMPRESA.1 was withdrawn.

According to the diligence carried out on October 13, 2022, ENDESA is a public limited company of Spanish nationality. According to the data available in AXESOR, the company has a "Large" size with XXX employees, and in the year 2021 (the last fiscal year presented), it had a sales volume of ***CANTIDAD.1 euros and an operating result of ***CANTIDAD.3 euros.

SIXTH: On January 27, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against ENDESA in accordance with the provisions of Articles 63 and 64 of the LPACAP, in which it was indicated that it had a period of ten days to present allegations, in order to impose:

- For the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of said regulation, an administrative fine of 2,500,000.00 euros.
- For the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of said regulation, an administrative fine of 1,500,000.00 euros.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
26/214

- For the alleged violation of Article 33 of the GDPR, classified under Article 83.4 of said regulation, an administrative fine of 800,000.00 euros.
- For the alleged violation of Article 34 of the GDPR, classified under Article 83.4 of said regulation, an administrative fine of 800,000.00 euros.
- For the alleged violation of Article 44 of the GDPR, classified under Article 83.5 of said regulation, an administrative fine of 2,000,000.00 euros.

This initiation agreement, which was notified to ENDESA in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on January 30, 2023.

SEVENTH: On January 30 and 31, and February 1, 2, and 3, 2023, ENDESA submitted a document requesting an extension of the deadline to present allegations and to be provided with a copy of the file.

On February 3, 2023, the instructing body of the procedure agreed to extend the requested deadline by a maximum of five days, in accordance with the provisions of Article 32.1 of the LPACAP, and to send ENDESA a copy of the file.

The aforementioned agreement was notified to ENDESA on February 6, 2023, as evidenced by the acknowledgment of receipt in the file.

EIGHTH: On February 20, 2023, a timely and proper document from ENDESA was received by this Agency, in which it presented allegations against the initiation agreement.

In these allegations, in summary, it stated that:

- Preliminary allegation: Specification of certain essential factual points for the legal analysis of the file, since there are, in its view, some issues in the Initiation Agreement that, being very relevant for the assessment of ENDESA's conduct, have not been interpreted by the AEPD, in its opinion, correctly.
- ENDESA had implemented security measures appropriate to the risk:
- Document number 1 is provided with a detailed explanation of each of the developments in the platform ***HERRAMIENTA.1, as well as its hourly valuation.
- Document number 2 is provided with a detailed explanation of each of the developments and tasks necessary for the implementation of the security measure in ***HERRAMIENTA.2.
- There is concurrence of violations of Article 5.1.f) of the GDPR and Article 32 of the GDPR.

- The principle of legality of Article 5.1.f) of the GDPR has been violated.
 - The sanction for the violation of Article 33 of the GDPR is not applicable:
 - Document number 3 is provided in which ENDESA continues to request ***EMPRESA.1 for additional information regarding the Data Security Breach to continuously reevaluate its conclusion that the Breach is not reportable, without ***EMPRESA.1 or ***EMPRESA.9 providing relevant information, in its opinion.
 - Document number 4 is provided in which ENDESA again requests ***EMPRESA.1 to provide more information about the Data Security Breach, and ***EMPRESA.1, once again, provides incomplete information, in its opinion.
 - Document number 5 is provided with the security breach management protocol developed by ENDESA.
 - The sanction for the violation of Article 34 of the GDPR is not applicable.
 - The sanction for the violation of Article 44 of the GDPR is not applicable:
 - Document number 6 is provided with the Standard Contractual Clauses signed with its suppliers located outside the European Economic Area, in compliance with its internal procedure for carrying out international transfers.
 - Document numbers 7, 8, and 9 are provided with the Standard Contractual Clauses signed with the suppliers ***EMPRESA.15, ***EMPRESA.12, and ***EMPRESA.9, respectively.
 - There is a lack of proportionality regarding the severity of the sanction to be imposed on ENDESA.
- NINTH: On June 13, 2023, the instructing body of the procedure agreed to open a period for the practice of evidence, considering incorporated the notification of the personal data security breach that led to this procedure and its documentation, the documents obtained and generated during the preliminary investigation phase, and the corresponding report, which are part of procedure AI/00178/2022, as well as the allegations to the initiation agreement presented by ENDESA and the accompanying documentation.

In that same document, this Agency required ENDESA to present the following information within five business days: the expert report from an independent third party referenced by the aforementioned company on page 7 of its allegations to the initiation agreement of this sanctioning procedure, in order to demonstrate that “despite some Facebook ads remaining active (...), the credentials offered through that medium no longer allowed access to the systems ***HERRAMIENTA.1 and ***HERRAMIENTA.2 because they were disabled” and that “as a result of the new security measures implemented by Endesa, no additional unauthorized user would achieve the purpose of selling/renting access credentials to Endesa’s systems, as those measures would prevent it.”

On June 14, 16, and 19, 2023, ENDESA submitted a document in which it requested an extension of the deadline to present the aforementioned report.

On June 19, 2023, the instructing body of the procedure agreed to extend the requested deadline by a maximum of two days, in accordance with the provisions of Article 32.1 of the LPACAP.

The aforementioned agreement was notified to ENDESA on June 20, 2023, as evidenced by the acknowledgment of receipt in the file.

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es
 28/214

On June 23, 2023, ENDESA submitted a response to this Agency, in which it provided as Document number 1 the requested report.

TENTH: On June 23, 2023, the instructing body of the procedure sent a request to ENDESA to present the following information within five working days:

- Indication of whether it has signed new standard contractual clauses for the international transfers of data made to ***COMPANY.9, adapted to the implementing decision 2021/914 of the Commission, June 4, 2021, regarding the standard contractual clauses for the transfer of personal data to third countries in accordance with Regulation (EU) 2016/679 of the European Parliament and of the Council (Text relevant for EEA purposes), and, if applicable, provide a signed copy of the same.

- Accreditation of the assessment regarding the law and practices of ***COUNTRY.1 and ***COUNTRY.2 applicable to the processing of personal data carried out by the entities ***COMPANY.15, ***COMPANY.12, and ***COMPANY.9, referred to in paragraph b) of clause 14 of the aforementioned Implementing Decision of June 4, 2021.

The aforementioned request was notified to ENDESA on June 26, 2023, as evidenced by the acknowledgment of receipt in the file.

On July 3, 2023, ENDESA submitted a response to this Agency, in which it provided:

- Document number 1: a copy of the burofax sent by ***COMPANY.1 to ***COMPANY.9 notifying the definitive closure of the sales campaign that ***COMPANY.9 was conducting for Endesa.
- Document number 2: proof from Correos confirming the sending of the aforementioned burofax to ***COMPANY.9.
- Document number 3: notice from Endesa's internal supplier system confirming that, on November 2, 2021, the subcontractor ***COMPANY.9 was disassociated.
- Document number 4 and number 5: impact assessments of the international transfers regarding the data transferred to ***COUNTRY.1 and ***COUNTRY.2, in cases where ***COMPANY.15 and ***COMPANY.12 acted as importers of the data, all of which is due to the fact that the contractual relationship between Endesa and ***COMPANY.15 is still in force, and in the case of ***COMPANY.12, it was maintained until November 2022.
- Document number 6: impact assessment regarding the law and practices of ***COUNTRY.2 applicable to the processing of personal data carried out by the supplier ***COMPANY.15 itself.
- Document number 7: agreement for the termination of the contract signed between Endesa and ***COMPANY.16, which implies the end of the subcontracting with ***COMPANY.12.

ELEVENTH: On August 23, 2023, the instructing body of the procedure issued a proposal for resolution in which it proposes to impose on ENDESA:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/214

- For the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of said regulation, an administrative fine of 2,500,000.00 euros.
- For the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of said regulation, an administrative fine of 1,500,000.00 euros.
- For the alleged infringement of Article 33 of the GDPR, classified in Article 83.4 of said regulation, an administrative fine of 800,000.00 euros.
- For the alleged infringement of Article 34 of the GDPR, classified in Article 83.4 of said regulation, an administrative fine of 800,000.00 euros.
- For the alleged infringement of Article 44 of the GDPR, classified in Article 83.5 of said regulation, an administrative fine of 2,000,000.00 euros.

This proposal for resolution, which was notified to ENDESA in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on August 24, 2023, as evidenced by the acknowledgment of receipt in the file.

TWELFTH: On August 24, 2023, ENDESA submitted a document through which it requests an extension of the deadline to present allegations and that a copy of the file be provided to it.

THIRTEENTH: On August 28, 2023, the instructing body of the procedure agreed to extend the requested deadline by up to five days, in accordance with the provisions of Article 32.1 of the LPACAP, and that a copy of the file be sent to ENDESA.

The aforementioned agreement was notified to ENDESA on August 30, 2023, as evidenced by the acknowledgment of receipt in the file.

FOURTEENTH: On September 14, 2023, a document from ENDESA was received at this Agency, in due time and form, in which it presented allegations to the proposal for resolution. In these allegations,

in summary, it stated that:

- Preliminary allegation: Specification of certain essential factual points for the legal analysis of the file, since there are, in its view, some issues in the Initiation Agreement that, being very relevant for the assessment of ENDESA's conduct, have not been interpreted by the AEPD, in its opinion, correctly.
- The sanction for the infringement of Article 32 of the GDPR is not applicable:
- Document number 1 is provided, the email dated November 29, 2021, by which ENDESA requests the reset of the users reported by ***COMPANY.1 as fraudulent and the confirmation that they had been successfully reset on that same day.
- There is a concurrence of infringements of Article 5.1.f) of the GDPR and Article 32 of the GDPR.
- The principle of legality of Article 5.1.f) of the GDPR has been violated.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/214

-

No sanction is applicable for the infringement of Article 33 of the GDPR.

-

No sanction is applicable for the infringement of Article 34 of the GDPR:

☐

Document number 2 is provided with a statement from ***DEPARTMENT.7 detailing the actions taken by Endesa to personally assist the data subjects who may have been affected by the incident, as well as examples of such tasks.

-

No sanction is applicable for the infringement of Article 44 of the GDPR.

-

There is a lack of proportionality regarding the severity of the sanction to be imposed on Endesa. In view of all the actions taken by the Spanish Data Protection Agency in this procedure, the following facts are considered proven:

PROVEN FACTS

FIRST: On December 1, 2015, as stated in Document number 7 accompanying the statement of objections to the initiation agreement of this sanctioning procedure, the Director of the Spanish Data Protection Agency issued a resolution authorizing the international transfer of personal data requested by Endesa to ***COMPANY.15, located in ***COUNTRY.2.

SECOND: On June 1, 2020, Endesa and ***COMPANY.1 signed a contract to market Endesa's products and services through various commercial actions, as indicated in Document 1 of the statement from ***COMPANY.1 dated November 25, 2022.

THIRD: On July 22, 2020, as stated in Document 9 accompanying Endesa's statement of objections to the initiation agreement of this sanctioning procedure, Endesa, as the data exporter, and ***COMPANY.9 (with an address in ***COUNTRY.1) as the data importer, signed a service provision contract to comply with Article 46.2.c) of Regulation (EU) 2016/679 of April 27, on Data Protection ("GDPR") and in accordance with the provisions of Decision 2010/87/EU of the Commission, of February 5, 2020, regarding standard contractual clauses for the transfer of personal data to processors established in third countries.

FOURTH: On March 3, 2021, as stated in Document 5 accompanying the statement from ***COMPANY.1 dated November 25, 2022, ***COMPANY.1 and ***COMPANY.9 signed a contract for the "intermediation activity in customer registrations for Endesa through making commercial telemarketing calls using Endesa's databases."

FIFTH: On March 14, 2021, the user "D.D.D." published an advertisement on Facebook, as stated in Document number 2 of Endesa's statement dated November 11, 2022: "System for obtaining energy and gas cups for rent only with the customer's address. Info in the inbox!!"

C/ Jorge Juan, 6

www.aepd.es

31/214

SIXTH: On April 28, 2021, a contract was signed between (...) and ***COMPANY.1 for telemarketing services, as stated in Document number 4 accompanying Endesa's statement dated October 7, 2022.

SEVENTH: On May 5, 2021, as stated in Document 8 accompanying the statement of objections to the initiation agreement of this sanctioning procedure, Endesa and ***COMPANY.12 signed a contract to comply with Article 46.2.c) of Regulation (EU) 2016/679 of April 27, on Data Protection ("GDPR"), in accordance with Decision 2010/87/EU of the Commission, of February 5, 2020, regarding standard contractual clauses for the transfer of personal data to processors established in third countries.

EIGHTH: On July 28, 2021, Endesa authorized ***COMPANY.1 to subcontract ***COMPANY.9 for the provision of telemarketing services, as stated in Document number 6 accompanying Endesa's statement dated October 7, 2022, which set the "start date of the subcontracted work as August 1, 2021" and the "end date as August 1, 2022."

NINTH: On August 24, 2021, the person responsible for ***DEPARTMENT.1 of Endesa sent an email to the Information Security Officer of the Endesa Group, informing about a suspicious advertisement on Facebook.

As stated in Document number 6 accompanying Endesa's statement submitted on July 26, 2022, the content of the email was as follows: "(...)"

As Endesa stated in its submission on July 26, 2022, this notice activated the analysis and investigation process, the first step of which is to confirm the veracity of the advertisement.

TENTH: On September 1, 2021, as stated in Document number 4 accompanying Endesa's statement dated November 11, 2022, Endesa received an email from ***COMPANY.16, with the following content: "(...) The person we do know is D.D.D., as we have recognized their profile picture. (...) Their full name is D.D.D.. (...)"

ELEVENTH: On September 3, 2021, as stated in Document number 8 of Endesa's statement dated November 11, 2022, the user "****USER.3" assigned to ***COMPANY.12 was reset or disabled on the platform ***TOOL.1.

TWELFTH: On September 10, 2021, as stated in Document number 8 of Endesa's statement dated November 11, 2022, Endesa sent an email with the following content:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/214

"(...) Given that we are talking about an employee currently active at ***COMPANY.15, I would appreciate it if you act with the utmost speed and proceed to sever ties with our operations. I understand that, among other things, you will take legal action against said employee. I would appreciate it if you keep me promptly informed of the measures you take against him. Likewise, I understand that ***COMPANY.15 must implement the necessary cybersecurity and tracking measures that allow for the location, as ENDESA has done, of possible marketing of users assigned to you and, therefore, under your full responsibility. For our part, we proceed to immediately deactivate the user. (...)"

THIRTEENTH: On September 10, 2021, as stated in Documents 8, 9, and 10 of ENDESA's letter dated November 11, 2022, the user ***USER.8, assigned to ***COMPANY.15, was reset or disabled on the ***TOOL.1 platform. And it was proceeded to withdraw and delete it from the ***TOOL.2 systems.

FOURTEENTH: On September 13, 2021, as stated in Document number 10 accompanying ENDESA's letter dated July 26, 2022, the first assessment of the violation of personal data security was carried out, where the information obtained up to that moment was recorded in a document signed on September 14, 2021.

The content of the document is as follows:

“On August 24, an advertisement was detected on Facebook selling a user of ***PLATFORM.1 with access to client information for an energy campaign in Spain; the image below contains the advertisement.

(...)

Once the advertisement was detected, the incident study was initiated, obtaining on September 10 verification of its authenticity and identification of the credentials used fraudulently for access to Endesa's application ***PLATFORM.1.

During the investigation of the incident, the compromise of the credentials of a user of the application was detected, which were being used by the Facebook advertiser to sell accesses. The validity of these credentials has been verified, but it has not been possible to confirm whether the sale of the credentials was realized, and if it was, the number of application records that may have been accessed is unknown. Based on the information collected so far, which includes the time elapsed since the advertisement was published, the type of service offered, and the limitations in the queries provided by the application, it is estimated that the number of affected records could be in a range of access between 100 and 1,000 affected records.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

33/214

At the time of making this assessment, no customer claims have been detected that can be associated with this incident.

On September 13, a Security Breach Committee was convened to analyze the incident.

Assessment of the scope

(...)

III. CONCLUSION

In a meeting held (...), after conducting a timely and proper assessment of the scope of the security incident and the possible repercussions for the rights and freedoms of the affected data subjects, the preliminary decision was made not to communicate the security incident to the supervisory authority as it does not reach the threshold set forth in the agency's guidelines on security breaches. However, from ***DEPARTMENT.4, the need to continue the investigation is noted.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

34/214

subject to the power to carry out a new assessment of the incident, considering that the information provided is not complete and the present analysis is preliminary.

Considering the previous statements, the executed and planned action plan is enumerated to ensure the security measures to be established:

• (...)

FIFTEENTH: On September 21, 2021, as stated in Document number 3 accompanying ENDESA's letter dated November 11, 2022, ENDESA received an email with the following content:

“(...) to confirm that the person you indicated (C.C.C.) was an employee of ***EMPRESA.15 but has been off the company since 2016. We have tried to identify any type of link between this person and the user agent being used; so far, nothing has been found. We have traced the social media of both and found no apparent link.”

SIXTEENTH: On September 21, 2021, as stated in Document 8 of ENDESA's letter dated November 11, 2022, the user ***USUARIO.5 of the platform ***HERRAMIENTA.1, assigned to ***EMPRESA.12, was reset or disabled.

SEVENTEENTH: On September 28, 2021, as stated in Document number 11 accompanying ENDESA's letter dated July 26, 2022, a second assessment was carried out where the information

from the first was completed; although its content is practically identical, it adds as a proposed measure the “Disassociation from the company and study of legal actions against the employee whose credentials have been compromised.” (sic) The report considers that the impact of the present incident was “Medium” and that it was not necessary to notify the incident to the AEPD.

EIGHTEENTH: On October 18, 2021, as stated in Document number 8 accompanying ENDESA's letter dated October 7, 2022, an email was received from Facebook with the subject “Copyright report form #(...)”, in which it is communicated that Facebook removed or disabled access to three links that had been reported for violating its Statement of Rights and Responsibilities. It is also indicated that two links have already been removed from Facebook. Finally, regarding six other links, it states, “Please note that this channel is for reporting intellectual property infringements only, such as copyright or trademark rights. Based on the information you provided, it seems that you need help with another matter. The following help links may be useful to you: (...)”.

NINETEENTH: On October 19, 2021, as stated by ***EMPRESA.1 in its letter dated November 25, 2022, it detects that a user of the agent ***EMPRESA.9 has attempted to carry out a fraudulent registration since, among other issues, it can be seen that the phone number used to send the customer the SMS confirmation of sale (the customer must respond to this SMS to confirm the sale) matches another phone number used for the same purpose for another customer, so it is possible that the customer did not accept the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
35/214

contract, having been accepted through SMS confirmation by a person different from the contracting holder.

TWENTIETH: On October 19, 2021, as stated in Document 2 of the letter from ***COMPANY.1 dated November 26, 2022, ***COMPANY.1 sent an email to ENDESA with the following content:
“(...)”

TWENTY-FIRST: On October 19, 2021, as stated in Document 2 of the letter from ***COMPANY.1 dated November 25, 2022, ***COMPANY.1 sent a communication to all participating Subagents in the ENDESA campaign, with the following content:

“We have detected a series of operations from different holders in which the contact number (mobile where the SMS is sent) is coincident. This means that it is not the customer who has signed the specific conditions of the contract. This type of action (identity theft) leads to criminal liability and logically to the closure of the campaign.

To avoid such situations, confirm mandatory before sending the SMS that the mobile number belongs to the contract holder before recording the sale. Audits are being conducted in this regard, and anyone performing such actions will have an automatic code closure. (...)”

TWENTY-SECOND: On October 20, 2021, as stated in Document 2 of the letter from ***COMPANY.1 dated November 25, 2022, ***COMPANY.1 sent an email to ENDESA with the following content:

“(...) After internal analysis on the export of the file from ***TOOL.4, after applying the following filters: Sales in process or in force, corresponding to contracts that are in these states with the last status change in ***TOOL.4 corresponding to the months of July, August, September, and October, we filtered 144 customers who have a duplicated contract consent phone number.

Of these orders, there are 7 (detailed customers) in process or pending BO (marked in red). The remaining 137 (marked in black) are from active customers with a duplicated contract consent number. (...)”

TWENTY-THIRD: On October 20, 2021, an email was sent from ***COMPANY.9 to ***COMPANY.1 with the following content, which was forwarded to ENDESA, as stated in Document number 12 of the letter submitted by ENDESA on October 7, 2022, and in Document 2 of the letter from ***COMPANY.1 dated November 26, 2022:

“Today we proceeded with the dismissal and the corresponding report for computer fraud, law typified (...) against the salespeople involved in the fraudulent sale. This last action was taken so that

regardless of the responsibility that we clearly assume as a company, we want to make it clear that this is not a practice endorsed by us, we totally repudiate it and it does not define our way of working. For that reason, we additionally initiated an internal audit, where we found other customers and salespeople with similar practices, with whom we proceeded in the same manner and we provide you with all the data found so far, and we will expand information in subsequent emails.”

And the list of all reported salespeople and duplicated mobile numbers in sales is provided.

TWENTY-FOURTH: On October 20, 2021, as stated in Document 2 accompanying the letter from ***COMPANY.1 dated November 25, 2022, ***COMPANY.1 sent an email to ENDESA with the following content:

“I will detail the points we are already working on to detect any possible additional incidents to those already detected.

- Verify by phone call (recordings of calls and Excel list provided) the following points:
 - Confirmation with the customer that they are interested in the contracting; those who are not interested should indicate this to request the cancellation of the change of supplier to Endesa.
 - Confirm with all customers that the payment account is correct; those not provided by the customer should indicate this to cancel the company change or if they are active, modify the payment account.
- Initially, we will manage the sales that we understand may be affected by this situation and subsequently, we will call all customers processed since September (the date when we detected the beginning of this practice) to resolve the contract situation if there are any more affected.

In another order, we are canceling in ***TOOL.4 the 172 orders that are pending BO from ***COMPANY.9 so that they can proceed. (...)”

TWENTY-FIFTH: On October 25, 2021, as stated by ***COMPANY.1 in its letter dated November 25, 2022, to prevent the workers of ***COMPANY.9 from taking refuge in other subcontractors, ***COMPANY.1 proceeded to close the systems and to communicate reliably to the rest of the agents in the area the closure of the campaign.

TWENTY-SIXTH: On October 27, 2021, as stated in Document 2 of the letter from ***COMPANY.1 dated November 25, 2022, ***COMPANY.1 received an email from ***COMPANY.9, with the following content:

“(...) In order to identify all affected customers, measures have been taken that have already been discussed over the phone; which have been reported due to the action taken.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/214

Based on this, several sales representatives have decided to collaborate by providing details indicating what they were doing.

1. They contacted the client and explained the product; if the client agreed and was aware of the contract, they proceeded with the closing. However, the client raised objections indicating that they could not respond to the SMS for various reasons (blocked for SMS, did not have a mobile phone, had no battery, was about to travel, etc.). What the sales representative did was obtain the number of another client who was with Endesa and asked this latter to respond to the SMS.

2. Through the internet, the advisors have contracted ***PLATFORM.1. What the sales representatives did was use this tool to extract data, so the recordings were made with other people. Attached are the users of ***PLATFORM.1 that have been used. It is worth mentioning that we requested this tool at the time, but you denied it, indicating that it was prohibited. Attached are the users who have utilized it:

***USER.3

***USER.10

***USER.5

***USER.6

***USER.7

3. Another case involved clients who, at some point, did not want to pass texts due to their length and

became tired of receiving several calls. What they did was simulate sales with other people, and the message was also responded to by others. (...)"

This email is accompanied by four images:

- Image of a Facebook ad, dated October 17, from the user "E.E.E.", with the following content:

"Users are created for energy campaign

System of ***PLATFORM.1

For energy campaign"

- Image of a Facebook ad, dated October 13, from the user "F.F.F.", with the following content:

"***PLATFORM.1 rental for 30 days"

- Image of a Facebook ad, dated October 13, from the user "F.F.F.", with the following content:

"We have user ***PLATFORM.1 available for monthly rental"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/214

- Image of a Facebook ad, from the user "C.C.C.", with the following content:

"[several surprised face emojis]

If you are just starting in the world of sales for Energy Spain

We have a system that will help you increase your leads and sales!!!!

A user of #***PLATFORM.1 is created for the energy campaign in Spain!!!!... See more"

TWENTY-SEVENTH: On October 27, 2021, as stated by ENDESA in its letter dated October 7, 2022, a supplier of ENDESA alerted them about the irregular use that some of its advisors had made with certain access credentials to ***TOOL.1 that had been acquired irregularly. In this communication, five compromised users of ***TOOL.1 were identified, who were identified by the subcontracting company of the ENDESA supplier.

In document number 3 accompanying the aforementioned letter, an email received by ENDESA on October 27, 2021, is observed, indicating:

"Through the internet, the advisors have contracted ***PLATFORM.1. What the sales representatives did was use this tool to extract data, so the recordings were made with other people. (...)

Attached are the users who have utilized it:

***USER.3

***USER.10

***USER.5

***USER.6

***USER.7

TWENTY-EIGHTH: On October 27, 2021, as stated in Documents 1 and 2 of the letter submitted by ENDESA on July 3, 2023, in response to a request from this Agency, ***COMPANY.1 sent a certified letter to ***COMPANY.9, with the following content:

"(...)

On October 19 of this year, ***POSITION.1, G.G.G., sent you an email warning that identity thefts were being detected in several clients, as the phones and recordings did not match the contracted client, and that the sales campaign was being suspended provisionally to initiate an audit and clarify the facts, along with Endesa Energía.

At this moment, and still unable to determine the exact number of fraudulent sales due to the laborious nature of the process, I inform you, in the representation I hold, of the definitive closure effective October 19, of the sales campaign.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/214

TWENTY-NINTH: On October 28, 2021, as stated in Document 5 of the writing from ***COMPANY.1 dated November 25, 2022, ***COMPANY.1 sent a certified electronic communication to ***COMPANY.9, with the following content:

“(…)

On October 19 of this year, ***POSITION.1, G.G.G., sent you an email warning that identity theft was being detected in several clients, as the phones and recordings did not match the contracted client, and that the sales campaign was being suspended as a precautionary measure to initiate an audit and clarify the facts, together with Endesa Energía.

At this moment, and still unable to determine the exact number of fraudulent sales due to the laborious nature of the investigation, I inform you, in the representation I hold, of the definitive closure effective October 19, of the sales campaign for supply contracts of Endesa Energía, all in accordance with the clauses of the contract signed between the parties. (…)

THIRTIETH: On November 2, 2021, ***COMPANY.9 was deactivated as a supplier in ENDESA's systems, as stated in Document 3 of the writing submitted by ENDESA on July 3, 2023.

THIRTY-FIRST: On November 4, 2021, as stated in Document 1 of the writing from ***COMPANY.1 dated November 25, 2022, ***COMPANY.1 prepared a report on the violation of personal data security in question, detected by them on October 19, 2021. The report indicates:

“(…)

The security breach can be classified as an integrity breach insofar as there has been an intentional alteration of the mobile phone number of the client used to send the SMS confirmation of the sale, with the aim of having another person accept the sale, and, in some cases, there has also been an intentional alteration of the client's bank account number.

Likewise, the security breach can be considered a breach of confidentiality since, in some cases, the call recording was made with a fictitious client, and therefore, this person had access to personal data of the client whose identity was being impersonated.

(…)

Volume of affected individuals: There are 137 sales operations affected by completed fraudulent contracting, another 7 sales operations pending validation by Endesa, and 172 sales operations that were blocked while pending validation by the back office of ***COMPANY.9. There may be individuals who have been affected by two or more fraudulent contracts, so the number of affected individuals will be less than the number of sales operations indicated. The final number of affected individuals will be determined by Endesa upon completion of the management.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/214

to close the security breach as they do not allow ***COMPANY.1 to continue collaborating with them in resolving the breach.

However, the affected individuals are easily identifiable.

Profile of affected individuals: Adults aged 18 to 65 residing in Spain, clients or potential clients of Endesa.

The severity level of the consequences for the affected individuals can be considered high as they could face energy supply cuts, stress, and additional costs.

(…)

The security breach suffered is due to the commission of a crime of identity theft and fraudulent contracting by the company ***COMPANY.9, which may have negative consequences for the affected parties.

After the analysis conducted, it is concluded that the verification procedure for sales made must be reinforced, as well as the procedure imposed by Endesa on its distributors for telephone contracting.

With the currently imposed procedure, there are cases where it is difficult to verify whether the identity of the person claiming to contract the service corresponds to the actual person contracting it.

For example, in a real situation, a real client could request that a different phone number be entered for

contracting purposes than the number from which the commercial call is being made, or they could even request that the SMS confirmation of the sale be sent to a different number than the one where the commercial call is being made (for example, if the call is being received on a landline).

On the other hand, if the operation were subject to fraud, as has been the case, even with a welcome or loyalty call, there would be a possibility that the fraud would not be identified since the involved salesperson could have entered a phone number different from the actual one of the contract holder. Therefore, we understand that additional measures are needed from Endesa to identify the contract holders, as it is not possible to expand technical measures to limit security breaches like the one suffered, considering the procedure that ***COMPANY.1, as Data Processor, must follow at the request of the Controller.

Currently, the security breach is still being managed by Endesa.

THIRTY-SECOND: On November 4, 2021, as stated in Document 8 accompanying the written allegations to the initiation agreement of the present sanctioning procedure, ENDESA, ***COMPANY.16, and ***COMPANY.11 signed an ANNEX TO THE FRAMEWORK AGREEMENT SIGNED (...), which complied with Article 46.2.c) of Regulation (EU) 2016/679, of April 27, on Data Protection ("GDPR"), and with the Commission Implementing Decision (EU) 2021/94 of June 4, 2021, regarding the standard contractual clauses for the transfer of personal data to third countries in accordance with the GDPR, concerning international data transfers between the controller and processor, which indicates that ***COMPANY.16 provides telephone marketing services to ENDESA and it is necessary for this to subcontract ***COMPANY.11, which will act as the data importer.

THIRTY-THIRD: On November 11, 2021, as stated in Document 7 accompanying the written allegations to the initiation agreement of the present sanctioning procedure, ENDESA and ***COMPANY.15 signed an ANNEX TO THE FRAMEWORK AGREEMENT SIGNED, which complied with Article 46.2.c) of Regulation (EU) 2016/679, of April 27, on Data Protection ("GDPR"), and with the Commission Implementing Decision (EU) 2021/94 of June 4, 2021, regarding the standard contractual clauses for the transfer of personal data to third countries in accordance with the GDPR, concerning international data transfers between the controller and processor.

THIRTY-FOURTH: On November 19, 2021, as stated in Document number 8 of ENDESA's written submission of November 11, 2022, the user ***USER.2, assigned to ***COMPANY.8, was reset or disabled and was removed and deleted from the systems of ***TOOL.1.

THIRTY-FIFTH: On November 29, 2021, as stated in Document number 8 of ENDESA's written submission of November 11, 2022, the user ***USER.4, assigned to ***COMPANY.15, was reset or disabled in the systems of ***TOOL.1.

Also on November 29, 2021, as stated in Document number 1 accompanying the written allegations to the resolution proposal of the present sanctioning procedure, an email in English was sent to "***DEPARTMENT.5," informing that the following users have been compromised and requesting that they be reset as soon as possible:

- ***USER.3
- ***USER.4
- ***USER.5
- ***USER.6
- ***USER.7

On the same day, as stated in Document number 1 accompanying the written allegations to the resolution proposal of the present sanctioning procedure, an email in English was sent from "***DEPARTMENT.5," in response to the previous one, confirming that the compromised accounts had been correctly reset and that, for each user, an SMS with a link to change the password (where possible) had been sent, and an email had been sent to that user's manager with information that the user in question had been compromised, along with the password change.

THIRTY-SIXTH: On December 13, 2021, as stated by ENDESA in its written submission on July 26, 2022, the last identified announcement was published.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

related to the illicit use of credentials of the ***TOOL.1 platform.

And in January 2022, the last identified publication regarding the sale of customer databases for electricity and gas was made. No new publications related to this incident have been detected after the notification made on February 10, 2022.

THIRTY-SEVENTH: On December 14, 2021, as stated in Document number 8 accompanying the aforementioned writing, an email was received from Facebook with the subject "Intellectual Property Complaint No. (...)", in which it is indicated: "The Facebook team has received your complaint. (...) We remind you that if you have contacted us regarding an alleged infringement of your legal rights, you do not need to take any further action. We will investigate the matter as soon as possible. (...)".

THIRTY-EIGHTH: On January 12, 2022, as stated in Documents number 9 and 10 of the ENDESA writing dated November 11, 2022, the user ***USER.3 and the user ***USER.5, assigned to ***COMPANY.12, were removed from the ***TOOL.2 systems.

The last access of user ***USER.5 to the ***TOOL.2 system had been on November 25, 2021.

The last access of user ***USER.3 to the ***TOOL.2 system had been on November 26, 2021.

THIRTY-NINTH: On January 17, 2022 (as stated in Document number 8 of the writing submitted by ENDESA on July 26, 2022), advertisements were published by user B.B.B., which affected ENDESA's energy customer databases.

FORTIETH: On January 31, 2022, ENDESA drafted a burofax, as stated in Document number 11 of the ENDESA writing dated November 11, 2022, addressed to ***COMPANY.1, with the following content:

"Dear Supplier:

We are writing to you regarding Contract No. (...) signed between ENDESA ENERGÍA, S.A.U. (hereinafter ENDESA ENERGÍA) and ***COMPANY.1 (hereinafter ***COMPANY.1) and as a continuation of a previous communication sent by this entity dated December 20, 2021, through which we informed ***COMPANY.1 of the application of penalties in accordance with the provisions of Clause 12 of the aforementioned Contract.

As is known by ***COMPANY.1, ENDESA ENERGÍA has detected, through the corresponding quality control audit in accordance with the provisions of Clause 15.4 of the signed Contract, numerous irregularities related to the contracting management procedure provided in Annex 2D of the signed Contract during the period from October to November 2021, both inclusive. So much so that, as is also known by ***COMPANY.1, various requests for information have been received from the AEPD regarding contracts managed by ***COMPANY.1.

Specifically, and as a reminder, we list the various requests that have been received to date by ENDESA ENERGÍA from the AEPD, which originate from contracting management carried out by ***COMPANY.1 and which demonstrate the repeated and ongoing breach of the signed Contract and the procedures established therein:

(...)

Given the seriousness of the detected irregularities that constitute a repeated breach of the signed Contract, through this communication and without prejudice to the application of penalties that were already communicated by letter dated December 20, 2021, and other possible penalties that may arise in accordance with the signed contract, we inform you that it is the intention of ENDESA ENERGÍA, under the provisions of Clause 13, to terminate this contract with effect from the date of receipt of this communication. (...)"

FORTY-FIRST: On February 7, 2022, as stated in Document number 9 of the ENDESA writing submitted on October 7, 2022, ENDESA sent a burofax with a written communication to FACEBOOK SPAIN S.L., which was delivered on February 8, 2022, with the following content:

"(...) FIRST: It has been detected since late 2021 to date that the social network FACEBOOK is being used for fraudulent practices that severely harm the interests of ENDESA, all of which are related to the sale of access credentials to management platforms containing personal data. In this regard:

1. Searches have been conducted on social networks and open sources, detecting that all advertisements for the sale of credentials are published on FACEBOOK.

2. Currently, at least a total of 10 active publications have been identified (...)
3. All of them have been requested for removal without receiving any response and without any action being recorded in this regard. For the advertisements with the oldest publication dates, this removal request has been made more than 10 times without achieving completion.
4. These advertisements have been published by 3 profiles essentially: "B.B.B.", "C.C.C.", and "D.D.D.", with the first two being the most active, including their public and marketplace profiles (...)
5. Additionally, 2 marketplace profiles associated with "B.B.B." and "C.C.C." have been identified, presumably controlled by the same person, to which more than 210 and 197 publications are associated, respectively (...). These advertisements are screenshots of personal data databases whose origin or ownership we do not know.

In addition to the aforementioned, Groups have been detected that include similar actions as those indicated: (...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
44/214

As you will be able to verify, various user advertisements appear announcing the sale/rental of usernames and passwords for access to the platform ***PLATAFORMA.1, owned by ENDESA. As of today, it is unknown whether there is a higher number of profiles as well as offers.

(...)

FOURTH: There have been repeated warnings to your company regarding the aforementioned behaviors without, which is even more serious, any remedy for the damage despite the ongoing situation. In numerous cases, it is even stated that "we are not clear that the content reported is illegal, so we cannot take any action at this time." This request is sent via burofax after numerous previous attempts sent to the addresses provided for this purpose.

FIFTH: Given the seriousness of the facts mentioned in the previous section, (...) we feel obliged to inform you that the described practices, prima facie (...) could constitute a sale/rental of credentials owned by ENDESA that may be classified as a crime under article 197 ter b) of the Spanish Penal Code (...)

For the reasons stated in the previous sections, we require your company to immediately commit to removing such advertisements and preserving them so that, in case they are requested, they can be treated as evidence in a possible judicial process. (...)

FORTY-SECOND: On February 8, 2022, Facebook Spain S.L. responded to ENDESA as follows (as stated in Document 10 accompanying ENDESA's letter of October 7, 2022):

"Facebook Spain S.L. (hereinafter <>) acknowledges receipt of your correspondence.

Facebook Spain S.L. (hereinafter, "Facebook Spain") acknowledges receipt of your correspondence.

First of all, please note that Facebook Spain is not the competent entity to resolve your inquiry. Nothing in this correspondence should be interpreted as an admission to the contrary. We inform you that, for users located in Spain, Facebook Spain does not operate nor has control over Facebook Products (as defined in our Terms of Service, available at <https://www.facebook.com/terms.php>).

For users located in Spain, the operation and control of Facebook Products correspond to Facebook Ireland Limited, an entity incorporated in Ireland with its registered office in Dublin. Facebook Ireland Limited is the entity with which users located in Spain maintain a contractual relationship. Facebook Spain is an autonomous, independent, and legally distinct entity from Facebook Ireland Limited.

Therefore, Facebook Spain has no capacity to decide or take any action regarding the requests made in your correspondence.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

45/214

We request that you direct your inquiry to the competent entity, Facebook Ireland Limited, through the Help Services available at:

<https://www.facebook.com/help/>, <https://help.instagram.com/>, or through:

Facebook Ireland Limited

Attn: Legal Department

4 Grand Canal Square

Grand Canal Harbour

Dublin 2, Ireland

Thank you for contacting us. We hope the above information is useful. We reserve all our rights.

Sincerely,

Facebook Spain”

FORTY-THIRD: On February 8, 2022, after the appropriate investigations, ENDESA became aware of certain coincidences between the data appearing in the published databases and those that could be included in ENDESA's commercial system, ***HERRAMIENTA.2.

ENDESA conducted a new assessment of the incident and on February 9, 2022, verified the authenticity of the advertisements and the identity of the two advertisers, both former employees of ENDESA suppliers with access to ***PLATAFORMA.1 (***HERRAMIENTA.1). A total of nine compromised users were detected between September 2021 and January 2022, who were being used by the Facebook advertisers to sell access to ***PLATAFORMA.1 (***HERRAMIENTA.1). Additionally, it was verified that six of them had access to ***HERRAMIENTA.2. The validity of the credentials was also verified, in all cases assigned to ENDESA suppliers for customer acquisition and service work.

FORTY-FOURTH: On February 9, 2022, a report was prepared assessing the extent of the personal data security breach, as stated in Document number 5 accompanying ENDESA's letter of July 26, 2022, in which the existence of a risk to the rights and freedoms of the affected individuals is considered, and the necessity to notify the AEPD is established.

This report states the following:

“On August 24, several advertisements were detected on Facebook selling users of the ***PLATAFORMA.1 application with access to customer information for an energy campaign in Spain. Once the advertisements were detected, an investigation was initiated, confirming the authenticity of these and the identity of the two advertisers, both former employees of ENDESA suppliers with access to ***PLATAFORMA.1.

During the progress of the investigation, a total of nine compromised users were detected between September 2021 and January 2022. Among the measures taken to control the incident, monitoring of the advertisements published by the two profiles related to the incident was conducted, detecting in January 2022 an advertisement for the sale of customer databases for energy.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

46/214

It is verified that in the images of the Excel files published in the advertisements, there are partial data of Endesa customers and data of users from other companies; the latter could not have been obtained from Endesa's applications, which leads to the conclusion that they are compilations of data from customers of different companies.

The nine compromised users were being used by the advertisers on Facebook to sell access to ***PLATFOM.1; moreover, it is confirmed that six of them had access to ***TOOL.2. The validity of the credentials has been verified, in all cases assigned to Endesa suppliers to carry out customer acquisition and support work; these users could have been used illegally in parallel, which prevents knowing the number of records of the applications that may have been accessed.

Based on the information gathered so far, which includes the time elapsed since the publication of the advertisement, the type of service offered, and the limitations in the queries provided by the applications, it is estimated that the number of affected records could be in a range of accesses between 1,000 and 100,000.

(...)

III. CONCLUSION

In a meeting held (...), after conducting an assessment, in a timely manner, of the scope of the security incident and the possible repercussions for the rights and freedoms of the affected parties, the preliminary decision is made to communicate the security incident to the supervisory authority.

Considering the previous points, the executed action plan is listed:

- Resetting the passwords of potentially affected users (...)
- Removal of Facebook advertisements offering access (...)
- Burofax to Facebook to expedite the removals (...)
- Disabling simultaneous sessions on ***PLATFORM.1.
- Expanding the logs of ***PLATFORM.1 to obtain detailed information on the usage by its users.

It is also proposed to adopt the following measures to avoid similar problems, as well as to mitigate potential negative effects detrimental to the affected parties:

(...)

FORTY-FIFTH: On February 9, 2022, the Data Protection Officer sent an email with the following content, according to Document number 1 accompanying the DPD's letter of October 19, 2022:

"(...) To avoid any doubt, and as I mentioned in the meeting, the conclusion from ***DEPARTMENT.4 and mine as the ultimate responsible before the AEPD is that we are going to notify this breach.

To justify that we are notifying now, it is necessary that you provide us this morning with a detailed list of dates and actions taken that we can submit to the AEPD (...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/214

FORTY-SIXTH: On February 10, 2022, ENDESA notified the Spanish Agency for Data Protection (AEPD) of a breach of personal data security, consisting of a possible unauthorized access to certain commercial systems of Endesa Energía that could have affected about a thousand customers.

In this notification, the AEPD is informed of the following:

"In August 2021, certain Facebook advertisements were detected announcing the sale of credentials to access the ***PLATFORM.1 of ENDESA (which contains basic data related to the supply point). This incident was assessed, and the relevant measures were adopted. On 01/17/2022, a Facebook advertisement with similar characteristics to the previous ones was detected, informing of the sale of customer databases for energy and gas. An assessment of the advertisement was made, and no matches were found with data from ENDESA customers included in the CRM system. On 02/08/2022, data from, among others, some ENDESA customers included in the CRM system were detected. Approximate number of individuals whose personal data is collected, stored, or processed in another way; referring exclusively to the processing regarding which the personal data breach occurred: 6,500,000.

The incident has been: Intentional, to harm the responsible party or the affected individuals.

The origin of the incident has been: External: Others, unrelated to the responsible party and the data processor.

What may have occurred?: Abuse of access privileges by an employee to extract, forward, or copy personal data.

As a consequence of the incident, the following has been affected: Confidentiality.

Specifically referring to the data affected by the confidentiality breach.

Are the data securely encrypted, anonymized, or protected in such a way that they are unintelligible to anyone who may have had access or cannot identify the individuals?: No.

What may have occurred?: Identity theft, Loss of control over their personal data.

To what extent could the identified consequences affect individuals?:

Individuals will not be affected or may encounter some very limited and reversible inconveniences that they will overcome without any problem (time to re-enter information, inconveniences, irritations, etc.).

As of the date of this notification, are you aware of any of the identified damages materializing, to the extent indicated in the previous question?: Yes.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
48/214

Types of affected data: Basic data (e.g., name, surname, date of birth), ID card, NIE, Passport and/or any other identifying document, Payment method data (Bank card, etc.), Contact data

In total, how many people have had their data affected by the personal data breach?: 1000

Indicate the date of detection of the breach: 08/02/2022

Do you know the date when the breach started? Approximately 24/08/2021

Indicate the date when the breach was considered resolved: 10/02/2022

Has the breach been communicated to the affected individuals under the previously described conditions?: They will not be informed

The affected individuals will not be informed because: There is no high risk to their rights and freedoms
Along with the notification, Annex I includes the measures taken to resolve the breach and minimize the impact:

“Following the initial detection in August 2021 of unauthorized sale of access credentials to the platform ***PLATAFORMA.1, the following measures were adopted to mitigate possible negative effects:

- Resetting the passwords of the affected users to access the platform ***PLATAFORMA.1. This measure is carried out continuously.
- Monitoring new publications on Facebook. This measure is carried out continuously.
- Disabling simultaneous sessions on ***PLATAFORMA.1, so that two or more people cannot access at the same time with a single user. This measure was implemented in November 2021.
- Expanding the traceability (logs) of accesses to ***PLATAFORMA.1 to obtain detailed information on the usage by the users. This measure was implemented at the end of December 2021.
- Requesting the removal of Facebook ads where the sale of said users was offered. This measure is carried out continuously.

Subsequently, due to new events detected (sale on Facebook of certain databases that contain, among others, customer data from Endesa Energía included in the CRM system that houses basic data, contact data, CUPS, data related to the electricity or gas contract, and account number), the following additional measures will be implemented, among others:

(...)

FORTY-SEVENTH: On February 15, 2022, as stated in Document number 8 of the ENDESA letter dated November 11, 2022, the user ***USUARIO.1, assigned to ***EMPRESA.13, and the user ***USUARIO.9, assigned to ***EMPRESA.14, were reset or disabled from the platform ***HERRAMIENTA.1.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

49/214

FORTY-EIGHTH: On February 17, 2022, as stated in Document number 9 and 10 of the ENDESA letter dated November 11, 2022, the user ***USUARIO.6, assigned to ***EMPRESA.17, was removed from the systems of ***HERRAMIENTA.2.

FORTY-NINTH: On February 28, 2022, as stated in Document number 11 of the ENDESA letter submitted on October 7, 2022, ENDESA sent a burofax with a written communication to FACEBOOK SPAIN S.L., with the following content:

“(…)

In the aforementioned response to our burofax, they state that Facebook Spain SL has no capacity to

decide or take any action regarding what was requested in our correspondence. On behalf of our company, we absolutely disagree with what has been stated since my represented party is not a user of the platform and, therefore, we reiterate our initial letter as affected parties.

As pointed out, it has been detected that certain users of your platform are using it to publish certain information that could constitute a crime, a crime that we understand should be prosecuted in Spain as my represented party is not subject to the jurisdiction of the Irish courts for not having accepted such jurisdiction and the crime occurring in Spain against a Spanish company.

Therefore, our communication primarily aims to seek the collaboration of Facebook (Meta) in order to limit these alleged criminal actions that are seriously harming the interests of our company. We also reiterate the need to maintain the appropriate records for a possible judicial process. (...)"

FIFTIETH: On March 4, 2022, as stated in Document number 8 of the ENDESA letter dated November 11, 2022, the user ***USUARIO.4, assigned to ***EMPRESA.15, was removed and deleted from the systems of ***HERRAMIENTA.1, although it expired due to lapse.

FIFTY-FIRST: On March 16, 2022, as stated in Documents 9 and 10 of the ENDESA letter dated November 11, 2022, the user ***USUARIO.4, assigned to ***EMPRESA.15, was removed from the systems of ***HERRAMIENTA.2.

FIFTY-SECOND: On March 23, 2022, the deployment of MFA (multi-factor authentication) on the platform ***HERRAMIENTA.2 and on the platform ***PLATAFORMA.1 was completed, as indicated in the expert report dated June 23, 2023, submitted by ENDESA on July 3, 2023.

FIFTY-THIRD: On April 1, 2022, as stated in Documents number 2 and 3 of the letter submitted by ENDESA on April 6, 2022, ENDESA, through its provider ***EMPRESA.2, has printed and made available to

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
50/214

The company responsible for the postal service sent 760 shipments, which were delivered to Correos on the same day.

The communication model sent in Spanish is as follows:

"March 31, 2022

Dear customer,

We are contacting you to inform you that we have detected a possible unauthorized access to certain commercial systems of Endesa Energía and that from the moment we became aware of this fact, we have adopted the appropriate security measures, both technical and organizational, to prevent any high-risk impact on the rights and freedoms of our customers, ensuring that the confidentiality and integrity of your personal data has not been compromised.

You can consult our privacy policy at www.endesa.com/es/proteccion-datos-endesa, where you will find information regarding the processing of your personal data. If you prefer, you can contact our Data Protection Officer directly by sending a communication to ***EMAIL.1 to learn more about the measures taken or to obtain further information.

We take this opportunity to thank you for the trust placed in Endesa.

Best regards,

Endesa Energía."

FIFTY-FOURTH: On April 6, 2022, ENDESA received an email from one of the recipients of the communication regarding the personal data security breach to the affected parties, as stated in Document number 9 of ENDESA's letter dated July 26, 2022, with the following content:

"Good morning:

I am writing to you regarding a letter you sent me about a possible unauthorized access to the Endesa Energía system.

I do not know what you are talking about, as I am not an Endesa customer and although sometimes I receive a bill in my name with a charge of 0, the ID number does not correspond to mine. I have tried to resolve this by calling without any results or solutions, so I hope for a response from you if you want

to resolve the issue. If you want to contact me by phone, my number is (...)

Best regards.”

According to ENDESA, as stated in the aforementioned letter, this is the only email received from one of the recipients of that communication. Documentation proving their identity was requested, and there is no record of a response from them.

FIFTY-FIFTH: According to ENDESA in its letter submitted on July 26, 2022, ***HERRAMIENTA.1 is a tool specially designed to facilitate advice, attention, and sales in the different commercial channels of ENDESA.

This tool incorporates commercial information about the products and services offered by ENDESA at any given time (such as prices, supplements, validity, offers, or conditions), contains technical information about all supply points, as well as certain basic identifying data.

FIFTY-SIXTH: According to ENDESA in its letter submitted on July 26, 2022, users of ***HERRAMIENTA.1 can be of two types: (i) “internal” user, enabled for employees of Endesa Energía, and (ii) “external” user, enabled for external suppliers. There are no other external users, such as customers.

Both internal users and external users have access to all the main functionalities of the tool.

Furthermore, from a functional perspective, the platform has the role of “basic” user and the role with “administrator profile.” That is, a user with an “administrator profile” can also be either “internal” or “external.” Only users with the “administrator profile” can access the administration menu and upload information into the system (such as new offers, rates, or scripts). They can also edit certain fields of the tool and obtain extractions and reports.

FIFTY-SEVENTH: According to ENDESA in its letter submitted on July 26, 2022, the registration of external and internal users is carried out by the managers of each sales or support channel in the corporate technical support tool accessed through the Intranet available to all internal employees of the Endesa Group. Access requests are made from the Intranet.

External and internal users access the platform by entering their username and associated password.

FIFTY-EIGHTH: According to ENDESA in its letter submitted on July 26, 2022, the platform allows the option to enter the so-called Universal Supply Point Code (hereinafter, “CUPS”) or the address of the supply point, to display the associated technical information (described in Document number 4). If the customer already has an active contract with Endesa Energía, it also shows the following information: name and surname of the holder of the supply point, their National Identity Document number, contract number, CUPS, annual billing amount, technical data regarding the supply point, consumption data, and usage graph. Within the file related to the supply point, there are several sections that allow recommending other rates to the customer.

FIFTY-NINTH: According to ENDESA in its letter submitted on July 26, 2022, to determine the number of potentially affected individuals by the incident, the following analysis was carried out:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/214

(i) It was verified that the alleged irregular practice carried out by a subcontractor of one of the suppliers of ENDESA, which provides telephone sales services, had not extended to other suppliers.

(ii) The analysis perimeter was limited to all contracts made between July 1, 2021, the date on which ENDESA's sales volume experienced an unusual and unjustified increase (+500%), and October 15, 2021, the date on which the contract with the supplier was terminated, and thus, it ceased to provide its services.

(iii) Subsequently, a quality control and audit of the contracts under evaluation was carried out, and those cases in which the clients themselves had already contacted ENDESA to perform actions related to their contracts (for example, commercial inquiries) were discarded.

SIXTIETH: According to ENDESA's statement presented on July 26, 2022, the number of potential individuals affected by the resulting incident was: 760 clients.

SIXTY-FIRST: According to ENDESA's statement presented on July 26, 2022, although it was not possible to determine the possible objective sought by the individuals who facilitated the sale of credentials for access to the platform ***HERRAMIENTA.1, as well as, where applicable, the sale of customer databases of Endesa Energía, ENDESA considers that the consequences of the violation of personal data security are limited to the fact that the affected individuals could encounter certain inconveniences, very limited and, in any case, reversible. Due to the apparently fraudulent objective of data theft, the consequences for the affected clients would fundamentally be the sale of their data for the purpose of making commercial calls, as well as for sending emails and SMS, offering the possibility of changing energy marketing companies, which, in the worst-case scenarios and if it were to materialize, could result in the change of marketing company without their consent.

SIXTY-SECOND: According to ENDESA's statement presented on July 26, 2022, the violation of personal data security was caused by the apparent fraudulent sale of credentials for the platform ***HERRAMIENTA.1. These credentials were assigned to ENDESA suppliers, as external users of the platform, to facilitate tasks related to customer acquisition, advising, and customer service.

SIXTY-THIRD: According to ENDESA's statement presented on July 26, 2022, ENDESA became aware of the possible illicit use of the credentials through an email from one of the suppliers indicating irregularities by several of their employees; in that same email, five users were identified who had been employed in an apparently irregular manner.

SIXTY-FOURTH: According to ENDESA's statement presented on July 26, 2022, four other users who might be compromised were identified, detected in the demonstration videos and in the screenshots of the published ads.

SIXTY-FIFTH: According to ENDESA's statement presented on July 26, 2022, the compromised users were:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

53/214

- ***USER.1
- ***USER.2
- ***USER.3
- ***USER.4
- ***USER.5
- ***USER.6
- ***USER.7
- ***USER.8
- ***USER.9

SIXTY-SIXTH: According to ENDESA's statement presented on July 26, 2022, it has not received any complaints from clients potentially affected by this incident.

SIXTY-SEVENTH: According to ENDESA's statement presented on July 26, 2022, ENDESA, as part of the Endesa Group, has a series of security rules and standards to ensure the protection of personal data, based mainly on the following elements: (i) a cybersecurity framework, (ii) internal regulations on cybersecurity.

[...]

- Specifically, the measures implemented in the applications subject to this violation of personal data security consist of (...).

SIXTY-EIGHTH: According to ENDESA's statement presented on July 26, 2022, among the various activities and security measures that existed in ***HERRAMIENTA.2 before the incident, the following stand out:

(...)

And the application ***HERRAMIENTA.2 was integrated (...) at the time of the incident.

SIXTY-NINTH: According to ENDESA's statement presented on July 26, 2022, among the various

activities and security measures that were implemented in the platform ***HERRAMIENTA.1 before the incident, the following stand out:

□

(...).

SEVENTIETH: According to ENDESA's statement presented on July 26, 2022, as the incident developed and its possible effects were noticed, the following measures were implemented to reinforce the security of the applications ***HERRAMIENTA.1 and ***HERRAMIENTA.2:

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
54/214

SEVENTY-FIRST: On August 3, 2022, the user "D.D.D." published an advertisement on Facebook with the following content, as stated in Document number 2 accompanying ENDESA's letter dated November 11, 2022: "System for obtaining energy and gas cups for rent [emoji of the Spanish flag] Through the customer's address. [Emoji of a light bulb] Super accessible prices [emoji of a bundle of bills] Information via WhatsApp."

SEVENTY-SECOND: On August 23, 2022, the user "B.B.B." published an advertisement on Facebook with the following content, as stated in Document number 2 accompanying ENDESA's letter dated November 11, 2022: "User for sale Contact the seller [various surprised face emojis] User of #***PLATFORM.1 for energy campaign Spain!!! - Provides total supplies that the holder has under their name. - Gives all the information about their supply (cups, ID, postal code, address, rate, last bill). - Provides complete information if the customer has electricity and gas If you are interested in increasing the number of sales in your Call Center, message me via inbox." Two screenshots of the system are observed in the advertisement, with complete address and electricity and gas consumption data.

SEVENTY-THIRD: On August 24, 2022, as stated in Document number 8 of ENDESA's letter dated November 11, 2022, the user ***USER.6, assigned to ***COMPANY.17, was reset on the ***TOOL.1 platform. The following users were also removed and deleted from the ***TOOL.1 systems:

USER

ASSIGNED PROVIDER

***USER.1

***COMPANY.13

***USER.9

***COMPANY.14

***USER.8

***COMPANY.15

***USER.3

COMPANY.12 (COMPANY.12.)

***USER.5

COMPANY.12 (COMPANY.12.)

SEVENTY-FOURTH: On September 15, 2022, advertisements identified by ENDESA offering the sale of access credentials to ***TOOL.1 and databases were still published on Facebook (see the diligence document dated December 16, 2022 in the file).

SEVENTY-FIFTH: According to ENDESA's statement in its letter dated October 7, 2022, it identified four users of the ***TOOL.1 tool (***TOOL.1) who were compromised in the advertisements and demonstration videos published on the Facebook social network.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

55/214

SEVENTY-SIXTH: According to ENDESA's statement in its letter dated October 7, 2022, the identified compromised users had been assigned to one of the following ENDESA supplier companies:

- ***COMPANY.3
- ***COMPANY.12
- ***COMPANY.5
- ***COMPANY.6
- ***COMPANY.7
- ***COMPANY.8.

SEVENTY-SEVENTH: According to ENDESA's statement in its letter dated October 7, 2022, the ENDESA supplier that provided telemarketing services, whose subcontractor carried out the alleged irregular practice, was ***COMPANY.1, and the subcontractor to whom it entrusted part of the commissioned services was ***COMPANY.9.

SEVENTY-EIGHTH: According to ENDESA's statement in its letter dated October 7, 2022, in the analysis carried out for the correct identification of the customers whose data had apparently been unlawfully obtained from the ***TOOL.3 tool and, therefore, could have been processed without their consent, the following actions were taken:

- i. First, once the provider ***COMPANY.1 informed ENDESA of the irregular practice committed by personnel from ***COMPANY.9 and the appropriate verifications were made, it was verified that this practice did not extend to other providers.
- ii. Second, once the possible origin of the allegedly irregular contracts was identified, the temporal scope of their actions was limited, verifying that from July 1, 2021, the sales volume of Endesa Energía experienced an unusual and unjustified increase (specifically, sales increased by more than 500%), which could be representative of the irregular actions of the personnel hired by ***COMPANY.9. On October 15, 2021, the activity of this subcontractor was ceased – as a result of the termination of the contract with ***COMPANY.9 – thus limiting the temporal analysis of the contracts to the period between July 1 and October 15, 2015.
- iii. Finally, a quality control and audit of the contracts carried out by ***COMPANY.9 within the established temporal scope was conducted. In this analysis, cases were excluded where the customers whose names were used for a contract involving ***COMPANY.9 – within the defined time frame – had contacted ENDESA to carry out actions related to their contracts (for example, commercial inquiries), which indicated that the customers were aware of their contracts and did not express any objections.”

SEVENTY-NINTH: According to the diligence carried out on October 13, 2022, ENDESA is a public limited company of Spanish nationality. According to the data available in AXESOR, the company has a "Large" size with XXX

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/214

employees and in the year 2021 (last fiscal year presented) had an annual global turnover of ***AMOUNT.1 euros and a profit of ***AMOUNT.3 euros.

EIGHTIETH: As stated by ENDESA in its document submitted on November 11, 2022, during the investigation initiated at the end of August 2021, a total of 440 advertisements were identified on the social network Facebook offering the rental and/or sale of access credentials to the ENDESA tool ***TOOL.1 (hereinafter “***TOOL.1”).

The two users identified from whose Facebook profiles these advertisements were published were those corresponding to “B.B.B.” (who presumably also made posts under the profile of C.C.C.) and “D.D.D.”. During the investigation, the Information Security area of ENDESA made contact with user B.B.B., who offered the sale of credentials to access ***TOOL.1 in exchange for a monthly payment. He also indicated that he had different users available for sale.

As a result of the conversations held between the responsible parties at ENDESA and their suppliers,

and in turn, between them and their subcontractors, it has come to light that behind the user "B.B.B." / "C.C.C." is C.C.C., who, as has been communicated to this Office, was an employee until the year 2016 of ***COMPANY.10. This branch has never provided services for ENDESA and consequently C.C.C. never had an access user assigned to his name for ENDESA's applications.

On the other hand, the user "D.D.D." corresponds to the employee of ***COMPANY.11, a subcontractor in ***COUNTRY.1 of the provider ***COMPANY.12 who provides services for ENDESA, D.D.D., who, however, resigned at the beginning of the year 2020.

There is no record in the company's internal systems of a user registration in the name of D.D.D.

EIGHTY-FIRST: According to ENDESA's document of November 11, 2022, the compromised users put up for sale along with the provider to whom they were assigned were as follows:

USER

PROVIDER

***USER.1

***COMPANY.13 (hereinafter, ***COMPANY.13)

***USER.9

***COMPANY.14 (hereinafter, ***COMPANY.14)

***USER.2

***COMPANY.8 (hereinafter, ***COMPANY.8)

***USER.10

***COMPANY.15

In relation to the providers ***COMPANY.13, ***COMPANY.14, and ***COMPANY.8, all three provided sales services to ENDESA via telephone through outgoing calls from the company. The communication regarding the breach of personal data security and the misuse of the access users to ENDESA's applications that had been assigned to them was carried out through conversations and telephone meetings.

Regarding the provider ***COMPANY.15, it provided customer service and telephone sales to ENDESA, handling calls that, without prior commercial intervention from ENDESA, were made by interested parties. The operations manager, immediately after learning of the facts, contacted the provider to request explanations about what happened and the immediate implementation of measures with the implicated user.

EIGHTY-SECOND: As stated by ENDESA in its document of November 11, 2022, these were, for each of the compromised users, the data related to the registration and deregistration in the tool ***TOOL.1, as well as the role assigned to each user and the functions and access permissions granted:

User

Provider to which the user was assigned

Date of registration request

Date of reset or deactivation

Date of withdrawal and deletion in systems

Role

Functions and permissions granted

***USER.1

***COMPANY.13

11/03/2021

15/02/2022

24/08/2022

User

Consultation

***USER.9

***COMPANY.14

09/12/2021

15/02/2022

24/08/2022

User

Consultation

***USER.11

***COMPANY.8

26/11/2019

19/11/2021

19/11/2021

User

Consultation

***USER.10

***COMPANY.15

21/12/2020

10/09/2021

24/08/2022

User

Consultation

***USER.10

***COMPANY.16 (**COMPANY.12)

20/10/2020

03/09/2021

24/08/2022

User

Consultation

***USER.10

***COMPANY.15

15/08/2021

29/11/2021

04/03/2022

User

Consultation

***USER.10

***COMPANY.16

20/10/2020

21/09/2021

24/08/2022

User

Consultation

***USER.10

***COMPANY.17

28/10/2020

24/08/2022

24/08/2022

User

Consultation

According to Document number 8 accompanying the aforementioned document, user ***USER.14 expired due to expiration on 04/03/2022.

EIGHTY-THIRD: As stated by ENDESA in its document of November 11, 2022, these were, for each of the compromised users, the data related to the registration and deregistration in the tool ***TOOL.2, as well as the role assigned to each user and the functions and access permissions granted:

User

Provider to which the user was assigned

Date of registration request

Date of last access

Date of deletion in systems

Role

Functions and permissions granted

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

58/214

***USER.10

***COMPANY.1

5

12/04/2021

09/09/2021

10/09/2021

***ROLE.1

Consultation, creation, and modification of data (within its business scope).

***USER.10

***COMPANY.1

6

19/02/2020

26/11/2021

12/01/2022

***ROLE.3

Consultation, creation, and modification of data (within its business scope).

***USER.10

***COMPANY.1

5

06/03/2018

18/02/2022

16/03/2022

***ROLE.1

Consultation, creation, and modification of data (within its business scope).

***USER.10

***COMPANY.1

6

23/10/2020

25/11/2021

12/01/2022

***ROLE.3

Consultation, creation, and modification of data (within its business scope).

***USER.10

***COMPANY.1

7

20/07/2020

03/12/2021

17/02/2022

***ROLE.2

Consultation, creation, and modification of data (within its business scope).

EIGHTY-FOURTH: As stated by ENDESA in its letter dated November 11, 2022, "the committed users had a 'user' role in the tool ***TOOL.1, with assigned permission for consultation, so they could only view (i) regarding all consumers, whether customers of Endesa Energía or not, technical data – such as power, voltage, estimated consumption – associated with the supply point by entering the address or the so-called Universal Supply Point Code (hereinafter 'CUPS'); and (ii) if they were customers of

Endesa Energía with a valid contract, they could access the following information: name and surname of the holder of the supply point, National Identity Document number, contract number, CUPS, annual billing amount, debt indicator, information on prices, technical data related to the supply point, consumption data, and usage graph.

The approximate volume of supply points that can potentially be consulted – one by one, individually – from the tool ***TOOL.1, provided that a CUPS or an address is previously entered, is 30.6 million electricity supply points and 8.6 million gas supply points. In the case of customers with a valid contract, the approximate volume that a user can consult, under the same premises indicated above, is 4.8 million electricity customers and 1.2 million gas customers.

Regarding the tool ***TOOL.2, the identified committed users could access data related to customers with a valid contract with ENDESA, with the approximate volume during the period from July 1, 2021, to October 15, 2021, being 4.8 million electricity customers and 1.2 million gas customers. As for the type of data that could be viewed, it mainly includes: name and surname of the holder of the supply point, postal address, National Identity Document number, CUPS, phone number, email, contracted products, invoices, bank account number, credit quality, debts with the company.

Regarding the committed users and the period during which the personal data security breach occurred, there is no record (logs) of the use of the tools ***TOOL.1 or ***TOOL.2.

As a result of the personal data security breach, a series of measures were adopted, including the expansion of traceability (logs) of accesses to ***TOOL.1 to obtain detailed information on the actual use made by users – a measure that was implemented at the end of December 2021."

EIGHTY-FIFTH: On November 15, 2022, as stated in Document number 7 of ENDESA's letter dated July 3, 2023, in response to this Agency's request, a contract termination agreement was signed between ENDESA and ***COMPANY.16.

EIGHTY-SIXTH: As stated by ***COMPANY.1 in its letter dated November 25, 2022:

- Users of ***COMPANY.1 with access to ***TOOL.4: ***COMPANY.1 had a single access user (***USER.11) to the tool ***TOOL.4.

- Users of ***COMPANY.1 to perform bulk loading of requests through the tool ***TOOL.4: ***COMPANY.1 had a single access user (***USER.12).

- Users of ***COMPANY.9 authorized to load sales requests in the CRM of ***COMPANY.1. A list of all 46 related users through whom fraudulent sales have been loaded is provided.

EIGHTY-SEVENTH: As stated by ***COMPANY.1 in its letter dated November 25, 2022:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

60/214

- Each user of ***COMPANY.9 had an independent user in the CRM of ***COMPANY.1 to input the hiring requests that they had formalized through the commercial solicitation calls made. Once this information was entered by each agent, an Excel file was generated in the systems of ***COMPANY.1 containing the necessary data for the Back Office of ENDESA to manage the data in the commercial systems of ENDESA.

- Once the previous procedure was completed, ***COMPANY.1 proceeded, on a daily basis, to upload all the information en masse via FTP to the tool ***TOOL.4, owned by ENDESA. For this mass upload, ***COMPANY.1 only had access to the user for ***TOOL.4 and access via FTP.

- The sub-agents (users of ***COMPANY.9) could only access the CRM of ***COMPANY.1, without having direct access to the CRM of Endesa in any case.

- ***COMPANY.1 only had one user access to the following tools of ENDESA:

- ☐ ***TOOL.4 and the FTP access authorized by ENDESA to perform the mass upload of the hiring requests.

- ☐ ***PLATFORM.1: This is the platform for downloading "do not disturb" files from ENDESA. There was a single user with access to this application, and it was accessed via the web. ***COMPANY.1 only had permissions in this application to download the file.

- There is no other application to which ***COMPANY.1 and/or its collaborators had access within the

framework of the contractual relationship with ENDESA for the telephone solicitation of clients.

- Each user of ***COMPANY.9 could only upload to the CRM of ***COMPANY.1 the operations that they themselves had performed, being able to view only the statuses of those operations until the complete closure of the sale by ENDESA. They only had access to the personal data that they themselves entered into the CRM of ***COMPANY.1.
- Not all clients to whom these users had access were affected by the fraudulent practice of ***COMPANY.9, as only 137 operations were affected, whose fraudulent hiring was completed.
- ***COMPANY.1 could access ***TOOL.4 with its user to view the status of any hiring of any of its Sub-agents.

EIGHTY-NINTH: On July 3, 2023, in response to the request of this Agency, ENDESA submitted as Document number 4 a document titled “Data Transfer Impact Assessment,” in which ENDESA is listed as the exporting legal entity and ***COUNTRY.2 as the importing country, with ***PLATFORM.1, ***COMPANY.15, and ***COMPANY.16 as the importing legal entities.

This document indicates that ***COUNTRY.2 has a “Data protection level” that is “3 – Partially adequate.” And that “This country guarantees a level of data protection that is partially adequate due to the existence of data protection legislation and an independent supervisory authority for Data Protection and Privacy Commissioners.” The address and website of the data protection authority of ***COUNTRY.2 are attached.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
61/214

NINETIETH: On July 3, 2023, in response to the request from this Agency, ENDESA submits as Document number 5 a document titled “Data Transfer Impact Assessment,” in which ENDESA is listed as the exporting legal entity and ***COUNTRY.1 as the importing country, with ***COMPANY.11 as the importing legal entity.

This document indicates that ***COUNTRY.2 has a “Data protection level” that is “3 – Partially adequate.” It states, “This country guarantees a level of data protection that is partially adequate due to the existence of data protection regulations and an independent supervisory authority for Data Protection and Privacy Commissioners.” The contact details and website of the data protection authority of ***COUNTRY.1 are provided.

NINETY-FIRST: On July 3, 2023, in response to the request from this Agency, ENDESA submits as Document number 6 a document titled “DTIA- Country Risk Analysis of Legislation and Practices- ***COUNTRY.2,” which indicates that “The information contained in this report should be considered in the impact assessment conducted for each international transfer between group companies in which ***COMPANY.15 acts as the importer.”

In conclusion, it states: “It is understood that ***COUNTRY.2 has a regulatory framework that, while it cannot be considered equivalent to that established in the European Union regarding the protection of personal data, can be considered reasonably adequate.

However, to reach a definitive conclusion on the suitability of the international transfer, as well as on the adoption of additional safeguard measures to ensure that the level of protection of the transferred data aligns with the essential equivalence standard of the European Union, it is necessary to take into account and evaluate the other components related to the particularities of each of the transfers.”

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Data

Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Preliminary Issues

In this case, in accordance with the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, given that ENDESA carries out, among other processes, the collection and storage of the following personal data of individuals, such as: first name and surname, identity document, address, telephone number, banking data, supply data, among others.

ENDESA carries out this activity in its capacity as data controller, as it is the entity that determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines a “personal data breach” as “a breach of security that results in the accidental or unlawful destruction, loss, alteration of, or unauthorized access to personal data transmitted, stored, or otherwise processed.”

In this case, there is a personal data breach under the circumstances indicated above, categorized as a confidentiality breach, due to unauthorized access to personal data processed by ENDESA, and as an integrity breach, due to the modification of certain data to carry out fraudulent registrations.

Among the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1.f) of Article 5 of the GDPR. The security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, the notification of a personal data breach to the supervisory authority, and the communication to the data subject, respectively.

Finally, international transfers of personal data are regulated in Articles 44 and following of the GDPR.

III

Claims Made

Claims regarding the initiation of the sanctioning procedure

In relation to the claims made regarding the initiation of the current sanctioning procedure, responses are provided in the order presented by ENDESA:

Preliminary.- Specification of certain essential factual points for the legal analysis of the file

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

63/214

ENDESA claims the existence, in the Initiation Agreement, of certain issues that, while being very relevant for the assessment of Endesa's conduct, have not been interpreted correctly by the AEPD:

(a) Evidentiary value of the security breach assessment and management report prepared by

***EMPRESA.1:

ENDESA argues that the AEPD bases much of its reasoning on the security breach assessment and management report prepared by ***EMPRESA.1 on November 4, 2021.

And that: (i) ***EMPRESA.1 never shared said report, nor its conclusions, with Endesa (even when Endesa continued to request information about the case from ***EMPRESA.1), despite having a contractual and legal obligation to inform Endesa of all details of the incident of which it was aware; and (ii) when ***EMPRESA.1 provided the report to the AEPD (November 2022), Endesa had already terminated the service provision contract with ***DEPARTAMENTO.6 of Endesa with this provider (January 2022), and furthermore, the relationship between that channel and ***EMPRESA.1 was not "friendly."

ENDESA claims that, since the date of its preparation (November 4, 2021), it was never updated by ***EMPRESA.1 with the new information that was emerging from Endesa's investigations and that Endesa shared with ***EMPRESA.1, which means it does not reflect the reality of the investigations into the data security breach or its actual consequences. It is for this lack of rigor that Endesa also believes that this report should be excluded from the evidentiary list of the File and, therefore, its content should not be considered as a basis for making any decision within the framework of this File.

ENDESA emphasizes that the report provided by ***EMPRESA.1 should be considered a partial report (in the sense of a report from an interested party), as ***EMPRESA.1 was involved in the incident itself and, in fact, it partly arose from its failure to control and supervise the compliance by ***EMPRESA.9 with Endesa's instructions and its obligations as a data processor. It is clearly evident that it is a "defensive" report prepared by an entity that needs to protect its interests against potential liability claims, having acted as a data processor for Endesa and potentially bearing some degree of responsibility for the events that ultimately led to the present proceedings.

Therefore, ENDESA understands that this is not an impartial expert or legal report on the incident prepared by an external party with no involvement in it and without interests in the outcome of this sanctioning file from which conclusions can be drawn to assess Endesa's compliance regarding: (i) the obligation to notify the incident to the AEPD; and (ii) the application of appropriate security measures. On the contrary, the purpose of this report is to shift all types of responsibility for the incident onto Endesa, attempting to make this Agency see that ***EMPRESA.1, even when it flagrantly breached its obligations as a data processor (did not provide adequate information to Endesa to advise on the scope and consequences of the incident, did not implement the necessary security measures...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

64/214

due to the risk and did not control compliance by ***COMPANY.9 with its obligations as a subcontractor), always acted with the utmost diligence and in strict compliance with the law (quad non).

In this regard, this Agency wishes to point out that the actions of ***COMPANY.1 are not the subject of this procedure, but rather the actions of ENDESA in the violation of the security of the personal data reported.

In this sense, as stated in all the documentation in the file and as detailed in the Background, Established Facts, and Legal Grounds of this document, this Agency is based not only on the report prepared by ***COMPANY.1 on November 4, 2021, but also on all the information it has become aware of throughout this procedure.

Precisely due to its possible implication in the violation of the security of personal data, this Agency requested certain information from ***COMPANY.1, within the framework of the preliminary actions of this procedure. However, this is by no means the only information on which this Agency relies to propose the corresponding sanctions against ENDESA.

For all the reasons stated, this allegation is dismissed.

(b) Interactions with Facebook to request the removal of advertisements through which the sale/rental of access credentials to Endesa's systems was offered:

ENDESA alleges that throughout the Initiation Agreement, the AEPD accuses it of a lack of diligence in requesting Facebook to remove those advertisements through which the sale/rental of access credentials to its systems was offered because: (i) it did not address Facebook Ireland Limited for this purpose, as Facebook Spain had proposed in response to the first burofax sent by Endesa on February 4, 2022; and (ii) it did not succeed in having Facebook remove said advertisements and, therefore, did not implement the proposed measures.

ENDESA indicates that the Initiation Agreement errs in this interpretation since: (i) It is not true that Endesa did not send a communication to Facebook Ireland Limited due to a lack of diligence, but rather because it consciously, and after analyzing the implications of doing so, decided that doing so would precisely recognize Irish jurisdiction, which would imply, if necessary, having to direct any claim before the Irish courts, which was, and is, an inappropriate and unfair burden. This was the main reason why, instead, Endesa decided to send a second burofax to Facebook Spain on February 28, 2022 (which demonstrates, in its view, great diligence on the part of Endesa) insisting on its request). ENDESA states that recognizing Irish jurisdiction would imply assuming that all incidents occurring within the framework of the platform managed by Facebook would have a cross-border nature and, with that, any action would be debatable.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
65/214

(legal or administrative) action that may be initiated against Facebook if not before the Irish authorities.

(ii) It is not true that the fact that Facebook did not remove the ads through which the sale/rental of access credentials to Endesa's systems was offered is a consequence of a lack of diligence on the part of the Company, nor does it imply, as indicated in the Initiation Agreement, that the security measures proposed by Endesa at the beginning of the identification of the data security breach were not implemented.

ENDESA states that: (a) Endesa sent numerous requests and even two burofaxes to Facebook Spain requesting the removal of the ads (Endesa cannot be held responsible for the non-removal of the ads since Facebook is solely responsible for the management of the platform and its publications); and (b) Endesa did implement the proposed security measures from the outset of the breach, which were adequate to mitigate the consequences of the Data Security Breach, since, even prior to sending the first burofax, it had already blocked access for the compromised users to Endesa's tools by disabling their credentials. In other words, the existence of obsolete credentials on Facebook was no longer relevant, as they no longer posed any risk to the rights of the affected parties.

Once those credentials were disabled, and although the Facebook ads remained active, the risk from a data protection perspective was eliminated, since the possibility of accessing the data for which Endesa is responsible, stored in its tools, disappeared (even if the original credentials were sold/rented). Additionally, since Endesa proceeded to implement additional security measures such as multi-factor authentication and the deactivation of multi-session access, the possibility of unidentified users being able to gain unauthorized access to Endesa's systems was eliminated, regardless of whether new Facebook ads were published or the previous ones remained active.

Notwithstanding the above, ENDESA explains that, since the fact that the ads remained active on Facebook could still imply the commission of an infringement or crime of disclosure of secrets or intellectual property, Endesa decided to insist on its claim against Facebook by sending a second burofax.

For all these reasons, ENDESA emphasizes that, despite some Facebook ads remaining active—due to issues, in its opinion, unrelated to Endesa—the credentials offered through that medium no longer allowed access to systems ***HERRAMIENTA.1 and ***HERRAMIENTA.2 because they were disabled, and as a result of the new security measures implemented by Endesa, no additional unauthorized user would be able to achieve the purpose of selling/renting access credentials to Endesa's systems, as those measures would prevent it.

However, ENDESA has commissioned an independent third party to prepare an expert report demonstrating the aforementioned aspects, which will be made available to the AEPD once completed.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
66/214

This report was submitted during the evidence practice period, through a document from ENDESA dated June 23, 2023, as Document number 1.

In this regard, this Agency wishes to point out, first of all, that ENDESA cannot change the jurisdiction at will, nor can it decide who is responsible for the processing.

In the present case, as indicated by Facebook Spain in its response to the burofax sent by ENDESA, the entity responsible for the processing of personal data at the European level is Facebook Ireland Limited, an entity incorporated in Ireland with its registered office in Dublin. As reported to ENDESA, Facebook Spain has no capacity to decide or take any action regarding what was requested by ENDESA in its burofax dated February 7, 2022. Therefore, ENDESA should have communicated with

Facebook Ireland Limited, through the means provided by Facebook Spain (internet or postal). The definition of "main establishment" is set out in Article 4.16 of the GDPR. Regarding the data controllers, the aforementioned article states, in its letter a), that the main establishment is, "in the case of a data controller with establishments in more than one Member State, the place of its central administration in the Union, unless decisions regarding the purposes and means of processing are taken in another establishment of the controller in the Union and that latter establishment has the power to implement such decisions, in which case the establishment that has adopted such decisions shall be considered the main establishment." Therefore, in this case, the main establishment of Facebook in the Union is Facebook Ireland Limited, established in Ireland.

Of course, all incidents that occur within the framework of the platform managed by Facebook have a cross-border nature, and for their management, the GDPR has enabled a "one-stop-shop mechanism" that allows interested parties in Spain to file a complaint regarding a matter concerning a company that has its main establishment in another Member State such as Ireland, which will be resolved jointly by the lead supervisory authority and the interested supervisory authorities (including the supervisory authority receiving the complaint), through the procedure provided for in Article 60 of the GDPR. So much so, that this Agency receives numerous complaints from interested parties in Spain against controllers with their main establishment in Ireland, who carry out cross-border processing of personal data and whose lead authority is the Irish Data Protection Authority. All this under the applicable regulations.

For the reasons stated, this Agency reiterates that not having even attempted communication through the web with Facebook Ireland Limited to try to have the ads in question removed constitutes serious negligence on the part of ENDESA.

Secondly, this Agency considers that ENDESA did not act with due diligence in preventing access to the systems by users whom ENDESA knew had been compromised.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

67/214

According to the proven facts of the proposed resolution:

- On August 24, 2021, the person responsible for ***DEPARTMENT.1 of ENDESA sent an email to the Information Security officer of the Endesa Group, informing about a suspicious ad on Facebook, published by "B.B.B.", offering access to ***PLATFORM.1. This notice initiated ENDESA's analysis and investigation of the matter at hand in this procedure.

- On September 1, 2021, ENDESA received an email from ***COMPANY.16, confirming that it knew the identity of D.D.D., and provided his full name.

- On September 3, 2021, the user "****USER.3" assigned to ***COMPANY.12 was reset or disabled on the ***TOOL.1 platform. Although this user was not deleted in ***TOOL.2 until January 12, 2022, his last access to ***TOOL.2 was on November 26, 2021.

- On September 10, 2021, ENDESA sent an email to ***COMPANY.15, stating that it was "an employee currently active at ***COMPANY.15", requesting that he be removed from its operations and indicating that the user would be "deactivated immediately."

On the same day, the user ***USER.8, assigned to ***COMPANY.15, was reset or disabled on the ***TOOL.1 platform. He was subsequently removed and deleted from the systems of ***TOOL.2.

- On September 21, 2021, ENDESA received an email confirming that C.C.C. was an employee of ***COMPANY.15 but had been terminated from the company since 2016.

On the same day, the user ***USER.5 from the ***TOOL.1 platform, assigned to ***COMPANY.12, was reset or disabled. Although the user was deleted in ***TOOL.2 on January 12, 2022, his last access to ***TOOL.2 was on November 25, 2021.

- On October 27, 2021, ***COMPANY.1 alerted ENDESA via email about the irregular use that some of its advisors had made with certain access credentials to ***TOOL.1. In this communication, five compromised users of ***TOOL.1 were identified, who were also identified by the subcontractor

company ***COMPANY.9:

***USER.13

***USER.14

***USER.15

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

68/214

***USER.16

***USER.9

This email also includes four images of Facebook ads offering access to ENDESA's systems.

In addition to these compromised users identified by ***COMPANY.1, ENDESA has found other users who were also compromised:

***USER.1

***USER.2

***USER.10

Regarding the compromised users identified by ***COMPANY.1 in their email sent to ENDESA on October 27, 2021:

- The user ***USER.13, assigned to ***COMPANY.12, had already been reset or disabled in ***TOOL.1 on September 3, 2021, and removed from the systems on August 24, 2022. However, they were only removed from the ***TOOL.2 system on January 12, 2022, with their last access to the system on November 26, 2021.

This means that ***COMPANY.1 notified ENDESA that this user was compromised on October 27, 2021, but ENDESA had already reset the user in ***TOOL.1 on September 3, almost two months earlier (the reasons for this action are unknown to this Agency, but it is possible that ENDESA already knew that this user was compromised; in fact, two days earlier, ***COMPANY.16 indicated that one of the users posting the Facebook ads had been an agent of this company).

In any case, if the user in question was used to carry out fraudulent contracts in October 2021, this Agency considers that the password reset in September 2021 was of little use, and the risk to the rights and freedoms of the affected individuals remained active. Therefore, it is striking to this Agency that even after ***COMPANY.1 communicated this situation, ENDESA did not take further action regarding this user until August 24, 2022, the date on which the user was removed from the ***TOOL.1 platform.

This Agency is also struck by the fact that the user was reset in ***TOOL.1 on September 3, 2021, but was only removed from the ***TOOL.2 platform on January 12, 2022, with their last access to it on November 26, 2021. This means that even knowing that the user had been compromised in ***TOOL.1, the user freely accessed ***TOOL.2 for another month.

- The user ***USER.15, assigned to ***COMPANY.12, was reset or disabled in ***TOOL.1 on September 21, 2021, and removed from the systems on August 24, 2022. However, they were only removed from the ***TOOL.2 system on January 12, 2022, with their last access to the system on November 25, 2021.

This means that ***COMPANY.1 notified ENDESA that this user was compromised on October 27, 2021, but ENDESA had already reset the user in ***TOOL.1 on September 21, more than a month earlier (the reasons for this action are unknown to this Agency, but it is possible that ENDESA already knew that this user was compromised; in fact, on that same day, it was indicated to ENDESA that one of the users posting the Facebook ads had been an agent of ***COMPANY.15).

In any case, if the user in question was used to carry out fraudulent contracts in October 2021, this Agency considers that the password reset in September 2021 was of little use, and the risk to the rights and freedoms of the affected individuals remained intact. Therefore, it is striking to this Agency that even after ***COMPANY.1 communicated this situation, ENDESA did not take further action regarding this user until August 24, 2022, the date on which the user was removed from the ***TOOL.1 platform.

This Agency is also struck by the fact that the user was reset in ***TOOL.1 on September 21, 2021, but was not removed from the ***TOOL.2 platform until January 12, 2022, with their last access to it on November 25, 2021. This means that even knowing that the user had been compromised in ***TOOL.1, the user freely accessed ***TOOL.2 for another month.

- The user ***USER.14, assigned to ***COMPANY.15, was reset or disabled in ***TOOL.1 on November 29, 2021, and removed from the systems on March 4, 2022 (although the user was not disabled for security reasons but simply because the user expired). They were removed from the ***TOOL.2 system on March 16, 2022, with their last access to the system on February 18, 2022. This means that this user was reset or disabled in ***TOOL.1 a month after ENDESA was informed by ***COMPANY.1 that this user had been compromised. And even knowing that the user had been compromised in ***TOOL.1, the user freely accessed ***TOOL.2 for almost three more months.

- The user ***USER.9, assigned to ***COMPANY.6, was reset or disabled in ***TOOL.1 on February 15, 2022, and removed from the systems on August 24, 2022.

This means that this user was reset four months after ***COMPANY.1 had communicated to ENDESA that they had been compromised. Furthermore, the user had not even been disabled prior to the first burofax sent to Facebook on February 8.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

70/214

2022, as ENDESA states in its written allegations to the initiation agreement, thus the risks to the rights and freedoms of the interested parties remained intact.

-

User ***USUARIO.16, assigned to ***EMPRESA.5 was reset or disabled in ***HERRAMIENTA.1 and removed from its systems on August 24, 2022. However, it had been removed from the ***HERRAMIENTA.2 system on February 17, 2022, with its last access to the system on December 3, 2021.

That is to say, four months after ***EMPRESA.1 had informed ENDESA that this user had been compromised, it was removed from the ***HERRAMIENTA.2 systems, which allowed this user to access such platform freely for a month and a half. It is worth noting that all of this also did not occur before the first burofax was sent to Facebook Spain on February 8, 2022, as ENDESA states in its allegations to the initiation agreement. Furthermore, for reasons unknown, it was not reset from ***HERRAMIENTA.1 until August 24, 2022, more than 10 months after ***EMPRESA.1 communicated this situation to ENDESA.

Regarding the other users, the date on which ENDESA became aware that such users had been compromised is unknown, but the following can be noted:

-

User ***USUARIO.10, assigned to ***EMPRESA.15, was reset or disabled in ***HERRAMIENTA.1 on September 10, 2021, and removed from the systems on August 24, 2022. It was removed from the ***HERRAMIENTA.2 system on September 10, 2021, with its last access to the system on September 9, 2021.

That is to say, ENDESA reset the user in ***HERRAMIENTA.1 and ***HERRAMIENTA.2 on September 10, 2021 (the reasons for this action are unknown to this Agency, but ENDESA may have been aware that this user was compromised, as on that same day ENDESA sent an email referencing an active employee in ***EMPRESA.15, whose user was to be deactivated immediately).

-

User ***USUARIO.2 (***USUARIO.2), assigned to ***EMPRESA.8, was reset or disabled in ***HERRAMIENTA.1 and removed from its systems on November 19, 2021.

-

User ***USUARIO.1, assigned to ***EMPRESA.13, was reset or disabled in ***HERRAMIENTA.1 on February 15, 2022, and removed from the systems on August 24, 2022. That is to say, it was not reset before the first burofax was sent to Facebook on February 8, 2022, as ENDESA states in its

allegations to the initiation agreement.

In light of all the above, this Agency cannot but disagree with ENDESA's assertion that it had implemented the proposed security measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

71/214

from the onset of the violation of personal data security and appropriate to mitigate the consequences of the data security breach, since it is not true that access for the compromised users to ENDESA's tools was diligently blocked, disabling their credentials, nor

much less that this took place before the first burofax was sent to Facebook.

Regarding the fact that Endesa proceeded to implement additional security measures such as multifactor authentication and the disabling of multi-session access, which eliminated the possibility of unauthorized access to Endesa's systems by users not identified as compromised, regardless of whether new Facebook ads were published or previous ones remained published, this Agency reiterates that such measures should have been adopted by ENDESA beforehand, given that the risk of compromised users allowing access to ***HERRAMIENTA.1 and ***HERRAMIENTA.2 was quite probable, especially since there was no multifactor authentication and multiple sessions were allowed to be open simultaneously, which enabled a lack of control over access to ENDESA's systems. This, combined with the impossibility of conducting traceability under the conditions of the logs of these systems, resulted in an ideal breeding ground for a situation like that of the object of this procedure, in which it is not even possible to verify the number of unauthorized accesses to these systems due to the lack of traceability that would allow it.

Finally, since ENDESA referred to an expert report by an independent third party, which demonstrates the allegations, this Agency proceeded to request that it present the aforementioned report during the evidentiary period of this procedure.

In this report, dated June 23, 2023, the expert team provides a chronology of events considered relevant, indicating (page 4) that from "September 3, 2021, to February 18, 2022," "the compromised credentials detected during that period in FB were disabled." In this regard, this Agency wishes to point out, firstly, that ENDESA had sent the burofax to Facebook Spain on February 7, 2022. And that on February 15, 2022, two users of the ***HERRAMIENTA.1 platform (***USUARIO.1 and ***USUARIO.9) were reset and (...) a user of the ***HERRAMIENTA.2 platform (***USUARIO.6) was deleted, so these users were not reset or deleted before sending the aforementioned burofax, as ENDESA had claimed.

Secondly, this assertion made in the expert report is not entirely correct. As has been established in the proven facts of this procedure, of the compromised users that ***EMPRESA.1 communicated to ENDESA in its email of October 27, 2021, the user ***USUARIO.3 was deleted in August 2022 (although it had been reset in September 2021, a month before ***EMPRESA.1 notified that it was one of the users that had been compromised, so once that user was compromised, access to ***HERRAMIENTA.1 was not deleted until August 2022) and the user ***USUARIO.6 was reset and deleted from ***HERRAMIENTA.1 in August 2022. Meanwhile, on the ***HERRAMIENTA.2 platform, two users were deleted in January 2022 (***USUARIO.3 and ***USUARIO.5), one on February 17, 2022 (***USUARIO.6), and another on March 16, 2022 (***USUARIO.4). That is to say, that subsequent to the date indicated in

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

72/214

In the expert report, the compromised credentials during that period have been disabled.

In any case, the mere fact that ENDESA needed FIVE MONTHS (which is the period cited in the

expert report) to reset or eliminate access credentials to its systems containing the personal data of so many clients and non-clients, after its own provider informed it of the compromised users (and even their access password), evidences, in the opinion of this Agency, the scandalous lack of diligence of the company in managing the permissions granted to its providers and subcontractors for access to the aforementioned data and controlling such accesses and the proper use of that data.

For all the above, this allegation is dismissed.

First.- On the impropriety of the sanction imposed for the alleged infringement of articles 5.1. f) and 32 of the GDPR

1. On the implementation of security measures appropriate to the risk

(a) The AEPD understands that Endesa should have had implemented, from the outset, the security measures that it began to apply once it became aware of the incident.

ENDESA cites Judgment number 188/2022 of the Supreme Court, dated February 15 (ECLI:ES:TS:2022:543), which indicates that the obligation to implement security measures imposed by data protection regulations has a nature of an obligation of means and not of result.

And ENDESA explains that the AEPD, when assessing compliance or non-compliance with the obligation to implement security measures by Endesa, should analyze, solely, whether Endesa had, prior to the incident, measures that “in accordance with the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of their alteration, loss, processing, or unauthorized access” (literal transcription of the aforementioned Judgment).

ENDESA argues that this has not been the case. This is because the AEPD did not take into account, in that agreement, several pieces of evidence provided by Endesa to justify that the security measures implemented at the time the first Facebook ads were published and the first fraudulent contracts occurred were in accordance with the state of technology, taking into account the nature of the processing and the data processed, as can be inferred, among others: (i) from the Business Impact Analysis and the Risk Assessment prepared by Endesa regarding the tools ***HERRAMIENTA.1 and ***HERRAMIENTA.2 and provided to the AEPD within the framework of the File; (ii) from the fact that, in May 2021, an ethical hacking exercise was conducted to detect possible vulnerabilities of the tools ***HERRAMIENTA.1 and ***HERRAMIENTA.2 and to rectify those identified; and (iii) from the compliance, by both tools, with the policy for managing logical access to IT systems.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

73/214

ENDESA indicates that it is at that moment, prior to the materialization of the breach, when the level of security of the measures implemented should be evaluated in accordance with the state of technology and in relation to the nature of the processing carried out and the personal data in question, since evaluating it afterwards, once the breach has occurred, would completely undermine the obligation to implement security measures as an obligation of means and not of result. To attribute, afterwards and once the consequences of the breach are known, the lack of implementation of the specific measures that, once the circumstances of the case are known, would have prevented the incident, turns the obligation contained in Article 32 of the GDPR into an obligation of result, contravening what is established by the Supreme Court.

ENDESA argues that this is what the AEPD does in its Initiation Agreement, when it merely states that Endesa should have implemented the security measures that, once the incident occurred, it decided to implement to improve the security of the tools (turning the obligation of Article 32 of the GDPR into an obligation of result).

In this regard, this Agency wishes to point out that it does not consider that the obligation to implement security measures imposed by data protection regulations has a nature of an obligation of result and not of means.

However, it is equally true that ENDESA did not have, before the incident occurred, measures that “in

accordance with the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the avoidance of their alteration, loss, processing, or unauthorized access.”

It cannot be understood that it was not in accordance with the state of technology or the processing of personal data in question that a large company like ENDESA, with a business volume of billions of euros and that continuously processes data of millions of people, did not consider it reasonable to implement, at a minimum, for example, as it later did, a multifactor user authentication system, nor that it prevented a user from having multiple sessions initiated at the same time, nor to deactivate or reset immediately (without taking months) users who had the slightest suspicion of being compromised, nor did it have a system that allowed for the traceability of the activity carried out by the aforementioned users, among other possible measures.

Regarding the Business Impact Analysis documents of the application ***HERRAMIENTA.2 and ***HERRAMIENTA.1, in the “Impact-CheckList” tab, a value of 4 (Medium-High Impact) is assigned to the possibility that the loss of confidentiality and integrity of personal data could result in fines of millions of euros, but nothing is said about possible measures to prevent users of these applications from being compromised.

As for the document “Assurance check report,” with the report of the results obtained in the Ethical Hacking to detect possible vulnerabilities in the application ***HERRAMIENTA.2, there is also no reference to the possibility of compromised users or to the possible measures to be implemented to prevent or...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
74/214

to resolve such a situation. A number of other issues have been analyzed, but none related to this matter that gave rise to the present proceedings. Furthermore, the last Ethical Hacking conducted on the application dates back to May 2021, prior to the events that are the subject of the present proceedings, which reveal possible vulnerabilities. Therefore, it cannot be argued that it was an adequate preventive measure when no similar event occurred after the publication of the announcements on Facebook.

Thus, this allegation is dismissed.

(b) The AEPD understands that several months passed since Endesa identified the possible improvements it could implement regarding the security measures of the tools

***TOOL.1 and ***TOOL.2

and implemented them.

Endesa argues that the implementation of additional security measures in the systems is not a simple task, and that it usually has its determined and marked timelines, since: (i) the development of new functionalities or measures usually has a time valuation in hours that cannot be shortened; and (ii) the implementation of new measures does not usually depend solely on Endesa, but also on its infrastructure or software providers.

In this regard, concerning ***TOOL.1, Endesa highlights that the implementation projects for the possible improvements identified totaled a time valuation of 1,055 hours, so it is normal for the total implementation duration to last 3 months, despite being given the highest priority (attached as Document number 1 is the detailed explanation of each of the developments, as well as their hourly valuation).

Endesa explains that ***TOOL.2 is developed on the CRM of ***PLATFORM.1. ***PLATFORM.1 is a SaaS (Software as a Service) on which Endesa can develop multiple functionalities, such as the deactivation of multiple logins that it decided to implement after learning the details of the incident. However, this does not mean that Endesa could deactivate this functionality immediately, but rather that it was necessary to carry out specific software development for this, which involved: (i)

inventorying technical integration users; (ii) inventorying batch processes and execution users; and (iii) analyzing the use cases that can be given to an agent. In turn, all this development involves overcoming several phases that cannot be completed in less than 3 months (attached as Document number 2 is the detailed explanation of each of the developments and tasks necessary for the implementation of this security measure).

Endesa argues that the time elapsed from when the possible security improvements were identified until they were implemented is not due to a lack of diligence on Endesa's part in their development (these developments were given the highest priority), but to the fact that this is the usual and reasonably expected time for the implementation of this type of improvements.

Additionally, Endesa considers that the fact that, despite the effective implementation of the measures requiring time, these had already been identified in detail and proposed in the Endesa Committee demonstrates great diligence on its part.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

75/214

Date: September 13, 2021, at which time the incident did not yet qualify as a Notifiable Data Security Breach.

In this regard, this Agency acknowledges that the developments implemented take time and that a period of three months may be a reasonable timeframe for this (although it is equally true that, as indicated in the expert report submitted on July 3, 2023, the deployment of multi-factor authentication for users on ***HERRAMIENTA.1 and ***HERRAMIENTA.2 was completed on March 23, 2022, that is, six months after such a measure had been identified in the Committee's report of September 2021, double the estimated time).

However, the severely negligent behavior of ENDESA in the alleged violation of Article 32 of the GDPR is evident in its conduct before and after the incident occurred, given that there was not even a consideration of the possibility of misuse of users of ***HERRAMIENTA.1 and ***HERRAMIENTA.2, which meant that adequate measures had not been implemented to ensure user authentication with the necessary guarantees, preventing unauthorized access to the systems and allowing for proper tracking of these users' activity in those systems.

Neither were the compromised users reset or removed immediately from ***HERRAMIENTA.1 or ***HERRAMIENTA.2, and despite the fact that no additional development was needed to remove them, it took months, which allowed unauthorized access to the personal data owned by ENDESA during that entire time and facilitated a large number of fraudulent registrations. A preventive reset of all users of the systems was also not carried out in light of a potential threat (which later turned out to be true).

On another note, despite what was indicated by FB SPAIN, ENDESA did not contact FACEBOOK IRELAND LIMITED through any of the available means to request the removal of the published ads offering access to its systems.

For all the above reasons, this Agency considers that ENDESA's actions have been severely negligent, and therefore, this allegation is dismissed.

(c) The AEPD, taking (in its opinion) as a basis the report prepared by ***EMPRESA.1, understands that Endesa could have implemented additional security measures on the tools ***HERRAMIENTA.1 and ***HERRAMIENTA.2:

ENDESA claims that the AEPD has based the vast majority of its arguments regarding the lack of security measures implemented by Endesa on the conclusions and statements contained in the report provided by ***EMPRESA.1, which it reiterates should not be taken into account for these purposes.

In this regard, this Agency reiterates that the actions of ***EMPRESA.1 are not the subject of this proceeding, but rather the actions of ENDESA in the reported violation of personal data security.

And that, as stated in all the documentation in the file and as detailed in the Background, Established Facts, and Legal Grounds of this document.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
76/214

In this document, this Agency relies not only on the report prepared by ***EMPRESA.1, but also on all the information it has become aware of throughout this procedure.

And that, precisely due to its possible implication in the violation of personal data security, this Agency requested certain information from ***EMPRESA.1, within the framework of the preliminary actions of this procedure. However, this is by no means the only information on which this Agency bases its proposal for the corresponding sanctions against ENDESA.

Moreover, the measures referred to by this Agency that ENDESA was supposed to have implemented are, precisely, the measures that were implemented after the incident in question.

For all the above reasons, this allegation is dismissed.

(d) The AEPD understands that Endesa was not diligent in contacting Facebook for the removal of the ads since, after receiving the response indicating that Facebook Spain was not the competent entity, it did not send any request to Facebook Ireland Limited in this regard and, therefore, did not implement the proposed security measures.

:

ENDESA reiterates that the Initiation Agreement errs in reaching this conclusion since: (i) the decision not to contact Facebook Ireland Limited was made by Endesa consciously to not expressly acknowledge Irish jurisdiction (not due to a lack of diligence); and (ii) the proposed security measures were indeed implemented by Endesa, with great diligence and even prior to sending the first burofax to Facebook Spain, by disabling the credentials of the compromised users so that, although the ads remained active on Facebook, the sold/rented users could no longer access Endesa's systems. In this regard, this Agency reiterates what was stated in section b) of the previous allegation in the document of allegations to the initiation agreement of this procedure, and therefore, this allegation is dismissed.

(e) The AEPD understands that Endesa took several months to delete the accounts of the compromised users from the Company's systems.

:

ENDESA claims that, in the Initiation Agreement, it is alleged that Endesa took several months to delete the accounts of each of the compromised users from the Company's systems.

In this sense, ENDESA clarifies that, once the account of each user is disabled or reset, the user cannot access it or use it for any purpose, remaining permanently expelled from the system.

Therefore, the fact that the account has not been completely deleted from ENDESA's systems is due to the purpose of avoiding orphaned records and the loss of

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
77/214

critical business information, without this meaning that the user could regain access to it as seems to be implied by the Initiation Agreement.

This is indicated by ***PLATFORM.1 itself in its help manual, which states: "The removal of a user from ***PLATFORM.1 affects many processes within the organization. After leaving the organization, you obviously do not want the user to retain access to their account. However, simply deleting a user can result in orphaned records and the loss of critical business information. For these reasons, deactivating rather than deleting the user is the appropriate action to take. Deactivation removes the user's login access but retains all activity and historical records, facilitating the transfer of ownership to other users."

In other words, ENDESA explains that, for the reasons stated, the fact that a period of time elapsed until the complete deletion of credentials after they had been disabled does not mean, in any case, that

these users could continue to access the ***TOOL.1 and ***TOOL.2 systems. Nor does it mean that other unidentified users who were not flagged as compromised could access the systems, since ENDESA proceeded to implement multifactor authentication measures as well as the deactivation of multi-session access. All of this made any unauthorized access unfeasible, regardless of whether Facebook ads remained published.

In this regard, this Agency certainly understands that, once the account of each user has been disabled or reset, they cannot access it or use it for any purpose.

However, what is being attributed to ENDESA is that it delayed for months in disabling or resetting the compromised users, as has been extensively explained in the response to point b) of the previous allegation in the statement of objections to the initiation agreement of this procedure.

This Agency also wishes to highlight that, regarding ***TOOL.1, the dates of disabling/resetting users and the deletion of users were provided separately, but that, regarding ***TOOL.2, only the date of user deletion was provided, so it is not evidenced that there was any resetting or disabling.

In any case, and as has been evidenced throughout the procedure, ENDESA delayed for months in disabling or deleting the compromised users, which allowed access to its systems for months, facilitating fraudulent registrations.

For the reasons stated, this allegation is dismissed.

2. Regarding the occurrence of violations

ENDESA indicates that the Initiation Agreement includes a first proposal for a sanction for non-compliance with Article 5.1.f of the GDPR since "it is considered that ENDESA did not adequately guarantee the confidentiality and integrity of the personal data of its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

78/214

"ownership" and a second proposed sanction for non-compliance with Article 32 of the GDPR because "it is considered that ENDESA did not apply the appropriate technical and organizational measures to ensure a level of security adequate to the risk of a breach occurring as the one that took place."

ENDESA argues that the same facts would lead, if the AEPD's criteria in said Initiation Agreement were maintained, to the imposition of two sanctions for the infringement of two different provisions, Article 5.1.f) and Article 32, both of the GDPR.

And that this duplicity of sanctions constitutes a case of concurrence of punitive norms in the administrative sphere, specifically in what doctrine refers to as "concurrence of sanctioning administrative norms." The different types of concurrence of infringements and norms, whose exact delimitation presents some complexity, are linked to the institution of "non bis in idem." These are principles inherent to the criminal sphere (e.g., Article 8 of the Penal Code) and also apply to the sanctioning power of the administration in its material aspect and to the administrative sanctioning procedure in its procedural aspect, initially through jurisprudential application and, later, through express inclusion in some of its representations in positive law (e.g., in Article 29.5 of Law 40/2015, on the Legal Regime of the Public Sector - hereinafter LRJSP).

ENDESA indicates that the GDPR itself contains a specific regulation of the concurrence of infringements in Article 83.3.

ENDESA explains that the concurrence of sanctioning administrative norms occurs when a subject, with a single act or set of acts and a single injury to the same legal good, commits the type punished in both. According to doctrine and jurisprudence, for the concurrence of infringements to exist, a triple identity must be present: (i) of subject; (ii) of object; and (iii) of reason or foundation. In the present case, ENDESA considers that it is faced with unique facts, which are regarded by the AEPD as a lack of appropriate security measures to protect the personal data for which ENDESA was responsible. And that, even if it were accepted for mere dialectical purposes that such consideration were true, the Initiation Agreement identifies that such facts infringe two different provisions, one containing a general principle (principle of integrity and confidentiality) and the other containing a specific mandate (appropriate security measures).

ENDESA emphasizes not only the duplicity of possible infringements but also the extreme identity of the legal good protected in both provisions. Thus, while Article 5.1.f) refers to the obligation to ensure "adequate security" of personal data through the application of "appropriate technical or organizational measures," Article 32 is the specification of that principle when it obliges the controller to apply "appropriate technical and organizational measures" to guarantee "an adequate level of security." ENDESA understands that the obligations are equivalent, even qualified with exactly the same indeterminate legal concepts (adequate security and appropriate measures). And it can even be concluded with the assertion that there are two equivalent provisions, one with a general approach and the other with more specific content, so that the same act could not be sanctioned twice, violating the principle of non bis in idem.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
79/214

referring to the constitutional principle of "non bis in idem." The consequence would be the impossibility of sanctioning the same facts for the infringement of Article 5.1.f) and Article 32 of the GDPR.

ENDESA explains that, although "non bis in idem" is not expressly stated in the Spanish Constitution, the Constitutional Court has repeatedly declared that it must be understood as implicit in Article 25.1 of the CE, due to its close connection with the principle of punitive legality (see, among others, Judgment 2/1981, of January 30). Unlike what is provided in International Conventions on fundamental rights, such as the Charter of Fundamental Rights of the European Union, in its Article 50.

In any case, even if the full application of "non bis in idem" is not accepted on the grounds that the violated provision is not the same (which is formally the case), ENDESA understands that what undoubtedly occurs in the present case is a concurrence of punitive norms in which there is a triple identity of subject (the actor, Endesa), object (the argued insufficiency of appropriate security measures), and reason or legal foundation (the aim of ensuring an adequate level of security).

When two punitive norms concur, ENDESA points out that the material "non bis in idem" prevents sanctioning twice for the same facts, although it is not regulated which one should be applied. There are different criteria in the jurisprudence for these cases: (i) the application of the special norm over the general norm; (ii) the application of the more severe sanctioning norm, following the criterion of Article 8 of the Penal Code; or (iii) in some cases, the courts have opted to give precedence to the administrative sanction that is imposed first, regardless of the specialty, a criterion that is not applicable to the case at hand.

In ENDESA's general opinion, and in this sense, only the sanction related to the alleged breach of Article 32 of the GDPR should be imposed, and not the one corresponding to the alleged breach of the general principle of Article 5.1.f) of the GDPR.

All of this is for the hypothetical case in which the AEPD considers that there was indeed a breach of such article and does not take into account what was previously argued regarding the sufficiency of security measures.

ENDESA understands that this is also the criterion resulting from the application of the methodology established in the Guidelines 4/2022 of the European Data Protection Board ("EDPB") on the calculation of administrative fines under the GDPR. The EDPB indicates that different situations of concurrence of infringements and/or sanctions may arise, and that a case-by-case analysis is necessary. Following the methodology of the aforementioned Guidelines, the steps to be followed would be as follows (Chapter 3):

- First, it must be analyzed whether we are dealing with a single fact (related to a single processing activity or linked activities). The criterion must be based on conduct carried out by the same subject, in a unified manner (even if it has different phases), close in space and time so that an external observer may consider it as a single activity. In the present case, ENDESA understands that it should be considered that we are dealing with a single conduct.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
80/214

- Secondly, it is necessary to determine whether that conduct is sanctionable under two different provisions. In the present case, ENDESA understands that the answer is affirmative (possible infringements of Articles 5.1.f) and 32 of the GDPR).

- Thirdly, it is necessary to determine which of the norms should prevail. ENDESA explains that, as cited by the CEPD in its Guidelines, community jurisprudence has sometimes opted for the principle of specialty (case C-10/18 Marine Harvest). For the application of the principle of specialty, there must be consistency in the objectives pursued by the two applicable norms, as is the case at hand. The consequence would be the application solely of the special norm, excluding the application of the general norm.

Continuing with the process of choosing the applicable norm, and in the case where the principle of specialty is not taken into account, the next criterion employed by the CEPD, although in ENDESA's opinion it would not be as suitable as the previous criterion for this case, would be the criterion that the CEPD refers to as "unity of act," which is provided for in Article 83.3 of the GDPR, according to which "If a controller or a processor intentionally or negligently infringes diverse provisions of this Regulation for the same processing operations or linked operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements." In the present case, the consequence would be the application of the sanction corresponding to the infringement of Article 5.1.f) of the GDPR.

In conclusion: ENDESA understands that the facts subject to the present procedure cannot be sanctioned simultaneously for infringement of Articles 5.1.f) and 32 of the GDPR, as this would be contrary to the principle of "non bis in idem"; if it is understood that the requirements to apply the aforementioned principle are not met, it is understood that there would be a situation of concurrence of sanctioning administrative norms, and the most appropriate criterion for choosing which of them should be applied would be the principle of specialty ("specialia generalibus derogant"); finally, and subsidiarily to all the above, in any case, sanctioning should only occur for the infringement that entails the most severe penalty.

In this regard, this Agency wishes to point out that Article 5.1.f) of the GDPR is violated when there is a loss of confidentiality, integrity, or availability of personal data, which may or may not occur due to the absence or deficiency of security measures.

This principle merely determines the channel through which the maintenance of confidentiality, integrity, or availability can be achieved when it specifies "through the application of appropriate technical and organizational measures," which are not strictly security measures.

ENDESA concludes that the appropriate technical and organizational measures referred to in Article 5.1.f) of the GDPR are the security measures of Article 32 of the GDPR. However, this would simplify the essence of the GDPR, whose compliance is not limited to the implementation of technical and organizational security measures; it would mean, in

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
81/214

In this case, the guarantee required is reduced through the principle of integrity and confidentiality to its achievement solely with security measures.

This Agency reiterates that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle. However, Article 32 of the GDPR includes the obligation to implement appropriate technical and organizational security measures to ensure a level of security adequate to the risk. Of security. Only of security.

Furthermore, its objective is to ensure a level of security appropriate to the risk, while in the case of Article 5.1(f) of the GDPR, confidentiality and integrity must be guaranteed. As can be seen, the two articles pursue different purposes, although they may be related.

Regarding the examination of non bis in idem, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) states that,

“(…) According to the legislation and jurisprudence presented, the principle of non bis in idem prevents punishing the same subject twice for the same act based on the same grounds, understood as the same legal interest protected by the sanctioning norms in question. Indeed, when there is a triple identity of subject, act, and grounds, the sum of sanctions creates a sanction foreign to the proportionality judgment made by the legislator and materializes the imposition of a sanction not legally provided for, which also violates the principle of proportionality.

But for "bis in idem" to be applicable, a triple identity must exist among the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

a) The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority that judges and irrespective of who the accuser is or the specific body that has resolved, or whether it is judged alone or in conjunction with others affected.

b) The factual identity implies that the judged facts must be the same, and excludes cases of real competition of infringements where there is not a single unlawful act but several.

c) The identity of grounds or causal identity implies that the sanctioning measures cannot coincide if they respond to the same nature, that is, if they share the same teleological foundation, which occurs between penal and administrative sanctions, but not between punitive and merely coercive measures.”

Taking into account the above, in the present sanctioning procedure, the principle of non bis in idem has not been violated, since, although broadly understood, the facts are detected as a consequence of a violation of personal data security, the infringement of Article 5.1(f) of the GDPR is specified in a clear loss of confidentiality and integrity, while the infringement of Article 32 of the GDPR is reduced to the absence and deficiency of the security measures (only of security) detected, present independently of the violation of the personal data security in question. In fact, if these security measures (not appropriate to the risk, by the way) that ENDESA had implemented had been detected by this Agency without the loss of confidentiality and integrity of the personal data occurring, ENDESA would only have been sanctioned for Article 32 of the GDPR.

And all this against the allegations made by ENDESA, which considers that both provisions require a single conduct, which is to implement adequate security. This is not true, since Article 5.1(f) of the GDPR is not limited to guaranteeing security appropriate to the risk, but to guaranteeing integrity and availability. And not only through security measures, but through all kinds of appropriate technical or organizational measures.

As indicated, Article 5.1(f) of the GDPR sanctions a loss of availability and confidentiality only, and Article 32 of the GDPR sanctions the absence and deficiency of the security measures implemented by the data controller. Absent or deficient security measures that, in themselves, infringe the GDPR regardless of whether the loss of confidentiality has occurred.

Therefore, the principle of non bis in idem is not considered violated in the present sanctioning procedure.

Regarding Article 83.3 of the GDPR, it establishes that:

“3. If a data controller or processor intentionally or negligently violates, for the same processing operations or related operations, various provisions of this Regulation, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements.”

In the present case, a fine of 2,500,000 euros is proposed for the alleged infringement of Article 5.1(f) of the GDPR and a fine of 1,500,000.00 euros for the alleged infringement of Article 32 of the GDPR.

In total, they would amount to 4,000,000 euros.

The total annual global turnover of ENDESA has been established at ***AMOUNT.1 euros.

Article 83.2 of the GDPR provides that:

“5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the total annual

global turnover of the preceding financial year, opting for the higher amount:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
83/214

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9 (...)."

In the present case, 4% of the total annual global turnover of ENDESA would amount to ***AMOUNT.2 euros. Therefore, the sum of the proposed fines in this sanctioning procedure would not exceed this amount, and the proportionality rule of the GDPR has not been exceeded.

Regarding ENDESA's reference to the provisions of Guidelines 4/2022 of the European Data Protection Board on the calculation of administrative fines under the GDPR, these do not apply to the present case, but rather to facts that occurred after the adoption of the aforementioned Guidelines. For all the above reasons, this allegation is dismissed.

3. Violation of the principle of legality.

ENDESA indicates that the Constitutional Court has declared that the fundamental right to legal sanctions enshrined in Article 25.1 of the Spanish Constitution includes a dual guarantee. One, of a formal and relative scope, refers to the rank that the defining norms must have (principle of legality); and another, of a material and absolute scope, relates to the requirement of the normative predetermination of unlawful conduct and the corresponding sanctions. This second guarantee is identified with the so-called principle of legality.

Furthermore, the principle of legality contains, in turn, two mandates. The first of these, which ENDESA emphasizes for these purposes, is that of specificity (see, among others, Judgment of the Constitutional Court 297/2005, of November 21). Specificity requires a sufficient description of the behaviors classified as infractions and the corresponding sanctions in each case. The fact that it cannot be determined with sufficient certainty what conduct may constitute a breach would be a case of violation of that fundamental principle. Thus, ENDESA argues that Article 5.1.f) of the GDPR establishes a general principle that lacks specific concreteness through clear positive or limiting acts that the obligated party can know and comply with. On the contrary, it uses indeterminate legal concepts in a chained manner ("adequate security," "appropriate measures"), which do not allow for a transparent understanding of the scope of obligations or prohibitions.

Consequently, ENDESA understands that in the application of the norm, the administration must be extremely careful when identifying the facts constituting an infringement and explaining the reason why those facts fall under the poorly defined type.

In this regard, this Agency wishes to point out that infringements in the field of data protection are classified in paragraphs 4, 5, and 6 of Article 83 of the GDPR. This is a classification by reference, fully accepted by our Constitutional Court. In this sense, Article 71 of the LOPDGDD also makes reference to them by stating that "Acts and behaviors that constitute infringements are those to which..."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
84/214

referring to paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law."

In this regard, the Opinion of the Council of State dated October 26, 2017, concerning the Draft Organic Law on the Protection of Personal Data states that "The European Regulation does indeed classify, albeit in a generic sense, the behaviors constituting an infringement: indeed, paragraphs 4, 5, and 6 of its Article 83, as transcribed above, contain a catalog of infringements for violation of the provisions of the European norm indicated in such paragraphs. Article 72 of the Draft Law rightly assumes the existence of such a catalog when it states that "the acts and behaviors that constitute a

violation of the content of paragraphs 4, 5, and 6 of the European Regulation and of this organic law are considered infringements."

In this case, as concluded by the Council of State, the European model of sanctions in the GDPR entails a wide range in the amount of the sanction, depending on the concurrence of the circumstances of Article 83.2, which are objective and verifiable by the courts. In fact, as is evident from the STC 150/2020, dated October 22, what is considered contrary to the principle of specificity and *lex certa*, the material aspect of Article 25 of the Spanish Constitution, is: entrusting such correspondence entirely to judicial or administrative discretion, "since this would amount to a mere blank authorization to the administration by a legal norm devoid of its own material content."

In the GDPR, a norm that establishes infringements and sanctions, such an undesirable circumstance as entrusting "entirely" (sic) to administrative discretion the correspondence between infringement and sanction does not occur. On the contrary. Article 83.4 GDPR and 83.5 GDPR already establish a first distinction regarding the amount of the sanctions to be imposed based on the infringed provisions. Article 83.6 GDPR, on the other hand, also properly delineates the infringement. Article 83.2 GDPR, furthermore, contains the circumstances that the European legislator considers that the supervisory authorities must take into account to determine the amount of the sanction, which are circumstances that do not depend on "administrative discretion," but rather on an objective assessment, and reviewable by the courts.

Therefore, this allegation is dismissed.

Second.- On the impropriety of the sanction imposed for the alleged infringement of Article 33 of the GDPR

ENDESA argues that it is essential, for the correct understanding of the matter, to clarify beforehand three concepts that cannot be confused or are interchangeable.

- Security Breach: An irregular event that affects the systems and technological environments of a company from multiple possible areas. A security breach does not necessarily entail an impact on the information and does not entail...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

85/214

necessarily affects the personal information that may be contained in the systems.

-

Personal Data Security Breach: occurs when a Security Breach also affects personal data stored or processed in the entity's information systems. According to Article 4.12 of the GDPR, it is "any breach of security that results in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data."

-

Notifiable Personal Data Security Breach: is a Security Breach that: (i) in accordance with Article 33 of the GDPR, must be communicated to the supervisory authority (in this case, the AEPD) because it is likely to pose a risk to the rights and freedoms of the affected data subjects; and (ii) in accordance with Article 34 of the GDPR, must be communicated to the affected data subjects because it is likely to pose a high risk to their rights and freedoms.

As an important additional element for interpretation, it should be noted that Articles 33 and 34 of the GDPR refer to notifications of data security breaches and not to security breaches.

ENDESA indicates that to determine compliance or non-compliance with the obligation contained in Article 33 of the GDPR, the first thing that must be examined is the moment when a data controller or processor is understood to be aware of a Notifiable Personal Data Security Breach, that is, a breach of data security that may constitute a risk to the rights and freedoms of the affected data subjects. Once that moment has been determined, it must be established whether the notification was made within the timeframe established in Article 33 of the GDPR (72 hours).

In this regard, and contrary to what is stated in the Initiation Agreement, ENDESA reiterates that it communicated the Personal Data Security Breach to the AEPD at the very moment it had sufficient knowledge of its scope and, therefore, as indicated in Article 33 of the GDPR, when it became aware: (i) that it affected personal data for which Endesa is responsible (i.e., that it was a Personal Data Security Breach); and (ii) that it could constitute a risk to the rights and freedoms of the affected data subjects (i.e., that it was a Notifiable Personal Data Security Breach).

It claims that for the aforementioned determination of the exact moment when it is understood that Endesa became aware of the Notifiable Personal Data Security Breach, it is essential to bring up again the chronological sequence of the main facts involving, in addition to Endesa, the companies ***EMPRESA.1 as an external provider of Endesa (processor for Endesa) and ***EMPRESA.9 as a provider of ***EMPRESA.1 and subcontractor of Endesa (sub-processor for Endesa). This chronological sequence is as follows:

Date

Fact

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

86/214

24/08/2021

Endesa detects an advertisement on Facebook through which a user code for the ***HERRAMIENTA.1 tool of Endesa was offered, potentially granting access to personal data of Endesa customers.

10/09/2021 to 13/09/2021

Once the necessary work to confirm the veracity of the advertisement has been carried out, the Personal Data Security Breach is analyzed to determine whether it is notifiable in accordance with Articles 33 and 34 of the GDPR.

14/09/2021

Endesa issues a first report concluding that, considering the available information, it is unlikely that the identified Personal Data Security Breach constitutes a risk to the rights and freedoms of the affected data subjects since there was no evidence of fraudulent access to ***HERRAMIENTA.1 and therefore, the Breach is not notifiable.

28/09/2021

Endesa issues a new report updating the previous one and concluding in the same manner, in light of the available information. That is, the Personal Data Security Breach remains not notifiable in accordance with Articles 33 and 34 of the GDPR.

In accordance with the information provided throughout the File and recorded in the Initiation Agreement, by this date Endesa had already proceeded to reset or disable the account of ***HERRAMIENTA.1 for three (3) compromised users.

19/10/2021

First detection of a fraudulent registration by ***EMPRESA.1, investigation of the case and communication to Endesa.

Following the communication, a total closure of the users of ***EMPRESA.9 and access to any tool of Endesa is carried out.

20/10/2021

***EMPRESA.1 completes the investigation of the case, identifying 137 fraudulent contracts, 7 pending validation by Endesa, and 172 orders pending validation by ***EMPRESA.9.

At this moment, and although Endesa still did not have all the information about the incident, following the procedure that, des-

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid

sedeagpd.gob.es

87/214

From the ***DEPARTMENT.6 and the Territorial Unit for Claims of Endesa, which was specifically developed for this incident, it begins to verify the contracts and directly contact the affected parties to resolve the situation. Evidence of this is that, as stated in the Initiation Agreement, Endesa prohibited ***COMPANY.1 from making such calls, as Endesa wished to offer personalized attention to the affected parties.

27/10/2021

***COMPANY.1 receives an email from the manager of ***COMPANY.9 detailing the modus operandi of its sales representatives to carry out fraudulent contracts and informs Endesa, attaching screenshots of Facebook ads offering the rental and/or sale of access credentials to the application ***TOOL.1.

It is at this moment that the AEPD understands that Endesa became aware of the Personal Data Security Breach (an aspect with which Endesa agrees) and that, therefore, it should have proceeded to notify the breach to the AEPD (an aspect with which ENDESA completely disagrees). In its view, the Initiation Agreement errs in this conclusion by equating Security Breach of Personal Data with Notifiable Security Breach, understanding that each and every one of the former must be notified to the AEPD.

It is sufficient to refer to Article 33 of the GDPR to conclude that this is not the case.

04/11/2021

Alleged date of preparation of the report on evaluation and management of the security breach prepared by ***COMPANY.1 and which was never shared by Endesa in violation of its obligations as data processor.

18/11/2021

Endesa, in the context of its investigations, continues to request additional information from ***COMPANY.1 regarding the Security Breach to continuously reevaluate its conclusion that the Breach is not notifiable, without ***COMPANY.1 or ***COMPANY.9 providing relevant information for these purposes (see Document number 3 attached to this statement of allegations).

January 2022

Endesa identifies new ads published on Facebook offering the sale of customer databases from various companies in the sector.

After its analysis, Endesa determines that the identified Security Breach remains non-notifiable, as it has no record of fraudulent access to ***TOOL.1 having materialized. As can be seen, this is the same conclusion reached in September 2021.

It is not, as the AEPD asserts in its Initiation Agreement, that at this time Endesa was not “capable of noticing that there was a security breach as such” or that it was not “aware that there was a security breach affecting its data.” On the contrary, Endesa was aware of the existence of a Security Breach, although it considered, after a detailed analysis of its scope, that it was not notifiable (in accordance with Article 33 of the GDPR).

07/01/2022

Endesa again requests ***COMPANY.1 to provide more information regarding the Security Breach, and ***COMPANY.1, once again, provides incomplete information (see Document number 4 attached to this statement of allegations) after several requests from Endesa, preventing Endesa from reevaluating its conclusion that the Breach is not notifiable.

31/01/2022

Endesa terminates the service contract signed with ***COMPANY.1 as a consequence of: (i) the lack of information received from ***COMPANY.1 regarding the incident; and (ii) the non-compliance of ***COMPANY.1 with its obligations as data processor.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

89/214

04/02/2022

Endesa sends a burofax to Facebook through which it informs that certain users of the platform are publishing information that could constitute a crime and requests their collaboration for its removal. Again, it is not, as the AEPD asserts in its Initiation Agreement¹⁷, that “it seemed that by February 4, 2022, Endesa was indeed aware that the personal data in its ownership could be affected by a security incident.” On the contrary, Endesa has been aware since October 27, 2021, that it has suffered a Data Security Breach, although it does not consider, up to that moment, that this is reportable (in accordance with Article 33 of the GDPR) as it understands, after the corresponding analyses, that it is unlikely to pose a risk to the rights and freedoms of the affected parties.

08/02/2022

Notifiable Data Security Breach. Endesa was already aware of the Data Security Breach since October 27, 2021, although it considered, after the appropriate analyses, that it was not reportable.

09/02/2022

After completing the appropriate analyses of the Data Security Breach with the detail that some of the compromised users have had access to the tool ***HERRAMIENTA.2, Endesa determines that, in this case, the breach is Notifiable, as it now understands that it is likely to pose a risk (not high) to the rights and freedoms of the affected parties.

10/02/2022

Endesa proceeds to notify the Data Security Breach to the AEPD through its electronic headquarters. ENDESA explains that, as can be seen from the previous table, the main milestones of the incident suffered by Endesa would be:

- (i) August 24, 2021: Endesa detects that a Security Breach may have occurred in its systems and proceeds to analyze it.
- (ii) September 10 to 13, 2021: Endesa confirms the Security Breach and determines that, within the framework of it, there has been unauthorized access to data for which the Company is responsible, resulting in a Data Security Breach, and proceeds to analyze it to determine whether it is, or is not, reportable in accordance with Articles 33 and 34 of the GDPR.
- (iii) September 14, 2021: Endesa issues a first report on the Data Security Breach, concluding that, on that date, it is unlikely to pose a risk to the rights and freedoms of the affected parties, and therefore would not be reportable.
- (iv) September 18, 2021: Endesa issues a second report on the Data Security Breach, concluding that, on that date, it remains non-notifiable.
- (v) October 2021: ***EMPRESA.1 provides Endesa with additional information about the Data Security Breach, leading Endesa to analyze it in detail again. After the appropriate analyses and with the limited information provided so far by ***EMPRESA.1, Endesa concludes again that the Data Security Breach is not reportable, as, with the information provided, it is unlikely to constitute a risk to the rights and freedoms of the affected parties.

This is so because: (i) the sales representatives who carried out fraudulent contracts have been identified and dismissed (in addition to being reported to the Police); (ii) access for all sales representatives of ***EMPRESA.9 to Endesa's tools containing personal data of the Company's clients has been blocked; and (iii) the affected parties are completely identified, and Endesa has been individually contacting them to understand their situation in detail and reverse, if applicable, any fraudulent contracts they may have suffered.

- (vi) November 2021: While Endesa, in following up on the Data Security Breach and in compliance with its obligations as the data controller, continues to request information about it from ***EMPRESA.1 with little success due to the provider's negligence, it supposedly drafts and issues a report on the Data Security Breach that: (i) it never shares with Endesa in violation of its obligations as the data processor for Endesa; and (ii) concludes that the Data Security Breach could pose a high risk to the affected parties when it does not have the necessary information to reach such a conclusion nor does it know the extent of the consequences of it.

In fact, the report from ***EMPRESA.1 itself, whose validity and rigor Endesa contests, and which the AEPD uses, among other arguments, to justify the proposal of a sanction that Endesa considers inappropriate: (i) clearly indicates, in several of its sections, that the security breach is still being

managed by Endesa, as it could not be considered closed with the limited information available in November 2021; and (ii) errs in its conclusions by stating that “the severity level of the consequences for the affected individuals can be considered high as they could face energy supply cuts, stress, and additional costs,” since in no case would they have faced such consequences.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
91/214

serious issues such as power supply cuts (these do not occur automatically nor can they be carried out without prior notice to those affected).

Notwithstanding the limited information available (due to the lack of diligence of ***EMPRESA.1 and ***EMPRESA.9), Endesa reevaluates its conclusion regarding the notification of the Data Security Breach and concludes, once again and in light of the lack of evidence, that it is not subject to notification. This is so because Endesa, unlike ***EMPRESA.1, is aware of the actions it has been taking since August 2021 as well as the true consequences that the affected parties could face as a result of the Data Security Breach and, therefore, can determine that it is unlikely to pose a risk to their rights and freedoms.

(vii) January 2021: Endesa continues to advance in the internal investigation of the Data Security Breach and requests, unsuccessfully, additional information about it from ***EMPRESA.1 to reevaluate its decision regarding the non-necessity of notification. In light of the lack of evidence regarding a possible risk to the affected parties, Endesa concludes once again that the Data Security Breach is not subject to notification.

(viii) February 2021: Endesa, thanks to its own investigation of the incident (***EMPRESA.1 was unable to provide Endesa with all the necessary information to conduct the corresponding analysis on the scope of the Data Security Breach), determines that the compromised users have had access not only to the tool ***HERRAMIENTA.1 but also to the tool ***HERRAMIENTA.2, which contains categories of data additional to those contained in ***HERRAMIENTA.1. Based on this information and the fact that the tool ***HERRAMIENTA.2 stores contact data of Endesa customers, as well as data related to bank account numbers and other economic data, Endesa determines that the Data Security Breach must be notified to the supervisory authority (the AEPD), since it is likely that it now constitutes a risk to the rights and freedoms of the affected parties (the parties whose data may have been accessed unlawfully are not fully identified or specified).

As can be observed in the previous paragraphs, the correct differentiation between each of the moments and their technical qualification in accordance with what is indicated at the beginning of this allegation (Security Breach, Data Security Breach, and Notifiable Data Security Breach) is of utmost importance when qualifying the notification of the Data Security Breach made by Endesa as late or "on time."

So much so that, while ENDESA understands that the notification of the Data Security Breach was made in a timely manner since it was carried out 24 hours after concluding that it could pose a risk to the rights and freedoms of the affected parties, the AEPD understands that said notification should have been made on October 27, 2021, at the moment when Endesa became aware, through an email issued by ***EMPRESA.1, that the credentials of five users of ***HERRAMIENTA.1 compromised in the security breach...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
92/214

The personal data was unlawfully acquired to extract data from Endesa customers, which was used to carry out fraudulent contracts.

At that time, as stated above, Endesa was indeed aware, contrary to what is indicated in the Initiation Agreement on multiple occasions, that it had suffered a Data Security Breach, but did not consider, at

that moment (given the limited information provided by ***EMPRESA.1, the lack of evidence regarding a possible risk to the affected parties, and the fact that Endesa had already taken all possible actions to make it unlikely that the Data Security Breach constituted a risk to the rights and freedoms of the affected parties), that it was reportable in accordance with Articles 33 and 34 of the GDPR.

With maximum diligence, Endesa constantly reevaluated, as indicated, its conclusion regarding the Data Security Breach. This reevaluation culminated, on February 10, 2022, with the issuance of the corresponding report already provided to the AEPD within the framework of this File, in which, after new evidence revealed a possible access by the compromised users to the tool ***HERRAMIENTA.2, it was concluded that, at that time, it was indeed necessary to notify the Data Security Breach to the AEPD as the requirements established for this in Article 33 of the GDPR were met.

As previously indicated, until this analysis was conducted and this report was issued, Endesa was facing a Data Security Breach that could not be considered a reportable Data Security Breach as it did not reach the necessary threshold to be communicated to the AEPD.

Therefore, ENDESA proceeds to analyze both theses:

(i) Thesis of late notification:

The AEPD establishes, throughout the Initiation Agreement, that: (a) Endesa denies having suffered a Data Security Breach until February 2022; and (b) Endesa should have notified the breach of personal data security to the AEPD on October 27, 2021, the date on which ***EMPRESA.1 informs it that some agents from ***EMPRESA.9 are carrying out fraudulent contracts.

The first aspect (a) is fully rejected by Endesa. It is not true that Endesa denies having suffered a Data Security Breach. Endesa denies that the Data Security Breach met, until February 2022, the requirements established in the applicable data protection legislation for it to be mandatory to notify the AEPD.

The second aspect (b) must also be fully rejected by ENDESA. Firstly, because the AEPD relies, to reach this conclusion, on a report prepared by a third party involved in the Data Security Breach and, therefore, completely biased, which was completely unaware of all the details of the Data Security Breach and the consequences that could arise from it for the affected parties. Secondly, because the AEPD takes this date

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
93/214

as the date on which Endesa should have notified the Data Security Breach by equating, in violation of the provisions indicated by the GDPR and the Guidelines developed by the supervisory authorities (including the AEPD) and the European Data Protection Board, any Data Security Breach to a Notifiable Data Security Breach.

(ii) Thesis of timely notification. Why Endesa's thesis on notification is the only legally admissible one: Contrary to what the AEPD argues, ENDESA has always claimed, throughout the entire informative administrative procedure, that it complied in a timely manner with the obligation to notify the Data Security Breach imposed by Article 33 of the GDPR. This is so because only 24 hours elapsed from the moment Endesa determined that the Data Security Breach was notifiable (February 9, 2022) to its effective notification through the electronic headquarters of the AEPD (January 10, 2022).

As indicated by the "Guide for the management and notification of security breaches" published by the AEPD at the time, data controllers (in this case, Endesa) must follow an action plan in managing security breaches that begins, after the preparatory phase, with the detection and identification phase and continues with the analysis and classification phase before reaching, if applicable, the notification phase.

This Guide was subsequently replaced, on May 25, 2021, by the current "Guide for the notification of personal data breaches."

In these phases prior to notification, data controllers must analyze the sources of detection of the incident, the nature, class, type, and level of risk faced by the organization in order to first determine whether they are dealing with a security breach or not.

And the analysis does not end here. According to the aforementioned AEPD Guide, once the controllers are aware that they have suffered a data security breach, they must: (i) collect and analyze information related to the data security breach; (ii) classify the data security breach; (iii) investigate, communicate, and coordinate internal and external means; (iv) implement the response plan; and, finally, (v) determine the risk that such a data security breach may pose to the rights and freedoms of the affected data subjects in order to proceed, if that risk is high, to notify the competent authority of the data security breach.

In this same sense, the “Guidelines on the notification of personal data breaches in accordance with Regulation 2016/679” developed by the Article 29 Working Party (now the European Data Protection Board) indicate, when analyzing when a controller should be understood to “be aware” that a data security breach has occurred, that:

“The exact moment when a data controller can be considered to ‘be aware’ of a specific breach will depend on the circumstances of the case.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
94/214

cha violation. In some cases, it will be relatively clear from the outset that a violation has occurred, while in others it may take some time to establish whether personal data has been compromised.”

“After being informed of a possible violation by a person, a media outlet, or another source, or when the data controller itself has detected a security incident, it may initiate a brief investigation period to determine whether or not a violation has occurred. During this investigation period, it cannot be considered that the data controller ‘is aware’.”

In a very similar manner, the security breach management protocol developed by Endesa (see Document number 5 attached to this writing) establishes a series of milestones or differentiated phases in the management of Security Breaches that, as could not be otherwise, range from analyzing the characteristics of the Breach to determine whether it can be considered a Data Security Violation, to analyzing and conducting a “risk assessment regarding the rights and freedoms of natural persons” to determine whether, due to its impact and relevance, the Data Security Violation should be reported to the supervisory authority.

In this case, Endesa determined very early on that the Security Breach suffered in its systems constituted a Data Security Violation. Following this, and in accordance with the information it had access to, it evaluated and re-evaluated multiple times the risk that the affected parties could face as a consequence of the Data Security Violation, ultimately determining, on February 9, 2022, that the Data Security Violation should be reported to the AEPD (as it did 24 hours later).

It is for all the above reasons that it understands that Endesa proceeded to communicate the Data Security Violation to the AEPD in a very short period of time from when it became aware that it was indeed facing a Notifiable Data Security Violation, since, until all information related to the incident was gathered and the corresponding analysis was conducted, Endesa was only facing a Data Security Violation regarding which it was unlikely to pose a risk to the rights and freedoms of the affected parties (as has been demonstrated subsequently). Endesa's actions are therefore supported by the very Guide for the notification of personal data breaches currently prepared by the AEPD, which states: “It is not mandatory to notify all personal data breaches, as the GDPR provides for an exception to this obligation when, in accordance with the principle of proactive responsibility, the controller can ensure that it is unlikely that the personal data breach poses a risk to the rights and freedoms of natural persons.”

Taking all of the above into account, Endesa considers that there was, therefore, no infringement of Article 33 of the GDPR, and that no sanction would be appropriate.

In this regard, this Agency wishes to point out that Article 33 of the GDPR is crystal clear in stating that:

C/ Jorge Juan, 6
www.aepd.es

28001 – Madrid
sedeagpd.gob.es
95/214

“1. In the event of a breach of personal data security, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of it, unless it is unlikely that the breach would result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by the reasons for the delay.”

That is to say, any breach of personal data security must be communicated to the supervisory authority no later than 72 hours after becoming aware of it, except for those that are unlikely to pose a risk to the rights and freedoms of natural persons.

The GDPR does not refer to the degree of probability or risk that must exist for such a breach of personal data security to be reportable, in the words of ENDESA. It is sufficient that there is a probability (of any degree) that there is a risk to the rights and freedoms of natural persons (of any degree). It is also not necessary for that risk to have materialized for such an incident to be reportable; it is enough that it is probable.

In this case, this Agency considers that ENDESA did not correctly qualify the incident by deeming it non-reportable and reiterates that the incident in question was reportable as soon as ENDESA became aware of it through announcements on Facebook regarding the possible breach. It can be highlighted, among other events, that on September 1, 2021, ***COMPANY.16 already informed ENDESA that D.D.D. was involved in the sale of credentials; on September 10, 2021, ENDESA was already aware, due to the investigation of the incident, of the veracity of the announcement and the identification of the credentials used fraudulently to access the Endesa application

***PLATFORM.1.endesa.es; on October 20, 2021, ***COMPANY.1 informed ENDESA that fraudulent registrations had occurred; and especially following the communication from ***COMPANY.1, ENDESA learned that five users of ***TOOL.1 had been compromised and that there had been improper use of personal data held in its systems, which occurred on October 27, 2021. However, the breach was not reported until February 10, 2022. Regardless of whether the users had been reset or deleted (which has already been sufficiently analyzed as not having been done immediately or diligently), the reality is that the incident had already occurred, the confidentiality of the personal data owned by ENDESA had been lost, and there was a probable risk to the rights and freedoms of natural persons, given that ENDESA had lost control over access to that data, regardless of whether there had been (or not) unauthorized access, in addition to ***TOOL.2. Therefore, this Agency reiterates that in this case, ENDESA should have notified the breach of personal data security within a maximum period of 72 hours from the moment it became aware that the incident had occurred, as stated in the Guidelines 1/2021 on examples of notification of breaches of personal data security, from the European Data Protection Board, adopted on December 14, 2021, version 2.0, when describing the breach caused by the copying of commercial data from the company's database by its employee:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
96/214

“74. Although the sole objective of the former employee who maliciously copied the data may be limited to obtaining the contact information of the company's clientele for their own commercial purposes, the data controller is not in a position to consider that the risk to the affected data subjects is low, as the data controller has no guarantees regarding the employee's intentions. Thus, although the consequences of the security breach could be limited to exposure to unsolicited self-marketing by the former employee, further and more serious misuse of the stolen data cannot be ruled out, depending on the purpose of the processing established by the former employee.”

In this regard, it should be noted that the notification of the breach should not take place after the data controller has conducted a detailed examination of the situation, but rather when the controller detects

that the breach has occurred, with this analysis being able to take place in parallel with the notification, as stated in the aforementioned Guidelines 1/2021 on examples of notification of personal data security breaches:

“8. Data security breaches are problems in themselves, but they can also be symptoms of a vulnerable and possibly outdated data security regime; they may also indicate system deficiencies that need to be addressed. As a general truth, it is always better to prevent security breaches by preparing in advance, as many of their consequences are, by nature, irreversible. Before a data controller can fully assess the risk arising from a breach caused by some type of attack, the root cause of the problem must be identified in order to determine whether the vulnerabilities that led to the incident are still present and, therefore, whether they can still be exploited. In many cases, the data controller may determine that the incident may pose a risk, and thus must notify it. In other cases, it is not necessary to postpone the notification until the risk and impact of the breach have been fully assessed, as the complete risk assessment can occur in parallel with the notification, and the information thus obtained can be provided to the supervisory authority in phases without undue delay.

9. The breach must be notified when the data controller considers that it is likely to pose a risk to the rights and freedoms of the data subject. Data controllers must carry out this assessment at the moment they become aware of the breach. The data controller should not wait for a detailed forensic examination and (early) mitigation measures before assessing whether the data breach is likely to pose a risk and, therefore, must be notified.

10. If a data controller self-assesses the risk as unlikely, but it turns out that the risk materializes, the competent supervisory authority may exercise its corrective powers and decide to impose sanctions.”

And it is reiterated in the Guide for the notification of personal data breaches by the AEPD

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

97/214

“(…) when at the time of notification it was not possible to fulfill the obligation to provide all necessary information, the GDPR provides that the information will be provided gradually, as soon as possible and without delay. In general, the Spanish Data Protection Agency allows for the possibility of making an “initial” notification before the indicated 72 hours, by filling out the form with the preliminary information available, or, if applicable, the preliminary estimates regarding the personal data breach. Before the maximum period of 30 days from the initial notification, the data controller must complete all the information by means of a “modification” of the previous notification, including the decision made regarding the communication of the personal data breach to the affected individuals (…)” Furthermore, such notification must take place without undue delay and no later than within 72 hours from the moment the personal data breach is known, so that this Agency can exercise the functions assigned to it.

According to Recital 87 of the GDPR:

“(87) It must be verified whether all appropriate technological protection has been applied and whether the necessary organizational measures have been taken to immediately determine whether a personal data security breach has occurred and to inform the supervisory authority and the data subject without delay. It must be verified that the notification has been made without undue delay, taking into account, in particular, the nature and severity of the personal data security breach and its consequences and adverse effects for the data subject. Such notification may result in an intervention by the supervisory authority in accordance with the functions and powers established by this Regulation.”

This issue is also addressed in the Guide for the notification of personal data breaches by the AEPD, specifying that, after notifying a personal data breach, the data controller may receive various communications or electronic notifications from the AEPD, for example:

- Communication with information regarding the registration of the notified personal data breach.
- Notification with a request for additional information regarding the personal data breach or the processing of personal data in question under the functions and powers of this Agency referred to in

Article 47 of the LOPDGDD, as well as Article 58 of the GDPR.

- Notification with an order to inform the affected individuals of the personal data breach under Article 34.4, considering that the risk to the affected individuals is high, under the functions and powers of this Agency referred to in Article 47 of the LOPDGDD, as well as Article 58 of the GDPR.”

For all the above reasons, this allegation is dismissed.

Third.- On the impropriety of the sanction imposed for the alleged infringement of Article 34 of the GDPR

The AEPD indicates in the Initiation Agreement that Endesa, at the time of making the corresponding notification regarding the personal data security breach to the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

98/214

affected parties did not provide all the information required by Article 34 of the GDPR.

First of all, Endesa emphasizes that the notification made to the affected parties was carried out solely in compliance with the corresponding requirement from the AEPD dated March 4, 2022, since, from the analysis of the incident conducted by Endesa, it was determined that the security breach did not pose a high risk to the rights and freedoms of the affected individuals, as was subsequently demonstrated (in its opinion).

In fact, as has been evidenced (in its opinion), Endesa only received a single response to the notification made, and none of the affected parties suffered significant inconveniences or very significant or irreversible consequences as a result of the breach, since: (i) Endesa implemented sufficient mechanisms to mitigate the consequences of the breach, assuming all management costs; and (ii) all affected parties were personally attended to by the Endesa team and were adequately informed about the scope of the breach, its consequences, and the possible mitigation measures that could be implemented in a personalized and specific manner based on the characteristics of the user. Once again, the report provided by ***COMPANY.1, whose validity and rigor Endesa disputes, and which the AEPD uses, among other arguments, to justify the proposal of a sanction that Endesa considers inappropriate, errs in its conclusions by stating that “the level of severity of the consequences for the affected individuals can be considered high as they could face energy supply cuts, stress, and additional costs.” Even if it were not taken into account that, as has been evidenced (in its opinion), Endesa acted diligently to minimize the consequences that could arise from the breach for the affected parties, in no case would they have faced consequences as severe as energy supply cuts, as described in the report of ***COMPANY.1, since, in accordance with the applicable energy regulation, these do not occur automatically nor can they be carried out without prior notice to the affected parties.

In fact, by the date of receipt of the AEPD's requirement, Endesa had already taken further measures to ensure that there was no longer a probability of the high risk to the rights and freedoms of the affected individuals that the AEPD had identified (for example, it had terminated the contract with ***COMPANY.1 and its subcontractors so that they could not carry out additional fraudulent contracts) and was in contact with many of the affected parties to address their concerns and attend to their requests, thus fulfilling the condition set forth in Article 34.3 b) of the GDPR to determine that communication to the affected parties is not necessary. Notwithstanding the above and in order to show its utmost cooperation with this Agency and in an exercise of transparency that is clearly unnecessary from a regulatory standpoint, Endesa decided to comply with the AEPD's requirement and provide the requested information to the affected parties.

To this end, and since Endesa's intention was to attend to each of the affected parties individually (as it had been doing since it became aware of the first fraudulent contracts and continued to do so after the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

Regarding the notifications of the Data Security Breach, Endesa opted, as inferred from the content of the notification, to provide the information related to the Data Security Breach required by Article 34 of the GDPR in a two-layer format, similar to that validated by the LOPDGDD.

In the first layer (the notification itself), useful information for the affected parties is provided, such as the description of the Data Security Breach and its nature (“unauthorized access to certain commercial systems of Endesa”), the confirmation that Endesa had implemented, prior to the time of the notification, “the appropriate security measures, both technical and organizational, to prevent a high-risk impact on the rights and freedoms” of the affected parties (as mentioned in the previous paragraphs, at the time of the notification, the high risk assessed by the AEPD could no longer exist since the appropriate measures had already been taken to mitigate it), and the contact address of ***PUESTO.2 through which one can “learn the details of the measures taken or obtain more information.”

In the second layer, to which the affected parties: (i) could access, if they wished, by contacting ***PUESTO.2; or (ii) would have access once Endesa contacted them to address, in a personalized manner, their situation and reverse, if applicable, any fraudulent contracting they may have suffered, the Company would provide the affected parties with the remaining information required by Article 34 of the GDPR in a personalized manner, since not all affected parties could suffer the same consequences following the Data Security Breach nor were they affected in the same way, so the possible risk mitigation measures would vary depending on the specific case.

Through this layered information system, Endesa ensured not only that information about possible consequences and mitigation measures was provided in a personalized manner and appropriate to the specific case as mentioned above, but also that the affected parties were attended to by a team, that of ***DEPARTAMENTO.4 of Endesa specialized in the commercial field, specialized in data protection matters and knowledgeable about the possible consequences that the Data Security Breach could have on the rights and freedoms of the affected parties.

In this regard, it is of utmost importance to highlight that any communication or inquiry that the affected parties may have sent to the DPO mailbox provided in the communication (***EMAIL.1) would be addressed in a particular and individualized manner by ***DEPARTAMENTO.4 of Endesa specialized in the commercial field (hereinafter, “***DEPARTAMENTO.4”). This demonstrates the proactivity and diligence displayed by Endesa in providing the affected parties with all the necessary information related to the Security Breach, which task was centralized in ***DEPARTAMENTO.4. This department was authorized to attend to and respond in a personalized manner to the inquiries that, if applicable, had been directed by the affected parties. However, it should be noted that, as Endesa demonstrated in its response to the request received on June 27, 2022, ***DEPARTAMENTO.4 only received one communication, the inquiry of which was not raised by the affected party.

It is for this reason that Endesa decided to carry out a notification of the Data Security Breach in two layers, to avoid conveying to all affected parties information...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

100/214

generic information that may not be applicable to your specific case. In either of the two previous cases (proactive action by the interested party at an initial moment or subsequent proactive action by Endesa), the interested parties would have access to the rest of the information required by Article 34 of the GDPR, such as the details of the types of affected data, the description of the specific security measures implemented by Endesa to mitigate potential adverse effects, and the description of the possible consequences that the Data Security Breach suffered by Endesa could cause them. As can be seen, none of these points is extrapolable to all affected parties, and it is for this reason that Endesa, in order to achieve effective communication of the incident, decided to carry it out in two layers (one more generic and another individualized).

In this regard, the AEPD itself, in its infographic on how to carry out the corresponding notifications of personal data breaches to the interested parties, indicates that it is necessary to take into account that the notification "does not imply a single action or act" and that, therefore, "it can be executed in different actions depending on the information that the controller has about the magnitude of the breach and the affected persons" (the underlining and bold text are ours).

Endesa did so in this case to achieve more effective communication with the affected interested parties, taking into account the characteristics of the Data Security Breach.

Furthermore, it is worth noting that both ***DEPARTMENT.6 of Endesa and ***DEPARTMENT.7 conducted an audit and review procedure of all the contracts managed by ***COMPANY.9 during the period from June 1 to October 15, 2021. This is because, as has been demonstrated, ***COMPANY.1 did not provide Endesa with complete and detailed information about the Security Breach; as a control measure and being highly protective, Endesa decided to review all the contracts processed by ***COMPANY.9 over a generous period of time.

Therefore, in the interest of objectivity and in terms of strict legal defense, in light of the statements made by ***COMPANY.1 in its response to the AEPD's request regarding its proposal "to Endesa to make calls to customers who may have been affected to confirm both the legality of the contracting and the verification of the account number provided," but, "Endesa prohibited it," it should be noted that Endesa did carry out the review and individualized attention of each contract processed by ***COMPANY.9.

These tasks were delegated to independent providers of ***COMPANY.1 and to ***DEPARTMENT.7. In this regard, this Agency wishes to point out that the necessity or otherwise of communicating the breach of personal data security in question has already been analyzed, and it was concluded that it was necessary to communicate it to the affected parties, which is why a resolution dated March 7, 2022, was issued ordering ENDESA to do so, in compliance with the provisions of Article 34 of the GDPR. Therefore,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
101/214

The communication to the interested parties regarding this incident by ENDESA was mandatory compliance and not an exercise of "collaboration" on their part.

From the fact that only one response was received to the sending of such communication (by the way, in which it is indicated that this person had no relationship with ENDESA), it cannot be inferred that the incident in question did not constitute a high risk to the rights and freedoms of the affected parties.

Rather, it could be inferred that no response was received from the affected parties because the communication was deficient and did not clearly indicate that a violation of the security of the personal data of these affected parties had occurred, which could lead to a series of unwanted consequences for them.

It cannot be stated categorically, as ENDESA does, that "none of the affected interested parties suffered significant inconveniences or very significant or irreversible consequences as a result of the breach," since ENDESA itself acknowledged that it was unable to know the specific number of unauthorized accesses or their extent. Simply put, there is no record that any such occurrences had taken place.

Regarding ENDESA's assertion that "all affected interested parties were attended to personally by the Endesa team and were adequately informed of the scope of the breach, its consequences, and the possible mitigation measures that could be implemented in a personalized and specific manner based on the characteristics of the user," it seems that ENDESA is referring to those affected by the actions of ***EMPRESA.1/***EMPRESA.9. However, the scope of the incident in question exceeded such actions, as the reality is that more users were compromised than those communicated by these providers, and the personal data contained in ***HERRAMIENTA.1 and ***HERRAMIENTA.2 were exposed to more individuals, not only to those working in these companies. Therefore, it is not true that all affected interested parties were attended to.

Furthermore, ENDESA itself states that only one communication was received as a result of the communication made to the affected parties, which suggests that personalized attention would only have occurred regarding those individuals in whom a fraudulent account was detected as a result of the actions of ***EMPRESA.1/***EMPRESA.9. In any case, it has not been proven throughout this procedure that such personalized attention took place.

Regarding the reference to the report from ***EMPRESA.1 in which it is stated that one of the consequences could be the cutting off of the energy supply, in addition to stress and additional costs, while it is true that such supply cannot be cut off automatically or without prior notice, it is equally true that even having notified, if the person in question does not pay what is owed, even if the account was fraudulently opened, the supply would indeed be cut off. And it is also true that, in any case, once that person became aware that ENDESA was claiming a certain debt for a service they did not request, that individual would be subjected to a situation of stress and would have to face a series of expenses that, had the violation of the security of their personal data not occurred, would not have taken place. All this without forgetting that the data could be subjected to other uses whose consequences ENDESA was unaware of, thus the risk to the rights and freedoms of individuals was high.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

102/214

Regarding the fact that ENDESA had already taken further measures to ensure that there was no longer a likelihood of a high risk to the rights and freedoms of the affected party, such as terminating the contract with ***EMPRESA.1 and its subcontractors and being in contact with many of the affected parties due to the actions of such companies, it cannot be understood that these were measures that eliminated the high risk for the affected parties, given that the scope of the incident was greater than what the employees of those companies had carried out. Therefore, not all unauthorized accesses were through ***EMPRESA.1 and its subcontractors, nor was it only the confidentiality of the data of those individuals who were fraudulently registered that was at risk; rather, the confidentiality of all personal data from the ***HERRAMIENTA.1 and ***HERRAMIENTA.2 systems of ENDESA was compromised, which is why this Agency ordered ENDESA to send the aforementioned communication to all affected parties.

Regarding the information provided by ENDESA, without assessing the appropriateness of using a layered model, the following information was provided to the affected parties:

“We are contacting you to inform you that we have detected a possible unauthorized access to certain commercial systems of Endesa Energía and that from the moment we became aware of this fact, we have adopted the appropriate security measures, both technical and organizational, to prevent a high-risk impact on the rights and freedoms of our clients, ensuring that the confidentiality and integrity of your personal data has not been compromised.”

This information provided is not truthful, as the confidentiality of the personal data of the affected parties had already been compromised (and perhaps in some cases, the integrity as well). It is also not true that the measures adopted prevented a high-risk impact on the rights and freedoms of the affected parties. The only thing that ENDESA could prevent was, at most, fraudulent contracting with ENDESA. However, the personal data that may have been accessed could be used for other purposes, such as obtaining more personal data from these affected parties through social engineering and impersonating their identity in other situations.

In any case, it seems that ENDESA forgets that Article 34 of the GDPR does not require that damage must have occurred, but rather that it is about communicating to the affected parties that there could be a risk to their rights and freedoms, for example, being a victim of phishing, another cyberattack, or a change of supply company. There is a very high risk of being a victim of identity theft and fraud, as this Agency is more than accustomed to seeing in its day-to-day operations. And this information is not derived from the communication made by ENDESA.

Finally, regarding the fact that ENDESA reviewed all the contracts managed by ***EMPRESA.9 between June 1 and October 15, 2021, this Agency understands that this was what it was supposed to

do as the data controller and has nothing more to add.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
103/214

For the reasons stated, the present allegation is dismissed.

Fourth.- On the inadmissibility of the sanction imposed for the alleged infringement of Article 44 of the GDPR

ENDESA argues that when working with suppliers located outside the European Economic Area and, therefore, carrying out international data transfers, it implements adequate safeguards in accordance with Articles 44 and 46 of the GDPR, contrary to what is indicated in the Initiation Agreement.

ENDESA indicates that it is truly surprising that the AEPD, in its Initiation Agreement, proposes the imposition of an alleged infringement of Article 44 of the GDPR, when in none of the four (4) requests for information sent to Endesa (three directed directly to the Company and one to its DPO) over the more than seven (7) months that the preliminary investigation proceedings of the present case have lasted, this Agency has requested any proof from Endesa of the implementation of adequate safeguards for the corresponding international transfers.

Had it done so, Endesa, as it does through the written allegations to the initiation agreement of the present procedure, would have provided this Agency with the corresponding Standard Contractual Clauses signed with its suppliers located outside the European Economic Area, in compliance with its internal procedure for carrying out international transfers (Document number 6).

Notwithstanding the above and in order to prove the adequate implementation of sufficient safeguards for carrying out international transfers in accordance with Articles 44 and following of the GDPR, the aforementioned written allegations include, as Documents numbers 7, 8, and 9, the corresponding Standard Contractual Clauses signed with the suppliers ***COMPANY.15 (...), ***COMPANY.12 (...) and ***COMPANY.9 (...).

In this regard, the following are attached: (i) the Standard Contractual Clauses signed at the time of contracting; and (ii) the updated Standard Contractual Clauses in accordance with the Implementing Decision (EU) 2021/94 of the Commission, of June 4, 2021, which have been signed subsequently. ENDESA argues that prior to carrying out the corresponding international data transfers identified in the Initiation Agreement, it implemented sufficient safeguards in accordance with the applicable data protection regulations.

Specifically, it signed with its processors and sub-processors located in ***COUNTRY.2 and ***COUNTRY.1 the corresponding standard contractual clauses approved by the European Commission as provided in Article 46.2 c) of the GDPR.

For all these reasons, Endesa considers the proposed sanction for the alleged infringement of Article 44 of the GDPR contained in the Initiation Agreement to be inadmissible.

In this regard, this Agency wishes to point out that Article 67 "Preliminary investigation proceedings" of the LOPDGDD establishes that "1. Before the adoption of the initiation agreement of the procedure, and once the complaint has been admitted for processing, if any, the..."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
104/214

The Spanish Agency for Data Protection may carry out preliminary investigation actions in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure. In other words, these actions are not mandatory in any way; rather, it is at the discretion of this Agency to carry them out.

Furthermore, in the present case, ENDESA has made international transfers to ***COUNTRY.1 and ***COUNTRY.2, and continues to make transfers to ***COUNTRY.2, countries with respect to which

the Commission has not declared that they guarantee an adequate level of protection, in the terms set forth in Article 45 of the GDPR.

Article 46 of the GDPR deals with "transfers subject to adequate safeguards" and states in its paragraph 1 that, in the absence of a decision under Article 45, paragraph 3, the data controller or processor may only transfer personal data to a third country or international organization if it has provided adequate safeguards and provided that data subjects have enforceable rights and effective legal remedies.

Article 46, paragraph 2, of the GDPR adds that "adequate safeguards" may be provided, without the need for express authorization from a supervisory authority, among others, by standard data protection clauses adopted by a supervisory authority and approved by the Commission in accordance with the examination procedure referred to in Article 93, paragraph 2. (Article 46, paragraph 2, letter c).

In this regard, the European Commission has adopted the Implementing Decision (EU) 2021/914 of the Commission, dated June 4, 2021, concerning standard contractual clauses for the transfer of personal data to third countries in accordance with Regulation (EU) 2016/679 of the European Parliament and of the Council.

These standard contractual clauses adopted by the European Commission constitute a method for providing "adequate safeguards" in the absence of an adequacy decision under Article 46, paragraph 2, letter c), of the GDPR, establishing new standard contractual clauses that can be used by both the controller and the processor in order to offer adequate safeguards within the meaning of Article 46, paragraph 1 of the GDPR, with the previous decisions of 2001 and 2010 being repealed as of September 27, 2021. However, according to its clause 4.4, contracts entered into before September 27, 2021, in accordance with Decision 2001/497/EC or Decision 2010/87/EU, are considered to provide adequate safeguards within the meaning of Article 46, paragraph 1, of the GDPR until December 27, 2022, provided that the processing operations covered by the contract remain unchanged and that the standard contractual clauses ensure that the transfer of personal data is subject to adequate safeguards.

Having established the above, it is worth highlighting that clause 14 of the decision refers to the "Law and practices of the country that affect compliance with the clauses." This clause contains four modules related to the transfer from controller to controller; transfer from controller to processor; transfer from processor to processor; and transfer from processor to controller, to which the provisions it contains apply. It establishes the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
105/214

"MODULE ONE: transfer from controller to controller

MODULE TWO: transfer from controller to processor

MODULE THREE: transfer from processor to processor

MODULE FOUR: transfer from processor to controller (only if the processor in the EU combines the personal data received from the controller in the third country with the personal data collected by the processor in the EU)

a) The parties ensure that they have no reason to believe that the law and practices of the third country of destination applicable to the processing of personal data by the data importer, particularly the requirements for the communication of personal data or the measures for access authorization by public authorities, prevent the data importer from fulfilling the obligations imposed by this clause. This assertion is based on the premise that the law and practices that essentially respect fundamental rights and freedoms and do not exceed what is necessary and proportionate in a democratic society to safeguard one of the objectives listed in Article 23(1) of Regulation (EU) 2016/679 do not oppose this clause.

b) The parties declare that, in providing the guarantee referred to in point a), they have duly taken into

account, in particular, the following aspects:

- i) the specific circumstances of the transfer, such as the length of the processing chain, the number of parties involved, and the channels of transmission used; the anticipated further transfers; the type of recipient; the purpose of the processing; the categories and format of the personal data transferred; the economic sector in which the transfer takes place; the location of the storage of the transferred data;
 - ii) the law and practices of the third country of destination—especially those requiring the communication of data to public authorities or authorizing access by such authorities—that are relevant given the specific circumstances of the transfer, as well as the applicable limitations and guarantees (12);
 - iii) the relevant contractual, technical, or organizational guarantees provided to complement the guarantees set out in this clause, particularly including the measures applied during the transfer and processing of personal data in the destination country.
- c) The data importer ensures that, when carrying out the assessment referred to in point b), it has done everything possible to provide the data exporter with the relevant information and commits to continue collaborating with the data exporter to ensure compliance with this clause.
- d) The parties agree to document the assessment referred to in point b) and make it available to the competent supervisory authority upon request.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

106/214

e) The data importer agrees to promptly notify the data exporter if, after being bound by this set of clauses and during the term of the contract, it has reason to believe that it is or has been subject to regulations or practices that do not comply with the requirements of letter a), even as a result of a change in regulations in the third country or a measure (such as a request for communication) indicating an application of such regulations in practice that does not comply with the requirements of letter a). [Module three: The data exporter will notify the controller.]

f) If the notification referred to in letter e) is made or if the data exporter has reason to believe that the data importer can no longer fulfill the obligations attributed to it by this set of clauses, the data exporter will promptly determine the appropriate measures (for example, technical or organizational measures to ensure security and confidentiality) that must be adopted by the data exporter and/or the data importer to remedy the situation [module three: if applicable, after consulting the controller]. The data exporter will suspend the transfer of data if it considers that there are no adequate guarantees or if so provided by [module three: the controller or] the competent supervisory authority. In this case, the data exporter will be entitled to terminate the contract regarding the processing of personal data under this set of clauses. If the contract has more than two contracting parties, the data exporter may only exercise this right of termination with respect to the relevant party, unless the parties have agreed otherwise. In the event of termination of the contract under this clause, clause 16, letters d) and e) will apply.

Thus, clause 14 establishes an obligation for both the exporter and importer to carry out an assessment that takes into account all the issues determined by the clause itself.

Article 46.2.c) must be interpreted in light of the doctrine of the CJEU as set out in its judgment in Schrems II:

“132 Since, as is evident from paragraph 125 of this judgment, it is inherent in the contractual nature of standard data protection clauses that they cannot bind public authorities of third countries, but that Articles 44 and 46, paragraphs 1 and 2, letter c), of the GDPR, interpreted in light of Articles 7, 8, and 47 of the Charter, require that the level of protection of natural persons guaranteed by that Regulation is not compromised, it may be necessary to supplement the guarantees provided for in those standard data protection clauses. In this regard, Recital 109 of the said Regulation states that ‘the possibility for [the] controllers [...] of processing to rely on standard data protection clauses adopted by the Commission [...] should not prevent controllers [...] from adding other clauses or additional

guarantees' and specifies, in particular, that 'controllers [...] should be encouraged to offer additional guarantees [...] that complement the standard data protection clauses.'

133 It is therefore evident that the standard data protection clauses adopted by the Commission under Article 46, paragraph 2, letter c), of the same Regulation are intended solely to provide controllers or processors established in the Union with contractual guarantees that are..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

107/214

apply uniformly in all third countries and, therefore, regardless of the level of protection guaranteed in each of them. To the extent that such standard data protection clauses cannot provide, due to their nature, guarantees that go beyond a contractual obligation to ensure compliance with the level of protection required by Union law, such clauses may require, depending on the situation of a specific third country, the adoption of additional measures by the data controller to ensure compliance with that level of protection.

134 In this regard, as the Advocate General pointed out in paragraph 126 of his conclusions, the contractual mechanism provided for in Article 46(2)(c) of the GDPR is based on the accountability of the data controller or processor established in the Union, as well as, subsidiarily, of the competent supervisory authority. It is therefore primarily the responsibility of that data controller or processor to verify, on a case-by-case basis and, if necessary, in collaboration with the recipient of the transfer, whether the law of the destination third country guarantees an adequate level of protection, in light of Union law, for the personal data transferred based on standard data protection clauses, providing, when necessary, additional guarantees to those offered by such clauses.

In this context, the Recommendations 01/2020 on measures that complement transfer instruments to ensure compliance with the level of protection of EU personal data, adopted on November 10, 2020, must also be taken into account, in which, when interpreting the aforementioned ruling of the CJEU, it states that "the Court leaves open the possibility for exporters to apply complementary measures that mitigate these protection gaps, so that it reaches the level required by Union law. The Court does not specify what measures could be. However, the Court emphasizes that exporters will have to determine them on a case-by-case basis. This aligns with the principle of proactive accountability in Article 5(2) of the GDPR, which requires that data controllers be responsible and able to demonstrate compliance with the principles of the GDPR regarding the processing of personal data (...)"

It should be noted that Endesa has provided, regarding the transfer to ***COUNTRY.1, carried out through ***COMPANY.12, a resolution of the contract between Endesa and ***COMPANY.16, dated November 15, 2022. It has also provided proof of the termination of ***COMPANY.9 as a supplier of Endesa, dated November 2, 2021. Therefore, these contracts were terminated before December 27, 2022.

Regarding the transfer to ***COUNTRY.2, ENDESA has provided the Impact Assessment on Transfers to ***COUNTRY.2, which aims to evaluate, in relation to the transfer of personal data from the exporter to the importer, the level of adequacy of the destination third country, as well as the adoption of appropriate technical and organizational security measures to mitigate the risk of such transfer.

In this regard, this assessment is limited to evaluating the technical and organizational security measures applied by the data importer, without addressing the necessity or otherwise of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

108/214

adopt additional contractual measures complementary to the standard contractual clauses that may be necessary.

In this regard, it is noteworthy that, concerning the legislative assessment of the importing country, the

evaluation yields the result "3 – Partially adequate," limited to considering the existence of data protection legislation and an independent supervisory authority in the third country, but it does not even analyze the functions and powers of this authority.

Furthermore, it provides the document titled "analysis of legislation and practices" of ***COUNTRY.2, aimed at evaluating whether the personal data being transferred is adequately protected concerning the potential access of authorities in the countries to which the data is transferred. This document states that the Constitution of ***COUNTRY.2 guarantees the fundamental right to personal and family privacy and includes the necessity of a court order for the interception of communications. The existence of a data protection law is also taken into account in this document.

From the analysis of this documentation, it cannot be asserted that the evaluation includes a sufficient analysis of the law and practices of ***COUNTRY.2 that would allow for an assessment of whether the destination third country offers an adequate level of protection. Thus, it does not contain any evaluation regarding the existence of norms that require the communication of data to public authorities or authorize access by such authorities, as well as the applicable limitations and guarantees. According to the aforementioned CJEU ruling, this analysis should include the elements set out in Article 45.2 of the GDPR, which includes the analysis of the existence of international treaties signed by the third country or other international commitments adopted (art. 45.2.c) GDPR), the study of the national legislation of the third country in the sense intended by Article 45.2.a) of the GDPR:

"the rule of law, respect for human rights and fundamental freedoms, relevant legislation, both general and sectoral, including that relating to public security, defense, national security, and criminal legislation, and access of public authorities to personal data, as well as the application of such legislation, data protection standards, professional standards, and security measures, including standards on further transfers of personal data to another third country or international organization observed in that country or international organization, case law, as well as the recognition of effective and enforceable rights and administrative remedies and judicial actions that are effective for the data subjects whose personal data are being transferred."

Analysis that is also reflected in recitals (20) of the Commission Implementing Decision (EU) 2021/914.

"The parties must take into account, in particular, the specific circumstances of the transfer (such as the content and duration of the contract, the nature of the data transferred, the type of recipient, and the purpose of the processing), the law and practices of the destination third country that are applicable given the circumstances of the transfer, and the guarantees established to complement the guarantees provided in the standard contractual clauses (such as contractual measures,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

109/214

relevant technical and organizational measures applicable to the transfer and processing of personal data in the destination country). Regarding the effect of the mentioned law and practices on compliance with the standard contractual clauses, various elements can be assessed in a comprehensive evaluation; for example, reliable information on the practical application of the law (jurisprudence, reports from independent supervisory bodies, etc.), the existence or absence of requests in the same sector, and, under strict conditions, the documented practical experience of the data exporter and/or the data importer."

The deficiencies observed in the Data Protection Impact Assessment of ***COUNTRY.2 as a country importing personal data prevent it from being considered that the guarantee of the aforementioned clause 14 has been provided.

For all the above reasons, this allegation is dismissed.

Fifth.- On the grading of the sanction imposed on Endesa and the relative lack of proportionality of the Initiation Agreement of the sanctioning procedure

ENDESA argues, first of all, the strangeness regarding the criterion that the AEPD has followed when analyzing and ultimately proposing to sanction Endesa in comparison with other cases related to data

security breaches against which sanctioning or investigation procedures have been initiated.

For example:

a. The resolution of the AEPD regarding procedure E/08809/2019 concluded with the filing of the proceedings, indicating that the investigated entity "had reasonable preventive technical and organizational measures in place to avoid this type of incident and in line with the level of risk," when that Data Security Breach:

- affected approximately 22 million records worldwide (compared to the 760 affected individuals in the Data Security Breach of Endesa currently at hand);
- involved the attackers extracting basic and economic-financial data such as credit card information, in addition to other data that were not compromised in the incident affecting Endesa, such as usernames and passwords of the affected individuals;
- resulted in the data controller receiving up to eighty (80) information requests from the affected individuals, compared to the single request received by Endesa and provided in the context of the File; and
- occurred even with the implementation of security measures.

b. The resolution of the AEPD regarding procedure PS/00118/2020 concluded with the imposition of a warning sanction, considering that "in light of the complexity of the affected information systems, as well as the actions taken to minimize the negative consequences of the aforementioned breach of personal data security of its clients, it is deemed lawful not to impose a sanction consisting of an administrative fine," when in that Data Security Breach:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

110/214

- The notification of the data security breach to the AEPD was made on August 28, 2019, when the investigated entity became aware that its customer information system had been subject to unauthorized access on July 10, 2019 (almost two months later);
- The investigated entity in this case did not provide the AEPD with the risk analysis of the processing for which it is responsible, whereas Endesa did provide it, responding in a timely manner to this Agency on four (4) occasions when it was requested for information; and
- The investigated entity stated that "the machine affected by the security incidents was technically obsolete," and therefore did not have adequate security measures corresponding to the risk posed by the processing.

c. The resolution of the AEPD regarding procedure E/05937/2021 concluded with the imposition of a warning sanction, considering that "no evidence has been found to support the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection," when in said Data Security Breach:

- The notification of the data security breach to the AEPD was made, in accordance with what was indicated by the AEPD in its resolution, "beyond the 72 hours from the moment it was known that it had occurred." In this case, the AEPD indicates that the reasons for such delay have been properly substantiated, as the investigated entity claimed that the notification was delayed "due to the investigations carried out to clarify whether there was data access and/or fraudulent activity, which required multiple analyses by the security teams." This reason could be considered similar to that alleged by Endesa. In this case, however, despite the acknowledgment of the notification period by the entity affected by the incident, the existence of investigations did seem to be sufficient on this occasion to avoid the economic sanction; and
- The investigated entity in this case processes categories of data such as name, identification number, email address, economic and financial data, etc., as it is a credit card issuer. Therefore, the impact of the incident appears to be similar to that suffered by Endesa.

d. The resolution of the AEPD regarding procedure PS/00254/2019 concluded with the imposition of a warning sanction, considering that the investigated entity, having resolved the detected vulnerabilities and improved the security level subsequent to the personal data security breach, "is considered legally

compliant not to impose a sanction consisting of an administrative fine and to replace it with the warning sanction,” when in said Data Security Breach:

- It involved unauthorized access to the personal data of up to 30,000 affected individuals (compared to the 760 individuals affected by the Data Security Breach of Endesa that we are currently addressing); and
- The AEPD considered that, from the investigations carried out, a lack of diligence by the responsible party in implementing security measures was evident.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

111/214

relevant security, even indicating that “the lack of consideration of the risk that unauthorized access by third parties to subscriber data related to a political party may pose, and its subsequent public dissemination, aggravates the culpability and sanctioning reproach of the conduct.”

Considering the above, it surprises ENDESA that the AEPD considers that only the Data Security Breach suffered by Endesa deserves the imposition of a sanction that far exceeds the amount of sanctions imposed to date.

It indicates that it is striking, therefore, the disparity of criteria that the AEPD applies when analyzing the security measures implemented by the entities investigated by the AEPD, as well as the consequences that, in terms of administrative sanctions, arise from the alleged infringements contained in the Initiation Agreement.

Secondly, ENDESA emphasizes how the AEPD, in the Initiation Agreement, applies to it, in relation to all the alleged infringements contained therein, the aggravating factors of:

(i) “serious lack of diligence”: As has been outlined throughout this document, the assessment of this lack of diligence is primarily based on the following factual elements that do not correspond to the qualification attributed to them by the AEPD:

(a) the report on evaluation and management of the security breach prepared by ***EMPRESA.1, when ENDESA expressly contests it for the reasons mentioned throughout this document;

(b) the alleged delay in the implementation of the security measures identified by Endesa prior to the notification of the Data Security Breach, when it has been fully justified, in accordance with what is indicated in this document, based on the complexity of the implementation of the same;

(c) the fact that Endesa did not address Facebook Ireland Limited to demand the removal of the identified ads, when this decision has been justified, it has been proven that Endesa, on the contrary, addressed Facebook Spain multiple times (and through 2 burofaxes) for this purpose and it has been demonstrated that, prior to the sending of the burofaxes, Endesa had already disabled the credentials of the compromised users, so that they could no longer access their accounts in Endesa's systems;

(d) the alleged delay in notifying the Data Security Breach to the AEPD, when Endesa has demonstrated, within the framework of this document, that it proceeded to make the notification within 24 hours from when it became aware that the Data Security Breach could pose a risk to the rights and freedoms of the affected parties (prior to this moment Endesa did not consider that the Data Security Breach was Notifiable);

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

112/214

(e) the fact that Endesa did not identify, on its own, the need to notify the data subjects of the breach and did not provide all the information required by Article 34 of the GDPR, when Endesa has demonstrated, within the framework of this document, that it could not, in any case, derive a high risk for the rights and freedoms of the data subjects from this Data Security Breach, which met one of the assumptions of Article 34 of the GDPR (Article 34.3 b) of the GDPR) to determine that notification was not necessary and that it did provide the data subjects, in a two-layer format, all the information

required by Article 34 of the GDPR; and

(f) the fact that Endesa has not implemented, after more than four (4) years of application of the GDPR, the appropriate safeguards for the execution of international data transfers, when Endesa has demonstrated, within the framework of this document, that it has always done so, providing this Agency with the corresponding Standard Contractual Clauses approved by the European Commission signed with its suppliers located outside the European Economic Area.

(ii) "linking the infringer's activity with the processing of personal data": Considering Endesa's activity (electricity marketing) as an aggravating factor is, in ENDESA's opinion, completely inexplicable, unless the relationship between the activity and the intended aggravation is argued and justified. The activity of electricity marketing implies, of course, that it is accustomed "to the processing of personal data," but that this implies an aggravation when the majority of companies worldwide process data of customers and third parties and carry out an activity that involves being in constant contact with them is difficult to perceive, since, if this were the case, this aggravating circumstance (which should be exceptional) would be applied to the vast majority of cases analyzed by the AEPD, completely distorting the nature of such aggravation (as is happening as a result of the disproportionate application that the AEPD is carrying out of this aggravating circumstance).

Finally, as can be inferred from the Initiation Agreement, ENDESA argues that the AEPD did not consider, when grading the proposed sanctions, the application of all the mitigating circumstances that, in its opinion, exist in the behaviors of Endesa subject to this procedure.

All of this taking into account that, from the very moment Endesa became aware of the incident, the Company put all means at its disposal to: (i) assess the impact of the Security Breach and, subsequently, of the Data Security Violation; (ii) mitigate the effects of the incident; (iii) take appropriate measures to prevent incidents like the one that occurred from happening again in the future; (iv) cooperate with the AEPD by making the appropriate communications and responding to all information requests in a timely manner; and (v) mitigate the minimal effects that the data subjects suffered as a result of the incident.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

113/214

For all these reasons, Endesa considers that, if this Agency understands that it has committed the infringements described in the Initiation Agreement, the following mitigating circumstances would apply to all the alleged infringements:

(i) Measures taken by the controller to mitigate the damages suffered by the data subjects, as provided in Article 83.2 c) of the GDPR.

In this regard, it is necessary to indicate that:

(a) Before Endesa received any claims as a result of the Data Security Violation, the Company proceeded to carry out a follow-up and audit of the contracts made by ***EMPRESA.9, in order to address and resolve, as quickly as possible, any harmful effect that could arise from the Data Security Violation for the data subjects;

(b) Endesa adopted the appropriate technical and organizational protective measures after becoming aware of the Data Security Violation to ensure that no risk materialized for the rights and freedoms of the affected data subjects.

(ii) Cooperation with the supervisory authority, as provided in Article 83.2 f) of the GDPR.

Regarding the mitigating factor related to the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement, it is necessary to indicate that:

(a) Only 24 hours elapsed from the time Endesa became aware that it was a notifiable Data Security Violation and it notified the AEPD; and

(b) Endesa, as has been evidenced and is clear from the File, responded to each and every one of the information requests it received from the AEPD (3 directed to Endesa and 1 directed to its DPO) in a

timely manner, fully cooperating with this Agency.

(iii) Lack of benefits obtained, as provided in Article 76.2 c) of the LOPD-gdd.

Finally, Endesa considers that the mitigating circumstance set forth in Article 76.2 c) of the LOPD-gdd regarding the lack of benefits obtained as a result of the alleged commission of the infringement should apply. This is because at no time has Endesa obtained any economic benefit as a result of the security breach suffered.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
114/214

On the contrary, it has been clearly harmed, as it has seen how third parties outside the organization accessed its systems and the data contained therein for illegitimate purposes.

Among some of the harmful effects that Endesa has suffered as a consequence of the Data Security Breach are: (i) Endesa has had to dedicate significant resources to the evaluation, analysis, and management of the Data Security Breach; and (ii) it has required the implementation, by Endesa, of greater security measures, both technical and organizational, in order to try to prevent an attack of this nature from happening again, with the investment that such implementation entails.

In its opinion, Endesa has not benefited in the slightest from the Data Security Breach but has been, along with the affected parties, the main victim of it. In this regard, Endesa believes that this fact should be considered by the AEPD as a mitigating circumstance regarding the conduct of the signing entity in relation to the grading of the sanction to be imposed for the alleged infringement of Article 32.1 of the GDPR.

Firstly, regarding the alleged disparity of criteria of the AEPD, this Agency wishes to point out that each case is different and must be analyzed according to its own circumstances.

Article 32.1 of the GDPR establishes that "(...) the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk (...)". That is to say, the probability and severity of the risks posed by the processing of personal data in the specific case must be evaluated, for the rights and freedoms of the data subjects, in order to adopt the measures that are appropriate to that specific case.

There is no universal formula for this, nor even a general one, nor does a violation of Article 32 of the GDPR automatically occur in the event of a personal data security breach. It is a matter of analyzing in each case what risks a particular processing could entail for the data subjects and assessing what measures would have been implemented to prevent such a risk from occurring, in order to determine whether such measures would be appropriate for that specific case.

Taking this into account, this Agency decided to archive the proceedings in the aforementioned cases E/008809/2019 and E/05937/2021, since there was no evidence that the measures adopted by the data controllers, before the incident and once it occurred, were not appropriate based on the existing risk in those processes. In the case of ENDESA, this is not the case; the measures adopted beforehand were not appropriate based on the risk to the rights and freedoms of the data subjects, which is why this Agency decided to initiate sanctioning proceedings in order to sanction it for a possible infringement of Article 32 of the GDPR, among others.

Regarding the delay in notifying this Agency of the personal data security breach, in the procedure E/05937/2021, Article 33.1 of the GDPR states that: "(...) If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by an indication of the reasons for the delay."

At C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
115/214

In the cited procedure, the data controller duly indicated the reasons for the delay in notifying the supervisory authority, which is why such article was not considered infringed, contrary to what occurs

with ENDESA in the present procedure, where months passed since the incident should have been reported to this Agency without any justification for such delay, as was reasonably explained in the response to the second allegation in the written submissions regarding the initiation agreement of the present sanctioning procedure.

Regarding procedure PS/00118/2020, the incident (which lasted only three days and affected a maximum of 75,000 interested parties, compared to the ENDESA incident that lasted months and affected millions of interested parties, contrary to ENDESA's claims) was considered such that the degree of reproachability of the actions of the data controller allowed for the imposition of a warning instead of a fine, which is not the case in the present sanctioning procedure against ENDESA. In relation to procedure PS/00254/2019, a similar situation occurs, given that the incident in question did not affect millions of people and the circumstances of the breach differ from the severely negligent actions of ENDESA.

Secondly, regarding the application of aggravating factors, the serious lack of diligence on the part of ENDESA has been evidenced throughout the file not by the report of ***COMPANY.1, but by all the documentation on record, all of which has been detailed in the proven facts and extensively explained in the legal grounds, especially in the response to the allegations made against the initiation agreement.

Regarding the alleged infringement of Article 5.1(f) of the GDPR, ENDESA's conduct has been severely negligent as it took months to reset or delete the compromised users, which allowed access to personal data held in ENDESA's systems for months and enabled fraudulent user registrations. It was also severely negligent in requesting Facebook to remove the relevant ads, as it did not address FACEBOOK IRELAND LIMITED, as it was indicated to be the correct channel.

Regarding the alleged infringement of Article 32 of the GDPR, ENDESA's severely negligent conduct is evident in its behavior before and after the incident occurred, as it had not even anticipated the possibility of misuse of the users of ***TOOL.1 and ***TOOL.2, and thus had not implemented adequate measures to ensure user authentication with the necessary guarantees, preventing unauthorized access to the systems and allowing for proper tracking of these users' activities in those systems.

Compromised users were also not reset or deleted immediately from either ***TOOL.1 or ***TOOL.2; it took months, which allowed for unauthorized access to the personal data processed by ENDESA during that entire time and facilitated a large number of fraudulent registrations. There was also no preventive reset of all users in the systems in the face of a potential threat (which later turned out to be true).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
116/214

Furthermore, despite what was agreed on September 13, 2021, by the Security Gaps Committee and the measure adopted in August 2021 to request the removal of Facebook ads offering access, ENDESA did not follow the guidance provided by FB SPAIN, nor did it contact FACEBOOK IRELAND LIMITED through any of the available means to have the published ads offering access to its systems removed.

Regarding the alleged violation of Article 33 of the GDPR, ENDESA's serious negligence is evident in that it took months to identify the violation of personal data security in question as reportable to the supervisory authority.

And regarding the alleged violation of Article 34 of the GDPR, ENDESA's serious negligence is evident in that it did not properly identify that the incident in question needed to be communicated to the affected individuals. ENDESA did not even communicate the breach to those affected by the potential fraudulent registrations and, furthermore, once this Agency ordered it to issue the corresponding communication, it did not even inform properly.

As for ENDESA's assertion that when it contacted Facebook Spain, the credentials of the compromised users had already been disabled, this is incorrect, as has been addressed in the

response to section b) of the previous allegation in the written submission regarding the initiation agreement of the present sanctioning procedure.

Regarding ENDESA's demonstration that it notified this Agency of the incident within 24 hours of becoming aware that it could pose a risk to the rights and freedoms of the data subjects, this Agency refers to the response to the third allegation in the written submission regarding the initiation agreement of the present sanctioning procedure.

ENDESA has also not demonstrated that this incident could not result in a high risk to the rights and freedoms of the data subjects nor that it had duly provided the data subjects with the information required by Article 34 of the GDPR, as has been addressed in the responses to the second and third allegations in the written submission regarding the initiation agreement of the present sanctioning procedure.

Thirdly, regarding the consideration of the fact that ENDESA's activity is linked to the processing of personal data as an aggravating factor, this Agency wishes to point out that Article 83.2 of the GDPR states that "When deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account: (...) k) any other aggravating or mitigating factor applicable to the circumstances of the case...".

In this regard, the Spanish legislator has considered including in Article 76 of the LOPDGDD that: "2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

(...)

b) The link of the infringer's activity with the processing of personal data."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

117/214

This Agency simply takes into consideration that circumstance, provided by the legislator, when deciding on the imposition of the administrative fine.

It is worth noting that, of course, the same consideration cannot be given for the purpose of deciding the imposition of an administrative fine for an infringement committed by a natural person or a small company unaccustomed to processing personal data, as for a large company like ENDESA, accustomed to processing personal data of millions of customers and non-customers, with a long history in this regard. It is certainly considered that the infringement is more serious for the purposes of imposing a fine if the data controller is among the latter, as is the case with ENDESA. This has been pointed out by the Audiencia Nacional in its SAN 65/2017, of February 7, 2017, when it collected the doctrine of the Supreme Court, "in assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

Fourthly, having reviewed the contracts made by ***EMPRESA.9 to prevent new fraudulent registrations cannot be considered a mitigating factor, as it is an obligation imposed by the regulations. For its part, the fact that certain security measures were adopted a posteriori to mitigate risks has already been assessed as a mitigating factor regarding the alleged infringement of Article 32 of the GDPR.

Fifthly, the mitigating factor related to the degree of cooperation with the supervisory authority is not applicable, since it has already been extensively explained that more than 24 hours (in fact, months) had passed since ENDESA became aware that a data security breach had occurred that was reportable (this Agency refers to the response to the second allegation in the written submissions to the initiation agreement of this sanctioning procedure).

Regarding ENDESA's response to each of the information requests sent by this Agency, it is not considered a mitigating factor since it is an obligation contemplated in the applicable regulations.

In this regard, Article 52 "Duty of cooperation" of the GDPR states: "1. Public Administrations, including

tax and Social Security authorities, and individuals shall be obliged to provide the Spanish Data Protection Agency with the data, reports, background information, and justifications necessary to carry out its investigative activity. (...)"

And Article 72 "Very serious infringements" establishes that: "1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that constitute one of this organic law when it is enforceable are considered very serious and shall prescribe after three years.

(...)

ñ) Failing to provide access to the competent data protection authority's personnel to personal data, information, premises, equipment, and processing means required by the data protection authority for the exercise of its investigative powers. (...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

118/214

Finally, this Agency wishes to point out that the lack of benefits obtained by ENDESA cannot be considered a mitigating factor.

This is in accordance with the Judgment of the National Court, dated 05/05/2021, rec. 1437/2020, which states: "On the other hand, it considers that the non-commission of a previous infringement should be appreciated as a mitigating factor. Well, Article 83.2 of the GDPR establishes that, among other things, the circumstance 'e) any previous infringement committed by the controller or the processor' must be taken into account for the imposition of the administrative fine. The absence of the prerequisite for its application constitutes an aggravating circumstance; therefore, it cannot be taken into consideration, but it does not imply or allow, as the claimant intends, its application as a mitigating factor." Applied to the present sanctioning procedure, the lack of the prerequisite for its application regarding Article 76.2.c) of the LOPDGDD, that is, obtaining benefits as a consequence of the infringement, does not allow its application as a mitigating factor.

This criterion of gradation is established in the LOPDGDD in accordance with the provisions of Article 83.2.k) of the GDPR, according to which administrative fines will be imposed taking into account any "aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement," understanding that avoiding a loss has the same nature for these purposes as obtaining benefits.

If it is added that the sanctions must be "effective, proportionate, and dissuasive in each individual case," as provided in Article 83.1 of the GDPR, admitting the absence of benefits as a mitigating factor is not only contrary to the factual prerequisites contemplated in Article 76.2.c), but also contrary to what is established in Article 83.2.k) of the GDPR and to the indicated principles.

Thus, valuing the absence of benefits as a mitigating factor would nullify the dissuasive effect of the fine, as it diminishes the effect of the circumstances that effectively impact its quantification, providing the responsible party with a benefit to which they are not entitled. It would be an artificial reduction of the sanction that could lead to the understanding that infringing the regulation without obtaining benefits, financial or otherwise, would not produce a negative effect proportional to the seriousness of the infringing act.

In any case, the administrative fines established in the GDPR, in accordance with what is provided in its Article 83.2, are imposed based on the circumstances of each individual case, and it is not considered that the absence of benefits is an appropriate and determining factor for assessing the seriousness of the infringing conduct.

For all the above reasons, this allegation is dismissed.

Allegations to the proposed resolution of the sanctioning procedure

In relation to the allegations made regarding the proposed resolution of the present sanctioning procedure, responses are provided in the order presented by ENDESA:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

Preliminary.- Specification of certain essential factual points for the legal analysis of the file ENDESA reiterates that in the aforementioned resolution proposal, this Agency has identified issues that, while highly relevant for the assessment of ENDESA's conduct, have not been interpreted correctly by the AEPD.

(a) The importance that both the incident and the protection of personal data have had and continue to have for Endesa

It is alleged that the incident and data security breach suffered by Endesa, which resulted in its notification to the AEPD, was addressed from the very beginning with the utmost rigor and seriousness, and received maximum attention in all analyses conducted. Information security is a matter of vital importance for Endesa.

Although the Resolution Proposal refers to a "scandalous lack of diligence" on the part of Endesa in managing and implementing remediation measures for the data security breach, and despite the fact that the instructing body of the file continues to apply the aggravating factor of "serious lack of diligence" to the proposed sanctions, the control of its customers' data is, for Endesa, a fundamentally strategic issue to which it dedicates a huge amount of economic and human resources.

The importance and seriousness with which the incident was addressed is reflected not only in the notification of the security breach to the AEPD and in the collaboration that Endesa has provided to the AEPD since the beginning of the file, but also in the investigation, containment, and remediation measures that were deployed at the time.

To undervalue these efforts and measures, as the Resolution Proposal does in this party's opinion, merely because the AEPD does not share the completely reasonable interpretation that Endesa has made of the applicable data protection regulations, undermines the principle of responsibility that should govern the administrative sanctioning procedure.

In this regard, it is an essential requirement, as established by jurisprudence, that the subjective element of culpability is present in Endesa's conduct, whether in terms of intent (dolo) or negligence (imprudencia). What is neither appropriate nor acceptable is to impose sanctions without any culpability being present, based solely on objective responsibility, as the Sanctioning Resolution does in some points that will be discussed later.

Additionally, it is noted that, within the framework of a sanctioning file such as the one at hand, a rigorous and objective legal analysis regarding the notification obligation, the legal qualification of certain security measures implemented before and after the incident, and the facts, must be conducted prior to the proposal for imposing economic sanctions as substantial as those that the AEPD proposes to impose on Endesa, to determine whether or not they constitute an administrative infringement of non-compliance with the GDPR, which is not an automatic consequence of an incident.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

120/214

ENDESA has consistently sought to argue with legal rigor and objectivity regarding all of the above, and therefore understands that it is not appropriate to trivialize this aspect and confuse what constitutes legitimate legal defense in a proceeding such as the present one with the importance or seriousness that the entity assigns to the underlying facts, which, as stated, is maximal.

In this regard, this Agency wishes to point out that it does not question that the security of information is an important matter for ENDESA. It is simply that, in the present case, this Agency considers that ENDESA has not acted with the due diligence that it should have.

This Agency does not undervalue the efforts made by ENDESA, but the fact of notifying the data security breach to the AEPD, as well as responding to the information requests sent by this Agency and the measures of "investigation, containment, and remediation" adopted by ENDESA, are merely obligations imposed on ENDESA by the applicable regulations on the processing of personal data and

not a reflection of "the importance and seriousness with which the incident was addressed." Regarding the assertion that this Agency intends to sanction ENDESA based solely on objective liability, such a statement can only be rejected. The existence of the requirement of the subjective element of the infringement has been duly evidenced in the file, as well as in the response to ENDESA's allegations regarding the initiation agreement of the present sanctioning procedure, and will be detailed in the response to the present allegations as well as in the legal grounds of this resolution. This Agency also wishes to point out that, of course, in the present case, it conducted a rigorous and objective legal analysis regarding the notification obligation, the legal qualification of certain security measures implemented before and after the incident, and the facts, to determine whether they constitute an administrative infringement of non-compliance with the GDPR. Finally, this Agency emphasizes that it has never trivialized the present issue nor diminished the importance or seriousness of the underlying facts, which is maximal. For the reasons stated, the present allegation is dismissed.

(a)

(b) Regarding the express challenge of the entire evaluation and management report of the security breach prepared by ***EMPRESA.1 (****EMPRESA.1):

ENDESA reiterates its challenge of the report provided by the entity ***EMPRESA.1, as it considers that this report cannot be taken into consideration for the purposes of the present sanctioning file. It indicates that it is not an expert report, nor a legal or technical report, nor objective, but rather a partial report (in the sense of a report from an interested party), since ***EMPRESA.1 was involved in the incident itself and, in fact, it was partly caused by its failure to control and supervise compliance.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

121/214

... compliance by ***EMPRESA.9 (****EMPRESA.9) with the instructions of Endesa and its obligations as a data processing sub-contractor. In fact, ***EMPRESA.1 never proved that this report existed or was shared with Endesa on the date it was supposedly signed, and, in hindsight, it is clearly (in its opinion) a "defensive" report prepared by an entity that needs to protect its interests against potential liability claims, having acted as the data processor for Endesa and potentially bearing some degree of responsibility for the events that ultimately led to the present proceedings.

Therefore, although in the Resolution Proposal the AEPD indicates that its conclusions are based "not only on the report prepared by ***EMPRESA.1 on November 4, 2021, but on all the information it has become aware of throughout (sic) the present proceedings," it again mentions this report (challenged by ENDESA) in the thirty-first background (pages 38 to 40), including it as part of the file, and uses it again to support (barely without any other objective basis) its thesis that one of the consequences of the incident could be the supply cut ("quod non" since not only the rapid action of Endesa but also the existing processes in accordance with sector regulations determine the impossibility of a supply cut in the terms that ***EMPRESA.1 surprisingly indicates and which the AEPD uncritically and unfoundedly accepts).

Finally, Endesa wishes to clarify that the purpose of this allegation is not to have the AEPD judge the actions of ***EMPRESA.1 nor to reproach ***EMPRESA.1's own actions as the Resolution Proposal seems to indicate at the beginning of page 67 and on page 78 (who must do so, if deemed necessary, is the AEPD itself), but rather: (i) to expose the partiality and lack of rigor of a document in the file on which the AEPD, as has been evidenced, relies to reinforce or justify the imposition of the proposed sanctions on Endesa; and (ii) to challenge the entirety of its content.

In this regard, first of all, this Agency wishes to point out that it is indeed up to the AEPD to assess whether the actions of ***EMPRESA.1 were in accordance with personal data protection regulations. And that the interpretation made by ENDESA regarding the actions of ***EMPRESA.1 and the meaning of what the AEPD has stated in the resolution proposal is merely an interpretation.

Secondly, this Agency wishes to clarify that the aforementioned report is mentioned in the background since, within the framework of the preliminary actions carried out by this Agency to determine the

existence of a possible infringement of personal data protection regulations by ENDESA concerning the incident subject to the present proceedings, information was requested from ***EMPRESA.1, which was duly provided to this Agency. That is why this report is part of the file, as it was one of the actions taken by this Agency in the context of the investigation that led to the present sanctioning procedure.

The fact that the aforementioned report was shared by ***EMPRESA.1 with ENDESA is irrelevant for these purposes. ENDESA's assessment of the report in question, regarding its impartiality and vested interest, does not alter the conclusions of this Agency, which are not based exclusively on the aforementioned report.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
122/214

Thus, the possibility that this Agency has taken into account of a supply cut due to non-payment when carrying out a fraudulent registration is not a conclusion that this Agency would not have reached had it not been for the report from ***COMPANY.1. It is not that such a cut would be immediate, but it is a more than evident possibility, and any analysis would have concluded that such a situation could have arisen if the invoices for the supplies fraudulently registered were not paid.

For the reasons stated, this allegation is dismissed.

(c) Interactions with Facebook to request the removal of advertisements through which the sale/rental of access credentials to the Endesa systems was offered:

ENDESA alleges that, in accordance with the Proposal for Resolution, the fact that Endesa did not send any communication to Facebook Ireland "constitutes a serious negligence on the part of ENDESA." Furthermore, the AEPD reiterates throughout the Proposal for Resolution that the fact that Endesa did not address Facebook Ireland by any of the means offered for it to remove the advertisements through which access to the Endesa systems was offered constitutes a "seriously negligent" action that even deserves an aggravating circumstance.

ENDESA is surprised that the AEPD uses this decision of Endesa, made consciously and in a totally reasoned manner (in its opinion), to try to justify that Endesa's actions have been seriously negligent. This is for two main reasons:

i) The decision was made consciously and reasonably by Endesa, for reasons unrelated to those presented by the AEPD in the Proposal for Resolution. That is to say, although the AEPD uses the Proposal for Resolution to present an analysis of the role played, from a data protection perspective, by Facebook Spain and Facebook Ireland regarding the data they process, concluding that Facebook Ireland would be responsible for the processing of personal data at the European level, the truth is that: (a) at no time has Endesa denied this fact nor does it intend to decide who is responsible for the processing (as implied by the Proposal for Resolution on page 69); and (b) in no case has Endesa considered filing a data protection complaint against Facebook, so the analysis carried out by the AEPD in the Proposal for Resolution is completely irrelevant to the adjudication of this case.

In this regard, when Endesa indicated in its written allegations to the Initiation Agreement that it did not wish to recognize "Irish jurisdiction, which would imply, if necessary, having to direct any claim before the Irish courts, which was and is an inappropriate and unfair burden," it was not made for data protection purposes, but for the purpose of a possible judicial or administrative claim against Facebook for the possible commission of an infringement or crime of disclosure of secrets or intellectual property.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
123/214

Notwithstanding that, as previously indicated, the analysis regarding who would hold the role of data controller concerning the data processed by Facebook (Facebook Ireland or Facebook Spain) made

by the AEPD in the Proposal for Resolution should not be taken into account for the purpose of assessing Endesa's conduct, since such analysis is entirely irrelevant to the decision made by Endesa at the time and, therefore, it cannot be blamed for conducting such analysis incorrectly, it is surprising that the AEPD even suggests that such analysis should be carried out by Endesa.

It appears that the AEPD, in a matter as extremely complex and one that has been the subject of numerous jurisprudential debates both at the national and European levels, such as the determination of who acts as the data controller for the personal data that Facebook collects at the European level, blames Endesa for not having conducted the corresponding analysis when requiring its execution would be a completely disproportionate and unfair burden.

ii)

The removal of Facebook ads, as already stated in the allegations to the Initiation Agreement, had no practical utility regarding the protection of the rights and freedoms of the affected data subjects, since the credentials of ***HERRAMIENTA.2 and ***HERRAMIENTA.1 compromised, except for one, had already been disabled (as will be explained in the first allegation below). After this disabling, the possibility of accessing the data for which Endesa is responsible stored in its tools would disappear (even if the original credentials are sold/rented), so the effect of the disappearance of the Facebook ads on the rights and freedoms of the affected data subjects would be null.

In this regard, Endesa believes that it cannot be blamed for a serious lack of diligence from the perspective of data protection merely for not addressing Facebook Ireland to demand the removal of the ads, since their removal would not have had (in its opinion) any effect on the data subjects affected by the data security breach.

In summary, Endesa considers that the AEPD bases a large part of its argumentation on the alleged lack of diligence of Endesa on an aspect of the incident that, had it been carried out as the AEPD proposes, would not have provided any additional benefit for the rights and freedoms of the data subjects.

First of all, this Agency wishes to point out that it is only competent to assess whether ENDESA complied with the regulations on personal data protection. Not to assess issues related to intellectual property. In this sense, in the present case, a series of ads had been published offering access to ENDESA's systems, which allowed access to personal data owned by ENDESA, which it processed in its capacity as data controller. And as such, it should have adopted a series of measures, among others, that such ads be removed, as decided in August 2021, due to the risks they posed. However, Endesa did not approach Facebook Ireland. It should be noted that at that time multifactor authentication was not enabled, which was not adopted until April 2022.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

124/214

Secondly, it is not intended at any time for ENDESA to conduct any analysis regarding Facebook's role as a data controller, given that the data subject to the incident in question belongs to ENDESA.

Furthermore, it is worth noting that it is Facebook Spain itself that indicates that this matter falls under the jurisdiction of Facebook Ireland.

It was simply a matter of removing the published ads, which should have been requested from Facebook Ireland, a step that was not even attempted at any time.

Thirdly, ENDESA is accused of gross negligence in its conduct, but not solely for failing to contact Facebook Ireland, which has been extensively explained in the response to the allegations regarding the initiation of the current proceedings and detailed in the legal grounds of this resolution.

Finally, regarding the irrelevance of the continued publication of the aforementioned ads, this Agency would agree if it were not for the fact that ENDESA did not deactivate the compromised users until more than a month had passed and because it also did not have certainty that the compromised users were only those it was aware of (as previously indicated, multifactor authentication or another equivalent measure was not enabled, making Facebook's assistance necessary to remove the ads in question).

For all the above reasons, this allegation is dismissed.

First.- On the impropriety of the sanction imposed for the alleged infringement of articles 5.1. f) and 32 of the GDPR

1. On the implementation of security measures appropriate to the risk

The AEPD, in the Proposal for Resolution, attributes to Endesa a delay in resetting or disabling certain users when, according to the information provided in the case file, Endesa was already aware that they had been compromised.

However, ENDESA argues that this is not the case. And it is not the case because:

(i)

In ENDESA's opinion, it has been demonstrated that many of the compromised user accounts were disabled almost immediately after becoming aware that these users may have been compromised. As merely an example and referring to the section of "Proven Facts" in the Proposal for Resolution, it is verified that:

a

(a) On September 1, 2021, ***COMPANY.16 informs Endesa that it has recognized one of the individuals who published an ad on Facebook through which access credentials to ***TOOL.1 are offered, and Endesa, just 2 days later, on September 3, proceeds to disable said user "***USER.3";

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
125/214

b

(b) On September 10, 2021, Endesa sent an email to ***COMPANY.15 informing them that it had identified an employee as a suspected user who was posting advertisements on Facebook, and on the same day, proceeded to disable said user "***USER.8", as well as to remove them from the systems of ***TOOL.2; and

c

(c) On September 21, 2021, Endesa received an email informing them of the identification of one of the individuals who was selling Endesa credentials on the Internet, and on the same day, Endesa proceeded to disable said user "***USER.5".

Regarding points (a) and (c) above, and although the AEPD indicates that these users were not removed from ***TOOL.2 until January 12, 2022, ENDESA reiterates, as stated in its written allegations to the Initiation Agreement, that once the account of each user is disabled or reset, they cannot access it or use it for any purpose, being permanently expelled from the system, so that although the account has not been deleted, the user is prevented from accessing it.

The same applies to the date of last access. The fact that the date of last access is later than the date of disabling or resetting the user does not mean that the person whose user has been reset has accessed Endesa's systems again; rather, it may respond to possible accesses to the user by Endesa's own teams that are investigating the incident or by new sales representatives to whom that user has been assigned.

In this regard, this Agency wishes to point out that, in the information provided to this Agency and which is part of the file, the date on which the compromised users of ***TOOL.2 were disabled or reset is not recorded, but rather the date on which they were removed from the system.

As indicated in section 2 of Article 5 "Principles relating to processing" of the GDPR, "The data controller shall be responsible for compliance with the provisions of paragraph 1 and shall be able to demonstrate it ('proactive responsibility')." Based on this principle, ENDESA should have been able to prove, throughout the more than 9 months that the preliminary investigation proceedings lasted and the nearly 9 months of the current sanctioning procedure, the date on which the compromised users of ***TOOL.2 had been disabled or reset (as was done regarding the users of ***TOOL.1), and not simply provide the date on which such users were removed from the system. Therefore, this Agency is unaware whether the compromised users of ***TOOL.1 and ***TOOL.2 were disabled at the same time, a matter that is not evidenced.

In any case, this Agency considers that ENDESA's actions in disabling and removing the compromised users (both from ***TOOL.2 and ***TOOL.1) have been negligent, as will be detailed further on. Regarding the date of last access to the systems, it is true that it cannot be determined who accessed the systems on that date provided to this Agency. However, this only reinforces the existence of the infringement.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
126/214

of Article 32 of the GDPR, since it is not possible to know who last accessed the systems, due to the improper configuration of a logging system that would allow this information to be reliably known, and the existing system allowed multiple sessions to be initiated simultaneously, all of which is the subject of this sanctioning procedure.

(i)

ENDESA alleges that, in relation to the users reported by ***EMPRESA.1 to Endesa as fraudulent on October 27, 2021 (***USUARIO.13, ***USUARIO.14, ***USUARIO.15, ***USUARIO.16, and ***USUARIO.9), Endesa has verified, after reviewing all actions taken in the context of the incident, that the first reset of these users actually occurred on November 29, 2021. Attached as Document number 1 is the email sent by the Endesa team to ***EMPRESA.18 (...) requesting, on November 29, 2021, the urgent reset of these users.

As can be seen, on that same day, November 29, 2021, ***EMPRESA.18 confirms to Endesa that the users have been successfully reset, attaching proof of this. Due to the fact that this reset, as demonstrated, was not carried out directly by Endesa but was requested from ***EMPRESA.18, it did not appear in the information provided to the AEPD in the context of this file.

Therefore, contrary to what the AEPD indicates in its Proposal for Resolution, Endesa did not need "FIVE MONTHS (sic)" to reset or disable the compromised users after the communication from ***EMPRESA.1, but rather carried out this reset within a period of 1 month, which was necessary to conduct the corresponding internal analyses regarding the veracity of the information provided by ***EMPRESA.1.

Going into detail about each of the assertions made by the AEPD regarding these users, Endesa wishes to clarify the following:

(a)

User

***USUARIO.13: This user was, as indicated in the Proposal for Resolution, initially reset by Endesa on September 3, 2021 (let us remember, only 2 days after ***EMPRESA.16 informed Endesa that it could be compromised). Following this reset, the user was assigned to another commercial agent of ***EMPRESA.16, who used this same user for fraudulent contracts in October 2021, being reset again, as has been evidenced, on November 29, 2021.

That is to say, contrary to what the Proposal for Resolution indicates, it is not that the initial reset of the user carried out in September 2021 was of little use, but rather that this same user was used by a new employee of ***EMPRESA.16 to carry out fraudulent contracts in October 2021. It is also not true that Endesa did not reset the user again until August 24, 2022, but rather, as has been evidenced, it did so on November 29, 2021.

Once again, it is important to clarify, regarding the deletion of users in ***HERRAMIENTA.2, that this did not occur at the time of the user's reset, but rather months later in order to avoid orphaned records and loss.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
127/214

of critical commercial information, without this implying that the user can re-access the platform as seems to be inferred from the Proposal for Resolution.

(b)

User

***USER.15: This user is in the same situation as ***USER.13 mentioned earlier. That is to say, the first reset occurred on September 21, 2021, and was subsequently used by a new salesperson for fraudulent contracting. After the discovery of these, a new reset was carried out on November 29, 2021. ENDESA also reiterates in this case what was previously indicated regarding the deletion of users in ***TOOL.2.

(c)

Users

***USER.14, ***USER.16, and ***USER.9

: As has been evidenced, these users were reset for the first time on November 29, 2021 (and not on August 24, 2022, as indicated in the Proposal for Resolution), one month after ***COMPANY.1 informed Endesa that fraudulent contracts could be taking place through these users. As previously indicated, this was the necessary timeframe to verify the truth of the information provided by ***COMPANY.1 and to proceed with the reset of the identified users.

The above serves to demonstrate (in the opinion of ENDESA), additionally, that, as Endesa previously indicated, all affected users except one ("***USER.1") had been disabled by Endesa prior to the sending of the first burofax addressed to Facebook Spain and that, therefore, sending a new request to Facebook Ireland, in addition to being contrary to the interests of Endesa as stated in the previous allegation, lacked practical utility regarding the protection of the rights and freedoms of the affected parties.

It is evident from the above that the opinion of the AEPD regarding the "scandalous lack of diligence" of Endesa is, said with the utmost respect and in strict terms of defense, unfounded, as it is not supported, as has been evidenced, by the facts that took place within the framework of this incident. As demonstrated in this allegation, the majority of users were reset or disabled almost immediately (the same day or a few days after being identified) and the rest one month after ***COMPANY.1 informed Endesa that they could be used for fraudulent contracting. These actions taken by Endesa, therefore, are undoubtedly diligent, directly contradicting the interpretation made of them, erroneously (in the opinion of this party and said with all due respect), by the AEPD (the Proposal for Resolution mentions delays of 4 and 5 months in the resetting of users when it has been demonstrated that this is not the case).

In this regard, this Agency wishes to point out that the fact that the lack of diligence of ENDESA in managing the incident in question is not classified as "scandalous" in light of the new information provided along with the allegations to the proposal for resolution of this sanctioning procedure does not imply that ENDESA's actions were sufficiently diligent according to the applicable regulations. Quite the contrary. In the best of cases, ENDESA itself...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

128/214

It took ONE MONTH to perform such a simple action as resetting the users that its own provider indicated had been compromised (to the point that a police report was even submitted along with the aforementioned emails). Even if it took a month to conduct the necessary investigations to verify the truthfulness of the information provided by ***COMPANY.1, this Agency considers that ENDESA should have acted with the utmost diligence, taking into account the volume of personal data being processed as well as its characteristics, especially when it had already been decided in the first meeting of the Breach Committee on September 13, 2021, to reset the users that were compromised and a series of vulnerabilities had been detected, for which it was proposed (...), among others.

Therefore, being aware of this situation, ENDESA should have reset the users that ***COMPANY.1 had informed it were compromised as soon as possible, instead of waiting an entire month to do so, a behavior that entails a serious lack of diligence.

Regarding ENDESA's sending of the burofax to Facebook Ireland requesting the removal of advertisements selling credentials to access ENDESA's systems, ENDESA itself acknowledges that not all compromised users had been reset, but that at least one remained unreset, of which ENDESA was aware. And here lies the crux of the matter. The fact that ENDESA knew that a certain number of users had been compromised and that it was through the sale of credentials on Facebook via advertisements published on that social network did not ensure that those users were ALL the compromised users. In other words, ENDESA was unaware if there were more compromised users than those communicated by ***COMPANY.1 and those it had learned about on its own. Therefore, this Agency considers that ENDESA should have made every effort within its reach to request the removal of these advertisements and to contact Facebook Ireland if necessary, as Facebook Spain had indicated. And this should have been done as soon as it became aware, and not waited several months, until February of the following year, to do so.

ENDESA additionally claims, apart from the above, and although the AEPD avoids mentioning it in the Proposal for Resolution (which clearly causes defenselessness to Endesa), some of the conclusions reached in the expert report dated June 23, 2023, submitted to this File, which perfectly align with what Endesa alleges in this document and demonstrate the utmost diligence with which Endesa acted. The report, prepared by an impartial third party with extensive knowledge of the state of technology and security measures applicable in the industry (unlike the report submitted by ***COMPANY.1, which the AEPD, as indicated, seems to give so much credibility to and which this party contests), concludes that:

(i) For a large part of the incident, ***TOOL.1 had "a comprehensive event collection system that allows for a detailed trace of the data accessed by the user, and even at times which elements of the interface have been selected," which allowed Endesa to have greater control over the users and the actions they performed on the platform;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

129/214

(ii) "According to the evidence [Capturas_Borrado***HERRAMIENTA.1], users were deactivated as soon as it was detected that they could be compromised" (the underlining is ours);

(iii) "...the management of the incident up to its categorization as a data breach has been correct" (the underlining is ours);

(iv) "The implementation of multifactor authentication (MFA) has been correctly completed in ***HERRAMIENTA.2 and ***PLATAFORMA.1, as well as in other ENDESA applications that manage user data (such as ***USUARIO.17), preventing unauthorized users from accessing these systems" (the underlining is ours); and

(v) "User management is correct and systematic; user terminations are managed in a timely manner. It has been verified that the users identified during the incident management have been deactivated and that, from that moment on, it was not possible to use these users to access the applications, even though the announcements published remained active on social media" (the underlining is ours).

It is surprising to see how the Resolution Proposal completely omits the previous conclusions, which demonstrate Endesa's good practices in incident management and the utmost diligence displayed by this party. In fact, the report itself concludes that: (a) "the immediate deactivation of the compromised users whose sale was announced in the FB publications for access to ***HERRAMIENTA.1 and/or ***HERRAMIENTA.2 means that, from that moment on, it was impossible to access the systems even though the FB announcements remained active" (the underlining is ours); (b) "the implementation of the multifactor authentication system is an additional security measure that prevents possible unauthorized access to ***HERRAMIENTA.1 and/or ***HERRAMIENTA.2"; and (iii) that the previous

measures "are sufficient to prevent similar violations reported to the AEPD by ENDESA (without assessing the unlawful conduct that may be carried out by third parties acting in bad faith)" (the underlining is ours).

As can be seen, the previous conclusions reflected in the expert report demonstrate, once again, how precise and truthful the allegations made by this party regarding the implementation of security measures are within the framework of this file. This is why it surprises Endesa that the AEPD, after requesting the submission of said forensic report, not only does not echo the conclusions of the same in the Resolution Proposal but also contradicts them in such a flagrant manner, maintaining the proposal for the imposition of a totally disproportionate sanction of 1,500,000 euros.

Firstly, this Agency wishes to point out that ENDESA has not been left defenseless at any time. This Agency simply limits itself to highlighting the sections of the expert report in question that are pertinent to the purposes of this resolution.

Regarding ENDESA's observation on the report of ***EMPRESA.1, this Agency refers to what has already been previously answered.

Regarding the sections that ENDESA has highlighted:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
130/214

(i) As has been demonstrated throughout this procedure, the ***TOOL.1 system did not have an event collection system that would allow for sufficient knowledge of the actions performed by the various users. In fact, already in the first gap committee in September 2021, it was proposed to expand the system logs to improve this aspect. Furthermore, the fact that multiple active sessions were allowed simultaneously and the lack of multi-factor authentication specifically hindered the ability to track which person behind each user was performing certain actions.

(ii) Regarding the claim that users were deactivated as soon as it was detected that they were compromised, it has been established that this was not the case. ENDESA itself acknowledges that it took more than a month to reset the users that ***COMPANY.1 had reported as compromised. Additionally, the user ***USER.1 was only reset on February 15, 2022.

(iii) As for the management of the incident until its categorization as a data breach being correct, this Agency limits itself to verifying whether ENDESA's actions have been diligent concerning the adoption of appropriate security measures in data protection, which has not occurred in this case.

(iv) This Agency does not dispute that multi-factor authentication was implemented after the incident in question; rather, it considers that it was a necessary measure that should have been adopted by ENDESA much earlier to prevent incidents like the one that is the subject of this procedure.

(v) It is also not disputed that once users were deactivated, they could not access the applications. What this Agency considers is that the users should have been deactivated more swiftly.

ENDESA believes that it cannot be concluded, as the Proposal for Resolution does, that the measures taken by Endesa prior to the security breach were in violation of the GDPR (evidence that such a claim is incorrect is that these measures have been in place for years with full effectiveness), nor that the security measures implemented after the incident were ineffective in minimizing the impact that the incident had on the rights and freedoms of the affected data subjects and in preventing a recurrence of an incident like the one Endesa suffered. From a teleological perspective, if the security measures implemented by Endesa prior to the incident were sufficient, for 5 years in the case of ***TOOL.1 and almost 3 years in the case of ***TOOL.2, to prevent a data security breach, the fact that a breach occurred subsequently does not imply, given that the guarantee of the integrity of the measures does not exist and that zero risk does not exist, that the measures were insufficient. In this regard, this Agency wishes to point out that it is aware that zero risk does not exist and wants to clarify that it is not making a teleological interpretation. It must be taken into account that security measures should be adopted based on the state of the art, the costs of implementation, and the nature, scope, context, and

purposes of the processing. These circumstances vary over time, especially in the current moment.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
131/214

in which the evolution of information technologies poses new challenges for security, thus the threats and risks to the rights and freedoms of the interested parties are not the same as they were five years ago; therefore, it is necessary for the responsible party to evaluate the new risks and apply measures to mitigate them.

In this case, there was no multifactor authentication, it was possible that multiple sessions were open simultaneously, it was not possible to control access to ENDESA's systems nor to trace activity through logs. Therefore, it cannot be asserted that the measures adopted by Endesa were adequate to prevent unauthorized access, taking into account, among other circumstances, the amount of data processed, the number of individuals affected by the processing, the involvement of data processors in the processing, and even the technological context.

Furthermore, regarding the measures related to access security, as noted in the procedure, Endesa had implemented a measure based on passwords. However, it did not implement a complementary authentication system until April 2022, despite the fact that on September 13, 2021, the Security Breaches Committee, after verifying the truthfulness of the announcement published on Facebook, proposed the establishment of a multifactor authentication system, and despite the publication of new announcements on Facebook.

If ENDESA had adopted appropriate measures to reduce the impact or prevent the risk from materializing, there would be no infringement on its part. Moreover, if ENDESA had implemented the measures that it put in place as a result of the violation of the personal data security in question, it is likely that this violation would not have occurred and the infringement might not have existed. But this was not the case, which is why the present sanctioning procedure was initiated. Furthermore, the fact that 3 or 5 years had passed without a violation of personal data security does not imply that the measures were appropriate, but simply that there had been no unauthorized access, which is a very different matter.

For all the above reasons, this allegation is dismissed.

2. The eventual imposition of two sanctions for the alleged infringement of articles 5.1.f) and 32 of the GDPR would be contrary to law due to a violation of the principle of non bis in idem or, where applicable, of the rules applicable in cases of conflicts of punitive norms.

2.1.- Presentation

The notified Proposal for Resolution maintains the simultaneous imputation to Endesa of the infringement of article 5.1.f) of the GDPR and that of its article 32, and proposes the imposition of a sanction amounting, in total, to 4,000,000 euros.

ENDESA argues that these provisions enshrine, on the one hand, the principle of integrity and confidentiality, which translates into the obligation to process data "in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
132/214

accidental damage, through the application of appropriate technical or organizational measures" [Article 5.1.f) of the GDPR], and, on the other hand, the obligation to adopt "appropriate technical and organizational measures" to ensure, among other things, "an adequate level of security" (Article 32 of the GDPR).

ENDESA believes that what has been alleged up to this point, combined with the evidence provided in

the file, duly demonstrates that the technical and organizational measures in place at Endesa at the time of the incident that gives rise to this procedure complied with the provisions of Article 32 of the GDPR. It is not acceptable to require that they be infallible, which is what (in its opinion) the Proposal for Resolution seeks to justify in maintaining the accusation made against this provision.

In this regard, this Agency wishes to point out that it is not intended that the security measures adopted to protect personal data be infallible, but rather that they be appropriate based on the risk to the rights and freedoms of the data subjects, which has not occurred in the present case.

Notwithstanding the above, ENDESA argues that, even assuming for purely argumentative purposes that a violation of Article 32 of the GDPR occurred, it would not be appropriate to not only sanction Endesa for the same but also to impose an additional sanction for the alleged violation of Article 5.1.f) of that regulation. To put it graphically: it would not be appropriate to impose a sanction for supposedly lacking adequate measures to ensure data security and, in addition, for not having effectively guaranteed that security.

Otherwise, it understands that two sanctions would be imposed for facts that in this specific case are so intimately connected that it can be stated that both refer to the same issue. Moreover, those sanctions would be imposed based on two punitive norms that aim to protect the same legal good, namely, the guarantee of data security.

Contrary to what the Proposal for Resolution states regarding the idea that both provisions pursue different aims (a statement that, in its opinion, is made without the slightest argumentative support), ENDESA argues that, if the GDPR is examined, it is easily concluded that it always follows the dynamic that all principles related to data processing contained in Article 5 of the GDPR are subsequently concretized in the obligations specifically imposed on the data controller and the data processor, so that, with regard to security, the principle embodied in paragraph 1.f) of that Article 5 materializes in the obligations established in Article 32 to ensure an adequate level of security relative to the risk.

ENDESA asserts that the legal good protected by both provisions is, in summary, exactly the same. And that there is nothing in Article 5.1.f) that is not intended to be protected by the obligations imposed on the data controller and the data processor in Article 32.

Precisely for this reason, ENDESA maintains that, in the event that both proposed sanctions are imposed, the sanctioning resolution would directly violate the principle of non bis in idem.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

133/214

in idem, which would determine its nullity by full right due to the violation of the fundamental right to sanctioning legality enshrined in Article 25 of the Constitution.

All of this was extensively presented in the allegations against the Initiation Agreement, which are hereby reproduced for greater specificity, in which it was also noted that, even if there were doubts about whether the triple identity of subject, fact, and basis required for the application of the aforementioned principle is met, what is evident to ENDESA is that at a minimum we would be facing a concurrence of punitive norms that must necessarily be resolved according to the normative and jurisprudential rules established for this purpose, which would never lead to the imposition of two independent sanctions.

And it argues that none of the reasons put forward in the Proposal for Resolution to reject these allegations is correct from a legal perspective nor, therefore, allows for the maintenance of the intended double punitive sanction that has been referenced.

In this regard, this Agency wishes to point out that it could not disagree more with the analysis carried out by ENDESA regarding the principle embodied in Article 5.1.f) of the GDPR materializing in the obligations of Article 32 of the GDPR.

If this were the case, the violations of these articles would not be classified as different violations.

Regarding the classification of these violations, it should be clarified, beforehand, that the confidentiality and security of data are fundamentally reflected in two independent provisions of the

GDPR: in Article 5.1.f) and in Article 32 of the GDPR.

Article 5.1.f) of the GDPR is one of the principles related to processing. The principles related to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with intense expansive force; on the other hand, having a high level of specificity, they are mandatory norms that can be infringed.

Well, Article 5.1.f) of the GDPR encompasses the principle of integrity and confidentiality and determines that personal data shall be processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures.

There are multiple technical or organizational measures that are not security measures and that the data controller can implement as a means to guarantee this principle.

For example, raising awareness among employees of a data controller regarding what it means and implies for the rights and freedoms of the data subjects to guarantee the fundamental right to the Protection of Personal Data is not a security measure. It is a compliance management measure that clearly contributes to the guarantee of confidentiality.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

134/214

Linking the guarantee of confidentiality and integrity solely to security measures is a simplistic understanding of what the GDPR imposes and means. This is because it reduces it to security measures, when security measures constitute the last link in the chain, before starting anew.

Of course, the appropriate technical or organizational measures referred to in Article 5.1(f) of the GDPR can be security measures, but not exclusively.

On the other hand, Article 32 of the GDPR regulates how the security of processing should be articulated in relation to the specific security measures that must be implemented, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probabilities and severity of risks to the rights and freedoms of natural persons. The data controller and the processor shall apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which includes, among other issues, but not limited to, the ability to ensure the confidentiality of the data.

As can be seen, this provision, Article 32 of the GDPR, although related to Article 5.1(f) of the GDPR, like many of the articles of the GDPR that are also related, does not encompass the principle in its entirety. Article 5.1(f) of the GDPR explicitly requires that confidentiality be guaranteed and requires a loss of confidentiality for its application. There may be cases where there are inappropriate technical and organizational security measures without a loss of integrity and confidentiality. But the opposite can also occur, with appropriate technical and organizational security measures, and a loss of integrity and confidentiality of personal data having taken place.

In fact, the violation of any of these provisions is classified independently and autonomously in different sections of Article 83 of the GDPR, so the simultaneous violation of both provisions, as occurs in this case, is possible and something anticipated by the legislator, without the violation of one preventing the violation of the other, which does not in itself constitute a breach of the principle of non bis in idem. Furthermore, one of them, Article 5.1(f) of the GDPR, provides for administrative fines of up to 20 million euros, which is reduced to half in the case of Article 32 of the GDPR.

Similarly, in the LOPDGGDD, when addressing the classification of infringements solely for the purposes of prescription, very serious and serious infringements are clearly differentiated for the purposes of prescription, whether it concerns the violation of Article 5.1(f) of the GDPR or the violation of Article 32 of the GDPR, respectively.

Regarding the fact that all principles related to the processing of personal data cited in Article 5 of the GDPR have their specification in another article of the Regulation, this does not occur with Article 5.1(c) of the GDPR, which contemplates the principle of data minimization and does not have its

"reflection" in another section of the Regulation.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
135/214

Furthermore, this Agency reiterates what has already been stated in the resolution proposal regarding the aforementioned allegations to the initiation agreement of the present sanctioning procedure.

For all the reasons stated, the present allegation is dismissed.

2.2.- The reasons put forth in the Resolution Proposal cannot lead to the non-application of the principle

non bis in idem

or, failing that, the rules regarding the concurrence of punitive norms.

ENDESA argues that a mere reading of the two provisions deemed infringed by this Agency is sufficient to appreciate their intimate connection regarding the legal good protected by both.

It is not a matter of them "being related," as the Resolution Proposal somewhat lightly claims (in its opinion), but rather of provisions that are intimately related (in ENDESA's view), to the extent that one represents the formulation of a principle and the other the specification of the obligations to fulfill it. Indeed, ENDESA understands that while Article 5.1.f) refers to the obligation to ensure "adequate security" of personal data through the application of "appropriate technical or organizational measures," Article 32 seeks to specify that principle by imposing on the data controller and the processor the obligation to apply "appropriate technical and organizational measures" to ensure "an adequate level of security."

Viewed from another perspective, which nonetheless leads to the same conclusion, ENDESA explains that Article 32 establishes an obligation of means to prevent a result from occurring, and that obligation consists of having the appropriate technical or organizational measures, while Article 5.1.f) precisely enshrines the result that is intended to be achieved with such means, which is to guarantee the security and integrity of the data.

Precisely for this reason, ENDESA disagrees with what the Resolution Proposal states regarding the notion that the violation of Article 5.1.f) "may occur, or not, due to the absence or deficiency of security measures," since any potential infringement of that specific provision will always depend on the type of security measures that were implemented. In fact, to reach this logical conclusion, it is sufficient to note that if the security measures were infallible (which, obviously, even the GDPR does not require, as it makes them dependent on factors such as the state of the art, implementation costs, risks, etc.), then the cited Article 5.1.f) of the GDPR could never be violated.

And if this is the case from a strictly legal perspective based on an integrative interpretation of the GDPR that respects the mechanics it adopts of outlining principles and establishing corresponding obligations to guarantee them, ENDESA argues that it is even more so in a case like the one at hand, where from a factual point of view - and always in the opinion of this Agency - the alleged non-compliance with Article 5.1.f) would have responded to the claim that, supposedly, the security measures were "not appropriate to the risk," that is, to an alleged non-compliance with Article 32.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
136/214

There can be no doubt, in such cases, that any eventual infringement of the principle of integrity and confidentiality would merely be a consequence of the prior infringement of the obligation to have appropriate technical and organizational measures in place (assuming the approach of the Instruction). And precisely for this reason, it is also incorrect, in the opinion of ENDESA, what the notified Resolution Proposal states regarding the possibility that a company may not have adequate measures

and that, nevertheless, this does not imply an infringement of Article 5.1.f) of the GDPR, but only of Article 32. ENDESA explains that a breach of Article 32 may or may not materialize in a loss of confidentiality and integrity, but it will always represent a breach of Article 5.1.f), since it will imply failing to uphold the fundamental principle of ensuring adequate security.

In this regard, this Agency wishes to point out that at no time in the aforementioned resolution proposal has it been stated that ENDESA's breach of Article 5.1.f) of the GDPR was due to the security measures not being appropriate to the risk. What was stated verbatim was: "Taking as a reference what has been previously stated, in the present sanctioning procedure, the principle of non bis in idem has not been violated, since, although understood broadly, the facts are detected as a consequence of a violation of the security of personal data, the infringement of Article 5.1.f) of the GDPR is specified in a clear loss of confidentiality and integrity, while the infringement of Article 32 of the GDPR is reduced to the absence and deficiency of the security measures (only security) detected, which are present independently of the violation of the security of the personal data in question. In fact, if these security measures (not appropriate to the risk, by the way) that ENDESA had in place had been detected by this Agency without the loss of confidentiality and integrity of the personal data having occurred, ENDESA would only have been sanctioned for Article 32 of the GDPR."

On the contrary, this Agency completely separates what would be the infringement of Article 5.1.f) of the GDPR for failing to adequately guarantee the confidentiality and integrity of personal data from the infringement of Article 32 of the GDPR for not having appropriate security measures (measures solely for security). All of which was extensively explained in the response to the allegations against the initiation agreement of the present sanctioning procedure, to which this Agency refers.

ENDESA argues that the equivalence between Article 5.1.f) and Article 32 is total, and that the forced independence or separation that the Resolution Proposal claims as a fact, without any argument to demonstrate it, cannot be established between the two. Both provisions protect (in the opinion of ENDESA) the same legal asset, the first from the conceptual level of the principles and the second from the specification of the means to ensure their observance.

Therefore, ENDESA understands that sanctioning its breach separately means sanctioning the same thing twice, which is why the thesis followed by the Resolution Proposal is contrary to the principle of non bis in idem, which—should it be necessary to remind—materially prohibits the same subject from being sanctioned twice for the same act; or, at the very least, it is contrary to the rules relating to concurrency.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
137/214

of punitive norms, given that, even in the event that it were understood that the legal interest protected by both provisions is different (which it is not), what could never be doubted is that the alleged infringement of Article 5.1.f) would be an immediate consequence of the infringement of Article 32 and would solely and exclusively obey it, such that a single act would have given rise to two indissoluble infringements.

ENDESA asserts that the above is supported by the criterion repeatedly applied by our Courts in cases where they have judged whether it was possible to sanction a subject twice for two infringements when one was merely the consequence of the other, as -it insists- this Agency should accept would occur in this case if it did not accept that the separate sanctioning of the breach of Article 5.1.f) and that of Article 32 of the GDPR is not permissible.

A jurisprudential criterion that -in ENDESA's opinion- is fully transferable to the case at hand, as it is the Proposal for Resolution itself that recognizes that the alleged loss of confidentiality and integrity determining the presumed breach of Article 5.1.f) of the GDPR was due to the fact that the security measures implemented by Endesa were not appropriate and, therefore, to the presumed breach of its Article 32.

ENDESA cites as the first example of this consolidated jurisprudence the Judgment 2/2003, of January 16, of the Constitutional Court, which, following the doctrinal line set by the European Court of Human

Rights, declared that when a detailed examination of facts leads to the conclusion that one illicit act encompasses the elements of other illicit acts that a person may have committed, only the first can be pursued:

“(…) there are cases in which an act, at first glance, seems to constitute more than one illicit act, while a more ***EMPRESA.15 detailed examination shows that only one illicit act should be pursued because it encompasses all the illicit acts contained in the others (...). An obvious example would be an act that constituted two illicit acts, one of which contained precisely the same elements as the other plus one additional element.”

The citation of this precedent is relevant because this is exactly what would occur in the present case according to ENDESA, in which it is evident that the alleged breach of the principle of integrity and confidentiality that is reproached would be a direct consequence of the alleged inappropriate nature of the security measures implemented by Endesa, such that the breach of Article 32, which would be prior, would absorb the subsequent breach of Article 5.1.f). And this is in the hypothesis that it is ultimately considered by that Agency that these are provisions that protect different legal interests, which ENDESA cannot agree with for the reasons already stated.

ENDESA also invokes the Judgment of June 30, 2021, of the Superior Court of Justice of Madrid (ECLI:ES:TSJM:2021:774), in which it was analyzed whether it was possible to sanction a subject for breaching an order to cease activity of a premises and, at the same time, because that breach involved having that premises open without a functioning license.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
138/214

The Court considered that this duality of sanctions was not legally valid, as under no circumstances can one simultaneously sanction both a result (in this case, opening a premises without the necessary permits) and the action from which that result actually derives (breaching a cease order by opening to the public a premises without a license):

“This is, by opening the establishment without the required operating license, one is simultaneously disobeying the cease and closure order. Ultimately, the commission of the infringement typified in Article 37.5 cannot occur without simultaneously committing the infringement typified in Article 37.2, both of the LEPAR, and vice versa.”

The above leads the Court to the conclusion that there is a “medial concurrence between both infringements” and that the imposition of a double sanction “violates the principle of non bis in idem.” Translating this criterion to our factual scenario, even in the hypothesis that it had to be accepted that Articles 5.1.f) and 32 of the GDPR are not equivalent and that, therefore, their breaches would represent distinct infringements (which ENDESA can under no circumstances agree with), there would be no doubt that in this case one would indeed have been a consequence of the other, leading to the same conclusion as the Court, in the sense that the imposition of two sanctions, instead of punishing them according to the rules of medial concurrence, would violate the principle of non bis in idem.

It is also worth recalling the Judgment of May 13, 2004, of the High Court of Justice of Madrid (ECLI:ES:TSJM:2004:6240), in which the sanctions imposed on a company for failing to comply with the determinations of an emergency plan and, at the same time, for having discharged fuel into the waters of a port as a consequence of the former were judged.

ENDESA states that this is a case with which an absolute parallelism can be established because both a specific result (the discharge, equivalent in this case to the security breach) and the act that led to it (on that occasion, the failure to comply with the emergency plan, equivalent to the failure to have adequate technical and organizational measures) were sanctioned.

Well, ENDESA explains that what is relevant for these purposes is that the Court rejected the possibility of sanctioning both behaviors separately, understanding that the connection between them required considering them as one for punitive purposes:

“The detailed reading of both files reveals that the connection between the facts pursued in both is absolute and that, in any case, the failure to comply with the contingency plan and the presence of fuel

in the ballast tank constitute the factual and culpability premises of both sanctions.”

In the Court's opinion, “what is relevant is not so much that two distinct behaviors can be identified, but what degree of relationship or connection exists between them,” and since one fact derives from the other, there was an “evident medial relationship between one...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

139/214

conduct and another (the spill occurred because there was fuel oil in a ballast tank and the presence of the fuel in that tank occurred because the contingency plan was not complied with).

This is exactly the same as what happens in this case, in the opinion of ENDESA.

ENDESA argues that, beyond the legal discussion about whether the provisions whose infringement is attributed to ENDESA are equivalent - as this party defends with absolute conviction - or, on the contrary, can theoretically be violated independently - as stated in the notified Resolution Proposal - what must be considered from a sanctioning perspective in cases like this is whether there is or is not a connection or consequential relationship between the behaviors that are deemed unlawful.

And in this case, in ENDESA's opinion, that connection is more than evident, because, even if the principle of integrity and confidentiality had indeed been compromised, it would have been because, supposedly, the obligation to have adequate measures to guarantee it had been breached, thus existing an "evident medial relationship between one conduct and the other," using the same words as the Superior Court of Justice of Madrid.

ENDESA argues that all of the above ultimately demonstrates the impossibility of separately sanctioning the alleged infringement of articles 5.1.f) and 32 of the GDPR in the present case, as the first would merely be the consequence of the second and, therefore, in accordance with the jurisprudence presented, the principle of non bis in idem would be violated or, at a minimum, the rules governing the concurrence of punitive norms would be breached.

ENDESA argues that, beyond the legal discussion about whether the provisions whose infringement is attributed to ENDESA are equivalent - as this party defends with absolute conviction - or, on the contrary, can theoretically be violated independently - as stated in the notified Resolution Proposal - what must be considered from a sanctioning perspective in cases like this is whether there is or is not a connection or consequential relationship between the behaviors that are deemed unlawful.

And in this case, in ENDESA's opinion, that connection is more than evident, because, even if the principle of integrity and confidentiality had indeed been compromised, it would have been because, supposedly, the obligation to have adequate measures to guarantee it had been breached, thus existing an "evident medial relationship between one conduct and the other," using the same words as the Superior Court of Justice of Madrid.

In this regard, this Agency wishes to point out that the jurisprudence cited by ENDESA is not applicable to the case. This is not a case of an unlawful act that encompasses by itself the elements of other unlawful acts (as in Judgment 2/2003, of January 16, of the Constitutional Court), since, as explained in the response to the allegations regarding the initiation agreement, these are distinct issues: through article 5.1.f) of the GDPR, a loss of integrity and confidentiality is sanctioned, solely, and through article 32 of the GDPR, the absence and deficiency of the measures of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

140/214

security measures implemented by the data controller. Absent or deficient security measures that, in themselves, violate the GDPR regardless of whether confidentiality has been lost.

It is also not about sanctioning a result and the action from which that result derives (Judgment of June 30, 2021, of the High Court of Justice of Madrid), since the loss of confidentiality and integrity of personal data is not solely subject to the adoption of security measures. This Agency reiterates that

there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to ensure this principle.

However, Article 32 of the GDPR includes the obligation to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk. Of security. Only of security.

For the same reasons, it is also not the case that the conduct that violates Article 5.1.f) of the GDPR and the conduct that violates Article 32 of the GDPR should be considered as a single conduct for punitive purposes (as in the Judgment of May 13, 2004, of the High Court of Justice of Madrid), since one fact did not derive from the other.

This Agency reiterates that Article 5.1.f) of the GDPR is violated when there is a loss of confidentiality, integrity, or availability of personal data, which may or may not occur due to the absence or deficiency of security measures.

And this principle only determines the means through which the maintenance of confidentiality, integrity, or availability can be achieved when it explicitly states "through the application of appropriate technical and organizational measures," which are not strictly security-related (as is the obligation referred to in Article 32 of the GDPR).

ENDESA adds that these are rules that in this case are contained in Guidelines 4/2022, of the European Data Protection Committee ("EDPC"), on the calculation of administrative fines under the GDPR, whose application should lead, in accordance with the principle of specialty, to the alleged infringement of Article 32 of the GDPR being the only one that could be sanctioned.

ENDESA argues that the Proposal for Resolution merely states at this point - again without any support - that the aforementioned Guidelines would only apply to facts that occurred after their adoption and that, for that reason, they could not be applied in this case. However, the truth is that nothing prevents the application of the Guidelines to ongoing cases (even if the facts may be prior), as they are merely rules and criteria for the calculation of sanctions and because, furthermore, it is the only thing truly coherent with the objective of harmonization that these Guidelines expressly encompass and which motivated their approval by the EDPC. In fact, given that their application is more beneficial in this case considering the different amounts of the proposed sanctions for the alleged infringements, their application would be required by what is established in Article 9.3 of the Constitution.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
141/214

ENDESA adds that, even if this Agency were to consider that the aforementioned Guidelines are not applicable (which for this party would be a serious violation of the constitutional principle requiring favorable retroactivity in sanctioning matters), it would necessarily have to adhere to Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP), whereby only the sanction for non-compliance with Article 5.1.f) of the GDPR would be applicable.

In this regard, this Agency reiterates that the aforementioned Guidelines do not apply to the present case. However, even if they were applicable, this Agency considers that there are two distinct infringing behaviors, as previously stated in the response to the allegations regarding the initiation agreement and the resolution proposal of the present sanctioning procedure, and therefore Chapter 3 of the aforementioned Guidelines would also not apply.

Finally, regarding the applicability of Article 29.5 of the LRJSP as claimed by ENDESA, this Agency wishes to point out that Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR.

This is because the GDPR is a closed and complete system.

The GDPR is a directly applicable community regulation in the Member States, which contains a new, closed, complete, and global system aimed at ensuring the protection of personal data uniformly across the European Union.

Specifically, in relation to the sanctioning regime established therein, its provisions apply immediately,

directly, and integrally, providing a complete and gapless system that must be understood, interpreted, and integrated absolutely, completely, and integrally, thereby preserving its ultimate purpose, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data. The contrary would result in a reduction of the guarantees of the rights and freedoms of citizens.

In fact, a specific example of the absence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Article 83.2 of the GDPR) or specifies the existing rule concerning a possible concurrent offense (Article 83.3 of the GDPR).

Additionally, it must be noted that the GDPR does not allow the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of Article 83.7 of the GDPR). The LOPDGDD only develops or specifies some aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the intended purpose of the European legislator is to implement a uniform system throughout the European Union that guarantees the rights and freedoms of natural persons, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of such data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

142/214

In this regard, Recital 2 of the GDPR states that:

“(2) The principles and rules regarding the protection of natural persons with regard to the processing of their personal data must, regardless of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of natural persons.” (the underlining is ours)

It further indicates in Recital 13 of the GDPR that:

“(13) To ensure a consistent level of protection for natural persons throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including micro-enterprises and small and medium-sized enterprises, and offers natural persons in all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of the processing of personal data and equivalent sanctions across all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of personal data in the Union is not restricted or prohibited for reasons related to the protection of natural persons with regard to the processing of personal data.” (the underlining is ours)

In this system, what is decisive in the GDPR is not the fines. The corrective powers of the supervisory authorities provided for in Article 58.2 of the GDPR, combined with the provisions of Article 83 of the GDPR, show the prevalence of corrective measures over fines.

Thus, Article 83.2 of the GDPR states that “Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j).”

In this way, the corrective measures, which are all those provided for in Article 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed alongside the corrective measures or in substitution thereof.

And all this with the aim of enforcing compliance with the GDPR, preventing non-compliance, promoting compliance, and ensuring that the infringement is not more profitable than non-compliance. Therefore, Article 83.1 of the GDPR provides that “Each supervisory authority shall ensure that the

imposition of administrative fines in accordance with this Regulation..."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
143/214

Article for the infringements of this Regulation indicated in sections 4, 5, and 6 must in each individual case be effective, proportionate, and deterrent."

The fines must be effective, proportionate, and deterrent to achieve the purpose intended by the GDPR.

For this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case - or due to the application of a different medium competition than that provided in the GDPR, would undermine the effectiveness of the system, which would lose its meaning, its teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and deterrent. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms. Therefore, there is no legal gap, nor is there supplementary application of Article 29 of the GDPR. In addition to the above, it should be noted that there is no legal gap regarding the application of medium competition. Neither the GDPR allows nor does the LOPDGDD provide for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in the event of a possible violation of data protection regulations," Article 63 that opens the Title states that "The procedures processed by the Spanish Data Protection Agency will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no establishment of a subsidiary application regarding the LRJSP, which does not contain any provision in its wording relating to any administrative procedure.

In the same way that the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap nor subsidiary application of the same, nor is there room for the application of the section relating to medium competition for the same reasons.

For all the above, this allegation is dismissed.

2.3.- Conclusion: inadmissibility of separately sanctioning the alleged infringements of Articles 5.1.f) and 32 of the GDPR

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
144/214

In the opinion of ENDESA, the above demonstrates the error made by the Proposal for Resolution in attempting to sanction Endesa separately for the alleged violations of Articles 5.1.f) and 32 of the GDPR.

Therefore, ENDESA believes that this Proposal for Resolution should be rectified and, in the event that, despite the arguments presented in this document, this Agency considers that there is a concurrent violation of security obligations, Endesa could only be sanctioned for the alleged

non-compliance with Article 32 of the GDPR (if the specialty criterion contained primarily in the Guidelines is applied) or, at most, for Article 5.1.f) of the GDPR (if the general rule contained in the LRJSP is deemed applicable), without prejudice to the fact that Article 9.3 of the Constitution would require the application of the principle of specialty contained in the aforementioned Guidelines. In this regard, this Agency reiterates what has already been stated in its response to the allegations regarding the initiation agreement and the proposal for resolution of this sanctioning procedure, and thus the present allegation is dismissed.

3. Violation of the principle of legality

Regarding ENDESA's allegation in the written submissions to the Initiation Agreement, the AEPD responds that the principle of legality is not violated because the GDPR allows the supervisory authority to specify the amount of the sanction using a series of evaluative elements included in Article 83 GDPR, such as the modifying circumstances of liability in point 2 or the definition of types in points 3 and 4.

ENDESA argues that the above does not resolve the issue raised, as the legality in this case is not violated by the structure of the GDPR, but by the lack of specification of the infringing activity contained both in the Initiation Agreement and in the Proposal for Resolution. In this sense, despite the extensive nature of the file, including prior requests, the AEPD has not specified what the specific measures that Endesa has failed to comply with would be that would allow: (i) to avoid or reduce the risk of the incident in question occurring, and (ii) to defend the adequacy of the measures deployed by Endesa to the GDPR.

Therefore, the allegation expressed regarding the violation of the principle of legality in this aspect is reiterated, and in particular, what was stated in the conclusion of that document when it was said that "Consequently, in the application of the norm, the administration must be extremely careful when identifying the facts constituting the infringement and explaining the reason why those facts are encompassed within the type drafted in a non-exhaustive manner."

In this regard, this Agency wishes to point out that it has extensively detailed what the facts constituting the infringement have been and how they fit into the drafted type.

ENDESA argued in its submissions to the initiation agreement of this sanctioning procedure that: "Article 5.1.f) of the GDPR establishes a general principle that does not have specific concreteness through clear positive or limiting acts that the obligated subject can know and comply with. On the contrary, it uses indeterminate legal concepts."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
145/214

in a chained manner ("adequate security", "appropriate measures"), which do not allow for a transparent understanding of the scope of obligations or prohibitions."

In the present case, as detailed in Legal Basis IV, on August 24, 2021, ENDESA detected an advertisement on the social network Facebook selling access to the application ***HERRAMIENTA.1 with access to customer information.

On September 10, 2021, ENDESA confirmed the veracity of the advertisement and identified the credentials of the application user that were being used by the advertiser to sell access. That is to say, by September 2021, it had been verified that the confidentiality of the databases owned by ENDESA had been compromised.

Subsequently, on October 19, 2021, ***EMPRESA.1 detected that a user of ***EMPRESA.9 had attempted to carry out a fraudulent registration, which is why on October 27, 2021, a certified letter was sent to ***EMPRESA.9 communicating the definitive closure of the ENDESA supply contract sales campaign effective October 19, after having provisionally suspended that campaign on the same day. On October 20, 2021, ***EMPRESA.1 sent a communication to ENDESA indicating the operations affected by the fraudulent practice of ***EMPRESA.9, identifying 137 contracts made and another 7 operations pending validation by ENDESA that had not been registered. Additionally, 172 orders that were pending validation by the back office of ***EMPRESA.9 were identified and blocked to prevent

their processing.

That is to say, since September 2021, ENDESA was already aware of the existence of a security breach, and since October 2021, it knew that the confidentiality and integrity of the data of 137 interested parties had been compromised, and that there were another 179 potential interested parties whose data was more than likely to have been compromised.

For its part, on October 27, 2021, an email was sent to ENDESA attaching an email from the manager of ***EMPRESA.9 communicating to ***EMPRESA.1 the complaints filed with the Police of ***PAÍS.1 on October 19, 2021, against 23 commercial agents.

On October 27, 2021, ***EMPRESA.1 received an email from the manager of ***EMPRESA.9, which on the same day ***EMPRESA.1 forwarded to ENDESA, detailing the inquiries made regarding the fraudulent practice carried out by some of its agents and their modus operandi.

With the details of this modus operandi, it was established that the integrity and confidentiality of the personal data of at least those clients who had been fraudulently registered had been affected, since to proceed with the registration it was necessary to access their data and modify it with false information.

Also, in this email dated October 27, 2021, ***EMPRESA.1 identified five of the users of ***HERRAMIENTA.1 involved in the security breach.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
146/214

of personal data (used by ***COMPANY.9) and screenshots were attached showing Facebook ads offering the rental and/or sale of access credentials to the application ***TOOL.1.

On January 17, 2022, new ads were published on Facebook by user B.B.B., which affected the customer databases of ENDESA. Therefore, at least during the month of January 2022, the confidentiality of the data contained in the database owned by ENDESA continued to be inadequately guaranteed.

On February 7, 2022, ENDESA sent a burofax to FACEBOOK SPAIN S.L. indicating that there were users publishing information that could constitute a crime and requested its removal, from which it can be inferred that the ads selling credentials to access ***TOOL.1 were still published, further compromising the confidentiality of the data contained in that system.

On February 8, 2022, after appropriate investigations, ENDESA became aware of certain matches between the data appearing in the published databases and those that could be included in ENDESA's commercial system, ***TOOL.2.

ENDESA conducted a new assessment of the incident and on February 9, 2022, verified the authenticity of the latest ads and the identity of the two advertisers, both former employees of ENDESA's suppliers with access to ***PLATFORM.1 (***TOOL.1). A total of nine compromised users were detected between September 2021 and January 2022, who were being used by the Facebook advertisers to sell access to ***PLATFORM.1 (***TOOL.1). Additionally, it was confirmed that six of them had access to ***TOOL.2. The validity of the credentials was also verified, in all cases assigned to ENDESA suppliers for customer acquisition and service tasks.

That is to say, it was confirmed that the confidentiality of the data contained in ***TOOL.1 and ***TOOL.2 had not been sufficiently guaranteed since they were made available to unauthorized third parties, which also put the integrity of the data at risk by allowing numerous fraudulent registrations to occur.

Furthermore, ENDESA has pointed out that the fact that two or more people could access ***TOOL.1 simultaneously with the same user, a multi-session option enabled when the personal data security breach occurred, and that, in relation to the compromised users and the period during which this incident took place, no logs of the use of the tools ***TOOL.1 or ***TOOL.2 were maintained, prevents them from knowing the number of records of the applications that may have actually been accessed, at least since they became aware in August 2021 of the publication of the ad on Facebook.

The potential affected parties by the breach of personal data security in question, regarding the tool

***TOOL.1, were 30.6 million supply points and 8.6 million gas supply points of non-users.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
147/214

ENDESA customers, as well as data from 4.8 million electricity customers and 1.2 million gas customers of ENDESA.

Furthermore, regarding the tool ***HERRAMIENTA.2, the confidentiality of the personal data of 4.8 million electricity customers and 1.2 million gas customers of ENDESA was not guaranteed.

All of the above demonstrates, as previously indicated, that ENDESA did not adequately guarantee the confidentiality and integrity of the personal data in its possession.

Regarding ENDESA's demand that this Agency specify what specific measures ENDESA has not complied with, the very approach of the GDPR prevents such detail from being provided.

The proactive responsibility advocated by the GDPR involves the implementation of a compliance and management model for the GDPR that determines the widespread fulfillment of obligations regarding data protection. It includes the establishment, maintenance, updating, and control of data protection policies within an organization—understood as the set of guidelines that govern the actions of an organization, practices, procedures, and tools—ensuring privacy by design and by default, which guarantees compliance with the GDPR, prevents the materialization of risks, and allows it to demonstrate its compliance.

It pivots on risk management. As established in Report 0064/2020 from the Legal Department of the AEPD, it shows the metamorphosis of a system that has transitioned from being reactive to becoming proactive, since "at the current moment, it must be taken into account that the GDPR has represented a paradigm shift in addressing the regulation of the right to personal data protection, which is now based on the principle of 'accountability' or 'proactive responsibility' as repeatedly pointed out by the AEPD (Report 17/2019, among many others) and is reflected in the Explanatory Memorandum of the LOPDGDD: 'the greatest novelty presented by Regulation (EU) 2016/679 is the evolution from a model fundamentally based on compliance control to one that rests on the principle of active responsibility, which requires a prior assessment by the data controller or processor of the risk that may arise from the processing of personal data in order to adopt the appropriate measures based on that assessment.'"

It requires a conscious, committed, active, and diligent attitude. Consciousness implies the knowledge of one's organization by the data controller and how it is affected by data protection and the inherent risks of personal data processing; commitment involves the willingness to comply and to truly take responsibility for the implementation of data protection policies within the organization; the active attitude is related to proactivity, effectiveness, efficiency, and operability; and diligence is the care, zeal, and dedication put into compliance.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
148/214

The party that best knows its activity is the one that carries out the processing of personal data in question (in this case, ENDESA) and who must detail and demonstrate the measures adopted, in accordance with what is established, particularly in Article 5.2 of the GDPR. The deficiencies observed in the measures adopted by Endesa have already been highlighted by this Agency throughout this resolution.

For all the above, this allegation is dismissed.

Second.- On the impropriety of the sanction imposed for the alleged infringement of Article 33 of the GDPR

The Proposal for Resolution, in maintaining the proposed sanction for the alleged infringement of Article 33 of the GDPR, focuses mainly on the argument, which ENDESA considers to be erroneous,

that Endesa did not correctly qualify the incident by considering that it was not reportable after the first two analyses conducted.

The AEPD argues that “it is simply sufficient for there to be a probability (whatever it may be) that there is a risk (whatever it may be)” for, in accordance with Article 33 of the GDPR, a data controller must notify the existence of a security breach to the AEPD.

ENDESA is surprised that this is the interpretation of the AEPD in this proceeding when this same Agency, along with the first Guide for Managing Security Breach Notifications, published a tool intended to assist data controllers in their risk assessment, which, based on various factors (volume of affected data, type of data, and impact of the violation), assigned a risk level (from 2 to 100) and, based on that, provided a result regarding the necessity or not of notifying the security breach to the AEPD (and to the affected parties). In this regard, the tool only indicated the need to notify the breach to the AEPD in those cases where the risk level was: (i) from a quantitative perspective, greater than 20; or (ii) from a qualitative perspective, high based on the analyzed factors.

That is to say, according to the analysis of this tool, it was not sufficient, as the AEPD now indicates, that “there is a probability (whatever it may be) that there is a risk (whatever it may be)” for the security breach to be reportable to the AEPD, but that such risk should be sufficiently appreciable and probable (in the previous example, greater than 20).

ENDESA argues that in a similar sense, the current Guide for the notification of personal data breaches from the AEPD states literally that: “It is not mandatory to notify all personal data breaches, since the GDPR provides an exception to this obligation when, in accordance with the principle of proactive responsibility, the controller can guarantee that it is unlikely that the personal data breach entails a risk to the rights and freedoms of natural persons.”

ENDESA points out these last two words, “unlikely” and “risk,” as it is relevant to bring up the footnotes associated with them in the aforementioned Guide from the AEPD. In this regard, both footnotes associated with the previous words...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
149/214

In the Guide, reference is made to the Guidelines on the notification of personal data breach in accordance with Regulation 2016/679 published by the Article 29 Working Party (now the EDPB), in which it is stated that:

i

“When the breach relates to personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, or that includes genetic data, data concerning health or data concerning a person's sex life, or criminal convictions and offenses or related security measures, it will be considered likely that such damage and harm will occur”; and

ii

“...immediately after becoming aware of a breach, it is of vital importance that the data controller not only seeks to contain the incident but also assesses the risk that may arise from it.”

ENDESA claims that, as can be observed from the first mention, if in those cases where the security breach impacts special categories of data, it is considered likely that damage and harm will occur to the data subjects, “a sensu contrario” it must be interpreted that, in the remaining cases (where special categories of data are not affected – as is the case in this file) this will not be the case by default, so the probability that the breach constitutes a risk to the data subjects must be calculated and assessed. Otherwise, the Guidelines of the Article 29 Working Party would not have made this distinction.

ENDESA indicates that, in the case at hand, it determined, in its first two risk analyses of the incident, that it was not likely that it posed a risk to the rights and freedoms of the affected natural persons, among other aspects because no special category of data had been affected.

ENDESA explains that, returning to footnote number (ii) mentioned above, the Article 29 Working Party indicates that it is the responsibility of the data controller, in addition to containing the incident, to assess the risk that the security breach poses to the affected data subjects. That is to say, the data

controller (in this case, Endesa), prior to notifying the security breach to the AEPD, must assess the risk that it poses to the rights and freedoms of the affected data subjects and, based on that assessment and the risk, decide whether or not to make such notification. Therefore, it would directly contravene the guidelines of the Article 29 Working Party, and the literal wording of Article 33.1 of the GDPR, as indicated by the AEPD in its Proposal for Resolution; that is, that notification to the supervisory authority must be made whenever “there is a probability (of any kind) that there is a risk (of any kind).”

Furthermore, in this regard, ENDESA brings to attention the Guidelines 1/2021 on examples of notification of personal data breaches issued by the EDPB, to which the AEPD itself refers in its Proposal for Resolution to justify its conclusion. In these Guidelines, in several of its examples (more specifically in cases numbers 9, 13, and 15) where the Committee concludes that it would not be necessary to make a notification to the supervisory authority, it is indicated that, although there is a risk, it is low. That is to say, the Committee itself does not share the interpretation made by the AEPD in the Proposal for Resolution.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
150/214

solution by virtue of which the determination of any risk, “whatever it may be,” would lead to the conclusion that it is necessary to notify the security breach to the supervisory authority.

More specifically, one of the examples indicates: “In the specific case described, the risk is low, as special categories of personal data were not involved...” (case No. 13) and in another it is stated that “it was unlikely that this data security breach would pose a risk to the rights and freedoms of the data subjects, so no notification to the SA or to the affected data subjects was necessary” (case No. 15). ENDESA claims that, as can be observed, contrary to what the AEPD indicates in its Proposal for Resolution, neither any risk (“whatever it may be”), nor any probability (“whatever it may be”), turns, in the eyes of the EDPB, a security breach into one that must be notified in accordance with Article 33 of the GDPR.

That is to say, in accordance with Guidelines 1/2021, in those cases where it is determined that the risk is low (for example, because it does not affect special categories of data) or that the probability of the breach posing a risk is remote (“unlikely”), a notification to the supervisory authority would also not be necessary. This is specifically the case at hand, in which Endesa, after conducting the corresponding risk and probability analyses, determined, on two occasions, that both the risk to the rights and freedoms of the affected data subjects was low, and the probability of that risk materializing was remote.

And that, when the circumstances of the case changed, Endesa conducted a third analysis whose result indicated that at that moment it was indeed necessary to notify the security breach to the AEPD. It is worth highlighting that, if Endesa's intention from the very beginning had been to conceal this incident from the AEPD, it would not have carried out the notification of the breach once it considered it to be notifiable. And it did not do so until then because it was convinced, after conducting the appropriate analyses, that, up to that moment: (i) the risk to the rights and freedoms of the affected data subjects was low; and (ii) the probability of that risk materializing was remote.

Therefore, ENDESA claims that it is not true, as indicated in the Proposal for Resolution, that it did not notify the incident at the first moment it became aware of the announcements published on Facebook because it was conducting a “detailed examination of the situation.” On the contrary, Endesa conducted that examination of the situation as soon as it became aware of it, but determined, following the guidelines of the AEPD and the EDPB in this regard, that the notification threshold set out in Article 33 of the GDPR was not reached.

Notwithstanding the above, ENDESA is surprised that the AEPD, in its Proposal for Resolution, beyond indicating that it disagrees with the assessment of the non-necessity of notification of the breach made by Endesa in its first two reports [since, contrary to what is indicated in its own guidelines and in the guidelines issued by the EDPB, the AEPD understands in this case that notification to the

supervisory authority must be made whenever “there is a probability (whatever it may be) that there is a risk (whatever it may be)”, does not substantiate the presence of intent in Endesa's actions. That is to say, given that the first two reports prepared by Endesa analyzing the incident were drafted (in ENDESA's opinion) based on an interpretation

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

151/214

reasonable interpretation of the applicable data protection regulations and the interpretative guidelines, which demonstrates (in its opinion) due diligence, Endesa understands that the imposition of a sanction for non-compliance with Article 33 of the GDPR (especially when a sanction of such magnitude is proposed) must be preceded by a rigorous and complete legal foundation regarding the presence of intent in Endesa's actions, which is not provided in the Proposal for Resolution.

In this regard, this Agency acknowledges that the wording of the phrase in the proposal for resolution, contested by ENDESA, stating that “It is simply enough that there is a probability (whatever it may be) that there is a risk (whatever it may be). It is also not necessary for that risk to have materialized for such an incident to be reportable; it is enough that it is probable,” may not have been the most appropriate, or rather, it could require further development in its explanation.

Of course, not all violations of the security of personal data need to be reported to the corresponding supervisory authority. However, it is true that Article 33 of the GDPR contains a sort of general rule according to which all violations of the security of personal data must be reported to the supervisory authority, unless “...it is unlikely that such a security breach would pose a risk to the rights and freedoms of natural persons.”

From what is stipulated in the GDPR and from everything explained in the Guide for the Notification of Personal Data Breaches by the AEPD (both in its first version and in its current version), as well as in the aforementioned Guidelines 1/2021 on examples of notification of personal data security breaches, it follows that (as ENDESA states) “it is the responsibility of the data controller, in addition to containing the incident, to assess the risk that the security breach poses to the affected data subjects' rights and freedoms. That is, the data controller (in this case, Endesa), prior to making the notification of the security breach to the AEPD, must assess the risk that this poses to the rights and freedoms of the affected data subjects and, based on that assessment and the risk, decide whether or not to make such notification.” But this does not exclude the Agency's ability to subsequently evaluate the compliance with the GDPR of the decisions made by the data controller regarding general data protection.

From all the documentation in the present sanctioning procedure, this Agency has concluded that ENDESA has not correctly classified the violation of the security of personal data as reportable. ENDESA cites the first Guide for the Management of Security Breach Notifications, which included a tool to help assess the risk of incidents and the need to notify them to the AEPD and affected individuals.

First of all, this Agency wishes to point out that the conclusions that the data controller may reach by using this Guide and the tool in question are nothing more than a guide, precisely, a decision-making aid, but the decision on whether a security breach of personal data should be reported to the AEPD belongs solely and exclusively to the data controller, and its use in no case represents the Agency's pronouncement on the application of Article 33 of the GDPR regarding a specific incident.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

152/214

Secondly, the tool in question indicated that an incident should be reported to the AEPD when the level of risk and its probability were so low that it could be disregarded. To this end, it evaluated a series of factors and assigned a risk score (which had to be greater than 20 to be considered reportable) and

also analyzed different factors (if more than one coincided, it had to be reported).

As stated in the proven facts of this procedure, on September 13, 2021, according to Document number 10 accompanying ENDESA's submission of July 26, 2022, the first assessment of the personal data security breach was carried out, where the information obtained up to that moment was recorded in a document signed on September 14, 2021.

In said document, it is indicated that the main data contained in ***PLATAFORMA.1 are: name, surname, and address of the client, NIF, CUPS Number, contracted products, and that the estimated number of affected records would be between 100 and 1,000.

Based on the data contained in this document, ENDESA carried out a risk assessment following the tool provided by this Agency, in which it assigned the following score to the incident:

- Volume: between 100 and 1,000 records (2). [Not highlighted.]
- Non-sensitive data (x1) [Not highlighted.]
- Impact: External (6). [Highlighted]

And a risk of $3 \times (1 \times 6)$ was assigned: 12

Therefore, due to being a value lower than 20 and not coinciding with more than one highlighted factor (in another color), ENDESA considered that the incident was not reportable.

However, ENDESA itself has indicated in that same document that the data affected by the personal data security breach included the name, surname, address, among others, along with their NIF. Data that unequivocally identifies the interested parties.

On this point, it should be noted that, Recitals 51 and 75 of the GDPR distinguish a group of personal data that by their nature are particularly "sensitive" due to the significant risk that their processing may entail for fundamental rights and freedoms. Their common denominator is the risk they pose to fundamental rights and freedoms, as their processing can lead to physical, material, or immaterial harm and detriment.

Included in this group or category are the specially protected data regulated by Article 9 of the GDPR - Recital 51 of the GDPR - and, moreover, many others that are not mentioned in that provision. Recital 75 mentions in detail the personal data whose processing may entail variable degrees of severity and probability of risk for the rights and freedoms of natural persons as a consequence of potentially causing physical, material, or immaterial harm and detriment. Among them, it refers to those whose processing "may lead to discrimination issues,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

153/214

identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm;"

The numerical identifier of the DNI along with the corresponding verification character for the tax identification number unequivocally identifies a natural person. This quality makes it a particularly sensitive data point because, to the extent that its processing is not accompanied by the necessary technical and organizational measures to ensure that the person identifying themselves with it is indeed its holder, a third party can easily impersonate the identity of a natural person, or, in other words, can commit identity fraud, with the risks this entails for the privacy, honor, and assets of the impersonated individual.

The breach of the confidentiality principle for which ENDESA is responsible has involved, among other data, the NIF of the interested parties, which allows for their unique identification. For this reason, this Agency has considered in previous sanctioning procedures (for example, PS/00012/2022) that the NIF is a personal data point that is considered comparable to those of special categories, deserving of special protection due to the greater risk they pose to the rights and freedoms of the interested parties. All of this without forgetting that along with the NIF, the personal data of names, surnames, addresses, and bank accounts, among others, of the affected individuals were also compromised by the security breach, from which at least a risk of identity theft or fraud can be inferred.

Therefore, that initial assessment of the incident was not well conducted, as the risk score should have been higher, and a double value should have been assigned to the type of affected data due to their sensitive nature (the numerical value would have been 24, exceeding the threshold of 20 necessary to consider the incident as reportable). Additionally, these would have been considered significant factors, thus qualitatively also exceeding the threshold necessary to be reportable. Therefore, this Agency reiterates that ENDESA should have notified this Agency of the breach of personal data security much earlier than it did.

ENDESA cites the current AEPD Guide for the notification of personal data breaches, which indicates that the exception to this notification obligation to the supervisory authority occurs when the controller can guarantee that it is unlikely that the personal data breach poses a risk to the rights and freedoms of natural persons. Regarding the words “unlikely” and “risk,” it references the Guidelines 1/2021 on examples of notification of personal data security breaches, concluding that when personal data security breaches do not impact special categories of data, “a sensu contrario,” it would not be necessary to notify them by default.

In this regard, this Agency wishes to emphasize that even if the personal data security breach did not affect special categories of data, this does not automatically exempt the obligation to notify the incident to the corresponding supervisory authority; rather, the data controller must, in any case, evaluate the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
154/214

risks to the rights and freedoms of the data subjects as well as the likelihood of their occurrence, determining the possible impact of the incident in question.

In any case, as detailed above, in the present case, both due to the volume of the personal data compromised and the category of such data (in particular, given that the confidentiality of names, surnames, addresses, ID numbers, and even bank account numbers has been compromised, with the consequent risks this could pose to the rights and freedoms of the affected individuals), this Agency reiterates that the risk was greater than that assessed by ENDESA and that the notification of the incident should have been made earlier than it was.

ENDESA also cites some examples (numbers 9, 13, and 15, in particular) from the aforementioned Guidelines 1/2021, to conclude that in these examples it is considered unnecessary to notify the supervisory authority of the breach of personal data security. However, the cited examples would not be extrapolable to the present case.

Case number 9 refers to a situation of accidental transmission of data to a trusted third party, and the differences with the present case are more than evident: in the example from the Guidelines, it is an unintentional error, unlike what occurs in the present case (which involved an intentional action); the incident only affected the confidentiality of the data, whereas in the present case both the confidentiality and integrity of the data were affected; in the example, only a limited number of individuals were affected, while in the present case, the individuals affected by the incident numbered in the millions; and the person who had access to the data was subject to a duty of professional secrecy (which did not occur in the present case either).

Case number 13 from the cited Guidelines refers to a postal error, which also did not occur in the present case (as it involved access to ENDESA's computer systems). And in the example, special categories of data were not affected (which can be understood to have occurred in the present case, as detailed above).

Case number 15 from the cited Guidelines refers to personal data sent by mail by mistake, which also did not occur in the present case. Although both cases involve particularly protected data, it is true that in the example the risk to the rights and freedoms of the affected individuals was considered relatively low, unlike what occurs in the present case. Furthermore, the amount of compromised data and the number of affected individuals was very low (unlike what occurred in the present case).

Finally, this Agency considers that the example from the cited Guidelines that could be considered most similar to what occurred in the breach of personal data security subject to this sanctioning

procedure is possibly case number 8, referring to data exfiltration by an employee, since it was employees of companies working with ENDESA who put the accesses to the systems in question up for sale. While some differences are observed (in the example it is considered that normally only confidentiality is compromised and that special categories of personal data were not compromised), in the same example the Guidelines refer to the fact that “misuse is not excluded.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
155/214

additional and more serious than the stolen data, depending on the purpose of the processing established by the former employee.” And it concludes: “In summary, since the violation in question will not pose a high risk to the rights and freedoms of individuals, a notification to the supervisory authority will suffice. However, informing the affected parties could also be beneficial for the data controller, as it might be better for them to learn about the data breach from the company rather than from the former employee trying to contact them.” That is to say, even with the noted differences, in this case, the same Guidelines consider that the breach of personal data security should be reported to the supervisory authority.

Finally, ENDESA states that it did not intend to conceal the incident from the AEPD and that the presence of intent in ENDESA's actions regarding this matter has not been properly substantiated. On this issue, this Agency wishes to point out that it has never considered that ENDESA intended to conceal the breach of personal data security or that there was any intent in its actions. Rather, it has considered that when assessing the risk to the rights and freedoms of those affected by the incident, it was not as diligent as it should have been, which is why the assessment was not adequate and it did not make the notification referred to in Article 33 of the GDPR when it should have done so, thus it is considered that ENDESA has infringed said Article 33 of the GDPR.

For all the above reasons, this allegation is dismissed.

Third.- On the inappropriateness of the sanction imposed for the alleged infringement of Article 34 of the GDPR

ENDESA is interested in clarifying that, contrary to what the Proposal for Resolution indicates, it has not “forgotten” that the obligation of Article 34 of the GDPR is not “activated” when damage has occurred but when it is determined that the breach of security may entail a high risk to the rights and freedoms of the affected parties.

In fact, it argues that this is what ENDESA analyzes on the three occasions when it conducts the corresponding risk analysis that has already been presented to the AEPD. At no point does ENDESA wait, as the AEPD seems to imply, for damage to materialize; rather, it conducts the corresponding analysis in accordance with the GDPR and the published Guidelines on the matter and determines that the risk that the breach may pose to the affected parties is not high.

And it is only afterwards, and not as part of the analysis already conducted at the time by ENDESA, that it can be seen that said analysis was correct and that the breach did not actually pose a high risk to the rights and freedoms of the affected parties. Therefore, ENDESA does not seek to justify the lack of notification to the affected parties under the supposed excuse that they did not suffer damage (the risk analysis was conducted long before knowing whether the affected parties would suffer damage, and ENDESA would continue - and continues - to defend, regardless of whether the outcome is damaging or not, the rigor with...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
156/214

the one who conducted said analysis and the result thereof), but rather to ascertain that the result of the analysis carried out by Endesa (the incident did not pose a high risk to the rights and freedoms of

the data subjects) turned out to be more in line with the reality of the consequences than that conducted by the AEPD.

Notwithstanding the above and that ENDESA disagrees with the result yielded by the risk analysis conducted by the AEPD (the violation entails a high risk to the rights and freedoms of the data subjects) and, therefore, with the requirement issued by the AEPD regarding the need to notify the breach to the affected data subjects (especially since, at the date of receipt of said requirement, Endesa had already taken further measures to ensure that there was no longer a probability of the risk identified by the AEPD materializing), Endesa, in order to show its utmost cooperation with this Agency and in an exercise of transparency that is clearly unnecessary from a regulatory standpoint (in its opinion), decided to comply with the AEPD's requirement and provide the requested information to the affected data subjects.

ENDESA submits, as Document number 2, a statement from ***DEPARTMENT.7 detailing the proactive actions taken by Endesa to personally address the data subjects who may have been affected by the incident, as well as examples of such tasks.

Regarding the manner in which Endesa notified the data subjects, the AEPD, in the Proposal for Resolution, indicates that it does not assess the appropriateness of using a layered model. ENDESA assumes, therefore, that, as could not be otherwise since this possibility is contemplated in the AEPD's infographic on how to carry out the corresponding notifications of personal data breaches to the data subjects, Endesa cannot be reproached for not providing the data subjects with all the information required by Article 34 of the GDPR.

Endesa claims that it followed this layered information model to achieve more effective communication with the affected data subjects, taking into account the characteristics of the security breach (since not all data subjects could suffer the same consequences nor were they affected in the same way, the possible risk mitigation measures would vary depending on the specific case, making it more effective for such measures to be communicated to the data subjects in a personalized manner through ***DEPARTMENT.4).

Taking the above into account, ENDESA is surprised by the assertion made by the AEPD in its Proposal for Resolution, as it contradicts: (i) the fact that the AEPD does not assess the appropriateness of using a layered model (without assessment, there can be no reproach); and (ii) the AEPD's own infographic on how to carry out notifications of personal data breaches to the data subjects.

Finally, the Proposal for Resolution reiterates that the information provided to the data subjects in the notification made by Endesa is not truthful.

1 Likewise, in the communication sent to the affected parties, ENDESA did not include a description of the possible consequences that the breach of personal data security could cause them" – Page 144 of the Proposal for Resolution

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

157/214

First, because, according to the Proposal for Resolution, the notification indicates that the confidentiality and integrity of the personal data of the affected parties has not been compromised. The AEPD forgets that this notification was made at the end of March 2022, when Endesa: (i) had already proceeded to disable the compromised users; (ii) had already deployed multifactor authentication on the platforms ***HERRAMIENTA.2 and ***HERRAMIENTA.1; and (iii) was already in contact with most of the affected parties, providing them with personalized assistance to, as indicated in the notification, "prevent a high-risk impact on the rights and freedoms" of Endesa's customers.

It is for this reason that Endesa indicates that the confidentiality and integrity of the data has not been compromised (Endesa's intention was to indicate that, since it had implemented appropriate measures to avoid the risk, at that time the breach of confidentiality and the integrity of the data had already been remedied).

Secondly, the Proposal for Resolution states that "it is also not true that the measures adopted

prevented a high-risk impact on the rights and freedoms of the affected parties," since the compromised data could be used for other purposes. Endesa can only express its disagreement with this assertion since, as has been demonstrated subsequently, the measures implemented by Endesa were completely effective in preventing any type of harm to the affected parties. If this had not been the case, Endesa, or even the AEPD itself, would have received some complaint for these reasons (which has not been the case).

ENDESA argues that it is for this reason, and because, at the end of March 2022 (when the notification was made), Endesa: (i) was already in contact with most of the affected parties, providing them with personalized assistance and addressing any consequences that the breach may have caused; (ii) had already blocked any access to the platforms ***HERRAMIENTA.1 and ***HERRAMIENTA.2 by the compromised users and had implemented multifactor authentication measures; and (iii) already knew that the intentions of the individuals who had used the compromised users were not, as the AEPD indicates, identity theft or obtaining more data through social engineering, which Endesa determined (and informed the affected parties) that the measures adopted prevented any future risk.

In fact, ENDESA indicates that the ***HERRAMIENTA.1 platform itself, due to the way it was configured prior to the data security breach, prevents the execution of mass downloads of personal data (queries are made on an individualized basis, that is, to access the data of a particular person, it is necessary to first enter a supply point code), so the risk identified in the Proposal for Resolution regarding the possibility that the data could be used for other purposes (e.g., obtaining more data through social engineering) was extremely low and, therefore, negligible in terms of making the notification to the affected parties.

ENDESA considers that having informed otherwise, when through other channels the Endesa teams were already providing personalized attention to the affected parties and addressing any consequences they may have suffered,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

158/214

would have led to them receiving contradictory messages that, far from being informative and useful, would have created a false sense of danger that, by the end of March 2022, no longer existed (as has been fully proven a posteriori, in their opinion).

The AEPD considers, in ENDESA's view erroneously and completely disproportionate, that the assertion included in the communication to the affected parties regarding the confidentiality and integrity of the data not being compromised should be sanctioned with 800,000 euros when, it should be noted, the modification of the wording in the manner proposed by the AEPD would not have changed the purpose intended with this notification (which is none other than allowing the interested parties to take measures to avoid the risk), since the risk, as has been previously stated, was already fully mitigated and/or was being addressed by the specialized teams of Endesa at the time of making said notification.

Additionally, and as was the case regarding the proposed sanction for the alleged violation of Article 33 of the GDPR, the AEPD, in its Proposal for Resolution, again justifies the imposition of this sanction (for alleged non-compliance with Article 34 of the GDPR) on purely subjective aspects, without rigorously motivating, in their opinion, why they consider that Endesa's actions (which, in their view, were carried out with the utmost diligence, making a reasonable interpretation of the applicable regulations and guidelines) deserve such a disproportionate reproach.

In this regard, this Agency reiterates that the analysis carried out by ENDESA when determining that the personal data security breach did not need to be communicated to the affected parties was not adequate, which is why the Director of this Agency ordered ENDESA to carry out the communication referred to in Article 34 of the GDPR.

Regarding ENDESA's assertion that no high risk for the rights and freedoms of individuals was identified, this Agency reiterates that not all risks are related to fraudulent contracts for ENDESA products, but that the risks could be of another nature, since the affected parties could be, for example,

victims of phishing or social engineering, another cyberattack, or a change of supply company, or be victims of identity theft and fraud, all of which ENDESA would not be aware of. The fact that this data had been compromised means that its holders lost control over it and that it could be used unlawfully, not only at that moment but in the future.

Regarding Document number 2 submitted by ENDESA with the allegations to the proposal for resolution of this procedure, the actions of the company referred to are solely concerning the fraudulent contracts carried out by ***COMPANY.1. In this regard, this Agency reiterates that the scope of the personal data security breach exceeded what ***COMPANY.1 could communicate, as more users were compromised than those reported by these providers, and the data contained in ***TOOL.1 and ***TOOL.2 were exposed to more individuals, not only to those working in these companies.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
159/214

Regarding the manner in which ENDESA communicated the incident to the interested parties (layered information), this Agency has not made any reproach since it is not a matter of form that is considered infringed by ENDESA, but rather this Agency understands that the content of said communication does not comply with the requirements set forth in Article 34 of the GDPR.

In particular, concerning the possible consequences of the incident, if ENDESA's aim was for the affected individuals to contact the DPO to explain the consequences in each specific case, this should have been made abundantly clear. To suggest that the phrase “You can consult our privacy policy at www.endesa.com/es/proteccion-datos-endesa, where you will find information regarding the processing of your personal data. If you prefer, you can contact our Data Protection Officer directly by sending a communication to ***EMAIL.1 to learn about the details of the measures taken or to obtain more information” should be interpreted as ENDESA wishing for the affected individuals to contact the DPO to understand the possible consequences that the incident could have for them, is an argument that this Agency does not share at all and considers impossible to defend.

This Agency also wishes to point out that the consideration that ENDESA has infringed Article 34 of the GDPR does not contradict in any way the possibility of using a layered model to provide the information required by said article nor does it contradict the infographic of the AEPD itself. It is emphasized that Article 34 of the GDPR is not considered infringed due to a defect of form, but rather that the content of such communication has not fulfilled the requirements set by the regulations.

Regarding the assertion that the information provided in such communication was truthful because measures had already been adopted by March 2022 that remedied the violation of the security of the compromised personal data, this Agency does not share such an interpretation. Even if it were considered true and the risks to the rights and freedoms of the affected individuals had been mitigated, it is nonetheless true that the confidentiality and integrity of the personal data had indeed been compromised, and this should have been stated in the communication directed to the interested parties.

This Agency also does not share ENDESA's opinion that the compromised data could not be used for other purposes, as previously explained. In this regard, this Agency reiterates that ENDESA (and this Agency) would not have been aware of the possible incidents that could have arisen from the incident in question, as the risks are not solely the potential fraudulent contracting of ENDESA products.

The fact that the platform ***HERRAMIENTA.1 could not perform mass downloads of personal data does not prevent the consideration that the data obtained could have been used for other purposes, especially considering that ENDESA itself was unable to know how many records had been obtained during the months that the incident lasted. Therefore, this Agency in no way considers such risk as “negligible” regarding the communication of the incident to the interested parties.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid

This Agency also disagrees with the assertion that the opposite would have led to receiving contradictory messages and creating a false sense of danger. On the contrary, this Agency considers it blameworthy that ENDESA's message created a false sense of absence of risks, which it believes was not real, for the reasons previously explained.

Regarding the claim that the amount of the fine for the infringement of Article 34 of the GDPR (800,000 euros) is disproportionate because the risk was completely mitigated by ENDESA, this Agency reiterates that this was not the case, as ENDESA focuses solely and exclusively on the risks of fraudulent contracting of ENDESA products and not on other risks. The risk to the rights and freedoms of the affected individuals still exists because they have lost control of their data.

Finally, this Agency wishes to point out that the imposition of this sanction is in no way justified by purely subjective aspects or without explaining why ENDESA has not acted diligently. On the contrary, the reasons why ENDESA should have made the communication required by Article 34 of the GDPR have been detailed, which was not properly carried out by ENDESA, violating the provisions of the applicable regulations.

Furthermore, this Agency reiterates what was stated in response to the allegations regarding the initiation agreement of the current sanctioning procedure.

For all the above reasons, the present allegation is dismissed.

Fourth.- On the impropriety of the sanction imposed for the alleged infringement of Article 44 of the GDPR

ENDESA argues that, regarding the sanction imposed for the alleged violation of Article 44 of the GDPR, there are various procedural and substantive defects that, if maintained in the resolution to be issued, would be grounds for absolute nullity of the same.

4.1 ENDESA indicates that, in procedural terms, the Agency has begun with a direct accusation in the Initiation Agreement of the current procedure, without any basis whatsoever and without any factual support. The Initiation Agreement includes a sanction of, no more and no less than, two million euros (2,000,000€), for failing to comply with the obligations established in the GDPR for international data transfers. The Agreement further aggravated this infringement due to alleged serious negligence, given that "more than four years have passed since the GDPR became applicable, yet ENDESA has not adapted the international transfers of its personal data to what is required (...)".

ENDESA finds this approach of the Initiation Agreement and the way in which this sanction has continued to be maintained in the Proposal for Resolution to be seriously disconcerting, since:

a) The Agency seems to refer to ENDESA's state of compliance regarding international transfers as of the initiation of the procedure (when it refers to...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

161/214

referring to the more than four years since the mandatory compliance with the GDPR), instead of referring to the date of the facts subject to the procedure.

In this regard, this Agency wishes to point out that, in this case, Endesa did not comply with the provisions of Decision 2021/914 despite the extension granted therein and continued to carry out international transfers to ***COMPANY.15 without assessing whether the internal regulations of ***COUNTRY.2 allowed for the guarantee of the high level of protection that the GDPR confers to data subjects, which indicates a greater intensity in the lack of diligence, since after the CJEU ruling of 16/07/2020, Endesa was aware of the limitations that international transfers to a third country whose internal regulations might not guarantee an adequate level of protection could pose for the rights and freedoms of individuals, a circumstance that is aggravated by the temporal persistence of the non-compliance, reasons that allow for the application of the aggravating factor of culpability.

Therefore, this allegation is dismissed.

b) The Agency, despite having been aware of the existence of service providers outside the European

Union during the exhaustive prior investigation it conducted, at no time requested from Endesa any justification or information regarding the mechanisms applied by Endesa to carry out those international data transfers. However, it includes a sanction for this reason in an absolutely unprecedented amount.

Regarding this lack of prior inquiry, the Proposal for Resolution states that prior actions are not mandatory, according to Article 67 of the LOPD-gdd. ENDESA agrees with this assertion, but what is also true, and it understands leaves no doubt, is that a sanction cannot be imposed without having conducted a minimal investigation of the supposedly attributed fact, or without having the slightest indication of the existence of a fact constituting an infringement, or at least, without having made a mere inquiry about the existence of the fact for which one wishes to impose a sanction. The attribution of a non-existent and unverified fact, along with the enormous amount of the fine associated with such a non-existent fact, is what is truly surprising.

In this regard, this Agency wishes to point out that, as determined by Article 67.1 of the LOPDGDD:

“Before the adoption of the agreement to initiate proceedings, and once the complaint has been admitted for processing, if any, the Spanish Agency for Data Protection may carry out prior investigative actions...” Therefore, the carrying out of these investigative actions is not mandatory.

However, it is not true that no actions were taken to verify whether there were guarantees supporting the international transfers and, if applicable, to determine the possible existence of an infringement of Article 44 of the GDPR. Thus, it could be established that neither in the contracts with its suppliers provided by Endesa nor in the General Conditions of Contracting published on its website:

<https://globalprocurement.enel.com/es/documentos/condiciones-generales-contratacion> was there any reference to the existence of adequate guarantees, so when the initiation of the sanctioning procedure was agreed upon, there were indeed indications of a possible infringement.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

162/214

Therefore, the present allegation is dismissed.

c) ENDESA argues that, considering that the security breach was notified on February 10, 2022, it is not until June 26, 2023, during the evidentiary phase of the file - that is, more than sixteen months later and only because ENDESA has pointed out the incorrectness of the accusation - that the AEPD requests, for the first time, information regarding the international transfers, which was provided by ENDESA in a timely manner, to demonstrate the regularity of the mechanisms employed.

ENDESA also points out that the Agency not only requested information on how the transfers were carried out at the time of the events but also currently. Therefore, ENDESA has the impression that attempts are being made to seek arguments to maintain an accusation initially made without any factual support, redirecting it towards another assumption that has nothing to do with the facts subject to the procedure. Furthermore, the requested information refers to requirements that not only do not exist or did not exist in any imperative norm but that, as will be argued later, were not clearly identified on the dates when the events occurred (in fact, even as of the current date, ENDESA considers it extremely doubtful that it can be argued that an Evaluation of an International Transfer is more or less correct using one methodology or another).

In this regard, this Agency wishes to point out that the proposed resolution does not modify the accusation, which remains the infringement of Article 44 of the GDPR due to the lack of guarantees for the corresponding international transfers. The contractual clauses signed between the parties may not be binding for the authorities of ***COUNTRY.2 and therefore may not be sufficient to guarantee adequate protection; hence, Clause 14 of the Implementing Decision includes the need to ensure, through an appropriate assessment of the legislation of the country in question, a level of protection equivalent to that guaranteed within the Union by the GDPR. The lack of evaluation regarding the aspects contemplated in this clause means that the guarantee that it intends to offer cannot be considered provided and, therefore, it cannot be guaranteed that the transfer is subject to adequate guarantees in the sense of Article 46.1.c) of the GDPR.

This is reflected in Recital (19) of the Implementing Decision: “The transfer and processing of personal data under standard contractual clauses must not take place if the law and practices of the third country of destination prevent the data importer from complying with those clauses (...). The parties must ensure that, at the time of submitting to the standard contractual clauses, they have no reason to believe that the law and practices applicable to the data importer do not comply with these requirements,” which is guaranteed through the assessment referred to in letter b) of Clause 14. As can also be inferred from the JUDGMENT OF THE COURT OF JUSTICE (Grand Chamber) of July 16, 2020.

“102 The referring court also wishes to know what elements must be taken into consideration to determine the adequacy of the level of protection in the context of a transfer of personal data to a third country based on the standard data protection clauses adopted pursuant to Article 46(2)(c) of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
163/214

103 In this regard, although that provision does not enumerate the different elements to be taken into account to assess the adequacy of the level of protection that must be respected in the context of a transfer of such characteristics, Article 46, paragraph 1, of the aforementioned Regulation specifies that the interested parties must enjoy adequate guarantees and have enforceable rights and effective legal remedies.

104 The evaluation required for this purpose in the context of a transfer of such characteristics must, in particular, take into account both the contractual stipulations agreed upon between the controller or the processor established in the Union and the recipient of the transfer established in the third country in question, as well as, regarding any potential access by public authorities of that third country to the transferred personal data, the relevant elements of the legal system of that country. As for this latter aspect, the elements to be considered in the context of Article 46 of the aforementioned Regulation correspond to those mentioned, in a non-exhaustive manner, in Article 45, paragraph 2, of the same.

105 Therefore, it is appropriate to respond to the second, third, and sixth preliminary questions that Article 46, paragraphs 1 and 2, letter c), of the GDPR must be interpreted as meaning that the adequate guarantees, enforceable rights, and effective legal remedies required by those provisions must ensure that the rights of individuals whose personal data is transferred to a third country on the basis of standard data protection clauses enjoy a level of protection that is substantially equivalent to that guaranteed within the Union by the aforementioned Regulation, interpreted in light of the Charter. For this purpose, the evaluation of the level of protection guaranteed in the context of a transfer of such characteristics must, in particular, take into account both the contractual stipulations agreed upon between the controller or the processor established in the Union and the recipient of the transfer established in the third country in question, as well as, regarding any potential access by public authorities of that third country to the personal data transferred in this manner, the relevant elements of the legal system of that country and, in particular, those mentioned in Article 45, paragraph 2, of the aforementioned Regulation.

In summary, Commission Implementing Decision 2021/914 of June 4, 2021, addresses the need to conduct an evaluation of the relevant elements of the legal system of the country in its clause 14, so it cannot be asserted that in the absence of an adequate evaluation of the law of the destination country, the guarantee contemplated by the Implementing Decision has been adopted.

Therefore, this allegation is dismissed.

d) In the Proposal for Resolution, the Agency continues to impose a sanction, now limited to the alleged insufficiency of the Transfer Impact Assessment mechanism (known as “TIA,” the English acronym for “Transfer Impact Assessment”), with the same amount previously imposed in the Initiation Agreement for the...

C/ Jorge Juan, 6
www.aepd.es

28001 – Madrid
sedeagpd.gob.es
164/214

absolute absence of legal coverage for the transfers. ENDESA alleges that, despite the information provided, a fine is imposed in an amount that is likely the highest imposed in the entire European Union for insufficient TIA in international transfers (although it is also possibly the only sanction imposed in the entire European Union for this reason). That is to say, despite the change in the charge (it is no longer the absence of mechanisms, but the insufficiency of the same), the amount of the sanction remains unchanged.

In this regard, this Agency reiterates that there is no modification in the charge. However, the amount of the sanction has been modified, as will be explained later.

e) Furthermore, ENDESA alleges, also in relation to proportionality, that the fact that the Agency considers that the transfer mechanism employed is not sufficiently executed (insufficiency of the TIA) should nullify the modifying cause of liability consisting of assessing serious negligence for not applying adequate mechanisms for the transfer. In this sense, the Agency applied this aggravation because it indicated that, having passed four years since the obligation of the GDPR, the transfers had not been adapted to the new regulations. By now appreciating that the mechanism employed does exist, although it is not considered entirely correct, it is clearly evident that there was no negligence of any kind. The aggravating factor would disappear and, however, the amount of the sanction remains. In this regard, this Agency reiterates the lack of diligence observed in ENDESA's actions, which did not comply with the provisions of Decision 2021/914 regarding the extension granted therein and continued to carry out international transfers to ***COMPANY.15. While it is noted that the transfer made to ***COUNTRY.1 ended before the deadline set in the execution decision, a reduction of the sanction is warranted for this reason.

f) In addition, the Proposal for Resolution states that Endesa “has made international transfers to ***COUNTRY.1 and ***COUNTRY.2, and continues to make international transfers to ***COUNTRY.2 (...)”. Notwithstanding the fact that ENDESA has not denied this at any time, and that such transfers are made in strict compliance with the regulations (as it states), as pointed out during the evidentiary phase, the analysis of the international transfers made by Endesa, both on the dates of the events subject to the sanctioning procedure and, especially, on the current date, ENDESA understands cannot be subject to specific analysis within the framework of the present sanctioning procedure. The Agency would be acting to accumulate various sanctioning procedures without complying with the established rules in the legal system for the exercise of the sanctioning power of the administration. In particular, it alleges that without opening a specific process regarding specific facts (the initially charged facts, the non-existence of mechanisms regulating the transfers, were non-existent) and, additionally, opening a kind of “separate piece” of investigation on the matter in the midst of the evidentiary phase of the sanctioning file initiated in relation to a personal data security breach, placing Endesa in a position of procedural vulnerability and violating its rights.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
165/214

constitutional right to defense, in its aspect of access to the accusation from the moment it occurs and giving the possibility to argue about the alleged facts (the facts initially contained in the Initiation Agreement were, in their opinion, non-existent, so the new approach adopted in the Proposal for Resolution could never be subject to allegations by Endesa).

In this regard, this Agency wishes to point out that it is stated in the initiation agreement that neither in the contracts provided with their suppliers nor in the General Contracting Conditions published on their website: <https://globalprocurement.enel.com/es/documentos/condiciones-generales-contratacion> was there any reference to the existence of the same. Therefore, the right to defense has not been violated. ENDESA has been able to formulate allegations and provide whatever it deemed appropriate regarding its rights both to the initiation agreement and to the proposal for resolution.

Thus, the present allegation is dismissed.

g) ENDESA alleges that a sanction is imposed for a formal requirement that is not included in the GDPR, nor in the LOPD-gdd, nor in any other imperative norm of the legal system of the European Union ("EU"). Specifically, the aforementioned Transfer Impact Assessment mechanism, which is, in reality, nothing more than a mechanism or methodology of analysis derived from the Judgment of the Court of Justice of the European Union ("CJEU") in the Schrems II case, but which is not even established in that judgment in detail, but is progressively developed from the year 2020 in various interpretative guidelines from different bodies, such as the EDPB, which as late as June 2021 published its Recommendations 1/2021 on this matter. ENDESA indicates that the EDPB guidelines do not constitute imperative law, but are configured as interpretative guidelines of the regulation that should be considered as best practices or compliance formulas.

Notwithstanding this, Endesa indicates that it duly fulfilled its obligations of due diligence and proactive responsibility, attending to the requirements of the aforementioned Judgment and the Recommendations of the EDPB, going so far as to apply the most rigorous compliance formulas existing among experts in the matter. Formulas that, however, the Agency considers to be insufficient. Undoubtedly, in its opinion, the sanction of €2,000,000 for insufficiency of the TIA, if maintained, will be discussed among privacy experts throughout the EU and the rest of the world as a milestone, a novelty, and a first case of sanction for this reason, and will be criticized both for the strictness of its interpretation of the Schrems II Judgment and for the amount of the imposed sanction.

In this regard, this Agency wishes to point out that compliance with clause 14 of the Implementing Decision is not a formal requirement but a necessary requirement for international transfers to be carried out with the necessary guarantees for the protection of the fundamental rights of the data subjects. Nevertheless, in any case, the amount of the sanction has been reduced.

4.2. In addition to all the above, and already in the material scope, ENDESA categorically denies having failed to comply with the obligations established by the GDPR in relation to international transfers, for the following reasons:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
166/214

a) Firstly, because, contrary to what the Agency indicated in the Initiation Agreement, Endesa had the legally required mechanisms to carry out international data transfers outside the EU. Specifically, it had signed the standard contractual clauses of the EU that were valid at the time they were used, namely, the model approved by the European Commission decisions 2001/497/EC, 2004/915/EC, and 2010/87/EU, which were perfectly valid until December 27, 2022, nothing more and nothing less. The Resolution Proposal extensively develops the requirements set forth by the "Commission Implementing Decision (EU) 2021/914 of June 4, 2021, regarding standard contractual clauses for the transfer of personal data to third countries in accordance with Regulation (EU) 2016/679 of the European Parliament and of the Council" (hereinafter, the "Decision"). Endesa argues that the content of this Decision has nothing to do with the object of the present procedure, since that Decision approved models of standard contractual clauses that could coexist with the previous ones, which were perfectly valid until December 27, 2022.

In this regard, it should be noted that this Agency has taken into account that contracts entered into before September 27, 2021, under Decision 2001/497/EC or Decision 2020/87/EU could remain in force until December 27, 2022. However, from that date onwards, Endesa has not complied with the requirement set forth in clause 14 of the aforementioned Implementing Decision, which is why this Agency considers that Endesa has infringed Article 44 of the GDPR, and therefore, this allegation is dismissed.

b) Secondly, Endesa claims that the reinforcement mechanisms for the Standard Contractual Clauses were analysis protocols derived from the ruling of the CJEU in the Schrems II case on July 16, 2020. However, the specification of these protocols was neither easy, nor quick, nor unequivocal, nor has it been incorporated into any type of binding regulation in the European Union.

Endesa indicates that the EDPB, after publishing an initial document titled “Frequently Asked Questions on the Judgment of the Court of Justice of the European Union in Case C-311/18,” took until June 18, 2021, to publish its document “Recommendations 01/2020 on measures that complement transfer instruments to ensure compliance with the level of protection of personal data in the EU” (the “Recommendations”). The Recommendations are even subsequent to the Decision of the European Commission.

Delving into detail, Endesa explains that the Decision is based on the need for the signing parties (data exporter and importer) to ensure that they have carried out a series of analyses that, as the Agency cites in its Resolution Proposal, are incorporated into the new standard contractual clauses (which are not the ones Endesa had at the time of the events) through declarations from the parties.

For its part, the Recommendations establish a framework and a methodology for evaluation and analysis that may allow for the conclusion that the specific transfer does not pose a risk to the rights and freedoms of the affected data subjects, taking into account all relevant elements, such as the legislation.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
167/214

the destination country, the type of data transferred, or the profile of the recipient, among others.

ENDESA claims that it has provided sufficient documentation to the file to demonstrate, firstly, that it had a legally valid mechanism for the transfer (the standard contractual clauses of the Commission still valid at that time) and, secondly, that it had exercised due diligence by conducting a Transfer Impact Assessment, taking into account the elements mentioned in the Schrems II ruling.

ENDESA believes that the Proposal for Resolution does not justify the imposition of the sanction in this area. Not only because Endesa (in its opinion) has indeed demonstrated compliance with legal obligations and best practices in the matter, both for the case of ***COUNTRY.1 and for the case of ***COUNTRY.2 (despite the difference that the AEPD seems to see, in both cases a Transfer Impact Assessment has been carried out and standard contractual clauses were in place).

But because ENDESA understands that if the AEPD considers that the data transfers to ***COUNTRY.1 and ***COUNTRY.2 violate the GDPR, it must specify the exact reasons for such consideration.

And, if it is to assert that Endesa's criteria are incorrect and the legislation of both countries does not meet a sufficient level of security, it must indicate in what aspects the Agency believes that those legal systems incur such deficiencies. This is especially relevant in the case of these two countries, ***COUNTRY.1 and ***COUNTRY.2, for which the AEPD had expressly authorized such processing operation to Endesa under the legal framework prior to the GDPR.

In ENDESA's opinion, it is very difficult to understand and justify how, in this case, a data transfer expressly authorized by the Agency could cease to be correct when the legislation of the destination country remains the same (or, even, may have improved over the years) and Endesa has also added the analyses and methods required by the new European legislation in this regard.

In this regard, this Agency wishes to point out that clause 14 of the aforementioned Implementing Decision does contain a precise statement regarding the need to take into account, to provide the guarantee, whether the law and practices of the destination country respect the rights and freedoms of the data subjects, and in particular indicates that the following aspects should be considered:

- i) the specific circumstances of the transfer, such as the length of the processing chain, the number of parties involved, and the transmission channels used; the anticipated subsequent transfers; the type of recipient; the purpose of the processing; the categories and format of the personal data transferred; the economic sector in which the transfer takes place; the location of the storage of the transferred data;
- ii) the law and practices of the third country of destination—especially those requiring the communication of data to public authorities or authorizing access by such authorities—that are relevant given the specific circumstances of the transfer, as well as the applicable limitations and

guarantees;
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
168/214

iii) the relevant contractual, technical, or organizational guarantees provided to complement the guarantees set forth in this terms and conditions document, particularly including the measures applied during the transfer and processing of personal data in the destination country.

However, the documentation provided by ENDESA does not assess the law and practices of ***COUNTRY.2 regarding the requirement to communicate personal data to the authorities of the country.

ENDESA understands that this is no different from the exercise carried out by the CJEU in the Schrems II ruling, where it detailed one by one the reasons, cases, situations, and specific examples for which the European Court considered that the legal framework of the United States did not meet the sufficient guarantees that must be required from the perspective of the EU regarding data security. That detailed and substantiated breakdown allowed the CJEU to declare the invalidity of the Privacy Shield agreement. However, ENDESA claims that the Agency, in this case, determines that it has violated the GDPR because, despite the existence of a valid transfer mechanism (standard contractual clauses) and a privacy impact assessment, the data transfer poses a risk to the rights and freedoms of individuals. The vagueness of this accusation can only be grounds for absolute nullity (in ENDESA's opinion), as a consequence of the lack of specificity in ENDESA's actions.

In this regard, this Agency wishes to point out that it has not made any pronouncement on whether the law of ***COUNTRY.2 offers an adequate level of protection or not, a matter that must be assessed and documented by ENDESA so that the guarantee contained in clause 14 of the Adequacy Decision can be considered provided, and to base the transfer on the standard contractual clauses contained in Commission Implementing Decision (EU) 2021/914 of June 4, 2021.

For all the above reasons, this allegation is dismissed.

c) ENDESA claims that the level of legal uncertainty generated by the Schrems II ruling regarding the manner of conducting international data transfers has been a constant since its publication, to the point that, even currently, there is no absolute consensus on how to conduct the necessary analyses prior to making a data transfer outside the EU, beyond the "soft law" norms such as the aforementioned Recommendations of the EDPB. The vast majority of European companies as of now, September 2023, still do not know what they need to comply with or how, and those that have made some attempts to adapt to what is supposed to be required by the Schrems II ruling are only conducting tentative work that has not been validated by any standard. Obviously, this situation affects the element of culpability as the essence of sanctioning administrative law.

In that environment, ENDESA understands that imposing a fine of €2,000,000 for the alleged insufficiency of the TIA is presented as an absolutely inappropriate penalty, in addition to being disproportionate and extravagant. ENDESA asserts that the legal uncertainty arising from the indefiniteness of the regulatory framework cannot harm economic operators, especially when they demonstrate having deployed all due diligence.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
169/214

due diligence to address extremely complex requirements from the most specialized legal perspective in a matter such as personal data protection regulations. And, in parallel, without the Agency pointing out a single instance in which the legislation of the destination country, as well as the specific transfer, could pose a risk to the rights of the data subjects, having previously authorized exactly the same transfer, as stated.

In this regard, this Agency wishes to point out that, regarding the culpability of ENDESA, it has already

been mentioned that the Implementing Decision 2021/914 provided that contracts entered into before September 27, 2021, based on previous Decisions, offered adequate guarantees until December 27, 2022. Therefore, Endesa was aware that from that date onwards, its contract had to incorporate the new contractual clauses that require an assessment of whether the internal regulations of ***COUNTRY.2 guarantee the continuity of the level of protection.

Thus, this allegation is dismissed.

Fifth.- Regarding the grading of the sanction imposed on Endesa and the relative lack of proportionality of the Proposal for Resolution

In the Proposal for Resolution, the AEPD, in response to the allegation made by Endesa regarding the relative lack of proportionality of the proposed sanctions to Endesa compared to those proposed in other proceedings (which, in ENDESA's opinion, are much more serious), presents certain reasons that ENDESA considers entirely insufficient to dismiss the allegation made by Endesa.

And it argues that, although the AEPD indicates that each case is different and must be analyzed according to its own circumstances, there are a series of objective and comparable facts (since they are included in the AEPD's own sanctioning resolution) that leave no room for doubt (in its opinion) in the sense indicated by Endesa in its allegations; that is to say, that the sanctions proposed in the context of this proceeding are entirely disproportionate.

In this regard, it details, for example:

a. In relation to the AEPD's resolution regarding procedure E/05937/2021, which concluded with the imposition of a warning sanction even when the notification of the data security breach to the AEPD was reported, according to what the AEPD indicated in its resolution, "after a period exceeding 72 hours from the time it became aware that it had occurred," the AEPD indicates in the Proposal for Resolution that Article 33 of the GDPR was not considered infringed since "the data controller duly indicated the reasons for the delay in notifying the supervisory authority."

ENDESA explains that the reason for such a delay in procedure E/05937/2021 was that the notification was delayed "due to the investigations carried out to clarify whether there was data access and/or fraudulent activity, which required multiple analyses by the security teams." ENDESA finds it surprising that, in this case, contrary to what the AEPD indicates in the Proposal for Resolution, the AEPD did not consider that "the notification of the breach should not be made after

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

170/214

that the data controller has conducted a detailed examination of the situation, but only when the controller detects that the breach has occurred, and this analysis may be carried out in parallel with the notification."

At this point, ENDESA understands that it can be observed how the AEPD treats two circumstances, which it considers identical (delay in the notification of the breach), in different ways, demonstrating a clear disproportionality (in its opinion).

In this regard, this Agency reiterates that the facts subject to both proceedings are not comparable, as detailed in the response to the allegations regarding the initiation agreement of the present procedure. For its part, ENDESA itself indicated on page 24 of its allegations to the resolution proposal of the present procedure that "it is not true, as stated in the Resolution Proposal, that Endesa did not notify the incident at the first moment it became aware of the announcements published on Facebook because it was conducting a 'detailed examination of the situation.' On the contrary, Endesa conducted this examination of the situation as soon as it became aware of it, but determined, following the guidelines of the AEPD and the CEPD in this regard, that the notification threshold established in Article 33 of the GDPR was not reached."

The reasons for ENDESA's delay in notifying the supervisory authority were due to its failure to properly qualify the incident as notifiable, which is why this Agency considers that it violated Article 33 of the GDPR.

Therefore, this allegation is dismissed.

b. Regarding the AEPD's resolution related to procedure PS/00118/2020, which concluded with the imposition of a warning sanction even when: (i) the notification of the data security breach to the AEPD was made two months after the investigated entity became aware of it; (ii) the investigated entity in this case did not provide the AEPD with the risk analysis of the processing for which it is responsible (while Endesa did); and (iii) the investigated entity stated that "the machine affected by the security incidents was technically obsolete," and therefore did not have adequate security measures for the risk posed by the processing, the AEPD indicates in the Resolution Proposal that "the degree of reproachability of the actions of the data controller allowed for the substitution of the imposition of a fine with a warning." ENDESA finds it surprising how, in a case where the data controller: (i) notifies a security breach late (with a 2-month delay) without any apparent reason (in its opinion), when in the case at hand, Endesa has justified how it carried out risk analyses of the breach on three occasions, determining in the last one that it was likely to pose a risk to the rights and freedoms of the data subjects; and (ii) does not have, in its opinion, the minimum required security measures (conducting risk analyses and maintaining updated systems), when Endesa conducted the corresponding risk analysis that it provided to the AEPD and had security measures that, in ENDESA's opinion, were adequate to the risk, the AEPD understands that its conduct...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

171/214

conduct is not deserving of reproach, whereas, in the present case, it not only intends the opposite but proposes to impose the harshest sanctions to date.

In this regard, this Agency reiterates the differences noted in the response to the allegations regarding the initiation agreement of the present procedure: among others, the incident lasted only three days and affected a maximum of 75,000 interested parties, compared to the incident involving ENDESA, which lasted months and affected millions of interested parties, and it was considered that the degree of reproachability of the actions of the data controller allowed for the substitution of a fine with a warning, which is not the case in the present sanctioning procedure against ENDESA. Furthermore, this Agency reiterates that the measures adopted by ENDESA prior to the incident were not appropriate given the risk.

Recital 148 of the GDPR allows for the substitution of the imposition of a fine with a warning, taking into account "the nature, gravity and duration of the infringement, its intentional character, the measures taken to mitigate the damages suffered, the degree of responsibility or any relevant prior infringement, the manner in which the supervisory authority became aware of the infringement, compliance with measures ordered against the controller or processor, adherence to codes of conduct, and any other aggravating or mitigating circumstances."

In the present case, this Agency has assessed such circumstances for each of the infringements (all of which are detailed in the Legal Grounds VI, IX, XII, XV, XVIII, respectively) and has considered that what corresponds in the present infringements is not to substitute the fine sanction with a warning. Therefore, the present allegation is dismissed.

c. Regarding the resolution of the AEPD related to procedure PS/00254/2019, which concluded with the imposition of a warning sanction even when the AEPD considered that, from the investigations carried out, there was a lack of diligence on the part of the controller in implementing relevant security measures, even indicating that "the absence of consideration of the risk that unauthorized access by third parties to data of subscribers related to a political party may pose, and its subsequent public dissemination, aggravates the culpable and sanctionable reproach of the conduct."

ENDESA is again surprised at how the AEPD, in a case where (in its opinion) the AEPD clearly indicates that the data controller did not take into account the risk that unauthorized access to data of subscribers related to a political party may pose, and its subsequent public dissemination, and that, therefore, this "aggravates the culpable and sanctionable reproach of the conduct," states in the Proposal for Resolution that "the circumstances of the breach differ from the severely negligent conduct of ENDESA."

The AEPD understands that the actions of ENDESA, which in the context of this procedure and, among others: (i) had analyzed the risk posed to the interested parties by the compromised processing; (ii) had implemented security measures deemed adequate (in its opinion) to the risk in accordance with industry standards; (iii) has conducted up to 3 risk analyses regarding the impact that the incident may have...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
172/214

regarding the rights and freedoms of the affected data subjects; (iv) has implemented, after the breach, security measures to try to prevent a recurrence of the security violation and has attended to the affected data subjects in such a way that the identified potential risk has not materialized; and (v) has responded to 5 information requests issued by this AEPD, deserves a greater reproach (it insists, the greatest reproach to date regarding security violations) than an entity that had not even considered the risk that access to special categories of data could entail.

In this regard, this Agency reiterates that the security measures adopted by ENDESA prior to the incident were not appropriate based on the risk, that although it prepared three reports on the breach, it did not correctly classify the incident as reportable, that at best what has been mitigated is only the risk of fraudulent contracting of ENDESA products, and that responding to the information requests from this Agency is a legal obligation established by the applicable regulations, the violation of which may be subject to a specific sanctioning procedure.

Regarding the paragraph of the resolution of PS/00254/2019 cited by ENDESA, it only referred to the fact that the entity had not considered that the contact data for sending a newsletter related to a political party could be considered special categories of protected data, not due to the data exposed per se but due to its possible combination with other sources.

In any case, it is no less true that in such resolution it was deemed appropriate to replace the monetary fine with a warning, taking into account, among other factors, the diligence carried out by the entity regarding the prompt communication of the security breach to this Spanish Agency for Data Protection, which has not occurred in the present case.

Therefore, this allegation is dismissed.

Considering all of the above, ENDESA believes that the disparity of criteria that the AEPD applies when analyzing the security measures implemented by the entities investigated by the AEPD, as well as the consequences that arise in terms of administrative sanctions from the alleged violations contained in the Proposal for Resolution, is evident, and therefore reiterates the lack of relative (and absolute) proportionality of the Proposal for Resolution.

In this regard, this Agency reiterates everything previously stated, and therefore this allegation is dismissed.

Finally, ENDESA reiterates, as it did in the context of the allegations to the Initiation Agreement, its disagreement with the application of the circumstances that the AEPD considers aggravating of ENDESA's conduct. Without prejudice to ENDESA's belief that its actions in the context of this file have been fully diligent and, therefore, should not be subject to any reproach (much less to a reproach as disproportionate as that proposed in the Proposal for Resolution), in the event that the AEPD continues to believe otherwise, ENDESA understands that:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
173/214

(i) A "serious lack of diligence" on the part of Endesa should not be considered an aggravating circumstance. As stated in the previous allegations, ENDESA believes that all actions taken by Endesa within the framework of this file were carried out: (a) following a reasonable interpretation of the applicable data protection regulations and the interpretative guidelines published by the AEPD and the

CEPD; and (b) with the utmost diligence possible at a time of maximum concern within the company regarding what had occurred.

In this regard, given that it has been demonstrated, in accordance with the indications in the previous allegations, ENDESA argues that:

- (a) the report prepared by ***EMPRESA.1 is completely biased and subjective, and there is a well-founded suspicion that it was prepared in bad faith long after the occurrence of the events, and therefore it should not be taken into account within the framework of this file;
- (b) Endesa did not consciously reach out to Facebook Ireland as it did not want to accept Irish jurisdiction for the purposes of any potential subsequent judicial or administrative claim (not for data protection purposes), and doing so had no practical utility in terms of protecting the rights and freedoms of the affected data subjects (the credentials of ***HERRAMIENTA.2 and ***HERRAMIENTA.1 compromised, except for one, had already been disabled);
- (c) Endesa had implemented (in its opinion) adequate security measures in its systems commensurate with the risk (as evidenced by the risk analyses provided to the AEPD, the forensic report submitted to the AEPD, and the fact that, for years, no similar incident occurred);
- (d) Endesa deployed, once it became aware of the incident and with the utmost diligence possible, appropriate measures (in its opinion) to disable the compromised accounts as quickly as possible (as indicated in the Proposal for Resolution, several months never elapsed between when Endesa became aware of the account compromise and their disabling);
- (e) When conducting the initial analyses regarding the need to notify the AEPD of the security breach, Endesa made a reasonable interpretation (in its opinion) based on the regulations and guidelines published on the matter and proceeded to notify the AEPD of the breach within 24 hours of becoming aware that it could pose a (real) risk to the rights and freedoms of the affected data subjects. It is, in every way, unsustainable for ENDESA to maintain that "every incident" must be reported to the AEPD;
- (f) When notifying the incident to the affected data subjects, Endesa followed (in its opinion) the indications in the guidelines and infographics of the AEPD, informing the data subjects of those aspects that, given the time elapsed since the breach occurred, were most useful to them; and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

174/214

- (g) Endesa has complied and continues to comply (in its opinion), in a completely scrupulous manner, with the obligation to implement adequate guarantees for the execution of international transfers. ENDESA considers that the application of the aggravating factor of serious lack of diligence by the AEPD is totally unfounded and disproportionate, and does not reflect the reality of the actions carried out by Endesa.

In this regard, this Agency reiterates what was stated in response to the allegations regarding the initiation agreement and the proposed resolution of this sanctioning procedure:

- (a) The determination of the commission of infringements by ENDESA, as well as its serious negligence, has been evidenced throughout this procedure not by the report of ***COMPANY.1, but by all the documentation in the file, and no content from the aforementioned report is cited in the Legal Grounds to substantiate either the infringements or the grading of the amount of the sanctions, beyond the responses to the allegations presented by ENDESA in this regard;
- (b) ENDESA took more than a month to disable the credentials and although only one credential remained enabled, it was sufficient to access the personal data held in ENDESA's systems. Furthermore, this Agency reiterates that it is only competent to assess whether ENDESA complied with personal data protection regulations and not to evaluate issues related to intellectual property or other areas. In this sense, in the present case, a series of advertisements had been published offering access to ENDESA's systems, which allowed access to personal data owned by ENDESA, which it processed in its capacity as data controller. As such, it should have adopted a series of measures, among others, to ensure that such advertisements were removed. If it was necessary to contact Facebook Ireland for this, then that is what should have been done. Finally, ENDESA also did not have

certainty that the compromised users were only those of which it was aware, making it necessary to seek assistance from Facebook to remove the advertisements in question;

(c) This Agency reiterates that ENDESA did not have appropriate security measures in place prior to the incident, based on the risk (and the forensic report does not indicate anything in this regard, but rather analyzes the measures implemented as of the date of the report). The fact that no similar incident had occurred of which ENDESA was aware does not imply in any way that the security measures were appropriate, but simply that ENDESA was not aware of any similar incident. It also did not adopt adequate measures during the security incident to effectively mitigate the risk, and this is without prejudice to the fact that it adopted a series of measures, such as resetting user passwords, monitoring publications on Facebook, attempting to remove the aforementioned advertisements, disabling the possibility of maintaining simultaneous sessions, and increasing the traceability of access to ***TOOL.1;

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
175/214

(d) ENDESA became aware on August 24, 2021, that there were advertisements published on Facebook selling access credentials to its systems, and in its first report of the personal data breach, dated September 14, 2021, the validity of the accesses had already been verified. In any case, on October 27, 2021, ENDESA received an email from ***COMPANY.1 indicating that there were five compromised users, and it was not until November 29, 2021, that they were disabled. That is to say, the accounts were not disabled until more than a month had passed.

(e) This Agency does not assert that “every incident” must be reported to the supervisory authority. However, in this case, this Agency considers that ENDESA has not made an adequate interpretation of whether the breach of personal data security was reportable due to involving a risk to the rights and freedoms of natural persons, as detailed extensively in the Legal Grounds of this resolution.

(f) ENDESA has not duly provided the data subjects with the information required by Article 34 of the GDPR, as detailed extensively in the Legal Grounds of this resolution.

(g) ENDESA has complied and continues to comply (in its opinion), in a completely scrupulous manner, with the obligation to implement adequate safeguards for the execution of international transfers; however, ENDESA has not duly complied with the obligations established by Article 44 and subsequent articles of the GDPR, as detailed extensively in the Legal Grounds of this resolution. ENDESA considers that the application of the aggravating factor of serious lack of diligence by the AEPD is completely inappropriate and disproportionate, and does not reflect the reality of the actions carried out by ENDESA.

In this regard, this Agency reiterates everything detailed in the response to the allegations regarding the initiation agreement and proposed resolution of this procedure.

And for all the above reasons, it considers that ENDESA's actions have been severely negligent, and therefore dismisses this allegation.

(ii) ENDESA argues that the “linkage of the infringer's activity with the processing of personal data” should not be considered as an aggravating circumstance. As already indicated in the allegations to the Initiation Agreement, the activity of marketing electricity necessarily implies that ENDESA is accustomed to “the processing of personal data,” but that this should constitute an aggravation when the majority of companies worldwide process data of customers and third parties and engage in an activity that involves being in constant contact with them is difficult to perceive, since, if this were the case, this aggravating circumstance (which should be exceptional) would be applied to the vast majority of cases analyzed by the AEPD, completely distorting the nature of said aggravating factor (as is currently happening due to the excessive application, in ENDESA's view, that the AEPD is carrying out of this aggravating circumstance).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid

In this regard, this Agency reiterates that the Spanish legislator has included in the LO-PDGDD such circumstance when determining the imposition of a sanction, and that this is what this Agency does, taking such circumstance into consideration.

And that it is not the same for the purposes of deciding on the imposition of an administrative fine to consider an infringement committed by a natural person or a small company unaccustomed to processing personal data, than to consider that of a large company like ENDESA, accustomed to processing personal data of millions of customers and non-customers, with a long history in this regard. Of course, it is considered that the infringement is more serious for the purposes of imposing a fine if the data controller is among the latter, as is the case with ENDESA. This has also been pointed out by the Audiencia Nacional in its SAN 65/2017, of February 7, 2017, when it stated the doctrine of the Supreme Court, "in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

Additionally, and for the sake of brevity, ENDESA reiterates what has already been indicated in its written allegations to the Initiation Agreement regarding the lack of application, in the Proposal for Resolution, of mitigating factors concerning ENDESA's conduct, such as: (i) the measures taken by ENDESA to mitigate the damages suffered by the affected parties (as evidenced, ENDESA, prior to the initiation of this file, had already adopted the appropriate technical and organizational protective measures, in its opinion, to ensure that no risk materialized for the rights and freedoms of the affected parties and had provided individual and personalized assistance for this purpose); (ii) cooperation with the supervisory authority (ENDESA has responded, in a timely manner, to 6 requests issued by the AEPD); and (iii) the lack of benefits obtained (ENDESA has been clearly harmed by the security breach, as it has seen how third parties outside the organization accessed its systems and the data contained therein for an illegitimate purpose).

In this regard, this Agency reiterates that (i) having reviewed the contracts made by ***EMPRESA.9 to prevent new fraudulent registrations cannot be considered a mitigating factor, when it is an obligation imposed by the regulations and that having adopted appropriate measures to the risk afterwards has already been assessed as a mitigating factor for the alleged infringement of Article 32 of the GDPR; (ii) responding to each of the information requests sent by this Agency is not considered a mitigating factor since it is an obligation contemplated in the applicable regulations, the infringement of which is subject to a subsequent sanctioning procedure (Article 52 of the GDPR and Article 72.1.ñ) of the LOPDGDD); and (iii) the lack of benefits obtained by ENDESA cannot be considered a mitigating factor, according to the Judgment of the Audiencia Nacional, of 05/05/2021, rec. 1437/2020, which states: "On the other hand, it should be appreciated as a mitigating factor the non-commission of a previous infringement. Well, Article 83.2 of the GDPR establishes that the following circumstance must be taken into account for the imposition of the administrative fine, among others: 'e) any previous infringement committed by the data controller or the processor.' It is an aggravating circumstance that the prerequisite does not concur."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

177/214

for its application implies that it cannot be taken into consideration, but it does not imply or allow, as the claimant intends, its application as a mitigating factor."

Furthermore, this Agency refers to what has already been indicated in the response to the allegations regarding the initiation agreement of the present sanctioning procedure.

For all the above, the present allegation is dismissed.

IV

Integrity and confidentiality

Article 5.1.f) "Principles relating to processing" of the GDPR establishes:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')." In the present case, ENDESA had signed a contract with ***EMPRESA.1 on June 1, 2020, to market ENDESA's products and services through various commercial actions. To this end, on July 28, 2021, ENDESA issued an authorization to ***EMPRESA.1 for subcontracting in favor of ***EMPRESA.9 to handle the telemarketing of clients on behalf of ENDESA, and the start date for the subcontracted work was established as August 1, 2021.

On August 24, 2021, ENDESA detected an advertisement on the social network Facebook selling a user of the application ***HERRAMIENTA.1 with access to customer information. And on September 10, 2021, ENDESA verified the truthfulness of the advertisement and identified the credentials of the application user that were being used by the advertiser to sell access. That is, by September 2021, it had been verified that the confidentiality of the databases owned by ENDESA had been compromised. Subsequently, on October 19, 2021, ***EMPRESA.1 detected that a user of ***EMPRESA.9 had attempted to carry out a fraudulent registration, which is why on October 27, 2021, it sent a certified letter to ***EMPRESA.9 communicating the definitive closure of the sales campaign for ENDESA's supply contract effective October 19, after having suspended such campaign provisionally on the same day.

On October 20, 2021, ***EMPRESA.1 sent a communication to ENDESA indicating the operations affected by the fraudulent practice of ***EMPRESA.9, identifying 137 contracts made and another 7 operations pending validation by ENDESA that had not been registered. (...). Also, 172 orders that were pending validation by the back office of ***EMPRESA.9 were identified and blocked so that their contracting would not be processed.

That is to say, since September 2021, ENDESA was already aware of the existence of a violation of personal data security and since October 2021 that the confidentiality and integrity of the data of 137 interested parties had been compromised and that there were another 179 possible interested parties whose data were more than likely to have been compromised.

For its part, on October 27, 2021, an email was sent to ENDESA in which an email from the manager of ***EMPRESA.9 was attached, communicating to ***EMPRESA.1 the complaints filed with the Police of ***PAÍS.1 on October 19, 2021, against 23 sales agents who had "been given access to our database to carry out sales, illegally using the databases and the information presented in them for profit from another purpose," (...)

On October 27, 2021, ***EMPRESA.1 received an email from the manager of ***EMPRESA.9, which that same day ***EMPRESA.1 forwarded to ENDESA, detailing the inquiries made regarding the fraudulent practice carried out by some of its agents and their modus operandi since some of the salespeople had decided to cooperate after seeing the complaint filed against them with the Police. In this email, the three ways of operating, according to the management of ***EMPRESA.9, of the salespeople were detailed:

1. They contacted the client and explained the product; if the client agreed and was aware of the contracting, they proceeded with the closure. However, the client raised the objection indicating that they could not respond to the SMS for various reasons (blocked for SMS, did not have a mobile phone, did not have battery, about to travel, etc.). What the salesperson did was obtain a number from another client who was with ENDESA and asked this latter to respond to the SMS.

2. Through the internet, the salespeople contracted the program ***PLATAFORMA.1 (***HERRAMIENTA.1). As can be seen in images 4.1, 4.2, 4.3, and 4.4 attached in Document 2 accompanying this writing, different people "marketed" access to the program of ***PLATAFORMA.1 of Endesa. What the salespeople did was use this tool to extract data from Endesa clients, so the recordings were made with other people.

3. Another case involved clients who at some point did not want to pass texts because they were too long and got tired of receiving several calls. What they did in this case was simulate sales with other

people, and the message was also responded to by others.”

With the detail of this modus operandi, it is evidenced that the integrity and confidentiality of the personal data of at least those clients who had been fraudulently registered had been compromised, since

179/214

that in order to proceed with the registration it was necessary to access and modify their data with false ones.

Also, in this email dated October 27, 2021, ***COMPANY.1 identified five users of ***TOOL.1 involved in the violation of personal data security (used by ***COMPANY.9) and attached screenshots of Facebook ads offering the rental and/or sale of access credentials to the ***TOOL.1 application.

As a result of this situation, ENDESA verified that from July 1, 2021, the sales volume of ENDESA experienced an unusual and unjustified increase (specifically, sales increased by more than 500%), which could be representative of the irregular actions of the personnel hired by ***COMPANY.9.

On January 17, 2022, new ads were published on Facebook by the user B.B.B., which affected the customer energy databases of ENDESA. Therefore, at least during the month of January 2022, the confidentiality of the data contained in the database owned by ENDESA continued to be inadequately guaranteed.

On February 7, 2022, ENDESA sent a burofax to FACEBOOK SPAIN S.L. indicating that there were users publishing information that could constitute a crime and requested its removal, from which it is inferred that the ads selling credentials to access ***TOOL.1 were still published, compromising the confidentiality of the data contained in that system.

On February 8, 2022, after the appropriate investigations, ENDESA became aware of certain coincidences between the data appearing in the published databases and those that could be included in ENDESA's commercial system, ***TOOL.2.

ENDESA conducted a new assessment of the incident and on February 9, 2022, verified the veracity of the latest ads and the identity of the two advertisers, both former employees of ENDESA's suppliers with access to ***PLATFORM.1 (***TOOL.1). A total of nine compromised users were detected between September 2021 and January 2022, who were being used by the Facebook advertisers to sell access to ***PLATFORM.1 (***TOOL.1). Additionally, it was verified that six of them had access to ***TOOL.2. The validity of the credentials was also confirmed, in all cases assigned to ENDESA suppliers for customer acquisition and service tasks.

That is to say, it was confirmed that the confidentiality of the data contained in ***TOOL.1 and ***TOOL.2 had not been sufficiently guaranteed since they were made available to unauthorized third parties, which also put the integrity of the data at risk by enabling numerous fraudulent registrations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

180/214

On June 27, 2022, the AEPD requested justification from ENDESA regarding the number of individuals affected by the violation of personal data security, and the analysis provided on July 26, 2022, is included below:

“In the analysis carried out for the correct identification of the customers whose data had apparently been unlawfully taken from the tool ***HERRAMIENTA.1 and, therefore, could potentially have been processed without their consent, the following actions were undertaken:

(i) First, once the provider ***EMPRESA.1 informed ENDESA of the irregular practice committed by personnel from ***EMPRESA.9 and the appropriate verifications were conducted, it was confirmed that this practice did not extend to other providers.

(ii) Second, once the possible origin of the allegedly irregular contracts was identified, the temporal scope of their actions was delineated, verifying that from July 1, 2021, the sales volume of ENDESA experienced an unusual and unjustified increase (specifically, sales increased by more than 500%), which could be indicative of the irregular actions of the personnel contracted by ***EMPRESA.9. On October 15, 2021, the activity of this subcontractor was terminated – as a result of the termination of

the contract with ***EMPRESA.9 – thus limiting the temporal scope of the analysis of the contracts to the period between July 1 and October 15, 2015 (this year is considered a typographical error and is interpreted as 2021).

(iii) Finally, a quality control and audit of the contracts carried out by ***EMPRESA.9 within the established temporal scope was conducted. In this analysis, cases were excluded where the customers themselves, on whose behalf a contract was made involving ***EMPRESA.9 – within the defined timeframe – had contacted ENDESA to carry out actions related to their contracts (for example, commercial inquiries), which indicated that the customers were aware of their contracts and did not express any objections.

The number of potential individuals affected by the resulting incident was: 760 customers.

That is to say, ENDESA acknowledges that the confidentiality and integrity of the personal data of 760 customers were compromised, but only regarding the contracts in which ***EMPRESA.9 was involved between July 1 and October 15, 2021, in which the customers themselves were allegedly aware of their contracts and did not raise any objections in this regard.

However, ENDESA has indicated that the fact that two or more individuals could access ***HERRAMIENTA.1 simultaneously with the same user, a multi-session option enabled when the personal data security breach occurred, and that, in relation to the compromised users and the period in which this incident occurred...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

181/214

developed, the lack of a record (logs) of the use of the tools ***HERRAMIENTA.1 or

***HERRAMIENTA.2 prevents it from knowing the number of records of the applications that could have been actually accessed, at least since it became aware in August 2021 of the publication of the announcement on Facebook.

In this regard, ENDESA itself has acknowledged that the approximate volume of supply points that can potentially be consulted from the tool ***HERRAMIENTA.1 is 30.6 million supply points and 8.6 million gas supply points, from which technical data could be known – such as power, voltage, estimated consumption. And that in the case of customers with a valid contract, the approximate volume that a user could consult was 4.8 million electricity customers and 1.2 million gas customers, from which the name and surname of the holder of the supply point, National Identity Document number, contract number, CUPS, annual billing amount, debt indicator, information on prices, technical data related to the supply point, consumption data, and usage graph could be consulted.

Regarding the tool ***HERRAMIENTA.2, ENDESA has acknowledged that “identified committed users could access data related to customers with a valid contract with ENDESA, with the approximate volume during the period from July 1, 2021, to October 15, 2021, being 4.8 million electricity customers and 1.2 million gas customers. As for the type of data that could be viewed, they are mainly: name and surname of the holder of the supply point, postal address, National Identity Document number, CUPS, phone number, email, contracted products, invoices, bank account number, credit quality, debts with the company.”

That is to say, the potential affected parties by the violation of the security of the personal data in question, regarding the tool ***HERRAMIENTA.1, were 30.6 million supply points and 8.6 million gas supply points of users who are not customers of ENDESA, as well as data from 4.8 million electricity customers and 1.2 million gas customers of ENDESA.

Likewise, regarding the tool ***HERRAMIENTA.2, the confidentiality of the personal data of 4.8 million electricity customers and 1.2 million gas customers of ENDESA was not guaranteed.

All of the above demonstrates, as previously indicated, that ENDESA did not properly guarantee the confidentiality and integrity of the personal data in its ownership.

Therefore, it is considered that the known facts constitute an infringement, attributable to ENDESA, for violation of Article 5.1.f) of the GDPR.

V

Classification and qualification of the infringement of Article 5.1.f) of the GDPR

It is considered that ENDESA did not properly guarantee the confidentiality and integrity of the personal data in its ownership.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

182/214

The known facts constitute an infringement, attributable to ENDESA, classified under Article 83.5 of the GDPR, which stipulates the following:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

For the purposes of the statute of limitations for infringements, the infringement attributed prescribes after three years, in accordance with Article 72.1.a) of the LOPDGDD, which qualifies the following conduct as very serious:

“a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679”

VI

Sanction for the infringement of Article 5.1.f) of the GDPR

This infringement may be sanctioned with a fine of up to €20,000,000 or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.5 of the GDPR.

Furthermore, it is considered appropriate to graduate the sanction to be imposed in accordance with the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm they have suffered (paragraph a): for failing to properly guarantee, at least between July 1, 2021, and October 15, 2021, the integrity of the data of at least 760 affected parties who became victims of fraudulent contracts and for failing to guarantee the confidentiality of the data of 30.6 million electricity supply points and 8.6 million gas supply points of non-ENDESA customers, as well as for failing to guarantee the confidentiality of identification data, address, phone number, email, bank account number, among others, of 4.8 million electricity customers and 1.2 million gas customers of ENDESA between August 2021 and February 2022.

- Negligence in the infringement (paragraph b): Although in August 2021 ENDESA was already aware that it had published a truthful announcement

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

183/214

by selling the possibility of accessing its database, ENDESA took more than a month to reset or delete the compromised users reported by ***EMPRESA.1 and took months to delete the compromised user ***USUARIO.1 (it did not even carry out an immediate preventive reset of all users nor were new users created in order to avoid having to use the same user with multiple sessions initiated), which allowed access to personal data stored in ENDESA's systems for months and enabled fraudulent user registrations. It has also been severely negligent in requesting Facebook to remove the ads in question, as it did not address FACEBOOK IRELAND LIMITED, as it was indicated that this was the

correct channel. All of this allowed the confidentiality of the data to be compromised, at least until February 2022, and also allowed the integrity of such data to be compromised between July 1, 2021, and October 15, 2021, at a minimum.

All of the above demonstrates, as previously indicated, that ENDESA was severely negligent in ensuring the confidentiality and integrity of the data it owns.

Furthermore, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link between the infringer's activity and the processing of personal data (section b): it is a large company accustomed to processing personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, allows for the imposition of an administrative fine of €2,500,000 (two million five hundred thousand euros).

VII

Security of processing

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

In the present case, ENDESA issued an authorization to ***EMPRESA.1 for subcontracting in favor of ***EMPRESA.9, in which the start date for the subcontracted work was established as August 1, 2021.

On August 24, 2021, ENDESA detected an advertisement on the social network Facebook where a user of the ***HERRAMIENTA.1 application was being sold with access to customer information.

On September 8, 2021, ENDESA conducted a second assessment of the incident where it proposed (...).

On September 10, 2021, ENDESA obtained verification of the truthfulness of the advertisement and the identification of the credentials of the application user that were being used by the advertiser to sell access.

On September 13, 2021, ENDESA convened the Security Breach Committee and decided to adopt the following measures:

□

(...)

Also, in this Committee, it was proposed to adopt the following measures:

□

(...)

Therefore, by September 2021, ENDESA was already aware that a breach of the security of personal data had occurred in its systems and that it was possible to access the personal data of its customers and it was

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
185/214

aware that the security measures it had implemented were not appropriate and needed to be improved, even by that date.

In any case, this Agency considers that the measures adopted by ENDESA prior to the incident in question cannot be deemed appropriate in the terms of Article 32 of the GDPR, taking into account, among other circumstances, the large volume of data it processes, the number of affected individuals by the processing, and the involvement of data processors, given that the state of the art allowed for the implementation of adequate measures to, at a minimum, prevent the same user from having multiple sessions open at the same time, implement a multifactor login that would hinder unauthorized access, maintain a comprehensive log record to obtain details of the activities performed by its users, among others, and that the cost of implementing such measures was perfectly manageable for ENDESA, a company that had a sales volume of ***CANTIDAD.1 euros and an operating result of ***CANTIDAD.3 euros, especially considering the high risk to the rights and freedoms of the millions of individuals whose personal data ENDESA processes.

Subsequently, on October 19, 2021, ***EMPRESA.1 detected that a user from ***EMPRESA.9 had attempted to carry out a fraudulent registration. Given the suspicion that this could have been carried out by other agents of ***EMPRESA.9, ***EMPRESA.1 initiated an internal audit process and communicated to the person responsible for their account at ENDESA what had happened via telephone, also sending an email with the initial inquiries made and the first measures taken in this regard. On the same day, a complete shutdown of all users from ***EMPRESA.9 and access to any tool of the ENDESA campaign was carried out, and an internal audit was initiated to assess the volume of customers affected by fraudulent contracts.

***EMPRESA.1 terminated the contract with ***EMPRESA.9 effective October 19, 2021, the day it became aware of the fraudulent practice carried out by ***EMPRESA.9.

However, ENDESA indicates that, once the possible origin of the allegedly irregular contracts was identified, it proceeded to limit the temporal scope of its actions, verifying that from July 1, 2021, the sales volume of ENDESA experienced an unusual and unjustified increase (specifically, sales increased by more than 500%), which could be representative of the irregular actions of the personnel contracted by ***EMPRESA.9. And that as of October 15, 2021, the activity of said subcontractor ceased – as a consequence of the termination of the contract with ***EMPRESA.9 – thus limiting the temporal perimeter of the analysis of the contracts to the period between July 1 and October 15, 2021. Despite what has been stated by ENDESA, it has been established in the present procedure that the activity of ***EMPRESA.9 ceased on October 19, 2021.

As can be observed, between August 24, 2021 (the date on which ENDESA detects that an advertisement was published on the social network Facebook selling a user of the application ***HERRAMIENTA.1 with access to customer information) and October 19, 2021...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
186/214

October 2021 (date on which ***COMPANY.1 detects and communicates to ENDESA that a user of ***COMPANY.9 had attempted to carry out a fraudulent registration) nearly two months had passed.

As previously indicated, in September ENDESA was already aware that its security measures were inadequate and needed improvement; nevertheless, more than a month later, a new security incident was detected.

On October 20, 2021, ***COMPANY.1, following the audit conducted, sent a communication to ENDESA indicating the operations affected by the fraudulent practice of ***COMPANY.9, identifying 137 registrations made and another 7 operations pending validation by ENDESA that had not yet been registered. Additionally, 172 orders that were pending validation by the back office of ***COMPANY.9 were identified and blocked to prevent their registration. Furthermore, this communication outlined the measures intended to be implemented in the coming days to detect any additional irregularities.

On the other hand, this communication sent to ENDESA included an attached email from the manager of ***COMPANY.9 informing ***COMPANY.1 of the complaints filed with the Police of ***COUNTRY.1 against its sales representatives involved in this fraudulent practice, (...).

On October 27, 2021, ***COMPANY.1 received an email from the manager of ***COMPANY.9 detailing the inquiries made regarding the fraudulent practice carried out by some of its agents and their *modus operandi*, as some of the sales representatives had decided to cooperate after seeing the complaint filed against them with the Police. This email detailed the three methods of operation, according to the management of ***COMPANY.9, of the sales representatives. In this email dated October 27, 2021, five of the users of ***TOOL.1 involved in the violation of personal data security were also identified, and screenshots of Facebook ads offering the rental and/or sale of access credentials to the ***TOOL.1 application were attached.

On October 27, 2021, ***COMPANY.1 sent an email to ENDESA detailing these fraudulent practices carried out by some agents of ***COMPANY.9 and attaching screenshots of Facebook ads offering the rental and/or sale of access credentials to the ***TOOL.1 application along with the users utilized. The content of the email is reproduced below:

“Through the internet, the advisors have registered for ***PLATFORM.1 (***TOOL.1). What the sales representatives have done is (...). I attach the users of ***PLATFORM.1 (***TOOL.1) that they have used. It is worth mentioning that we requested this tool at the time, which you denied indicating that it was prohibited.”

As previously indicated, despite being aware in September that the security measures it had in place were not adequate to ensure the confidentiality of the personal data owned by ENDESA, it did not...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

187/214

They were neither reset nor immediately removed from ***HERRAMIENTA.1 or ***HERRAMIENTA.2; the users known to be compromised took months, which allowed for improper access to the personal data owned by ENDESA during that entire time and facilitated a large number of fraudulent registrations. A preventive reset of all users in the systems was also not carried out in light of a possible threat (which later proved to be true), nor were new users created that would allow for the use of multiple sessions for a single user.

In January 2022, ENDESA identified new advertisements published by user B.B.B., offering the sale of customer databases from various companies in the energy sector.

That is to say, four months after ENDESA detected that an advertisement was published offering a user for ***HERRAMIENTA.1 and it was verified to be true, and three months after ***EMPRESA.1 detected and communicated that there had been improper use of the users of ***HERRAMIENTA.1 by employees of the company ***EMPRESA.9, ENDESA identified new advertisements offering users to access the personal data contained in its systems.

This implies that five months after ENDESA detected an advertisement on Facebook selling a user to access ***HERRAMIENTA.1, there were still advertisements of that kind published, which evidences that the measures implemented by then were also not appropriate to prevent a security incident like that from continuing to occur.

On February 7, 2022, ENDESA sent a burofax to FACEBOOK SPAIN requesting the removal of a

series of advertisements "related to the sale of access credentials to management platforms with personal data."

On February 8, 2022, this communication from ENDESA was responded to via email indicating that FACEBOOK SPAIN was not the competent entity to resolve the matter, but rather FACEBOOK IRELAND LIMITED, and it requested that the communication be directed to that entity. Despite this communication, it has not been evidenced in the present file that ENDESA had directed any communication in this regard to FACEBOOK IRELAND LIMITED, as requested by FACEBOOK SPAIN, which also evidences a notable lack of diligence in implementing one of the first measures decided back in September 2021, namely the removal of the advertisements in question.

On February 8, 2022, after the appropriate investigations, ENDESA became aware of certain coincidences between the data appearing in the published databases and those that could be included in ENDESA's commercial system, ***HERRAMIENTA.2.

ENDESA carried out a new assessment of the incident and on February 9, 2022, verified the truthfulness of the advertisements and the identity of the two advertisers, both former employees of ENDESA's suppliers with access to ***PLATAFORMA.1 (***HERRAMIENTA.1). A total of nine compromised users were detected among

188/214

September 2021 and January 2022, which were being used by advertisers on Facebook to sell access to ***PLATFORM.1 (***TOOL.1). Furthermore, it was verified that six of them had access to ***TOOL.2. The validity of the credentials was also verified, in all cases assigned to ENDESA providers to carry out customer acquisition and support work. That is to say, despite the fact that by September 2021 ENDESA was aware that a security incident had occurred that put the personal data under its ownership at risk, its lack of diligence in adopting appropriate and necessary security measures to ensure that the confidentiality of such data could not be breached allowed for a total of nine users to be compromised until January 2022, who were being used to sell access to ***TOOL.1 through Facebook from August 2021 to February 2022, at a minimum.

Regarding the compromised users identified by ***COMPANY.1 in its email sent to ENDESA on October 27, 2021:

- The user ***USER.13, assigned to ***COMPANY.12, was reset or disabled in ***TOOL.1 on September 3, 2021, reset again on November 29, 2021, and deleted from the systems on August 24, 2022. However, it was only deleted from the ***TOOL.2 system on January 12, 2022, with its last access to the system being on November 26, 2021.

That is to say, ***COMPANY.1 notified ENDESA that this user was compromised on October 27, 2021, but ENDESA had already reset the user in ***TOOL.1 on September 3, almost two months earlier (the reasons for this action are unknown to this Agency, but it is possible that ENDESA was already aware that this user was compromised; in fact, two days prior, ***COMPANY.16 had indicated that one of the users posting Facebook ads had been an agent of this company).

In any case, if the user in question was used to carry out fraudulent contracts in October 2021, this Agency considers that the password reset in September 2021 was of little use, and the risk to the rights and freedoms of the affected parties remained intact. Furthermore, following the communication from ***COMPANY.1, the user was reset more than a month later.

This Agency also finds it noteworthy that the user was reset in ***TOOL.1 on September 3, 2021, but was only deleted from the ***TOOL.2 platform on January 12, 2022, with its last access to it being on November 26, 2021. That is to say, even knowing that the user had been compromised in ***TOOL.1, the user had free access to ***TOOL.2 for one more month.

- The user ***USER.15, assigned to ***COMPANY.12, was reset or disabled in ***TOOL.1 on September 21, 2021,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

189/214

reset again on November 29, 2021, and removed from the systems on August 24, 2022. However, it

was only removed from the ***HERRAMIENTA.2 system on January 12, 2022, with its last access to the system on November 25, 2021.

That is to say, ***EMPRESA.1 notified ENDESA that this user was compromised on October 27, 2021, but ENDESA had already reset the user in ***HERRAMIENTA.1 on September 21, more than a month earlier (the reasons for this action are unknown to this Agency, but it is possible that ENDESA already knew that this user was compromised; in fact, on that same day, it was indicated to ENDESA that one of the users posting Facebook ads had been an agent of ***EMPRESA.15).

In any case, if the user in question was used to carry out fraudulent contracts in October 2021, this Agency considers that the password reset in September 2021 was of little use, and the risk to the rights and freedoms of the affected parties remained intact. Furthermore, following the communication from ***EMPRESA.1, the user was reset more than a month later.

This Agency is also struck by the fact that the user was reset in ***HERRAMIENTA.1 on September 21, 2021, but was only removed from the ***HERRAMIENTA.2 platform on January 12, 2022, with its last access to it on November 25, 2021. That is to say, even knowing that the user had been compromised in ***HERRAMIENTA.1, the user freely accessed ***HERRAMIENTA.2 for another month.

-

The user ***USUARIO.14, assigned to ***EMPRESA.15, was reset or disabled in ***HERRAMIENTA.1 on November 29, 2021, and removed from the systems on March 4, 2022 (although this was because the user expired without further action). It was only removed from the ***HERRAMIENTA.2 system on March 16, 2022, with its last access to the system on February 18, 2022.

That is to say, this user was reset or disabled in ***HERRAMIENTA.1 more than a month after ENDESA was informed by ***EMPRESA.1 that this user had been compromised. And even knowing that the user had been compromised in ***HERRAMIENTA.1, the user freely accessed ***HERRAMIENTA.2 for almost three more months.

-

The user ***USUARIO.9, assigned to ***EMPRESA.6, was reset or disabled in ***HERRAMIENTA.1 on November 21, 2021, and on February 15, 2022, and removed from the systems on August 24, 2022.

That is to say, this user was only reset more than a month after ***EMPRESA.1 had communicated to ENDESA that they had been compromised.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

190/214

-

The user ***USUARIO.16, assigned to ***EMPRESA.5, was reset or disabled in ***HERRAMIENTA.1 on November 29, 2021, and removed from its systems on August 24, 2022. It was removed from the ***HERRAMIENTA.2 system on February 17, 2022, with its last access to the system on December 3, 2021.

That is to say, this user was only reset more than a month after ***EMPRESA.1 had communicated to ENDESA that they had been compromised.

Regarding the rest of the users, the date on which ENDESA became aware that such users had been compromised is unknown, but the following can be noted:

-

The user ***USUARIO.10, assigned to ***EMPRESA.15, was reset or disabled in ***HERRAMIENTA.1 on September 10, 2021, and removed from the systems on August 24, 2022. It was removed from the ***HERRAMIENTA.2 system on September 10, 2021, with its last access to the system on September 9, 2021.

That is to say, ENDESA reset the user in ***HERRAMIENTA.1 and ***HERRAMIENTA.2 on September 10, 2021 (the reasons for this action are unknown to this Agency, but it is possible that

ENDESA was aware that this user was compromised, as on that same day ENDESA sent an email referring to an active employee at ***EMPRESA.15, whose user was to be immediately deactivated).

-

The user ***USUARIO.2 (***USUARIO.2), assigned to ***EMPRESA.8, was reset or disabled in ***HERRAMIENTA.1 and removed from its systems on November 19, 2021.

-

The user ***USUARIO.1, assigned to ***EMPRESA.13, was reset or disabled in ***HERRAMIENTA.1 on February 15, 2022, and removed from the systems on August 24, 2022. That is to say, they were not reset before the first burofax was sent to Facebook on February 8, 2022, as ENDESA claims in its allegations regarding the initiation agreement.

All of the above demonstrates that, despite the fact that in October 2021 five of the compromised users had already been identified due to the violation of personal data security in question, ENDESA's lack of diligence in preventing access to its applications by the compromised users allowed for even more unauthorized access to personal data to occur for over a month beyond what had already taken place. Nor had the security measures proposed from the outset of the personal data security breach been implemented, which were supposedly adequate to mitigate the consequences of the data security breach, since it is not true that the accesses of the compromised users to ENDESA's tools had been diligently blocked, disabling their credentials.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

191/214

nor that this took place before the first burofax was sent to Facebook.

For its part, regarding the risk analysis conducted on the processing activity that has suffered the violation of personal data security prior to the incident that occurred, ENDESA provides, along with its written submission dated July 26, 2022, two documents, both generated by the tool

****HERRAMIENTA.1" used by the Enel Group to carry out the privacy risk assessment, concerning the tools ***HERRAMIENTA.1 and ***HERRAMIENTA.2. In neither of these documents is there any indication that the possibility of an employee of a supplier or a subcontracting company misusing the personal data held in ENDESA's information systems was even considered.

Furthermore, on September 15, 2022, the SGID verified that advertisements identified by ENDESA were still published on Facebook offering the sale of access credentials to ****HERRAMIENTA.1 and databases. This evidences that more than a year after an advertisement selling user access to ***HERRAMIENTA.1 was detected, ENDESA had not been sufficiently diligent in ensuring that such publications were removed from the social network in question, which was one of the first measures decided by the company a year prior.

All of the above demonstrates, as previously indicated, that ENDESA was not sufficiently diligent in implementing appropriate security measures to prevent security incidents like the one that occurred in this case.

Therefore, it is considered that the known facts constitute an infringement attributable to ENDESA for violation of Article 32 of the GDPR.

VIII

Classification and Qualification of the Infringement of Article 32 of the GDPR

In this case, it is considered that ENDESA did not apply the appropriate technical and organizational measures to ensure a level of security adequate to the risk of a personal data security breach such as the one that occurred.

The known facts constitute an infringement attributable to ENDESA, classified under Article 83.4 of the GDPR, which stipulates the following:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher

amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

192/214

For the purposes of the statute of limitations for infringements, the infringement attributed prescribes after two years, in accordance with Article 73.f) of the LOPDGDD, which qualifies the following conduct as serious:

"f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679."

IX

Sanction for the Infringement of Article 32 of the GDPR

This infringement may be sanctioned with a fine of up to €10,000,000 or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.4 of the GDPR.

Furthermore, it is considered appropriate to adjust the sanction to be imposed in accordance with the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm suffered (paragraph a): for not having implemented the appropriate security measures to the risk of a personal data security breach such as the one that has occurred in this case, which allowed the integrity of the data of at least 760 affected parties to be compromised between July 1, 2021, and October 15, 2021, and allowed the confidentiality of the data of 30.6 million electricity supply points and 8.6 million gas supply points of non-ENDESA customers and the confidentiality of identification data, address, phone number, email, bank account number, among others, of 4.8 million electricity customers and 1.8 million gas customers of ENDESA between August 2021 and February 2022 to be at risk.

In this regard, it is noteworthy that ENDESA itself acknowledges that two or more people could simultaneously access ***HERRAMIENTA.1 with the same user, with the multi-session option enabled, and that no logs of the use of the tools ***HERRAMIENTA.1 or ***HERRAMIENTA.2 were maintained, which indicates a lack of adequate security measures to detect and prevent unauthorized access.

Regarding the possible consequences of the lack of such personal data security measures, the main one is the loss of control over their data, with the consequent risk of being a victim of phishing, another cyberattack, and the contracting of unsolicited supplies, with the stress and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

193/214

additional costs that such situations could entail for them, as they could even be held liable for debts related to those unsolicited services.

- Negligence in the infringement (section b): Regarding the alleged infringement of Article 32 of the GDPR, ENDESA's severely negligent behavior is evident in its conduct both before and after the incident occurred, as there was not even a consideration of the possibility that there could be misuse of users of ***HERRAMIENTA.1 and ***HERRAMIENTA.2, which meant that adequate measures were not implemented to ensure user authentication with the necessary guarantees, preventing unauthorized access to the systems and allowing for proper tracking of these users' activity within those systems. Users known to be compromised were neither reset nor removed immediately or

effectively from either ***HERRAMIENTA.1 or ***HERRAMIENTA.2, as it took more than a month, which allowed for unauthorized access to ENDESA's personal data during that entire time and facilitated a significant number of fraudulent registrations. A preventive reset of all users in the systems was also not carried out in light of a potential threat (which later turned out to be true).

Despite the fact that by September 2021 ENDESA was aware that a security incident had occurred that jeopardized the personal data under its ownership, its lack of diligence in adopting appropriate and necessary security measures to prevent the confidentiality of such data from being compromised allowed for a total of nine users to be compromised until January 2022 (as ENDESA has acknowledged), who were being used to sell access to ***HERRAMIENTA.1 through Facebook from August 2021 to February 2022, at a minimum.

Furthermore, as of October 27, 2021, ENDESA had already identified five of the users of ***HERRAMIENTA.1 compromised in the violation of personal data security, who were reset more than a month after such communication. All of this demonstrates that, despite the fact that in October 2021 five of the users compromised by the violation of personal data security had already been identified, ENDESA's lack of diligence in preventing access to its applications by the compromised users allowed for even more unauthorized access to personal data to occur over the following months than had already taken place.

For its part, on February 8, 2022, FACEBOOK SPAIN responded to ENDESA indicating that it was not the competent entity to remove the published ads, but rather FACEBOOK IRELAND LIMITED, and requested that the communication be directed to that entity. Nevertheless, it has not been established in the present file that ENDESA directed any communication in this regard to FACEBOOK IRELAND LIMITED, as requested by FACEBOOK SPAIN, despite having been agreed upon in the meeting of September 13, 2021, and in August 2021 to request the cancellation of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

194/214

advertisements, due to the risks they posed, which also demonstrates a notable lack of diligence in implementing one of the first measures agreed upon in September 2021, namely the removal of the advertisements in question.

Furthermore, on September 15, 2022, the SGID verified that advertisements identified by ENDESA were still published on Facebook offering the sale of access credentials to ***HERRAMIENTA.1 and databases. This shows that more than a year after an advertisement selling user access to ***HERRAMIENTA.1 was detected, ENDESA had not been sufficiently diligent in requesting that such publications be removed from the social network in question, which was one of the first measures decided by the company a year earlier.

All of the above demonstrates, as previously indicated, that ENDESA was severely negligent in implementing appropriate security measures to prevent security incidents like the one that occurred in this case, and its actions following the incident in question were also negligent.

As a mitigating factor:

- Any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement (section k): upon becoming aware of the publication of advertisements on Facebook selling users for access to ***HERRAMIENTA.1, ENDESA adopted a series of measures, such as resetting user passwords, monitoring the publications on that social network, attempting to remove the aforementioned advertisements, disabling the possibility of maintaining simultaneous sessions, and increasing the traceability of accesses to ***HERRAMIENTA.1, among others.

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link between the infringer's activity and the processing of personal data (section b): it is a large

company accustomed to processing personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of an administrative fine of €1,500,000 (one million five hundred thousand euros).

X

Notification to the supervisory authority

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

195/214

Article 33 “Notification of a personal data breach to the supervisory authority” of the GDPR states:

“1. In the event of a personal data breach, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, not later than 72 hours after becoming aware of it, unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by reasons for the delay.

(...).”

In this case, it is recorded that ENDESA on August 24, 2021, had already detected that an advertisement selling user access to ***HERRAMIENTA.1 had been published on the social network Facebook. And by September 10, 2021, ENDESA had already verified the truthfulness of such advertisement, to the point that on September 13, 2021, it convened a Committee to decide and propose the adoption of the corresponding security measures.

Subsequently, on October 19, 2021, its provider ***EMPRESA.1 informed ENDESA that it had detected possible fraudulent registrations by its subcontractor ***EMPRESA.9 and even on October 27, 2021, ENDESA received an email from ***EMPRESA.1 informing that 5 users of ***HERRAMIENTA.1 had been compromised and explaining how such fraudulent registrations could have occurred.

Months later, in January 2022, ENDESA identified new advertisements published on the social network Facebook offering users for access to ***HERRAMIENTA.1. And on February 4, 2022, it requested FACEBOOK SPAIN to remove the aforementioned advertisements, as they could constitute a crime.

Despite all of the above, ENDESA did not inform this Agency of the existence of a possible breach of personal data security until February 10, 2022, when it verified that the data of the tool ***HERRAMIENTA.2 had been compromised, without any justification provided for such delay.

However, months earlier, it already knew that the security of the data contained in the tool ***HERRAMIENTA.1 had been compromised, which allowed for a large number of fraudulent registrations, all without having made any notification to this Agency.

As indicated in the response to the allegations regarding the initiation agreement and proposal for resolution of this sanctioning procedure, in this case, this Agency considers that ENDESA did not correctly classify the incident by deeming it non-notifiable and reiterates that the incident in question was indeed notifiable since ENDESA became aware on September 10, 2021, of the truthfulness of the August 2021 advertisement, in addition to knowing through ***EMPRESA.1 that five users of ***HERRAMIENTA.1 had been compromised and that there had been improper use of the personal data contained in its systems, which

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

196/214

took place on October 27, 2021. Regardless of whether the users had been reset or deleted (which

has already been thoroughly analyzed and found not to have been done immediately or diligently), the reality is that the incident had already occurred, the confidentiality of the personal data processed by ENDESA had been lost, and there was a probable risk to the rights and freedoms of individuals, since ENDESA had lost control of access to that data, regardless of whether unauthorized access had occurred (or not), in addition to ***HERRAMIENTA.2. Therefore, this Agency reiterates that in this case, ENDESA should have notified the personal data breach within a maximum period of 72 hours from when it became aware of the veracity of the announcements in September 2021 or at least from when it was informed by ***EMPRESA.1 that such an incident had occurred, in October 2021. Therefore, it is considered that the known facts constitute an infringement, attributable to ENDESA, for violation of Article 33 of the GDPR.

XI

Classification and qualification of the infringement of Article 33 of the GDPR

In this case, it is considered that ENDESA did not notify the supervisory authority in time that a personal data breach had occurred. The known facts constitute an infringement, attributable to ENDESA, classified under Article 83.4 of the GDPR, which stipulates the following:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”
For the purposes of the statute of limitations for infringements, the infringement attributed prescribes after one year, in accordance with Article 74.m) of the LOPDGDD, which qualifies the following conduct as minor:

“m) The incomplete, late, or defective notification to the data protection authority of information related to a security breach of personal data in accordance with the provisions of Article 33 of Regulation (EU) 2016/679.”

XII

Sanction for the infringement of Article 33 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

197/214

This infringement may be sanctioned with a fine of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the preceding financial year, opting for the higher amount, in accordance with Article 83.4 of the GDPR. Furthermore, it is considered appropriate to adjust the sanction to be imposed in accordance with the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected individuals and the level of damage and harm they have suffered (paragraph a): for failing to notify the data protection authority that a personal data breach had occurred within 72 hours, of which there were indications as early as August 2021 and was confirmed in September 2021, meaning it was only communicated five months later, without any legitimate reasons justifying such delay.
- Negligence in the infringement (paragraph b): ENDESA on August 24, 2021, had already detected that an advertisement selling user access to ***HERRAMIENTA.1 had been published on the social network Facebook. And on September 10, 2021, ENDESA had already verified the truth of such an advertisement, to the extent that on September 13, 2021, it convened a Committee to decide and propose the adoption of the corresponding security measures.

Subsequently, on October 19, 2021, its provider ***EMPRESA.1 informed ENDESA that it had detected possible fraudulent registrations by its subcontractor ***EMPRESA.9 and even on October

27, 2021, ENDESA received an email from ***EMPRESA.1 informing that 5 users of ***HERRAMIENTA.1 had been compromised and explaining how such fraudulent registrations could have occurred.

Months later, in January 2022, ENDESA identified new advertisements published on the social network Facebook offering users for access to ***HERRAMIENTA.1. And on February 4, 2022, it requested FACEBOOK SPAIN to remove the aforementioned advertisements, as they could constitute a crime.

Despite all the above, ENDESA did not inform this Agency of the existence of a possible personal data breach until February 10, 2022, and the reasons alleged by ENDESA cannot justify this delay.

All of the above demonstrates, as previously indicated, that ENDESA was grossly negligent in notifying the relevant supervisory authority of the existence of a personal data breach.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

198/214

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link between the infringer's activity and the processing of personal data (section b): it is a large company accustomed to processing personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 33 of the GDPR, allows for the imposition of an administrative fine of €800,000 (eight hundred thousand euros).

XIII

Communication to the affected party

Article 34 "Communication of a personal data breach to the affected party" of the GDPR establishes:

"1. When a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall communicate the breach to the affected party without undue delay.

2. The communication to the affected party referred to in paragraph 1 of this article shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33, paragraph 3, letters b), c) and d).

3. The communication to the affected party referred to in paragraph 1 shall not be necessary if any of the following conditions are met:

a) the data controller has implemented appropriate technical and organizational protection measures and those measures have been applied to the personal data affected by the personal data breach, in particular those that render the personal data unintelligible to any person not authorized to access them, such as encryption;

b) the data controller has taken further measures to ensure that the high risk to the rights and freedoms of the affected party referred to in paragraph 1 is no longer likely to materialize;

c) it would involve a disproportionate effort. In this case, a public communication or a similar measure shall be adopted to inform the affected parties in an equally effective manner.

4. When the data controller has not yet communicated the personal data breach to the affected party, the supervisory authority, after considering the likelihood that such a breach poses a high risk, may require the data controller to do so or may decide that one of the conditions mentioned in paragraph 3 is met."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

199/214

In the present case, the personal data breach posed a high risk to the rights and freedoms of natural persons, and none of the circumstances listed in paragraph 3 of Article 34 of the GDPR that would exempt ENDESA from the duty to communicate to the affected parties that this personal data breach had occurred were present.

In fact, in the notification of the incident in question to this Agency, dated February 10, 2022, ENDESA indicated that it would not communicate the personal data breach to those affected, believing that there was no high risk to their rights and freedoms, which is why this Agency issued an order (notified to ENDESA on March 8, 2022) for it to communicate to the affected parties in accordance with the terms of Article 34 of the GDPR.

The content of the letter template sent by ENDESA was as follows:

“March 31, 2022

Dear customer,

We are contacting you to inform you that we have detected a possible unauthorized access to certain commercial systems of Endesa Energía and that from the moment we became aware of this fact, we have adopted appropriate security measures, both technical and organizational, to prevent a high-risk impact on the rights and freedoms of our customers, ensuring that the confidentiality and integrity of your personal data has not been compromised.

You can consult our privacy policy at www.endesa.com/es/proteccion-datos-endesa, where you will find information regarding the processing of your personal data. If you prefer, you can directly contact our Data Protection Officer by sending a communication to ***EMAIL.1 to learn more about the measures taken or to obtain further information.

We take this opportunity to thank you for the trust placed in Endesa.

Best regards,

Endesa Energía.”

As can be seen, in the communication sent to the affected parties, it is stated that “the confidentiality and integrity of your personal data has not been compromised.”

However, this information provided is not true.

In ENDESA's notification of the personal data breach to this Agency, dated February 10, 2022, it is indicated that as a result of the incident, the confidentiality and integrity of the processing have been affected. And during the investigation proceedings, it has been confirmed that the credentials of users of ENDESA applications compromised in the personal data breach were used by salespeople from another company (**EMPRESA.9), who did not have access to ENDESA's databases, to extract data from ENDESA customers that were used to carry out fraudulent contracts.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

200/214

Furthermore, in the communication sent to the affected parties, ENDESA did not include a description of the possible consequences that the breach of personal data security could cause them and even goes so far as to deny that a high risk to the rights and freedoms of the affected individuals could arise. There is also no specific reference in the communication to the possibility of requesting additional information through another means regarding these possible consequences.

Therefore, it is considered that the known facts constitute an infringement attributable to ENDESA for violation of Article 34 of the GDPR.

XIV

Classification and qualification of the infringement of Article 34 of the GDPR

In this case, it is considered that ENDESA failed to fulfill the obligation to properly inform the affected parties that a breach of personal data security had occurred.

The known facts constitute an infringement attributable to ENDESA, classified under Article 83.4 of the GDPR, which stipulates the following:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with

administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" For the purposes of the statute of limitations for infringements, the infringement attributed prescribes after one year, in accordance with Article 74.ñ) of the LOPDGDD, which qualifies the following conduct as minor:

“ñ) The failure to communicate to the affected party a breach of data security that poses a high risk to the rights and freedoms of the affected parties, as required by Article 34 of Regulation (EU) 2016/679, unless the provisions of Article 73 s) of this organic law apply.”

XV

Sanction for the infringement of Article 34 of the GDPR

This infringement may be sanctioned with a fine of up to €10,000,000 or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.4 of the GDPR.

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established by Article 83.2 of the GDPR:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

201/214

As aggravating factors:

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the data processing operation in question as well as the number of affected parties and the level of damage and harm they have suffered (paragraph a): for not having properly provided, at least, to the 760 affected by the fraudulent registrations the information to which it was obligated regarding the breach of the personal data security in question.
- Negligence in the infringement (paragraph b): initially, ENDESA was negligent in identifying the need for the communication to the affected parties regarding the breach of personal data security, in the terms of Article 34 of the GDPR to be sent. And once this Agency ordered ENDESA to send the aforementioned communication to the affected parties, ENDESA was severely negligent in providing the information required by the aforementioned Article 34 of the GDPR in a truthful and complete manner.

As a mitigating factor:

- Any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or losses avoided, directly or indirectly, through the infringement (paragraph k): the contact of the Data Protection Officer was provided for obtaining more information.

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

As aggravating factors:

- The link of the infringer's activity with the processing of personal data (paragraph b): it is a large company accustomed to processing personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 34 of the GDPR, allows for the imposition of an administrative fine of €800,000 (eight hundred thousand euros).

XVI

Transfers of data to third countries or international organizations

Article 44 “General principle for transfers” of the GDPR establishes:

“Personal data that are subject to processing or are to be processed after their transfer to a third

country or international organization may only be transferred if, subject to the other provisions of this Regulation, the controller and the processor comply with the conditions established in this chapter, including those relating to further transfers of personal data.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

202/214

from the third country or international organization to another third country or another international organization. All provisions of this chapter shall apply in order to ensure that the level of protection of natural persons guaranteed by this Regulation is not undermined.”

In this regard, Article 45 “Transfers based on an adequacy decision” of the GDPR states that:

“1. A transfer of personal data to a third country or international organization may take place when the Commission has decided that the third country, a territory or one or more specific sectors of that third country, or the international organization in question ensures an adequate level of protection. Such transfer shall not require any specific authorization.

(...)”

Whereas Article 46 “Transfers subject to adequate safeguards” of the GDPR states that:

“1. In the absence of a decision pursuant to Article 45(3), the controller or processor may only transfer personal data to a third country or international organization if it has provided appropriate safeguards, and on condition that data subjects have enforceable rights and effective legal remedies.

2. The appropriate safeguards referred to in paragraph 1 may be provided, without requiring any specific authorization from a supervisory authority, by:

a) a legally binding and enforceable instrument between public authorities or bodies;

b) binding corporate rules in accordance with Article 47;

c) standard data protection clauses adopted by the Commission in accordance with the examination procedure referred to in Article 93(2);

d) standard data protection clauses adopted by a supervisory authority and approved by the Commission in accordance with the examination procedure referred to in Article 93(2);

e) a code of conduct approved in accordance with Article 40, together with binding and enforceable commitments of the controller or processor in the third country to apply appropriate safeguards, including with respect to the rights of data subjects; or

f) a certification mechanism approved in accordance with Article 42, together with binding and enforceable commitments of the controller or processor in the third country to apply appropriate safeguards, including with respect to the rights of data subjects.

(...)”

In this case, ENDESA in its response dated November 11, 2022, identifies for each of the users involved in the breach of the personal data security in question the ENDESA service provider with which they had entered into a contract:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

203/214

User

Assigned provider

***USER.1

***COMPANY.13 (hereinafter, ***COMPANY.13)

***USER.7

***COMPANY.14 (hereinafter, ***COMPANY.14)

***USER.2

(***USER.2)

***COMPANY.8 (hereinafter, ***COMPANY.8)

***USER.8

***COMPANY.15

***USER.3

COMPANY.12 (COMPANY.12)

***USER.4

***COMPANY.15 (hereinafter, ***COMPANY.15)

***USER.5

COMPANY.12 (COMPANY.12)

***USER.6

***COMPANY.17 (hereinafter, ***COMPANY.17)

***USER.9

This user is the same as ***USER.7

That is to say, ENDESA was working with providers located in countries both within and outside the European Union. Specifically, the providers ***COMPANY.15 and ***COMPANY.12 are located outside the European Union, in ***COUNTRY.2 and ***COUNTRY.1, respectively. It is also noted in this procedure that ENDESA had authorized ***COMPANY.1 to subcontract with ***COMPANY.9, a company located in ***COUNTRY.1. Therefore, ENDESA was making international transfers of personal data that it owned to these countries.

However, Article 45 of the GDPR allows for the international transfer of personal data without the need for specific authorization when the Commission has decided that the third country in question ensures an adequate level of protection. For other cases, Article 46 of the GDPR allows for these transfers provided that appropriate safeguards are offered and on the condition that data subjects have enforceable rights and effective legal remedies.

So far, neither ***COUNTRY.1 nor ***COUNTRY.2 have been declared as having an adequate level of protection by the European Commission, which is why the transfers of personal data to these countries must comply with the appropriate safeguards of Article 46 of the GDPR.

In this case, ENDESA has made international transfers to ***COUNTRY.1 and ***COUNTRY.2, and continues to make transfers to ***COUNTRY.2, countries for which the Commission has not declared that they ensure an adequate level of protection, in the terms set out in Article 45 of the GDPR.

Recital (108) of the GDPR regarding transfers in the absence of an adequacy decision states that "the controller or processor must take measures to compensate for the lack of data protection in a third country through appropriate safeguards for the data subject. Such appropriate safeguards may consist of the use of binding corporate rules, standard data protection clauses adopted by the Commission or by a supervisory authority, or contractual clauses authorized by a supervisory authority (...)".

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

204/214

Article 46 of the GDPR addresses "transfers subject to adequate safeguards" and states in its paragraph 1 that, in the absence of a decision pursuant to Article 45, paragraph 3, the data controller or the processor may only transfer personal data to a third country or international organization if they have provided adequate safeguards and provided that data subjects have enforceable rights and effective legal remedies.

Article 46, paragraph 2, of the GDPR adds that "adequate safeguards" may be provided, without the need for express authorization from a supervisory authority, among others, by standard contractual clauses for data protection adopted by a supervisory authority and approved by the Commission in accordance with the examination procedure referred to in Article 93, paragraph 2. (Article 46, paragraph 2, letter c).

This article must be interpreted in the sense declared by the Court of Justice of the European Union (CJEU) in its judgment of July 16, 2020, delivered in case C-311/18 (Schrems II):

“105 Therefore, it is appropriate to respond to the second, third, and sixth preliminary questions that Article 46, paragraphs 1 and 2, letter c), of the GDPR must be interpreted as meaning that the adequate safeguards, enforceable rights, and effective legal remedies required by those provisions must ensure that the rights of individuals whose personal data are transferred to a third country on the basis of standard contractual clauses for data protection enjoy a level of protection that is substantially equivalent to that guaranteed within the Union by the aforementioned Regulation, interpreted in light of the Charter. For this purpose, the assessment of the level of protection guaranteed in the context of a transfer of such characteristics must, in particular, take into account both the contractual stipulations agreed between the data controller or processor established in the Union and the recipient of the transfer established in the third country in question, as well as, regarding any potential access by public authorities of that third country to the personal data transferred in this way, the relevant elements of the legal system of that country and, in particular, those mentioned in Article 45, paragraph 2, of the aforementioned Regulation.”

In this regard, the European Commission has adopted the Implementing Decision (EU) 2021/914 of the Commission, of June 4, 2021, regarding standard contractual clauses for the transfer of personal data to third countries in accordance with Regulation (EU) 2016/679 of the European Parliament and of the Council.

These standard contractual clauses adopted by the European Commission constitute a method to provide "adequate safeguards" in the absence of an adequacy decision pursuant to Article 46, paragraph 2, letter c), of the GDPR, establishing new standard contractual clauses that can be used by both the controller and the processor in order to offer adequate safeguards within the meaning of Article 46, paragraph 1, of the GDPR, with the previous decisions of 2001 and 2010 being repealed as of September 27, 2021. However, according to its clause 4.4, contracts entered into before September 27, 2021, under Decision 2001/497/EC or Decision 2010/87/EU are considered to provide adequate safeguards within the meaning of Article 46, paragraph 1, of the GDPR until December 27, 2022, provided that the processing operations that are the subject of the

205/214

The contract remains unchanged and the standard contractual clauses ensure that the transfer of personal data is subject to adequate safeguards.

In this regard, it should be noted that ENDESA has provided:

-

Regarding ***COMPANY.15:

☐

Resolution of the Director of the AEPD, dated December 1, 2015, authorizing the international transfer of personal data from ENDESA to ***COMPANY.15, located in ***COUNTRY.2.

☐

Contract dated November 11, 2021, which replaces said authorization and complies with the provisions of the Commission Implementing Decision (EU) 2021/914 of June 4, 2021, regarding the standard contractual clauses for the transfer of personal data to third countries in accordance with Regulation (EU) 2016/679 of the European Parliament and of the Council.

☐

Data Protection Impact Assessment of ***COUNTRY.2 as the importing country of personal data.

☐

Impact assessment on the law and practices of ***COUNTRY.2 applicable to the processing of personal data carried out by the provider ***COMPANY.15.

-

Regarding ***COMPANY.12 (...)

☐

Contract between ENDESA and ***COMPANY.12.

☐

(...) compliance with the provisions of the Commission Implementing Decision (EU) 2021/914 of June 4, 2021, regarding the standard contractual clauses for the transfer of personal data to third countries in accordance with Regulation (EU) 2016/679 of the European Parliament and of the Council.

☐

Resolution of the contract between ENDESA and ***COMPANY.16, dated November 15, 2022.

☐

Data Protection Impact Assessment of ***COUNTRY.1 as the importing country of personal data.

-

Regarding ***COMPANY.9. (...)

☐

Contract between ENDESA and ***COMPANY.9., dated July 22, 2020.

☐

Burofax dated October 27, 2022, from ***COMPANY.1 to ***COMPANY.9., resolving the contract between them.

☐

Proof of termination of ***COMPANY.9. as a supplier of ENDESA, dated November 2, 2021.

From the above, it can be concluded that the contracts with ***COMPANY.12 and ***COMPANY.9. were terminated before December 27, 2022.

Having established the above, it is important to highlight, regarding the international transfer made to ***COUNTRY.2 under the contract signed between ENDESA and ***COMPANY.15, that clause 14 of the decision refers to the "Law and practices of the country affecting compliance with the clauses."

This clause contains four modules:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

206/214

related to the transfer from controller to controller; transfer from controller to processor; transfer from processor to processor; and transfer from processor to controller, to which the provisions contained therein apply. It establishes the following:

“MODULE ONE: transfer from controller to controller

MODULE TWO: transfer from controller to processor

MODULE THREE: transfer from processor to processor

MODULE FOUR: transfer from processor to controller (only if the processor in the EU combines the personal data received from the controller in the third country with the personal data collected by the processor in the EU)

a) The parties assure that they have no reason to believe that the law and practices of the third country of destination applicable to the processing of personal data by the data importer, especially the requirements for the communication of personal data or the measures for authorization of access by public authorities, prevent the data importer from fulfilling the obligations assigned to it by this set of clauses. This assertion is based on the premise that the law and practices that essentially respect fundamental rights and freedoms and do not exceed what is necessary and proportionate in a democratic society to safeguard one of the objectives listed in Article 23, paragraph 1, of Regulation (EU) 2016/679 do not oppose this set of clauses.

b) The parties declare that, in providing the guarantee referred to in point a), they have duly taken into account, in particular, the following aspects:

i) the specific circumstances of the transfer, such as the length of the processing chain, the number of parties involved, and the transmission channels used; the anticipated further transfers; the type of recipient; the purpose of the processing; the categories and format of the personal data transferred; the economic sector in which the transfer takes place; the location of the storage of the transferred data;

ii) the law and practices of the third country of destination —especially those requiring the communication of data to public authorities or authorizing access by such authorities— that are relevant given the specific circumstances of the transfer, as well as the applicable limitations and safeguards (12);

iii) the relevant contractual, technical, or organizational safeguards provided to complement the safeguards set out in this set of clauses, particularly including the measures applied during the transfer and the processing of personal data in the destination country.

c) The data importer assures that, in carrying out the assessment referred to in point b), it has done everything possible to provide the data exporter with the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

207/214

relevant information and commits to continue collaborating with the data exporter to ensure compliance with this set of clauses.

d) The parties agree to document the evaluation referred to in paragraph b) and make it available to the competent supervisory authority upon request.

e) The data importer commits to promptly notify the data exporter if, after being bound by this set of clauses and during the term of the contract, it has reason to believe that it is or has been subject to regulations or practices that do not meet the requirements of paragraph a), including as a result of a change in regulations in the third country or a measure (such as a request for communication) indicating an application of such regulations in practice that does not meet the requirements of paragraph a). [Module three: The data exporter will notify the controller.]

f) If the notification referred to in paragraph e) is made or if the data exporter has reason to believe that the data importer can no longer fulfill the obligations assigned to it by this set of clauses, the data exporter will promptly determine the appropriate measures (for example, technical or organizational measures to ensure security and confidentiality) that must be adopted by the data exporter and/or the data importer to remedy the situation [module three: if applicable, after consulting the controller]. The data exporter will suspend the transfer of data if it considers that there are no adequate guarantees or if so ordered by [module three: the controller or] the competent supervisory authority. In this case, the data exporter will be entitled to terminate the contract regarding the processing of personal data under this set of clauses. If the contract has more than two contracting parties, the data exporter may only exercise this right of termination with respect to the relevant party, unless the parties have agreed otherwise. In the event of termination of the contract under this clause, clause 16, paragraphs d) and e) will apply.

Thus, the aforementioned clause 14 establishes an obligation for both the exporter and importer to prepare an evaluation that takes into account all the issues determined by the clause itself.

For its part, the CJEU has explained in its ruling in Schrems II:

“132 Since, as is evident from paragraph 125 of this judgment, it is inherent to the contractual nature of standard data protection clauses that they cannot bind public authorities of third countries, but that Articles 44 and 46, paragraphs 1 and 2, letter c), of the GDPR, interpreted in light of Articles 7, 8, and 47 of the Charter, require that the level of protection of natural persons guaranteed by that Regulation is not compromised, it may be necessary to supplement the guarantees provided in those standard data protection clauses. In this regard, Recital 109 of the said Regulation states that ‘the possibility for [the] controllers [...] of processing to rely on standard data protection clauses adopted by the Commission [...] should not prevent controllers [...] from adding other clauses or additional guarantees’ and specifies, in particular, that ‘controllers [...] should be encouraged to offer additional guarantees [...] that complement the standard data protection clauses.’”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

208/214

133 It is therefore evident that the standard data protection clauses adopted by the Commission pursuant to Article 46(2)(c) of the same Regulation are intended solely to provide data controllers or processors established in the Union with contractual guarantees that apply uniformly across all third

countries and, therefore, regardless of the level of protection guaranteed in each of them. To the extent that these standard data protection clauses cannot provide, by their nature, guarantees that go beyond a contractual obligation to ensure compliance with the level of protection required by Union law, such clauses may require, depending on the situation of a specific third country, the adoption of additional measures by the data controller to ensure compliance with that level of protection.

134 In this regard, as noted by the Advocate General in point 126 of his conclusions, the contractual mechanism provided for in Article 46(2)(c) of the GDPR is based on the accountability of the data controller or processor established in the Union, as well as, subsidiarily, of the competent supervisory authority. It is therefore primarily the responsibility of that data controller or processor to verify, on a case-by-case basis and, if necessary, in collaboration with the recipient of the transfer, whether the law of the destination third country guarantees an adequate level of protection, in light of Union law, for the personal data transferred based on standard data protection clauses, providing, when necessary, additional guarantees to those offered by such clauses.

In this context, the Recommendations 01/2020 on measures that complement transfer instruments to ensure compliance with the level of protection of EU personal data, adopted on November 10, 2020, must also be taken into account, in which, when interpreting the aforementioned judgment of the CJEU, it is stated that “the Court leaves open the possibility for exporters to apply complementary measures that address these protection gaps, so that it reaches the level required by Union law. The Court does not specify what measures could be. However, the Court emphasizes that exporters will have to determine them on a case-by-case basis. This aligns with the principle of proactive accountability in Article 5(2) of the GDPR, which requires that data controllers be responsible and able to demonstrate compliance with the principles of the GDPR regarding the processing of personal data (...).”

In the present case, ENDESA has provided the Impact Assessment on Transfers to ***COUNTRY.2, which aims to evaluate, in relation to the transfer of personal data from the exporter to the importer, the adequacy level of the destination third country, as well as the adoption of appropriate technical and organizational security measures to mitigate the risk of such transfer.

In this regard, this assessment is limited to evaluating the technical and organizational security measures applied by the data importer, without addressing the necessity or otherwise of any other possible contractual complementary measures to the standard contractual clauses that may be necessary.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
209/214

In this regard, it is important to highlight that, in this document, regarding the legislative evaluation of the importing country ***COUNTRY.2, the evaluation yields the result “3 – Partially adequate,” limiting itself to considering the existence of data protection legislation and an independent supervisory authority in the third country, but does not even analyze the functions and powers of this authority. Furthermore, the document titled “analysis of legislation and practices” of ***COUNTRY.2 is provided, aimed at assessing whether the personal data being transferred is adequately protected concerning the potential access of the authorities of the countries to which the data is transferred. This document states that the Constitution of ***COUNTRY.2 guarantees the fundamental right to personal and family privacy and that it requires a judicial order for the interception of communications. The existence of a data protection law is also taken into account in this document.

After analyzing the circumstances addressed in the document, the following conclusion is reached:
CONCLUSION

It is understood that ***COUNTRY.2 has a regulatory framework that, while it cannot be considered equivalent to that established in the European Union regarding the protection of personal data, can be regarded as reasonably adequate.

However, to reach a definitive conclusion on the suitability of international transfer, as well as on the signing of additional guarantee measures to ensure that the level of protection of the transferred data

aligns with the essential equivalence standard of the European Union, it is necessary to consider and evaluate the other components related to the particularities of each of the transfers.

In summary, from the analysis of this documentation, it cannot be asserted that the evaluation includes a sufficient analysis of the law and practices of ***COUNTRY.2 that would allow for an assessment of whether the destination third country offers an adequate level of protection. Thus, it does not contain any evaluation regarding the existence of norms that require the communication of data to public authorities or authorize access by such authorities, as well as the applicable limitations and guarantees. According to the aforementioned CJEU ruling, this analysis should include the elements outlined in Article 45.2 of the GDPR, which includes the analysis of the existence of international treaties signed by the third country or other international commitments adopted (Article 45.2.c GDPR), the study of the national legislation of the third country in the sense intended by Article 45.2.a) of the GDPR:

“the rule of law, respect for human rights and fundamental freedoms, relevant legislation, both general and sectoral, including that related to public security, defense, national security, and criminal legislation, and the access of public authorities to personal data, as well as the application of such legislation, data protection standards, professional standards, and security measures, including standards on further transfers of personal data to another third country or international organization observed in that.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
210/214

country or international organization, the jurisprudence, as well as the recognition of the interested parties whose personal data is being transferred of effective and enforceable rights and of administrative remedies and judicial actions that are effective.”

In this regard, recital (20) of the Implementing Decision (EU) 2021/914 of the Commission states:

“The parties must take into account, in particular, the specific circumstances of the transfer (such as the content and duration of the contract, the nature of the data transferred, the type of recipient, and the purpose of the processing), the law and practices of the third country of destination that are applicable given the circumstances of the transfer and the guarantees established to complement the guarantees contemplated in the standard contractual clauses (such as relevant contractual, technical, and organizational measures applicable to the transfer and processing of personal data in the destination country). Regarding the effect of the mentioned law and practices on compliance with the standard contractual clauses, different elements can be assessed in a global evaluation; for example, reliable information about the application of the law in practice (jurisprudence, reports from independent supervisory bodies, etc.), the existence or absence of requests in the same sector, and, under strict conditions, the documented practical experience of the data exporter and/or the data importer.”

However, none of these circumstances have been taken into account. The deficiencies observed in the Data Protection Impact Assessment of ***COUNTRY.2 as a country importing personal data prevent it from being considered that the guarantee of clause 14 has been provided.

Therefore, it is considered that the known facts constitute an infringement, attributable to ENDESA, for violation of Article 44 of the GDPR.

XVII

Classification and qualification of the infringement of Article 44 of the GDPR

In this case, it is considered that ENDESA has not complied with the requirements necessary to carry out international data transfers to its suppliers and subcontractors located in ***COUNTRY.2.

The known facts constitute an infringement, attributable to ENDESA, classified under Article 83.5 of the GDPR, which stipulates the following:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

(...)

c) the transfers of personal data to a recipient in a third country or an international organization pursuant to Articles 44 to 49; (...)”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

211/214

For the purposes of the statute of limitations for violations, the alleged violation is subject to a three-year limitation period, in accordance with Article 72.1.I) of the LOPDGDD, which qualifies the following conduct as very serious:

“I) The international transfer of personal data to a recipient located in a third country or to an international organization, when the guarantees, requirements, or exceptions established in Articles 44 to 49 of Regulation (EU) 2016/679 are not met.”

XVIII

Sanction for the violation of Article 44 of the GDPR

This violation may be sanctioned with a fine of up to €20,000,000 or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.5 of the GDPR.

Furthermore, it is considered appropriate to adjust the sanction to be imposed in accordance with the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm suffered (paragraph a): for failing to comply with the requirements necessary for carrying out international transfers to its suppliers and subcontractors located in ***COUNTRY.2, affected by the security breach in question, of the data of 30.6 million electricity supply points and 8.6 million gas supply points of non-ENDESA customers, and the identification data, address, phone number, email, bank account number, among others, of 4.8 million electricity customers and 1.8 million gas customers of ENDESA.

- Negligence in the violation (paragraph b): ENDESA is a large company in its business sector, which must ensure the fundamental right to the protection of personal data it owns. In this case, this Agency considers that it has been severely negligent in analyzing whether ***COUNTRY.2 as an importing country of personal data enjoys adequate protection. In particular, considering that it is not only a large company from which greater professionalism could be expected, but also an entity accustomed to processing personal data. In this regard, the SAN of October 17, 2007 (rec. 63/2006) is very illustrative, which indicates that “...the Supreme Court has understood that there is recklessness whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must insist on rigor and exquisite care to comply with the legal provisions in this regard.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Denying the existence of negligent conduct on the part of the appellant would be equivalent to acknowledging that its conduct - by action or omission - has been diligent. Obviously, this perspective of the facts is not shared, as the serious lack of due diligence has been evidenced.

Throughout this sanctioning procedure, it has been established that ENDESA has not conducted a proper evaluation of ***COUNTRY.2 as an importing country of personal data (to which personal data continues to be sent currently).

Due to the importance of the protected legal asset, ENDESA was obliged to do so, yet it has failed to comply with this duty. Therefore, it is considered that its behavior has been severely negligent. Furthermore, it is considered appropriate to adjust the sanction to be imposed in accordance with the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link of the infringer's activity with the processing of personal data (paragraph b): it is a large company accustomed to processing personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the violation committed by infringing the provisions of Article 5.1.f) of the GDPR, allows for the imposition of an administrative fine of €500,000 (five hundred thousand euros).

XIX

Adoption of measures

Upon confirming the violation, it is appropriate to impose on the responsible party the obligation to adapt the international transfers of personal data that ENDESA carries out to ***COUNTRY.2 to the provisions of Articles 44 and following of the GDPR within a period of 6 months. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

The text of the resolution establishes what the violations committed have been and the facts that have led to the breach of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

It is warned that failure to comply with the adoption order of measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on ENDESA ENERGÍA, S.A.U., with NIF A81948077:

- For an infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of said regulation, an administrative fine of 2,500,000.00 euros.
- For an infringement of Article 32 of the GDPR, classified in Article 83.4 of said regulation, an administrative fine of 1,500,000.00 euros.
- For an infringement of Article 33 of the GDPR, classified in Article 83.4 of said regulation, an administrative fine of 800,000.00 euros.
- For an infringement of Article 34 of the GDPR, classified in Article 83.4 of said regulation, an administrative fine of 800,000.00 euros.

- For an infringement of Article 44 of the GDPR, classified in Article 83.5 of said regulation, an administrative fine of 500,000.00 euros.

SECOND: TO ORDER ENDESA ENERGÍA, S.A.U., with NIF A81948077, that pursuant to Article 58.2.d) of the GDPR, within a period of 6 months, prove that it has proceeded to adapt the international transfers of personal data it makes to ***COUNTRY.2 to the provisions of Articles 44 and following of the GDPR.

THIRD: TO NOTIFY this resolution to ENDESA ENERGÍA, S.A.U.

FOURTH: This resolution will be executable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that it must comply with the imposed sanction once this resolution becomes executable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, to the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

214/214

the banking entity CAIXABANK, S.A. In the absence of this, collection will proceed in the executive period.

Upon receipt of the notification and once it is executable, if the date of executability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the infringer, the infringement committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation proving the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following

the notification of this resolution, it will consider the provisional suspension terminated.

938-250923

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es